

# Internal Audit Management System

## User Manual

**Version:** 1.0 **Prepared By:** GRC Application Team **Date:** 30 June 2026 **Audience:** Customer Administrators, Audit Heads, Audit Managers, Auditors, and Client Trainers

### Document Control

#### Version History

| Version | Date         | Author               | Summary                                                         |
|---------|--------------|----------------------|-----------------------------------------------------------------|
| 1.0     | 30 June 2026 | GRC Application Team | Initial release covering the implemented Internal Audit module. |

#### Approvals

| Role                   | Name | Signature | Date |
|------------------------|------|-----------|------|
| Head of Internal Audit |      |           |      |
| Customer Administrator |      |           |      |

#### Revision History

| Version | Section(s) Changed | Reason           | Date         |
|---------|--------------------|------------------|--------------|
| 1.0     | All                | Initial document | 30 June 2026 |

### Table of Contents

- 1. Introduction
- 2. Role Documentation
  - 2.1 Audit Head
  - 2.2 Audit Manager
  - 2.3 Auditor
- 3. Module Documentation
  - 3.1 Dashboard
  - 3.2 Audit Charter
  - 3.3 Independence & Objectivity
  - 3.4 Audit Universe
  - 3.5 Risk Identification
  - 3.6 Risk Register
  - 3.7 Risk Universe
  - 3.8 Risk Assessment
  - 3.9 Strategic Plan
  - 3.10 Operational Plan
  - 3.11 Audit Engagement
  - 3.12 Engagement Meetings (Opening, Discussion, Closing)
  - 3.13 Fieldwork
  - 3.14 Findings
  - 3.15 Recommendations
  - 3.16 Audit Report
  - 3.17 Follow-up
  - 3.18 Feedback Survey
  - 3.19 Document Library
  - 3.20 Audit Trail
  - 3.21 Audit Settings
  - 3.22 User Management
  - 3.23 Organization (Internal Audit)
  - 3.24 Customer Accounts (Account Overview)
- 4. Complete Audit Lifecycle
- 5. Role × Module Access Matrix
- 6. Appendix

### 1. Introduction

Purpose

This manual describes how to use the **Internal Audit Management System**, a module of the GRC (Governance, Risk, and Compliance) application. It provides step-by-step guidance for performing every task available in the Internal Audit module so that a new user can operate the system without developer assistance.

Scope

This document covers only the Internal Audit functionality that is implemented in the application: the audit dashboard, audit charter, independence declarations, audit universe, risk identification, risk register, risk universe, risk assessment, strategic and operational planning, audit engagements and their meetings, fieldwork, findings, recommendations, audit reports, CAPA tracking, follow-up, feedback survey, document library, audit trail, audit settings, user management, the Internal Audit Organization area, and the Customer Accounts (Account Overview) page.

System Overview

The Internal Audit module supports the full audit lifecycle — from defining the audit universe and identifying risks, through annual planning (Strategic and Operational Plans), executing audit engagements (opening meeting, fieldwork, findings, discussion and closing meetings), issuing the audit report and recommendations, tracking corrective actions (CAPA), and following up on implementation. Access to each feature is controlled by a Role-Based Access Control (RBAC) system.

Supported Languages

The application supports three languages, selectable per user:

- **English** (default, left-to-right)
- **Arabic** (right-to-left / RTL)
- **Latvian** (left-to-right)

User-interface labels are translated through the application's localization system, and user-entered data (such as risk names and finding descriptions) is translated dynamically when records are created or edited.

Target Audience

- **Customer Administrators** — configure audit settings and manage users.
- **Audit Heads** — own the audit function end-to-end, including strategic planning.
- **Audit Managers** — manage audits and operational planning (cannot create strategic plans).
- **Auditors** — execute fieldwork, record findings, and track corrective actions within their department.
- **Client Trainers** — onboard new users to the system.

Role Documentation

The Internal Audit module is governed by a Role-Based Access Control (RBAC) system. This chapter documents the three audit roles that are assignable to users: **Audit Head**, **Audit Manager**, and **Auditor**.

**Note on internal role keys.** The names shown to users do not always match the internal role keys stored by the system. In particular, the role displayed as **"Auditor"** is internally the `Auditee` key ( `src/lib/permissions.ts:319-321` , `ROLE_DISPLAY_OVERRIDES` ). The legacy internal `Auditor` key is retired and is not offered for assignment. Throughout this manual:

| Displayed name | Internal key              |
|----------------|---------------------------|
| Audit Head     | <code>AuditHead</code>    |
| Audit Manager  | <code>AuditManager</code> |
| Auditor        | <code>Auditee</code>      |

The permission actions defined by the system are exactly: **view**, **create**, **edit**, **delete**, **approve** ( `src/lib/permissions.ts:8` ). There is **no "export" action** in the permission matrix — the Export column below is therefore shown as "—" for all roles. Where a page exposes an actual export/download control, that is documented in the relevant module chapter as a UI control, not as a permission.

Each permission also carries a **scope** of `all` , `department` , or `own` ( `src/lib/permissions.ts:12` ), which limits *which records* the action applies to.

2.1 Audit Head

**Internal role key:** `AuditHead`

**Screenshot:** *Insert screenshot here*

Role Overview

**Purpose.** The Audit Head has full access to the Internal Audit module across all audit data ( `src/lib/permissions.ts:206` , `433-454` ). This is the most senior audit role.

**Responsibilities.** The Audit Head owns the full audit lifecycle: maintaining the Audit Charter and Audit Universe, identifying audit risks, building the audit plan, overseeing engagements and fieldwork, issuing reports, and tracking corrective actions through to closure. The Audit Head is the **only** role that can create Strategic Plans ( `audit.strategic-plan` with all actions; `src/lib/permissions.ts:441` ).

**Access Scope.** All audit resources are scoped to `all` (organization-wide), with two narrower entries: Audit Trail is scoped to `own` (the Audit Head sees only their own activity; `src/lib/permissions.ts:452` ), and `organization.department` is view-only, needed for department dropdowns ( `src/lib/permissions.ts:453` ). Audit Settings is **view-only** ( `src/lib/permissions.ts:450` ).

Permission Matrix

Resources below are the `audit.*` resources granted to `AuditHead` ( `src/lib/permissions.ts:433-452` ). `edit` is shown as **Update**. Actions granted via `['*']` map to View + Create + Update + Delete + Approve.

| Resource                                        | View | Create | Update | Delete | Approve | Export |
|-------------------------------------------------|------|--------|--------|--------|---------|--------|
| audit.dashboard                                 | ✓    | ✓      | ✓      | ✓      | ✓       | —      |
| audit.auditables (Audit Universe)               | ✓    | ✓      | ✓      | ✓      | ✓       | —      |
| audit.charter (Audit Charter)                   | ✓    | ✓      | ✓      | ✓      | ✓       | —      |
| audit.risk-identification (Risk Identification) | ✓    | ✓      | ✓      | ✓      | ✓       | —      |
| audit.risk-register (RiskRegister)              | ✓    | ✓      | ✓      | ✓      | ✓       | —      |
| audit.process (Process)                         | ✓    | ✓      | ✓      | ✓      | ✓       | —      |
| audit.strategic-plan (Strategic Plan)           | ✓    | ✓      | ✓      | ✓      | ✓       | —      |
| audit.operational-plan (Operational Plan)       | ✓    | ✓      | ✓      | ✓      | ✓       | —      |
| audit.planning (Audit Engagement)               | ✓    | ✓      | ✓      | ✓      | ✓       | —      |
| audit.independence (Independence & Objectivity) | ✓    | ✓      | ✓      | ✓      | ✓       | —      |
| audit.fieldwork (Fieldwork / Feedback Survey)   | ✓    | ✓      | ✓      | ✓      | ✓       | —      |
| audit.reports (Report)                          | ✓    | ✓      | ✓      | ✓      | ✓       | —      |
| audit.capa (CAPA / Follow-up)                   | ✓    | ✓      | ✓      | ✓      | ✓       | —      |
| audit.documents (Document Library)              | ✓    | ✓      | ✓      | ✓      | ✓       | —      |
| audit.risk-universe (Risk Universe)             | ✓    | ✓      | ✓      | ✓      | ✓       | —      |
| audit.settings (Audit Settings)                 | ✓    |        |        |        |         | —      |
| audit.audit-trail (Audit Trail) — scope: own    | ✓    |        |        |        |         | —      |

Audit Head also has `organization.department:view` (scope `all` ) outside the `audit.*` namespace, used for department dropdowns ( `src/lib/permissions.ts:453` ).

Navigation

Filtering the **Internal Audit** and **Follow-up** sidebar sections ( `src/lib/navigation.ts:295-329` ) by the Audit Head's permissions yields the following items (exact labels from `navigation.ts` ):

Internal Audit

- Dashboard
- Independence & Objectivity
- Audit Charter
- Audit Universe
- Risk Identification
- RiskRegister
- Strategic Plan
- Operational Plan
- Audit Engagement
- Report
- Feedback Survey
- Document Library
- Audit Trail
- Audit Settings

Follow-up (standalone top-level menu)

- Follow-up

The **Customer Accounts** item under Internal Audit ( `audit.account-overview:view` , `navigation.ts:300` ) is **not** visible to the Audit Head — that permission belongs to the GRC Administrator only.

## Dashboard

The Audit Head has `audit.dashboard` access and sees the main Internal Audit dashboard at `/internal-audit/dashboard`. The page header is "Audit Dashboard" with an "Internal Audit > Dashboard" breadcrumb (`dashboard/page.tsx:756, 760`).

The dashboard presents:

- Four stat cards: **Total Risks**, **Extreme Severity**, **Ongoing Audits**, **Completed Audits** (`dashboard/page.tsx:793, 807, 821, 835`).
- A **Risk by Rating** chart (Extreme / High / Medium / Low) (`:845`).
- A **CAPA Status Overview** panel, paginated by department, showing Open and Closed counts by severity (`:886`).
- An **Annual Audit Plan** table (Gantt-style by month) (`:1002`).
- An **Auditor Schedule** table (monthly allocation by auditor) (`:1066`).

Because the Audit Head is in the drill-down-enabled set (`canDrillDown; dashboard/page.tsx:216-218`), the stat cards, chart bars, CAPA badges and audit plan rows are clickable and open detail dialogs.

## Tasks Performed

- Create and maintain the **Audit Charter** and **Independence & Objectivity** declarations — see the *Audit Charter* and *Independence & Objectivity* chapters.
- Build and maintain the **Audit Universe**, perform **Risk Identification**, and manage the audit **RiskRegister** — see the *Audit Universe*, *Risk Identification*, and *Risk Register* chapters.
- **Create Strategic Plans** (exclusive to this role) and manage **Operational Plans** — see the *Strategic Plan* and *Operational Plan* chapters.
- Plan and oversee **Audit Engagements**, conduct **Fieldwork**, and issue **Reports** — see the *Audit Engagement*, *Fieldwork*, and *Report* chapters.
- Track corrective actions via **CAPA** and the **Follow-up** form — see the *CAPA Tracking* and *Follow-up* chapters.
- Maintain the **Document Library** and review the **Audit Trail** (own activity) — see the *Document Library* and *Audit Trail* chapters.
- View **Audit Settings** (read-only).

## 2.2 Audit Manager

**Internal role key:** `AuditManager`

**Screenshot:** *Insert screenshot here*

### Role Overview

**Purpose.** The Audit Manager has the same access as the Audit Head **except that Strategic Plans are view-only** — the Audit Manager cannot create a new strategic audit plan. The Audit Manager can fully edit Operational Plans (`src/lib/permissions.ts:214, 456-480`).

**Responsibilities.** The Audit Manager manages the day-to-day audit program: maintaining the Audit Universe and RiskRegister, building and editing Operational Plans, running engagements and fieldwork, issuing reports, and tracking CAPA. The Audit Manager consumes (views) the Strategic Plan set by the Audit Head but does not author it.

**Access Scope.** All audit resources are scoped to `all`, except: Strategic Plan is **view-only** (`src/lib/permissions.ts:466`), Audit Settings is view-only (`:476`), and Audit Trail is scoped to `own` (`:478`). `organization.department` is view-only for dropdowns (`:479`).

### Permission Matrix

Resources granted to `AuditManager` (`src/lib/permissions.ts:458-478`). The only difference from the Audit Head is the **Strategic Plan** row (view-only).

| Resource                                        | View | Create | Update | Delete | Approve | Export |
|-------------------------------------------------|------|--------|--------|--------|---------|--------|
| audit.dashboard                                 | ✓    | ✓      | ✓      | ✓      | ✓       | —      |
| audit.auditables (Audit Universe)               | ✓    | ✓      | ✓      | ✓      | ✓       | —      |
| audit.charter (Audit Charter)                   | ✓    | ✓      | ✓      | ✓      | ✓       | —      |
| audit.risk-identification (Risk Identification) | ✓    | ✓      | ✓      | ✓      | ✓       | —      |
| audit.risk-register (RiskRegister)              | ✓    | ✓      | ✓      | ✓      | ✓       | —      |
| audit.process (Process)                         | ✓    | ✓      | ✓      | ✓      | ✓       | —      |
| audit.strategic-plan (Strategic Plan)           | ✓    |        |        |        |         | —      |
| audit.operational-plan (Operational Plan)       | ✓    | ✓      | ✓      | ✓      | ✓       | —      |
| audit.planning (Audit Engagement)               | ✓    | ✓      | ✓      | ✓      | ✓       | —      |
| audit.independence (Independence & Objectivity) | ✓    | ✓      | ✓      | ✓      | ✓       | —      |
| audit.fieldwork (Fieldwork / Feedback Survey)   | ✓    | ✓      | ✓      | ✓      | ✓       | —      |
| audit.reports (Report)                          | ✓    | ✓      | ✓      | ✓      | ✓       | —      |
| audit.capa (CAPA / Follow-up)                   | ✓    | ✓      | ✓      | ✓      | ✓       | —      |
| audit.documents (Document Library)              | ✓    | ✓      | ✓      | ✓      | ✓       | —      |
| audit.risk-universe (Risk Universe)             | ✓    | ✓      | ✓      | ✓      | ✓       | —      |
| audit.settings (Audit Settings)                 | ✓    |        |        |        |         | —      |
| audit.audit-trail (Audit Trail) — scope: own    | ✓    |        |        |        |         | —      |

Audit Manager also has `organization.department:view` (scope `all`) outside the `audit.*` namespace ( `src/lib/permissions.ts:479` ).

## Navigation

Because the Audit Manager holds at least `view` on every `audit.*` resource that the Audit Head holds (including `audit.strategic-plan:view`), the **Internal Audit** and **Follow-up** sidebar sections render the **same items** as for the Audit Head ( `src/lib/navigation.ts:295-329` ):

### Internal Audit

- Dashboard
- Independence & Objectivity
- Audit Charter
- Audit Universe
- Risk Identification
- RiskRegister
- Strategic Plan
- Operational Plan
- Audit Engagement
- Report
- Feedback Survey
- Document Library
- Audit Trail
- Audit Settings

### Follow-up

- Follow-up

The **Strategic Plan** item is visible, but the page itself is view-only for this role (no create). The **Customer Accounts** item is not visible.

## Dashboard

The Audit Manager has `audit.dashboard` access and sees the **same main dashboard** as the Audit Head at `/internal-audit/dashboard` — header "**Audit Dashboard**", with the four stat cards (Total Risks, Extreme Severity, Ongoing Audits, Completed Audits), **Risk by Rating** chart, **CAPA Status Overview**, **Annual Audit Plan** table, and **Auditor Schedule** table.

**Drill-down note.** The dashboard's clickable drill-down behaviour is enabled only for the `AuditHead` and (legacy) `Auditor` role keys ( `dashboard/page.tsx:216-218` ). The Audit Manager ( `AuditManager` ) is not in that set, so the stat cards, chart and tables render but are **not clickable** for drill-down. (Behaviour verified in code; confirm visually with a screenshot.)

## Tasks Performed

- Maintain the **Audit Universe**, **Risk Identification**, and **RiskRegister** — see the *Audit Universe*, *Risk Identification*, and *Risk Register* chapters.
- **View** the **Strategic Plan** (cannot create); build and edit **Operational Plans** — see the *Strategic Plan* and *Operational Plan* chapters.
- Plan and run **Audit Engagements**, conduct **Fieldwork**, and issue **Reports** — see the *Audit Engagement*, *Fieldwork*, and *Report* chapters.
- Track corrective actions via **CAPA** and **Follow-up** — see the *CAPA Tracking* and *Follow-up* chapters.
- Maintain the **Audit Charter**, **Independence & Objectivity**, and **Document Library**; review the **Audit Trail** (own activity).
- View **Audit Settings** (read-only).

### 2.3 Auditor

**Internal role key:** `Auditee` (displayed to users as "**Auditor**" via `ROLE_DISPLAY_OVERRIDES`, `src/lib/permissions.ts:319-321`)

**Screenshot:** *Insert screenshot here*

#### Role Overview

**Purpose.** The Auditor is a **department-scoped** role with strictly limited access. It can work only on **Fieldwork**, **CAPA Tracking**, and **Reports** (`src/lib/permissions.ts:220-222, 526-539`).

**Responsibilities.** The Auditor responds to and works within audit engagements for their own department: contributing to fieldwork, viewing reports, and recording/updating corrective actions (CAPA). The role explicitly has **no** access to the Dashboard, Audit Universe, Risk Identification, RiskRegister, Audit Planning, Document Library, Settings, or Risk Universe (`src/lib/permissions.ts:527-530`).

**Access Scope.** All granted audit resources are scoped to `department`, except Audit Trail which is scoped to `own` (`src/lib/permissions.ts:533-538`). `organization.department:view` is scoped to `department` for name lookups (`:533`).

#### Permission Matrix

Resources granted to `Auditee` (`src/lib/permissions.ts:532-538`).

| Resource                                                          | View | Create | Update | Delete | Approve | Export |
|-------------------------------------------------------------------|------|--------|--------|--------|---------|--------|
| audit.fieldwork (Fieldwork / Feedback Survey) — scope: department | ✓    |        | ✓      |        |         | —      |
| audit.capa (CAPA / Follow-up) — scope: department                 | ✓    |        | ✓      |        |         | —      |
| audit.reports (Report) — scope: department                        | ✓    |        |        |        |         | —      |
| audit.audit-trail (Audit Trail) — scope: own                      | ✓    |        |        |        |         | —      |

The Auditor also has `organization.department:view` (scope `department`) outside the `audit.*` namespace, used for department name lookups (`src/lib/permissions.ts:533`). The Auditor has **no** `audit.dashboard`, `audit.settings`, `audit.documents`, `audit.strategic-plan`, `audit.operational-plan`, `audit.planning`, `audit.auditables`, `audit.risk-identification`, `audit.risk-register`, `audit.risk-universe`, `audit.charter`, `audit.independence`, or `audit.process` permission.

#### Navigation

Filtering the **Internal Audit** and **Follow-up** sidebar sections (`src/lib/navigation.ts:295-329`) by the Auditor's permissions yields only the items whose required permission the role holds:

##### Internal Audit

- Report — gated by `audit.reports:view` (`navigation.ts:310`)
- Feedback Survey — gated by `audit.fieldwork:view` (`navigation.ts:311`)
- Audit Trail — gated by `audit.audit-trail:view` (`navigation.ts:313`)

##### Follow-up (standalone top-level menu)

- Follow-up — gated by `audit.capa:view` (`navigation.ts:327`)

There is **no Fieldwork item** in the Internal Audit sidebar section; the Fieldwork permission instead surfaces the **Feedback Survey** item (gated on `audit.fieldwork:view`), and the standalone **Follow-up** menu surfaces via `audit.capa:view`. The Auditor sees **no Dashboard** item.

#### Dashboard

The Auditor does **not** have `audit.dashboard` permission, so the **Dashboard** nav item is not shown. If the page at `/internal-audit/dashboard` is reached directly, the dashboard's `canView` check (driven by `usePermissions('audit.dashboard')`, `dashboard/page.tsx:191, 359-361`) fails and the page renders the **Unauthorized** screen with the message "**You don't have permission to access the Internal Audit Dashboard.**"

The code contains a simplified "My Audit Tasks" Auditee view ( `dashboard/page.tsx:668-743` ), but it is gated behind the same `audit.dashboard.canView` check at `:359`, which the `Auditee` role does not satisfy. The Auditor's working entry points are therefore the **Report**, **Feedback Survey**, **Audit Trail**, and **Follow-up** pages rather than the dashboard.

### Tasks Performed

- Contribute to **Fieldwork** for their department — see the *Fieldwork* chapter.
  - View **Reports** for their department — see the *Report* chapter.
  - Record and update **corrective actions (CAPA)** for their department, and use the **Follow-up** form — see the *CAPA Tracking* and *Follow-up* chapters.
  - Review their own **Audit Trail** activity — see the *Audit Trail* chapter.
-

# Dashboard

## Overview

**Purpose.** The Dashboard is the landing page of the Internal Audit module. It gives audit management a single, read-only snapshot of the audit function: risk exposure, audit activity, corrective-action (CAPA) status by department, the annual audit plan, and the auditor workload schedule.

**Business Objective.** Allow the Head of Internal Audit and Audit Managers to monitor the state of the audit programme at a glance and to drill into the underlying risks, audits, and findings without leaving the page.

## Access

| Role          | Access | Behaviour                                                                                                                                                                               |
|---------------|--------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Audit Head    | ✓ Full | Sees the full dashboard <b>and</b> can click any card, chart bar, or table row to open a drill-down dialog.                                                                             |
| Audit Manager | ✓ View | Sees the full dashboard, but cards/charts/rows are <b>not</b> clickable (no drill-down).                                                                                                |
| Auditor       | X None | The Auditor role does <b>not</b> have the <code>audit.dashboard</code> permission. The Dashboard does not appear in their sidebar, and opening the URL shows an "Unauthorized" message. |

**Permission required:** `audit.dashboard:view` (verified in `src/app/api/internal-audit/dashboard/route.ts:542` and the page's `usePermissions('audit.dashboard')` check at `dashboard/page.tsx:191` ).

**Note — drill-down is role-gated in the UI.** The clickable drill-down is enabled only when the signed-in user has the `AuditHead` (or internal `Auditor` ) role ( `dashboard/page.tsx:216-218` ). Audit Managers can read every figure but cannot open the drill-down dialog.

## Prerequisites

The Dashboard only displays data; it creates nothing. For figures to appear there must already be:

- Internal Audit **risks** in the Risk Register (drives Total/Extreme/High/Medium/Low risk counts).
- Audit Engagements** with statuses and dates (drives audit counts, the Annual Audit Plan, and the Auditor Schedule).
- Findings** linked to engagements/departments (drives the CAPA Status Overview).

If none exist, the page still loads and shows empty-state messages (see below).

**Screenshot:** *Insert screenshot here*

The page (for Audit Head / Audit Manager) shows, top to bottom: a breadcrumb, the page title "**Audit Dashboard**", a row of four statistic cards, a two-column charts row (**Risk by Rating** and **CAPA Status Overview**), the **Annual Audit Plan** table, and the **Auditor Schedule** table.

## Page Layout

| Section              | Description                                                                                                                   |
|----------------------|-------------------------------------------------------------------------------------------------------------------------------|
| Breadcrumb           | "Internal Audit" > " <b>Dashboard</b> " (Audit Head / Manager view).                                                          |
| Page title           | " <b>Audit Dashboard</b> ".                                                                                                   |
| Statistic cards      | Four cards: <b>Total Risks</b> , <b>Extreme Severity</b> , <b>Ongoing Audits</b> , <b>Completed Audits</b> .                  |
| Risk by Rating       | Horizontal bar list for <b>Extreme / High / Medium / Low</b> with counts.                                                     |
| CAPA Status Overview | Per-department <b>Open / Closed</b> counts split into <b>H</b> (high), <b>M</b> (medium), <b>L</b> (low) badges, with paging. |
| Annual Audit Plan    | Gantt-style table for the selected year: audit name, audit manager, and a Jan–Dec timeline.                                   |
| Auditor Schedule     | Gantt-style table of monthly allocation per auditor for the selected year.                                                    |
| Drill-down dialog    | Modal opened (Audit Head only) when a card / bar / row is clicked.                                                            |
| Loading state        | Spinner with " <b>Loading dashboard...</b> " while data loads.                                                                |

## Field Reference

The Dashboard is display-only — it has no input form or editable fields. The values shown are:



| Element              | Source field                                     | Description                                                                                                 |
|----------------------|--------------------------------------------------|-------------------------------------------------------------------------------------------------------------|
| Total Risks          | <code>riskStats.total</code>                     | Count of all Internal Audit risks in scope.                                                                 |
| Extreme Severity     | <code>riskStats.extreme</code>                   | Risks with level Extreme/Critical.                                                                          |
| Ongoing Audits       | <code>auditStats.ongoing</code>                  | Engagements with status In Progress/InProgress/Ongoing/Active (see System Behaviour for the fallback rule). |
| Completed Audits     | <code>auditStats.completed</code>                | Engagements with status Completed/Complete/Done/Closed.                                                     |
| Risk by Rating       | <code>riskStats.{extreme,high,medium,low}</code> | Bar value per severity.                                                                                     |
| CAPA Status Overview | <code>capaStatusByDepartment[ ]</code>           | Per-department open/closed counts by H/M/L severity, derived from findings.                                 |
| Annual Audit Plan    | <code>annualAuditPlan[ ]</code>                  | Audit name, Audit Manager (assigned auditor), duration in days, start/end month.                            |
| Auditor Schedule     | <code>auditorSchedule[ ]</code>                  | Each auditor's monthly assignments and duration.                                                            |

## Tables

### Annual Audit Plan

- Columns: **Audit Name**, **Audit Manager**, then **Jan ... Dec**.
- The start month cell shows a "{N} Days" badge; subsequent in-range months show a filled bar.
- Empty state: **"No audit plans for this year"**.
- Row action (Audit Head only): clicking a row opens the **Audit Details** drill-down dialog.
- No sorting, search, filter, pagination, or bulk actions on this table.

### Auditor Schedule

- Columns: **Auditor Name**, then **Jan ... Dec**. Subtitle: **"Monthly allocation by auditor"**.
- Start month shows a "{N} Days" badge (hover shows the engagement title); in-range months show a filled bar.
- Empty state: **"No auditor schedules for this year"**.

**CAPA Status Overview** has its own paging control showing **"{from} to {to} of {total}"** with previous/next arrows (2 departments per page).

**Drill-down dialog tables** (Audit Head only) — footer shows **"Showing {n} of {total} records"**:

| Drill-down    | Columns                                                                                                                                |
|---------------|----------------------------------------------------------------------------------------------------------------------------------------|
| Risks         | Risk ID · Description · Department · Category · Severity · Status · Action                                                             |
| Audits        | Audit ID · Title · Department · Type · Audit Manager · Status · Action                                                                 |
| CAPA          | CAPA ID · Title · Finding · Severity · Responsible · Target Date · Status · Action                                                     |
| Audit Details | Single record: Audit ID, Department, Type, Status, Duration, Audit Manager, Findings count, Evidence Requests count, Objectives, Scope |

## Buttons & Actions

| Control                                                | Permission                        | Visible To                               | Action                                                                                | API                                                                                        | Success                         | Failure                                      |
|--------------------------------------------------------|-----------------------------------|------------------------------------------|---------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------|---------------------------------|----------------------------------------------|
| Statistic card (Total / Extreme / Ongoing / Completed) | <code>audit.dashboard:view</code> | Audit Head (clickable); Manager (static) | Opens Risks or Audits drill-down                                                      | <code>GET /api/internal-audit/dashboard/drill-down?type=risks audits&amp;filter=...</code> | Dialog lists matching records   | Toast <b>"Failed to fetch detailed data"</b> |
| Risk by Rating bar                                     | <code>audit.dashboard:view</code> | Audit Head                               | Opens Risks drill-down filtered by that severity                                      | <code>GET .../drill-down?type=risks&amp;filter={level}</code>                              | Dialog lists risks              | Toast <b>"Failed to fetch detailed data"</b> |
| CAPA status badge (H/M/L)                              | <code>audit.dashboard:view</code> | Audit Head                               | Opens CAPA drill-down for that department + status                                    | <code>GET .../drill-down?type=capa&amp;department=...&amp;status=open closed</code>        | Dialog lists findings           | Toast <b>"Failed to fetch detailed data"</b> |
| Annual Audit Plan row / Auditor Schedule badge         | <code>audit.dashboard:view</code> | Audit Head                               | Opens <b>Audit Details</b> drill-down                                                 | <code>GET .../drill-down?type=audit-plan&amp;auditId=...</code>                            | Dialog shows audit detail       | Toast <b>"Failed to fetch detailed data"</b> |
| Drill-down row <b>Action</b> (↗) icon                  | <code>audit.dashboard:view</code> | Audit Head                               | Navigates: risk → Risk Register; audit → Fieldwork detail modal; capa → CAPA Tracking | — (client navigation)                                                                      | Target page/modal opens         | —                                            |
| <b>View Full Details</b> (in Audit Details dialog)     | <code>audit.dashboard:view</code> | Audit Head                               | Opens the Fieldwork detail modal for that engagement                                  | —                                                                                          | Modal opens                     | —                                            |
| CAPA paging ◀ / ▶                                      | <code>audit.dashboard:view</code> | Audit Head / Manager                     | Pages the CAPA Status Overview                                                        | —                                                                                          | Next/previous departments shown | —                                            |

There are **no** create, edit, delete, approve, submit, upload, download, or export controls on this page. The Dashboard does not write any data, generate any notification, or create any audit-trail entry — every action is a read or an in-app navigation.

## Step-by-Step Instructions

### View the dashboard

1. From the Internal Audit sidebar, click **Dashboard**.
2. Wait for **"Loading dashboard..."** to finish; the cards, charts, and tables populate.

### Drill into a figure (Audit Head)

1. Click a statistic card (e.g. **Extreme Severity**), a **Risk by Rating** bar, a CAPA **H/M/L** badge, or an **Annual Audit Plan** row.
2. The drill-down dialog opens with the description **"Click on any row to view more details"**.
3. Review the listed records; the footer shows **"Showing {n} of {total} records"**.
4. Click a row's  action icon to open the related record (Risk Register, Fieldwork modal, or CAPA Tracking).
5. Close the dialog to return to the dashboard.

### Page the CAPA Status Overview

1. Use the  /  arrows in the CAPA card header to move between departments (2 per page).

## Workflow

The Dashboard is a **read-only reporting view** and is not part of any state machine. There is no status change, validation, write, audit-trail entry, or notification originating from this page.

Open Dashboard → GET `/api/internal-audit/dashboard` → render figures → (Audit Head) click element → GET `.../drill-down` → render dialog → (optional) navigate to source record

## Status Reference

The Dashboard **does not own** any status. It only *displays* statuses owned by other modules and groups them:

- **Audit (engagement) status** is bucketed as **Ongoing** (In Progress / InProgress / Ongoing / Active), **Completed** (Completed / Complete / Done / Closed), or **Planned** (Planned / Planning / Draft / Pending).
- **Finding/CAPA status** is bucketed as **Open** (anything not Closed/Completed) or **Closed** (Closed / Completed).

These buckets are defined in `dashboard/route.ts` and `drill-down/route.ts`.

## Validation Rules

None. The page submits no data, so there are no required fields, field validation, duplicate checks, or approval checks. The only enforced rule is the **permission check** (`audit.dashboard:view`): users without it see the **"You don't have permission to access the Internal Audit Dashboard."** message.

## Success Scenarios

- **Dashboard loads:** GET `/api/internal-audit/dashboard` returns 200 → cards, charts, and tables render with live counts. No message is shown on success (silent load).
- **Drill-down opens:** GET `.../drill-down` returns 200 → dialog lists matching records with the "Showing {n} of {total} records" footer.

## Failure Scenarios

| Failure                | Why it happens                                              | What the user sees                                                                                                                     | Resolution                                                    |
|------------------------|-------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------|
| Dashboard fetch fails  | API returns non-200 or network error                        | Toast <b>"Failed to fetch dashboard data"</b> ; cards show 0                                                                           | Refresh the page; check connectivity/permissions              |
| Drill-down fetch fails | API returns non-200 or network error                        | Toast <b>"Failed to fetch detailed data"</b>                                                                                           | Close and retry                                               |
| No permission          | Role lacks <code>audit.dashboard:view</code> (e.g. Auditor) | <b>"You don't have permission to access the Internal Audit Dashboard."</b>                                                             | Use a role with dashboard access (Audit Head / Audit Manager) |
| No data                | Empty risk/engagement/finding data                          | Empty states: "No risk data available", "No CAPA data available", "No audit plans for this year", "No auditor schedules for this year" | Add the underlying records in the relevant modules            |

## System Behaviour

- **Read-only & automatic:** data is fetched once on page load ( `useEffect` ). No background polling.
- **Year auto-selection:** the Annual Audit Plan and Auditor Schedule default to the current calendar year; if there is no data for the current year, the page automatically falls back to the **most recent year that has audit data** ( `dashboard/route.ts:225-263` ).
- **"Ongoing" fallback:** if all engagement status counts are 0 but engagements exist, the total is shown as **Ongoing** ( `dashboard/route.ts:161-164` ).

- **Multi-tenant & Audit-Head scoping:** results are filtered to the user's customer account and, for an Audit Head, to risks/CAPAs assigned to that audit head (or unassigned/legacy records).
- **Dynamic translation:** Annual Audit Plan titles are passed through the data-translation hook so they display in the active language.
- **No writes/notifications/audit-trail:** confirmed — the dashboard endpoints are `GET` only.

### Notes

---

**Note.** "Audit Manager" is the column label used throughout the dashboard for the engagement's **assigned auditor** ( `dashboard/page.tsx:1012` , drill-down columns). It refers to the person assigned to run the audit, not necessarily a user holding the Audit Manager role.

**Tip.** Only the Head of Internal Audit can use the click-through drill-downs. If figures look off, drill in from the cards to see the exact records behind a number.

**Warning.** The CAPA Status Overview is built from **findings** data (severity High/Medium/Low, status Open/Closed). Findings without a department are grouped under **"Unknown"**.

# Audit Charter

## Overview — Purpose, Business Objective

The **Audit Charter** page presents the organization's Internal Audit Charter as an editable, on-screen document. The charter text is rendered from structured content (headings, paragraphs, tables, and lists) and contains a small number of inline **editable fields** (placeholder values shown in blue). Users with edit rights can fill in those fields (for example organization-specific names or values), save them, download the charter as a Microsoft Word ( `.docx` ) document, and upload a scanned/signed copy of the charter for record-keeping.

Business objective: provide a single, per-organization authoritative Internal Audit Charter that can be customized in-place, exported to Word, and supplemented with an officially signed copy — all stored against the tenant (customer account).

Key facts from the code:

- The charter is **per customer account** — there is exactly one charter record per tenant ( `customerAccountId @unique` , `prisma/schema.prisma:6262` ).
- On first view the charter is **auto-created** from a built-in default ( `DEFAULT_CHARTER_CONTENT` ) if none exists or if it has no editable fields ( `route.ts:29-45` ).
- The page heading is **"Audit Charter"** ( `page.tsx:457` ).

## Access — Which roles can use it + exact permissions

Permission resource: `audit.charter` (route guards in all charter API handlers; navigation entry `audit.charter:view` , `navigation.ts:303` ).

| Role (internal key)                         | Displayed as  | Charter permission                                                                                                                                    | Source                                                 |
|---------------------------------------------|---------------|-------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------|
| Audit Head ( <code>AuditHead</code> )       | Audit Head    | <code>audit.charter</code> → all actions ( <code>['*']</code> ) → can view, edit, save, upload, download                                              | <code>permissions.ts:436</code>                        |
| Audit Manager ( <code>AuditManager</code> ) | Audit Manager | <code>audit.charter</code> → all actions ( <code>['*']</code> ) → can view, edit, save, upload, download                                              | <code>permissions.ts:461</code>                        |
| Auditor ( <code>Auditee</code> )            | Auditor       | <b>No <code>audit.charter</code> permission</b> — the page is not in the Auditee permission set, so it is hidden from navigation and access is denied | <code>permissions.ts:532-539</code> (no charter entry) |

Notes:

- The legacy internal `Auditor` key ( `permissions.ts:503-506` ) is retired/hidden and is not assignable; do not treat it as the documented Auditor role.
- API actions required: viewing/downloading/streaming the signed copy require `audit.charter:view` ; saving field values, uploading a signed copy, and uploading a DOCX require `audit.charter:edit` ( `route.ts:58,91` ; `signed-copy/route.ts:83,124` ; `download/route.ts:179` ; `upload/route.ts:64` ).
- In the UI, edit-only controls (Save Changes, Upload Signed Copy, and the inline editable-field inputs) are shown only when the client `canEdit` is true ( `page.tsx:338,478,509,523` ). When the user cannot edit, fields render as read-only blue text ( `page.tsx:57-60` ).

## Prerequisites

- The user must be signed in with a role granting `audit.charter:view` (Audit Head or Audit Manager).
- A customer account context must exist (the charter is keyed by `customerAccountId` , resolved from the session via `getCustomerAccountId` ).
- No prior data setup is required: if no charter exists, the GET handler auto-creates one from the built-in default content ( `route.ts:29-45` ), so the page is usable immediately.

**Screenshot:** *Insert screenshot here*

Visible areas of the page (from `page.tsx` ):

- **Header row** ( `page.tsx:453-520` ): a document icon plus the title **"Audit Charter"**; directly beneath the title, the original uploaded file name is shown in small muted text **only if** `originalFileName` exists ( `page.tsx:458-462` ). On the right side of the header is the action button cluster.
- **Header action buttons** (right side): **"Download Word"** (always visible), **"Upload Signed Copy"** (edit users only), and **"Save Changes"** (edit users only).
- **Editable Fields panel** ( `page.tsx:522-530` , `EditableFieldsPanel` at 243-298): shown only to edit users and only when the document has at least one editable field. It is a blue-bordered card titled **"Editable Fields"** with the hint **"— changes apply throughout the document"**, containing one labeled input per unique field.
- **Document body** ( `page.tsx:533-545` ): a card rendering the charter content blocks — headings (h1–h6), paragraphs, bordered tables, and ordered/unordered lists. Inline editable fields appear within the text as blue underlined inputs (or blue text when read-only).
- **Sticky save bar** ( `page.tsx:548-562` ): appears at the bottom of the document card only for edit users and only when there are unsaved changes; shows **"You have unsaved changes"** and a **"Save Changes"** button.
- **Uploaded Signed Documents section** ( `SignedCopySection` , `page.tsx:300-332,571` ): shown only after a signed copy exists; a card titled **"Uploaded Signed Documents"** with a **"View Signed Copy"** button and the signed file name.
- **Loading state** ( `page.tsx:438-445` ): a spinner with **"Loading..."** while the charter loads.
- **Error/empty state** ( `page.tsx:564-568` ): if the charter cannot be loaded, the message **"Unable to load charter. Please refresh the page."** is shown in place of the document.

There is no breadcrumb, no summary/statistics cards, no tabs, no filters, no search box, and no pagination on this page.

## Page Layout

| Area                       | Present?                          | Details                                                                                                           |
|----------------------------|-----------------------------------|-------------------------------------------------------------------------------------------------------------------|
| Header / title             | Yes                               | Icon + "Audit Charter"; optional original file name subtitle ( <code>page.tsx:455-463</code> )                    |
| Breadcrumb                 | No                                | Not present                                                                                                       |
| Summary cards              | No                                | Not present                                                                                                       |
| Tabs                       | No                                | Not present                                                                                                       |
| Editable Fields form panel | Yes (edit users, if fields exist) | Blue card, title "Editable Fields", hint text, grid of labeled inputs ( <code>page.tsx:243-298</code> )           |
| Document body              | Yes                               | Renders headings, paragraphs, tables, lists with inline field inputs ( <code>page.tsx:120-205</code> )            |
| Tables (data grid)         | No (renders content tables only)  | The page renders tables that are part of the charter <i>content</i> ; there is no list/data grid with row actions |
| Filters / Search           | No                                | Not present                                                                                                       |
| Header buttons             | Yes                               | Download Word; Upload Signed Copy (edit); Save Changes (edit)                                                     |
| Sticky save bar            | Yes (edit users, when dirty)      | Message + Save Changes button ( <code>page.tsx:548-562</code> )                                                   |
| Signed documents panel     | Yes (when a signed copy exists)   | "Uploaded Signed Documents" card with "View Signed Copy" ( <code>page.tsx:300-332</code> )                        |
| Footer                     | No                                | Not present                                                                                                       |
| Dialogs                    | No                                | No modal dialogs; upload uses a hidden native file input ( <code>page.tsx:480-491</code> )                        |

## Field Reference

The editable fields are **not a fixed form** — they are derived dynamically from the charter content. Every inline node of type `field` produces one editable input; the field label is generated from the placeholder default value ( `labelFromDefault` , `page.tsx:234-239` ), and the input renders as a multi-line `Textarea` when the default value is longer than 60 characters, otherwise a single-line `Input` ( `page.tsx:55,271` ). The exact set of fields depends on the charter content (default content or an uploaded DOCX), so a fixed field list cannot be enumerated from the page code.

| Field                           | Required                                   | Type                                                                                                                                     | Default                                                                                                                                     | Validation                                                                                                                                                | Editable                                                                          | Description                                                                                                                                 |
|---------------------------------|--------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------|
| Inline charter fields (dynamic) | No (no required-field enforcement in code) | Text — single-line <code>Input</code> or multi-line <code>Textarea</code> (multiline when default length > 60)                           | The field's <code>defaultValue</code> from the content; the saved value falls back to the default if unset ( <code>page.tsx:54,270</code> ) | None — no client or server validation of field values; PATCH only requires <code>fieldValues</code> to be a non-null object ( <code>route.ts:68</code> )  | Yes for edit users; read-only blue text otherwise ( <code>page.tsx:57-60</code> ) | A placeholder value embedded in the charter text; editing it updates every occurrence throughout the document ( <code>page.tsx:265</code> ) |
| Signed copy file (upload)       | No                                         | File upload ( <code>.pdf</code> , <code>.docx</code> , <code>.jpg</code> , <code>.jpeg</code> , <code>.png</code> , <code>.webp</code> ) | None                                                                                                                                        | File must be provided and its extension must map to an allowed MIME type: PDF, DOCX, JPG/JPEG, PNG, WEBP ( <code>signed-copy/route.ts:5-17,28-38</code> ) | Edit users only                                                                   | Stored as the official signed copy of the charter                                                                                           |

Notes:

- The page-level UI does not expose the **DOCX upload** of new charter *content*; that endpoint exists ( `upload/route.ts` ) but is not wired to any button on `audit-charter/page.tsx` . The visible "Upload Signed Copy" button targets the *signed-copy* endpoint, not the content-upload endpoint.

## Tables

This page does not contain a data table/list with sortable columns, search, filtering, pagination, row actions, or bulk actions. Tables that appear inside the document body are part of the charter **content** and are rendered read-only/edit-inline as ordinary HTML tables ( `page.tsx:158-183` ) — they have no sorting or row actions.

## Buttons & Actions

| Control                                                  | Permission                             | Visible To                                                                                        | Action                                                                                                  | API                                                                               | Success Msg                           | Failure Msg                                                                                                                                                                                                               | Audit Trail  | Noti |
|----------------------------------------------------------|----------------------------------------|---------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------|---------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------|------|
| <b>Download Word</b><br>( page.tsx:468 )                 | audit.charter:view<br>(endpoint guard) | All who can view the page                                                                         | Fetches generated .docx and triggers browser download as audit-charter.docx ( page.tsx:391-408 )        | GET /api/internal-audit/audit-charter/download<br>( download/route.ts:117,179 )   | None (no toast on success)            | Failed to download document ( page.tsx:404 )                                                                                                                                                                              | Not verified | None |
| <b>Upload Signed Copy</b><br>( page.tsx:492-504 )        | audit.charter:edit                     | Edit users ( canEdit )                                                                            | Opens hidden file picker; on selection uploads the file as the signed copy ( page.tsx:480-491,411-435 ) | POST /api/internal-audit/audit-charter/signed-copy ( signed-copy/route.ts:20,83 ) | Signed copy uploaded ( page.tsx:427 ) | Server error message if present, else Failed to upload signed copy ( page.tsx:429 ); e.g. Unsupported file type. Allowed: PDF, DOCX, JPG, PNG ( signed-copy/route.ts:35 ) or No file provided ( signed-copy/route.ts:29 ) | Not verified | None |
| <b>Save Changes</b> (header)<br>( page.tsx:509-518 )     | audit.charter:edit                     | Edit users; disabled unless there are unsaved changes ( !dirty ) or while saving ( page.tsx:510 ) | Saves current field values ( page.tsx:370-388 )                                                         | PATCH /api/internal-audit/audit-charter ( route.ts:62,91 )                        | Charter saved ( page.tsx:382 )        | Failed to save charter ( page.tsx:384 )                                                                                                                                                                                   | Not verified | None |
| <b>Save Changes</b> (sticky bar)<br>( page.tsx:553-560 ) | audit.charter:edit                     | Edit users; shown only when dirty                                                                 | Same as header Save Changes                                                                             | PATCH /api/internal-audit/audit-charter                                           | Charter saved                         | Failed to save charter                                                                                                                                                                                                    | Not verified | None |
| <b>View Signed Copy</b><br>( page.tsx:318-327 )          | audit.charter:view<br>(endpoint guard) | All who can view the page; shown only after a signed copy exists                                  | Opens the stored signed copy in a new browser tab (inline)                                              | GET /api/internal-audit/audit-charter/signed-copy ( signed-copy/route.ts:89,124 ) | None (opens file)                     | Browser shows the endpoint error if no file: No signed copy found (404) ( signed-copy/route.ts:104 )                                                                                                                      | Not verified | None |
| Inline editable field inputs<br>( page.tsx:104-112 )     | audit.charter:edit                     | Edit users (read-only text otherwise)                                                             | Updates a field value in local state and marks the form dirty ( page.tsx:364-367 )                      | None (persisted only on Save)                                                     | n/a                                   | n/a                                                                                                                                                                                                                       | Not verified | None |
| Editable Fields panel inputs<br>( page.tsx:277-291 )     | audit.charter:edit                     | Edit users (if fields exist)                                                                      | Same as inline inputs (shared onChange )                                                                | None                                                                              | n/a                                   | n/a                                                                                                                                                                                                                       | Not verified | None |

No explicit audit-trail logging is performed inside any charter API handler reviewed; therefore audit-trail entries are marked **Not verified**. No notification/email logic is invoked by any charter handler.

## Step-by-Step Instructions

### A. View the charter

1. Open the Internal Audit menu and click **Audit Charter** (visible to Audit Head and Audit Manager).
2. Wait for the "Loading..." spinner to finish.
3. Read the rendered charter document. If editable, placeholder fields appear as blue inputs; otherwise they appear as blue read-only text.

### B. Edit and save inline fields (Audit Head / Audit Manager)

1. Locate the "Editable Fields" panel near the top of the page (it lists each editable field with a label).
2. Type the desired value into a field's input (single-line or multi-line). The same value also updates wherever that field appears in the document body.
3. Note the message "You have unsaved changes" appears in the sticky bar at the bottom of the document card.
4. Click **Save Changes** (in the header or in the sticky bar).
5. On success a toast shows "Charter saved" and the unsaved-changes indicator clears. (On failure a toast shows "Failed to save charter".)

### C. Download the charter as Word

1. Click **Download Word** in the header.
2. The button label changes to **"Generating..."** while the file is produced.
3. The browser downloads a file named `audit-charter.docx`.
4. If generation fails, a toast shows **"Failed to download document"**.

#### D. Upload a signed copy (Audit Head / Audit Manager)

1. Click **Upload Signed Copy** in the header.
2. In the file picker, choose a file of an allowed type: PDF, DOCX, JPG/JPEG, PNG, or WEBP.
3. The button shows **"Uploading..."** while the upload is in progress.
4. On success a toast shows **"Signed copy uploaded"**, and the **"Uploaded Signed Documents"** card appears (or updates) with the file name.
5. If the file type is not allowed, a toast shows the server message (e.g. **"Unsupported file type. Allowed: PDF, DOCX, JPG, PNG"**); if no file or another error, **"Failed to upload signed copy"** is shown.

#### E. View the uploaded signed copy

1. Scroll to the **"Uploaded Signed Documents"** card (visible only after a signed copy has been uploaded).
2. Click **View Signed Copy** — the file opens inline in a new browser tab.

### Workflow

The Audit Charter is a single editable document per tenant rather than a multi-stage approval workflow. The implemented data flows are:

**Save field values** Current Status: charter loaded (auto-created from default if needed) → User Action: edit fields and click **Save Changes** → Validation: client requires unsaved changes to enable the button; server requires `fieldValues` to be a non-null object ( `route.ts:68` ) and the charter record to exist ( `route.ts:76` ) → API: `PATCH /api/internal-audit/audit-charter` → DB Update: `auditCharter.fieldValues` updated for the tenant ( `route.ts:80-84` ) → Audit Trail: not verified → Notification: none → Next Status: saved (in-memory `dirty` cleared) → Next User: none.

**Upload signed copy** Current Status: any → User Action: click **Upload Signed Copy**, pick a file → Validation: file present and extension maps to an allowed MIME ( `signed-copy/route.ts:28-38` ) → API: `POST /api/internal-audit/audit-charter/signed-copy` → DB Update: `upsert signedCopyFileName, signedCopyData (Bytes), signedCopyMimeType, signedCopyUploadedAt` ( `signed-copy/route.ts:42-59` ) → Audit Trail: not verified → Notification: none → Next Status: signed copy available; **"Uploaded Signed Documents"** card shown → Next User: none.

**Download Word** and **View Signed Copy** are read-only retrievals (no status change, no DB write).

### Status Reference

This module does not implement a status field or lifecycle states for the charter (no `status` column on `AuditCharter` in `prisma/schema.prisma:6260-6273`, and no status logic in the page or handlers). The only state-like indicators are:

- **Unsaved changes** — client-only flag ( `dirty` ) that shows **"You have unsaved changes"** and enables Save Changes ( `page.tsx:346,548-552` ).
- **Signed copy present / absent** — derived from whether `signedCopyFileName` is set (controls visibility of the **"Uploaded Signed Documents"** card, `page.tsx:309` ).

There are no approval, draft, published, or archived statuses in the code.

### Validation Rules

- **Save (PATCH):** `fieldValues` must be present and an object; otherwise the API returns `400` with `fieldValues object required` ( `route.ts:68-70` ). The charter record must already exist for the tenant, else `404 Charter not found` ( `route.ts:76-78` ). Individual field values are not validated (no required, length, or format checks).
- **Signed copy upload (POST):** a file must be provided ( `400 No file provided, signed-copy/route.ts:28-30` ); the file extension must resolve to an allowed MIME — PDF, DOCX, JPG/JPEG, PNG, WEBP — otherwise `400 Unsupported file type. Allowed: PDF, DOCX, JPG, PNG` ( `signed-copy/route.ts:32-38` ). There is no explicit file-size check in this handler.
- **DOCX content upload (POST, not surfaced on this page):** file must be provided and end with `.docx`, else `400 Only .docx files are supported` ( `upload/route.ts:27-32` ).
- **Permission checks:** view actions require `audit.charter:view`; edit actions require `audit.charter:edit`, enforced by `withAuth` on every handler. The client also hides edit controls when `canEdit` is false.
- **Duplicate check:** none needed — the charter is uniquely keyed per customer account ( `@unique` ), so it is upserted rather than duplicated.

### Success Scenarios and Failure Scenarios

#### Success

- First visit with no existing charter → default charter content is auto-created and rendered ( `route.ts:29-45` ).
- Editing fields and saving → toast **"Charter saved"**, dirty indicator clears.
- Download Word → `audit-charter.docx` downloads.
- Upload an allowed signed file → toast **"Signed copy uploaded"**, **"Uploaded Signed Documents"** card appears.
- View Signed Copy → file opens inline in a new tab.

#### Failures

- **Save fails** (server returns non-OK, e.g. 400/404/500): toast **"Failed to save charter"** ( `page.tsx:384` ). Resolution: ensure fields contain valid text and retry; if it persists the charter record may be missing — refresh the page to re-trigger auto-create.
- **Download fails** (server returns non-OK): toast **"Failed to download document"** ( `page.tsx:404` ). Resolution: retry; if persistent, contact support (server-side generation error, `download/route.ts:175-176` ).
- **Signed copy upload — wrong type**: toast **"Unsupported file type. Allowed: PDF, DOCX, JPG, PNG"** ( `signed-copy/route.ts:35` ). Resolution: convert/upload one of the allowed types (PDF, DOCX, JPG/JPEG, PNG, WEBP).
- **Signed copy upload — no file / server error**: toast **"Failed to upload signed copy"** ( `page.tsx:429` ). Resolution: reselect a file and retry.
- **View Signed Copy when none stored**: the opened tab shows the API error `No signed copy found` (404). Resolution: upload a signed copy first. (In practice the button is only shown when a signed copy exists.)
- **Charter cannot be loaded**: the page shows **"Unable to load charter. Please refresh the page."** ( `page.tsx:566` ). Resolution: refresh.

## System Behaviour

---

- **Automatic record creation**: On GET, if no charter exists (or the stored content has no editable fields), the system upserts a charter with the built-in default content ( `route.ts:29-45` ).
- **Per-tenant isolation**: All charter operations key on `customerAccountId`; each customer account has exactly one charter ( `schema.prisma:6262` ).
- **Binary safety**: The signed-copy binary ( `signedCopyData` Bytes) is never returned in charter JSON responses — only metadata (file name, MIME, uploaded-at) is sent; the binary is streamed separately by the signed-copy GET endpoint ( `route.ts:6-17` , `signed-copy/route.ts:61-75` ). Note: `signedCopyData` is a Bytes column; per project encryption rules, `fileData`-style Bytes are auto-encrypted by the Prisma client extension when `ENCRYPTION_ENABLED` is set — encryption status for this specific column is **Not verified** here.
- **Word export generation**: The download endpoint builds the `.docx` server-side from the stored (or default) content and current field values, rendering field values in blue so they are re-detected if the document is later re-uploaded ( `download/route.ts:40-43,117-173` ).
- **Read-only behavior**: When the user lacks edit rights, the editable-fields panel, Save Changes button, Upload Signed Copy button, and sticky bar are all hidden, and inline fields render as static blue text ( `page.tsx:57-60,478,509,523` ).
- **Audit-trail logging**: Not verified — no audit-trail write was found in the charter handlers reviewed.
- **Notifications**: None — no notification or email logic in any charter handler.
- **Background processing**: None.

## Notes / Warnings / Tips

---

- **Tip**: Changing a value in the **"Editable Fields"** panel updates that value everywhere it appears in the document — this is stated in the panel hint **"— changes apply throughout the document"** ( `page.tsx:265` ).
  - **Warning**: Field edits are saved only when you click **Save Changes**; navigating away with **"You have unsaved changes"** showing will lose them (no autosave).
  - **Note**: The Auditor role (internal `Auditee`) has no charter permission and will not see this page in the navigation.
  - **Note**: The "Upload Signed Copy" button is for the *signed* copy only; it does not replace the charter's editable content. A separate DOCX content-upload API exists ( `upload/route.ts` ) but is not exposed by a button on this page.
  - **Note**: Allowed signed-copy file types per the server are PDF, DOCX, JPG/JPEG, PNG, and WEBP ( `signed-copy/route.ts:5-12` ); the on-screen error message phrases this as "Allowed: PDF, DOCX, JPG, PNG".
-



# Independence & Objectivity

## Overview — Purpose, Business Objective

The **Independence & Objectivity** module records and retains the independence and objectivity declarations made by the internal audit team. The page subtitle states its purpose directly: "Auditor independence and objectivity declarations per the Global Internal Audit Standards." ( `independence/page.tsx:252` )

Two declaration types are supported, each driven by IIA-aligned, fixed declaration text ( `src/lib/independence-declaration.ts` ):

- **Independence Declaration** — the declarant attests they are independent with respect to the activities, departments, and processes subject to a given audit engagement.
- **Objectivity Declaration** — the declarant attests they will perform the engagement with full objectivity and professional judgment.

Each declaration captures the declarant's details, the fixed declaration statements, a single declaration result, an optional explanation, a typed signature, and an optional reviewer/approval block. Completed declarations can be printed or saved as PDF as a signed record.

## Access — Roles and Required Permissions

All access is governed by the `audit.independence` resource permission ( `permissions.ts:444, 470, 491, 514` ; navigation gate `audit.independence:view` at `navigation.ts:302` ). Every API route is wrapped with `withAuth` against `audit.independence: view` (GET), `create` (POST), `edit` (PATCH), `delete` (DELETE) ( `declarations/route.ts:49,87` ; `declarations/[id]/route.ts:28,76,99` ).

| Role (displayed) | Internal key              | Permission on <code>audit.independence</code>                                    | Effect on this page                                                      |
|------------------|---------------------------|----------------------------------------------------------------------------------|--------------------------------------------------------------------------|
| Audit Head       | <code>AuditHead</code>    | <code>actions: ['*'], scope all</code> ( <code>permissions.ts:444</code> )       | Full access: view, create, edit, delete, and the reviewer/approval block |
| Audit Manager    | <code>AuditManager</code> | <code>actions: ['*'], scope all</code> ( <code>permissions.ts:470</code> )       | Full access: view, create, edit, delete, and the reviewer/approval block |
| Auditor          | <code>Auditee</code>      | No <code>audit.independence</code> entry ( <code>permissions.ts:532-539</code> ) | No menu item, no page access                                             |

Notes:

- The reviewer/approval controls are additionally gated client-side by role: the page sets `isReviewer = useHasRole("AuditHead") || useHasRole("AuditManager")` ( `independence/page.tsx:81` ). Only those two roles see the **Mark Reviewed** path and can edit the reviewer fields.
- The displayed **Auditor** role (internal key `Auditee`) is department-scoped to Fieldwork, CAPA, and Reports only and is **not** granted `audit.independence` ; it therefore cannot open this page. (The legacy internal `Auditor` key at `permissions.ts:514` does carry view/create/edit, but that key is retired/hidden and is not assignable.)
- There is **no approve action** used here. Review is performed by saving the record with status `Reviewed` via the `edit` permission, not a separate approve permission.

## Prerequisites

- The signed-in user must hold a role with `audit.independence` access (Audit Head or Audit Manager) for the menu item and page to appear.
- A customer account (tenant) context — every list/read/write is tenant-scoped via `getTenantFilter` and audit-head-scoped via `getAuditHeadFilter` ( `declarations/route.ts:30-32` , `declarations/[id]/route.ts` ).
- **Departments** are optional but recommended: the **Department** field (Independence type only) is populated from `/api/departments` ( `independence/page.tsx:113-117` ). If no departments exist, the dropdown simply shows no options (the fetch is non-blocking).
- No prior declaration is required — the first record can be created directly with **New Declaration**.

**Screenshot:** *Insert screenshot here*

The Independence & Objectivity page consists of:

- A **breadcrumb** at the top: a Home icon + "Internal Audit" > "Independence & Objectivity".
- A **page header** with a `ShieldCheck` icon, the title "Independence & Objectivity", and the subtitle "Auditor independence and objectivity declarations per the Global Internal Audit Standards." On the right, a **New Declaration** button (shown only when the user can create).
- A **list card** containing a filter/search toolbar (type tabs: "All", "Independence", "Objectivity"; and a search box) and a declarations table.
- A **table** of declarations with columns Code, Type, Name, Audit Engagement, Date, Result, Status, and Actions (row icon buttons: View, Print, Edit, Delete).
- A **Create / Edit / View dialog** invoked by the buttons above.
- A **Delete confirmation dialog**.

## Page Layout

**Breadcrumb** ( `independence/page.tsx:236-243` ): Home icon, "Internal Audit", chevron, "Independence & Objectivity" (current, highlighted).

**Header** ( `:245-261` ):

- Title "Independence & Objectivity" with a `ShieldCheck` icon.
- Subtitle: "Auditor independence and objectivity declarations per the Global Internal Audit Standards."
- **New Declaration** button (Plus icon) — visible only when `canCreate` is true.

**List toolbar** ( `:265-289` ):

- **Type tabs** (left): three buttons — "All", "Independence", "Objectivity". The active tab is highlighted. ( `:267-278` )

- **Search box** (right) with a magnifier icon and placeholder "Search..." ( : 279-288 ).

**Table** ( : 304-358 ) — see the Tables section. While loading, a spinner is shown ( : 291-294 ). When the filtered list is empty, an empty state appears with a ShieldCheck icon, "No declarations yet", and (if the user can create) "Use New Declaration to add one." ( : 295-302 ).

**Create / Edit / View dialog** ( : 363-523 ): a modal whose title is "New Declaration", "Edit Declaration", or "View Declaration" depending on context ( : 366-368 ). It contains:

- **Declaration Type** select — "Independence Declaration" / "Objectivity Declaration". Disabled when editing or viewing ( : 373-382 ).
- **Employee info** grid: **Name** (required), **Position**, **Department** (Independence type only), **Audit Engagement / Project**, **Date** ( : 385-419 ).
- A read-only **declaration statements** block with an intro sentence and a bulleted list of fixed statements, each with a check icon ( : 421-436 ).
- **Declaration Result / Objectivity Assessment** radio group (required) ( : 438-451 ).
- **Explanation** textarea — shown only when the result is "Potential impairment exists" or "Potential threat identified" ( : 453-458 ).
- **Employee Signature / Internal Auditor Signature** text input, placeholder "Type your full name" ( : 460-466 ).
- **Reviewer / approval** block — shown when the current user can review (Audit Head / Audit Manager editing an existing record) or when a reviewer name already exists. Contains **Reviewer Name** and **Reviewer Signature** ( : 468-485 ).
- **Footer** buttons depend on mode — see Buttons & Actions.

**Delete confirmation dialog** ( : 526-537 ): title "Delete Declaration", body "Are you sure you want to delete this declaration? This action cannot be undone.", buttons **Cancel** and **Delete** (red).

**Print page** ( independence/[id]/print/page.tsx ): a separate, print-optimized document opened in a new browser tab. It renders the full declaration (header with Code/Date/Status, Declarant block, statements, result + explanation, and signature blocks) and a **Print / Save as PDF** button (hidden when printing). See the System Behaviour section.

## Field Reference

Fields in the Create / Edit / View dialog. "Required" reflects actual client validation ( independence/page.tsx:151-159, 182-186 ).

| Field                                           | Required      | Type                                                            | Default                                                 | Validation                                                                          | Editable                                                                                                         | Description                                                                                                                                                                                            |
|-------------------------------------------------|---------------|-----------------------------------------------------------------|---------------------------------------------------------|-------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Declaration Type                                | No (defaults) | Select ("Independence Declaration" / "Objectivity Declaration") | "Independence" ( EMPTY, : 64 )                          | —                                                                                   | Editable only on <b>New</b> ; disabled when editing/viewing ( : 375 )                                            | Selects which fixed statements and result options apply; changing it resets Result ( : 375 )                                                                                                           |
| Name                                            | <b>Yes</b>    | Text                                                            | "" (new); current date is set for Date on new ( : 127 ) | Must be non-empty/trimmed, else toast "Name is required" ( : 152-154 )              | Editable unless read-only                                                                                        | Declarant name; stored as declarantName                                                                                                                                                                |
| Position                                        | No            | Text                                                            | ""                                                      | —                                                                                   | Editable unless read-only                                                                                        | Declarant position                                                                                                                                                                                     |
| Department                                      | No            | Select (department names)                                       | ""                                                      | —                                                                                   | Editable unless read-only; <b>Independence type only</b> ( : 394-410 )                                           | Populated from /api/departments ; preserves a previously-saved value not in the current list ( : 404-406 )                                                                                             |
| Audit Engagement / Project                      | No            | Text                                                            | ""                                                      | —                                                                                   | Editable unless read-only                                                                                        | Free-text engagement/project; stored as engagement                                                                                                                                                     |
| Date                                            | No            | Date                                                            | Today (new declarations, : 127 )                        | —                                                                                   | Editable unless read-only                                                                                        | Declaration date; stored as declarationDate                                                                                                                                                            |
| Declaration Result / Objectivity Assessment     | <b>Yes</b>    | Radio (per type)                                                | ""                                                      | Must be selected, else toast "Please select a declaration result" ( : 156-158 )     | Editable unless read-only                                                                                        | Independence: "I confirm full independence" / "Potential impairment exists". Objectivity: "No threats to objectivity identified" / "Potential threat identified" ( independence-declaration.ts:30-39 ) |
| Explanation                                     | No            | Textarea (3 rows)                                               | ""                                                      | —                                                                                   | Editable unless read-only; <b>shown only</b> when result is PotentialImpairment / PotentialThreat ( : 230, 453 ) | Explanation of the identified impairment/threat                                                                                                                                                        |
| Employee Signature / Internal Auditor Signature | No            | Text                                                            | ""                                                      | —                                                                                   | Editable unless read-only                                                                                        | Typed full name as a digital signature; placeholder "Type your full name"                                                                                                                              |
| Reviewer Name                                   | Conditional   | Text                                                            | ""                                                      | Required for <b>Mark Reviewed</b> — toast "Reviewer name is required" ( : 183-185 ) | Editable only by reviewer (Audit Head/Manager) on an existing record ( : 477 )                                   | Name of the reviewing CAE / Audit Manager                                                                                                                                                              |
| Reviewer Signature                              | No            | Text                                                            | ""                                                      | —                                                                                   | Editable only by reviewer on an existing record ( : 481 )                                                        | Reviewer's typed signature                                                                                                                                                                             |

System-set fields (not user-entered on the form): **Code** ( `declarationCode` , auto-generated DEC-NNNN ), **Status**, `reviewedDate` , `reviewedById` , `declarantId` , `customerAccountId` , `auditHeadId` , `createdAt` , `updatedAt` ( `declarations/route.ts:14-24,63-80` ; `schema.prisma:3590-3624` ).

## Tables

The declarations table ( `independence/page.tsx:304-358` ):

**Columns** (in order): Code, Type, Name, Audit Engagement, Date, Result, Status, Actions.

- **Code** — `declarationCode` (e.g. DEC-0001).
- **Type** — translated "Independence" / "Objectivity".
- **Name** — `declarantName` , or "-" when empty.
- **Audit Engagement** — `engagement` (truncated to ~200px), or "-".
- **Date** — `declarationDate` (date portion only), or "-".
- **Result** — the result's display label resolved per type, or "-" ( :211-215, 326 ).
- **Status** — a colored badge: Reviewed (green), Submitted (blue), Draft (amber) ( :203-209 ).
- **Actions** — right-aligned row icon buttons (see below).

**Sorting:** Not user-configurable on the page. The API returns declarations ordered by `createdAt: 'desc'` (newest first) ( `declarations/route.ts:41` ).

**Searching:** The search box matches (case-insensitive) against declarant name, engagement, and declaration code ( :217-226 ).

**Filtering:** The type tabs filter by declaration type — "All", "Independence", "Objectivity" ( :217-218, 267-277 ).

**Pagination:** None — all matching rows are rendered.

**Row actions** ( :328-352 ):

- **View** (magnifier icon, title "View") — opens the dialog read-only.
- **Print** (printer icon, title "Print") — opens `/internal-audit/independence/{id}/print` in a new tab.
- **Edit** (pencil icon, title "Edit") — opens the dialog editable; shown only when `canEdit` .
- **Delete** (trash icon, title "Delete") — opens the delete confirmation; shown only when `canDelete` .

**Bulk actions:** None.

## Buttons & Actions

Success/failure messages are toast notifications. "Not verified" marks values not confirmed in code.

| Control                                       | Permission                                                                     | Visible To                                             | Action                                                                   | API                                                                                                                | Success Msg                    | Failure Msg                                                                                | Audit Trail  | Notification       |
|-----------------------------------------------|--------------------------------------------------------------------------------|--------------------------------------------------------|--------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------|--------------------------------|--------------------------------------------------------------------------------------------|--------------|--------------------|
| <b>New Declaration</b>                        | audit.independence:create ( canCreate )                                        | Audit Head, Audit Manager                              | Opens dialog in create mode; Date defaults to today ( :124-129 )         | — (opens dialog)                                                                                                   | —                              | —                                                                                          | Not verified | None               |
| <b>Save Draft</b> (dialog)                    | create (new) / edit (existing)                                                 | Users with create/edit                                 | Saves with status Draft ( :506 )                                         | POST /api/internal-audit/declarations (new) or PATCH /api/internal-audit/declarations/{id} (existing) ( :163-170 ) | "Declaration saved" ( :172 )   | "Failed to save declaration" ( :176 )                                                      | Not verified | None found in code |
| <b>Submit</b> (dialog)                        | create/edit                                                                    | Non-reviewer creators (when not in reviewer mode)      | Saves with status Submitted ( :515-518 )                                 | POST/PATCH /api/internal-audit/declarations[/]{id}]                                                                | "Declaration saved"            | "Failed to save declaration"                                                               | Not verified | None found in code |
| <b>Mark Reviewed</b> (dialog)                 | audit.independence:edit + role AuditHead/AuditManager ( canReviewThis , :231 ) | Audit Head, Audit Manager (editing an existing record) | Requires Reviewer Name; saves with status Reviewed ( :182-188, 510-513 ) | PATCH /api/internal-audit/declarations/{id} (sets reviewedById, reviewedDate) ( [id]/route.ts:61-64 )              | "Declaration saved"            | "Failed to save declaration"; if Reviewer Name empty: "Reviewer name is required" ( :183 ) | Not verified | None found in code |
| <b>Cancel</b> (dialog)                        | —                                                                              | All who can open dialog                                | Closes dialog without saving ( :505 )                                    | —                                                                                                                  | —                              | —                                                                                          | —            | None               |
| <b>View</b> (row)                             | audit.independence:view                                                        | Audit Head, Audit Manager                              | Opens dialog read-only ( :330 )                                          | GET on dialog data already loaded                                                                                  | —                              | —                                                                                          | —            | None               |
| <b>Print</b> (row)                            | view                                                                           | Audit Head, Audit Manager                              | Opens print page in new tab ( :338 )                                     | GET /api/internal-audit/declarations/{id} (print page, [id]/print:48)                                              | —                              | "Declaration not found" if record missing ( [id]/print:70 )                                | —            | None               |
| <b>Edit</b> (row)                             | audit.independence:edit ( canEdit )                                            | Audit Head, Audit Manager                              | Opens dialog editable ( :343 )                                           | —                                                                                                                  | —                              | —                                                                                          | —            | None               |
| <b>Delete</b> (row)                           | audit.independence:delete ( canDelete )                                        | Audit Head, Audit Manager                              | Opens delete confirmation ( :348 )                                       | —                                                                                                                  | —                              | —                                                                                          | —            | None               |
| <b>Delete</b> (confirm dialog)                | delete                                                                         | Audit Head, Audit Manager                              | Deletes the declaration ( :190-201 )                                     | DELETE /api/internal-audit/declarations/{id}                                                                       | "Declaration deleted" ( :195 ) | "Failed to delete declaration" ( :199 )                                                    | Not verified | None               |
| <b>Close</b> (read-only footer)               | —                                                                              | Viewers                                                | Closes dialog ( :490 )                                                   | —                                                                                                                  | —                              | —                                                                                          | —            | None               |
| <b>Print / Save as PDF</b> (read-only footer) | view                                                                           | Viewers (existing record)                              | Opens print page in new tab ( :492-498 )                                 | —                                                                                                                  | —                              | —                                                                                          | —            | None               |
| <b>Print / Save as PDF</b> (print page)       | view                                                                           | Viewers                                                | Triggers window.print() ( [id]/print:106 )                               | —                                                                                                                  | —                              | —                                                                                          | —            | None               |

There is **no Export control** on this page. Printing/PDF is the only export path and is done via the browser's print dialog from the print page.

## Step-by-Step Instructions

### Create a new declaration

1. Open **Internal Audit > Independence & Objectivity**.
2. Click **New Declaration** (top right). The dialog opens with **Date** pre-filled to today.
3. In **Declaration Type**, choose "Independence Declaration" or "Objectivity Declaration".
4. Enter **Name** (required), and optionally **Position**, **Department** (Independence only), **Audit Engagement / Project**, and **Date**.
5. Read the fixed declaration statements shown in the gray panel.
6. Select a **Declaration Result** (Independence) or **Objectivity Assessment** (Objectivity) — this is required.
7. If you selected "Potential impairment exists" or "Potential threat identified", an **Explanation** field appears — describe the impairment/threat.

- Optionally type your full name in **Employee Signature / Internal Auditor Signature**.
- Click **Save Draft** to keep it as Draft, or **Submit** to record it as Submitted.
- On success a toast "Declaration saved" appears, the dialog closes, and the list refreshes.

## Review / approve a declaration (Audit Head / Audit Manager)

- In the list, click the **Edit** (pencil) action on the target declaration.
- The **Reviewed by / Approved by** block is shown. Enter **Reviewer Name** (required) and, optionally, **Reviewer Signature**.
- Click **Mark Reviewed**. The record is saved with status **Reviewed**; the reviewer id and reviewed date are set server-side.
- A toast "Declaration saved" confirms the action.

## View a declaration

- Click the **View** (magnifier) action on a row. The dialog opens read-only.
- Click **Close** to dismiss, or **Print / Save as PDF** to open the printable document.

## Print / save as PDF

- Click the **Print** (printer) row action, or **Print / Save as PDF** from the read-only dialog. The printable declaration opens in a new tab.
- Click **Print / Save as PDF** on that page to open the browser print dialog, then print or choose "Save as PDF".

## Delete a declaration

- Click the **Delete** (trash) row action.
- In the confirmation dialog ("Are you sure you want to delete this declaration? This action cannot be undone."), click **Delete**.
- A toast "Declaration deleted" confirms; the list refreshes.

## Workflow

| Current Status    | User Action                  | Validation             | API                                    | DB Update                                                                                | Reviewer Fields               | Next Status       | Next User            |
|-------------------|------------------------------|------------------------|----------------------------------------|------------------------------------------------------------------------------------------|-------------------------------|-------------------|----------------------|
| (none)            | Save Draft                   | Name + Result required | POST <code>/declarations</code>        | New row, <code>status=Draft</code> , auto DEC-NNNN                                       | —                             | Draft             | Declarant / reviewer |
| (none)            | Submit                       | Name + Result required | POST <code>/declarations</code>        | New row, <code>status=Submitted</code>                                                   | —                             | Submitted         | Audit Head / Manager |
| Draft / Submitted | Save Draft / Submit (edit)   | Name + Result required | PATCH <code>/declarations/{id}</code>  | Update fields + status                                                                   | —                             | Draft / Submitted | Audit Head / Manager |
| Draft / Submitted | Mark Reviewed (Head/Manager) | Reviewer Name required | PATCH <code>/declarations/{id}</code>  | <code>status=Reviewed</code> , <code>reviewedById</code> , <code>reviewedDate</code> set | Reviewer Name/Signature saved | Reviewed          | — (complete)         |
| Any               | Delete                       | Confirm dialog         | DELETE <code>/declarations/{id}</code> | Row removed                                                                              | —                             | (deleted)         | —                    |

The server only accepts status values `Draft`, `Submitted`, `Reviewed` (`[id]/route.ts:53`); on POST it normalizes to `Submitted` if requested, otherwise `Draft` (`route.ts:78`). No notifications or audit-trail writes were found in these route or page files for the declaration actions.

## Status Reference

Statuses are stored on `AuditDeclaration.status` (default `Draft`, `schema.prisma:3618`) and rendered as colored badges (`independence/page.tsx:203-209`).

| Status                  | Meaning                                                                         | How reached                                                                                                     | Who can set                  | Next statuses                                                          |
|-------------------------|---------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------|------------------------------|------------------------------------------------------------------------|
| <b>Draft</b> (amber)    | Declaration saved but not submitted                                             | <b>Save Draft</b> on create/edit; default on create when status is not "Submitted" ( <code>route.ts:78</code> ) | Any user who can create/edit | Submitted, Reviewed                                                    |
| <b>Submitted</b> (blue) | Declaration submitted by the declarant                                          | <b>Submit</b> on create/edit ( <code>page.tsx:515</code> )                                                      | Any user who can create/edit | Reviewed (via Mark Reviewed); can also be saved back to Draft via edit |
| <b>Reviewed</b> (green) | Reviewed/approved by Audit Head or Audit Manager; reviewer id and date recorded | <b>Mark Reviewed</b> by Audit Head/Manager ( <code>page.tsx:510</code> ; <code>[id]/route.ts:61-64</code> )     | Audit Head, Audit Manager    | Terminal (can still be edited/re-saved to another status by an editor) |

## Validation Rules

- Name required:** Submitting any save without a trimmed Name shows "Name is required" and blocks the save (`page.tsx:152-154`).
- Result required:** Saving without a selected result shows "Please select a declaration result" and blocks the save (`page.tsx:156-158`).
- Reviewer Name required for review:** **Mark Reviewed** requires a non-empty Reviewer Name, else "Reviewer name is required" (`page.tsx:183-185`).
- Declaration Type validity:** The server only persists `type` in {Independence, Objectivity}, defaulting to "Independence" otherwise (`route.ts:60`).
- Status validity:** The server only persists `status` in {Draft, Submitted, Reviewed} (`[id]/route.ts:53`); POST coerces to Submitted/Draft (`route.ts:78`).
- Result tied to type:** Result options are determined by the selected type; changing the type resets the result to blank (`page.tsx:375`).
- Explanation visibility:** The Explanation field is only present when the result is "Potential impairment exists" or "Potential threat identified" (`page.tsx:230, 453`). It is not separately validated as required.

- **Permission / tenant checks:** All API routes enforce the corresponding `audit.independence` action via `withAuth`, and scope every query by tenant and audit-head filters ( `declarations/route.ts`, `declarations/[id]/route.ts` ). Reads/updates/deletes on a record not visible in the caller's scope return 404 "Declaration not found".
- **No duplicate check** beyond the database uniqueness of `declarationCode` per tenant, which is system-generated ( `schema.prisma:3622` ).

## Success Scenarios and Failure Scenarios

### Success

- Create/edit save: toast "Declaration saved", dialog closes, list refreshes ( `page.tsx:172-174` ).
- Mark Reviewed: toast "Declaration saved"; status becomes Reviewed with reviewer id/date set.
- Delete: toast "Declaration deleted", list refreshes ( `page.tsx:195-197` ).
- Print: the print page renders the full declaration; the browser print dialog produces a printed copy or PDF.

### Failure

- *Missing Name* — caused by an empty Name; user sees "Name is required"; resolve by entering a name ( `page.tsx:152` ).
- *Missing Result* — no result selected; user sees "Please select a declaration result"; resolve by choosing a result ( `page.tsx:156` ).
- *Missing Reviewer Name on review* — Reviewer Name empty when clicking Mark Reviewed; user sees "Reviewer name is required"; resolve by entering the reviewer's name ( `page.tsx:183` ).
- *Save failure* — any non-OK API response throws; user sees "Failed to save declaration" ( `page.tsx:176` ). Resolve by retrying; if it persists, check permissions/connectivity.
- *Delete failure* — non-OK DELETE response; user sees "Failed to delete declaration" ( `page.tsx:199` ).
- *Load failure* — the list fetch failing shows "Failed to load declarations" ( `page.tsx:102` ).
- *Print of a missing/inaccessible record* — the print page shows "Declaration not found" ( `[id]/print:70` ).

## System Behaviour

- **Auto-generated code:** On create, a tenant-scoped `declarationCode` of the form `DEC-NNNN` (zero-padded, incremented from the current max) is assigned automatically ( `route.ts:14-24, 61` ).
- **Default date:** New declarations pre-fill **Date** with today's date in the form ( `page.tsx:127` ); if no date is sent, the server defaults `declarationDate` to the current date ( `route.ts:74` ).
- **Declarant attribution:** On create, `declarantId` defaults to the session user id when not provided ( `route.ts:69` ).
- **Tenant & audit-head isolation:** All reads/writes are scoped by `getTenantFilter` and `getAuditHeadFilter` so users only see/affect their own tenant's (and audit head's) declarations ( `route.ts:30-32`; `[id]/route.ts` ).
- **Review stamping:** Setting status to **Reviewed** server-side records `reviewedById` (session user) and `reviewedDate` (now, if not supplied) ( `[id]/route.ts:61-64` ).
- **Read-only view mode:** Opening a record via **View** disables all inputs and shows only **Close** and **Print / Save as PDF** in the footer ( `page.tsx:131-133, 488-501` ).
- **Reviewer field gating:** Reviewer Name/Signature are editable only when the current user is an Audit Head/Manager editing an existing (non-read-only) record ( `page.tsx:231, 477, 481` ).
- **Print document:** The print page hides app chrome via a print stylesheet and renders a standalone signed declaration including Code, Date, Status, Declarant details, statements, result, explanation, employee signature, and (if present) the reviewer block with Reviewer Name and Reviewed Date ( `[id]/print:88-205` ).
- **No notifications and no audit-trail writes** for declaration create/edit/review/delete were found in the page or route code (marked "Not verified" / "None found in code" above).
- **No background processing** beyond the standard request handling.

## Notes / Warnings / Tips

- The declaration statements and result options are **fixed, IIA-aligned text** shared between the form and the print document so the legal wording cannot drift ( `src/lib/independence-declaration.ts` header comment).
- **Department** appears only for the Independence type; switching to Objectivity hides it ( `page.tsx:394` ).
- Changing **Declaration Type** clears the selected result, so re-select the result if you switch types ( `page.tsx:375` ).
- Deletion is permanent — the confirmation explicitly warns "This action cannot be undone."
- Signatures are **typed names** acting as digital signatures, not drawn or uploaded images ( `schema.prisma:3611` ).
- To produce a signed PDF, use **Print / Save as PDF** and select "Save as PDF" in the browser print dialog.

# Audit Universe

## Overview — Purpose, Business Objective

The **Audit Universe** page provides a consolidated, read-only visualization of every auditable entity in the organization, grouped by audit **Category**. For each category it shows the linked **Processes**, **Risks**, and **Audits** (audit engagements), giving the audit function a single "map" of what can be audited and how engagements relate to the processes and risks they cover.

The page is built as a *visualization and reporting view* of data that is created and maintained elsewhere in the application (Audit Settings categories, Internal Audit processes, Internal Audit risks, and audit engagements). It does **not** itself create, edit, or delete auditable entities — the only interactive behavior on the page is opening an engagement's detail view. (Source: `src/app/(protected)/internal-audit/audit-universe/page.tsx`.)

Business objective: give the Audit Head / Audit Manager a top-down picture of audit coverage — categories, the processes and risks linked to each, and the engagements (with planned-vs-actual hours and status) addressing them — to support audit planning and coverage analysis.

## Access — Roles and Permissions

The page resource is `audit.auditables`. The route is registered at `/internal-audit/audit-universe` (`src/lib/permissions.ts:109`) and the navigation item "Audit Universe" requires `audit.auditables:view` (`src/lib/navigation.ts:304`). The backing API requires the same permission: `{ resource: 'audit.auditables', action: 'view' }` (`src/app/api/internal-audit/audit-universe/route.ts:182`).

| Role (display) | Internal key              | <code>audit.auditables</code> permission          | Can open this page?                                                                                                                                                                                                     |
|----------------|---------------------------|---------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Audit Head     | <code>AuditHead</code>    | * (all actions) — <code>permissions.ts:435</code> | Yes                                                                                                                                                                                                                     |
| Audit Manager  | <code>AuditManager</code> | * (all actions) — <code>permissions.ts:460</code> | Yes                                                                                                                                                                                                                     |
| Auditor        | <code>Auditee</code>      | none granted                                      | <b>No</b> — Auditee has no <code>audit.auditables</code> permission ( <code>permissions.ts:526-539</code> ); the role comments explicitly list "Audit Universe" as <b>NO access</b> ( <code>permissions.ts:528</code> ) |

Notes:

- "Auditor" is the **display name** for the internal `Auditee` role (`ROLE_DISPLAY_OVERRIDES`, `permissions.ts:319-321`). This role is department-scoped to Fieldwork, CAPA, Reports, and its own Audit Trail only, and therefore cannot see the Audit Universe page or its navigation item.
- Although the role matrices grant the \* wildcard (all actions including create/edit/ delete) on `audit.auditables`, **the page and its API expose only a view /GET operation** — there are no create/edit/delete controls or endpoints on this page. The extra actions are not exercised here.

## Prerequisites

Because this page only *displays* existing data, the following must already exist for the map and table to show anything:

- At least one audit Category.** Categories are created in **Audit Settings**. When none exist, the page shows the empty state (see Status Reference). The empty-state guidance reads: *"Add categories in Audit Settings, then link processes and risks to them."* (`page.tsx:291, 576`).
- Processes linked to a category** — Internal Audit processes (`InternalAuditProcess`) whose category is set, to populate the Processes column.
- Risks linked to a category** — Internal Audit risks (`InternalAuditRisk`) whose category is set, to populate the Risks column.
- Audit engagements** linked to a category — either directly (engagement's `auditCategoryId`) or via a category-linked risk's `engagementId` — to populate the Audits column (`route.ts:72-138`).

If a category exists but has nothing linked, the detail table shows the row *"No entities linked to this category yet"* (`page.tsx:557`).

## Page Layout

**Screenshot:** *Insert screenshot here*

Visible areas, top to bottom (all present in the component):

- Breadcrumb** — "Internal Audit" (links to `/internal-audit`) > "Audit Universe" (`page.tsx:202-213`).
- Page title** — `Audit Universe` (h1) (`page.tsx:238`).
- Summary stat cards** — four cards in a responsive grid (`page.tsx:242-261`):
  - Categories** (Tag icon) — `totalCategories`
  - Processes** (Workflow icon) — `totalProcesses`
  - Risks** (ShieldAlert icon) — `totalRisks`
  - Total Audits** (BarChart3 icon) — count of unique audit IDs across all categories
- Organization Map** card (`page.tsx:264-447`):
  - Header title **"Organization Map"** with a color **legend** to the right showing five status colors: **Planned** (slate), **In Progress** (sky), **Near Budget** (amber), **Completed** (emerald), **Over Budget** (red) (`page.tsx:266-280`).
  - A horizontally scrollable tree diagram: a root node labeled **"Audit Universe"**, then a column per category. Each category node branches into three sub-groups — **Processes**, **Risks**, and **Audits** — each listing its linked entity nodes. A process node shows its name and (if present) its process code; a risk node shows its risk ID and risk name; an audit node shows its audit ID, **Actual vs Planned** hours, and a status icon, color-coded by status/budget (`page.tsx:295-444`).

- **Audit-node tooltip** (on hover): engagement title, **Start** date, **End** date, **Status**, an "Over budget by Nh" line when applicable, and the hint "Click to view details" (page.tsx:414-430).

5. **Detail table** — card titled "**All auditable entities by category**" (page.tsx:451-567). Shown only when at least one category exists. A grouped table with a colored header row per category and one row per linked process/risk/audit.
6. **Empty states** — when there are no categories, both the Organization Map and a separate card render an empty placeholder (page.tsx:284-293, 569-579).
7. **Engagement detail modal** — `FieldworkDetailModal` in `mode="view"`, opened by clicking an audit node or audit table row (page.tsx:581-590).

There is no header action bar, no "Add"/"New" button, no search box, no filter controls, no pagination, and no footer on this page.

## Field Reference

This page has **no data-entry form** — it is read-only. There are no editable fields, required fields, or validation. The "fields" below are the **displayed attributes** sourced from the API for each entity type (route.ts:140-160); none are editable here.

| Field                  | Required | Type   | Default               | Validation | Editable | Description                                                                                       |
|------------------------|----------|--------|-----------------------|------------|----------|---------------------------------------------------------------------------------------------------|
| Category name          | —        | text   | —                     | —          | No       | Audit category grouping ( <code>AuditCategory.name</code> ).                                      |
| Process name           | —        | text   | —                     | —          | No       | Linked process name ( <code>InternalAuditProcess.name</code> ).                                   |
| Process code           | —        | text   | shown only if present | —          | No       | Optional process code badge ( <code>processCode</code> ).                                         |
| Risk ID                | —        | text   | —                     | —          | No       | Linked risk identifier ( <code>InternalAuditRisk.riskId</code> ).                                 |
| Risk name              | —        | text   | —                     | —          | No       | Linked risk name ( <code>riskName</code> ).                                                       |
| Audit ID               | —        | text   | —                     | —          | No       | Engagement identifier ( <code>auditId</code> ).                                                   |
| Engagement title       | —        | text   | —                     | —          | No       | Engagement title ( <code>engagementTitle</code> ), shown in detail row and tooltip.               |
| Department             | —        | text   | "—" when null         | —          | No       | Department name on the process/risk/engagement.                                                   |
| Description            | —        | text   | "—" when null         | —          | No       | Process description, risk description, or engagement objective.                                   |
| Last Audit Date        | —        | date   | "—" / "N/A" when null | —          | No       | Engagement effective end date ( <code>actualEndDate    endDate</code> ), formatted "Mon D, YYYY". |
| Planned hours          | —        | number | "-" when 0            | —          | No       | Engagement <code>plannedHours</code> , shown as "Nh".                                             |
| Actual hours           | —        | number | "-" when 0            | —          | No       | Engagement <code>actualHours</code> , shown as "Nh".                                              |
| Regulatory Requirement | —        | text   | "—" when null         | —          | No       | Risk's <code>relatedLawRegulation</code> .                                                        |

## Tables

### Organization Map (tree, not a tabular grid)

Not a standard table — it is a node tree. Per category, three sub-groups list nodes: Processes, Risks, Audits. Empty sub-groups render a dash ("—"). Audit nodes are clickable (open the engagement detail modal). No sort/search/filter/pagination.

### Detail table — "All auditable entities by category"

Columns (page.tsx:460-466):

| # | Column header             |
|---|---------------------------|
| 1 | Process / System / Entity |
| 2 | Department                |
| 3 | Description               |
| 4 | Last Audit Date           |
| 5 | Audit Frequency (Years)   |
| 6 | Regulatory Requirement    |
| 7 | Notes                     |

Behavior:

- **Grouping:** rows are grouped under a colored category header row that also shows counts: "(N process(es), N risk(s), N audit(s))" (page.tsx:477-479).
- **Row types per group:** process rows (Workflow icon + name + code badge), risk rows (ShieldAlert icon + name + risk ID badge), audit rows (ClipboardList icon + title + audit ID badge).
- **Populated columns by row type:**
  - Process rows: Process/System/Entity, Department, Description. Columns *Last Audit Date*, *Audit Frequency (Years)*, *Regulatory Requirement*, *Notes* show "—" (page.tsx:499-502).
  - Risk rows: Process/System/Entity, Department, Description, Regulatory Requirement. *Last Audit Date*, *Audit Frequency (Years)*, *Notes* show "—" (page.tsx:519-524).
  - Audit rows: Process/System/Entity, Department, Description, Last Audit Date. *Audit Frequency (Years)*, *Regulatory Requirement*, *Notes* show "—" (page.tsx:545-550).



- **Audit Frequency (Years)** and **Notes** columns are always "—" for every row type — no data source feeds them (Not provided by the API).
- **Row actions:** clicking an **audit row** opens the engagement detail modal (page.tsx:528-532). Process and risk rows are not clickable.
- **Sorting / searching / filtering / pagination / bulk actions:** none. Processes are ordered by name, risks by name, audits by creation order; categories by name (route.ts).

Buttons & Actions

| Control                               | Permission                            | Visible To                | Action                                                                                  | API                                                                        | Success Msg          | Failure Msg       | Audit Trail  | Notification |
|---------------------------------------|---------------------------------------|---------------------------|-----------------------------------------------------------------------------------------|----------------------------------------------------------------------------|----------------------|-------------------|--------------|--------------|
| Breadcrumb "Internal Audit" link      | audit.auditables:view (to reach page) | Audit Head, Audit Manager | Navigate to /internal-audit                                                             | None                                                                       | —                    | —                 | None         | None         |
| Audit node (Organization Map) — click | audit.auditables:view                 | Audit Head, Audit Manager | Open engagement detail modal ( FieldworkDetailModal , mode="view" ) for that engagement | Modal fetches engagement detail (handled inside modal — Not verified here) | — (no toast on open) | None on this page | None on open | None on open |
| Audit row (Detail table) — click      | audit.auditables:view                 | Audit Head, Audit Manager | Same as above — open engagement detail modal                                            | Same                                                                       | —                    | —                 | None         | None         |

No create/edit/delete/export/print buttons exist on this page. On modal close, the page re-fetches the audit universe ( fetchAuditUniverse() , page.tsx:583-587).

Step-by-Step Instructions

View the Audit Universe

1. In the left navigation under **Internal Audit**, click **Audit Universe**.
2. Review the four summary cards (Categories, Processes, Risks, Total Audits).
3. Examine the **Organization Map** to see categories and their linked Processes, Risks, and Audits. Use the color legend to interpret audit-node colors.

Inspect an engagement's details

1. In the **Organization Map**, hover an audit node to preview its title, start/end dates, status, and any over-budget note.
2. Click the audit node (or click the corresponding audit row in the "All auditable entities by category" table).
3. The engagement detail view opens (read-only).
4. Close the detail view; the page reloads the universe data automatically.

Review entities in tabular form

1. Scroll to "All auditable entities by category".
2. Each category header row shows counts of linked processes, risks, and audits.
3. Read the per-entity rows under each category header.

There are no tasks on this page to create, edit, link, or delete entities — those are performed in Audit Settings and the respective Internal Audit modules.

Workflow

This page does not advance any record through a workflow. The only interaction is:

| Current Status  | User Action             | Validation                             | API                                               | DB Update           | Audit Trail         | Notification | Next Status            | Next User |
|-----------------|-------------------------|----------------------------------------|---------------------------------------------------|---------------------|---------------------|--------------|------------------------|-----------|
| Page loaded     | Open page               | Permission check audit.auditables:view | GET /api/internal-audit/audit-universe            | None (read-only)    | None                | None         | Page rendered          | —         |
| Map/table shown | Click an audit node/row | None                                   | Detail loaded by FieldworkDetailModal (view mode) | None from this page | None from this page | None         | Modal open (read-only) | —         |

Engagement statuses themselves are set and changed in the Fieldwork / Planning modules, not here.

Status Reference

There is no editable status owned by this page. Two kinds of state appear:

A. Page-level display states

- **Loading** — skeleton placeholders while the API call is in flight (page.tsx:215-228).
- **Empty** — no categories returned: the Organization Map shows "No audit categories yet" with guidance "Add categories in Audit Settings, then link processes and risks to them." (page.tsx:289-291), and a separate card shows "No auditable entities yet" with the same guidance (page.tsx:574-577).
- **Populated** — categories exist; map and detail table render.

**B. Audit-node color states (derived from engagement status + hours; read-only)** The legend lists five visual states; colors are computed in getStatusStyle (page.tsx:169-182):

| Legend label | When applied (derived)                                                           | Color   |
|--------------|----------------------------------------------------------------------------------|---------|
| Planned      | Status is none of the "in progress"/"completed" sets (e.g., not started)         | slate   |
| In Progress  | Status in {in progress, inprogress, ongoing, active} and actual ≤ 80% of planned | sky     |
| Near Budget  | In-progress status and actual > 80% of planned (but ≤ planned)                   | amber   |
| Completed    | Status in {completed, complete, closed} and actual ≤ planned                     | emerald |
| Over Budget  | Actual hours > planned hours (for in-progress or completed)                      | red     |

These are display categorizations only; the underlying engagement `status` string is set elsewhere. The status shown in the tooltip is the raw engagement `status` value (page.tsx:420).

## Validation Rules

None on this page. There are no input fields, no required fields, no duplicate checks, no approval steps. The only enforced rule is the **permission check** on page/API access ( `audit.auditables:view` ); users without it do not see the navigation item and the API returns the standard authorization failure from `withAuth`.

## Success Scenarios and Failure Scenarios

### Success

- Page loads and the `GET /api/internal-audit/audit-universe` call returns 200; the summary cards, Organization Map, and detail table render. If there is no data, the empty states render (this is still a successful load).
- Clicking an audit node/row opens the read-only engagement detail modal.

### Failure

- API error / non-OK response:** if the fetch fails or returns a non-OK status, the component logs to the console ( `"Failed to fetch audit universe:"` ) and leaves `data` as `null`; after loading finishes the page shows the **empty** layout (no categories). There is **no on-screen error toast or banner** on this page (page.tsx:155-167). Resolution: reload the page; if it persists, verify the user has `audit.auditables:view` and that the backend is reachable.
  - Server-side, the API catches errors and returns `{ error: 'Failed to fetch audit universe' }` with HTTP 500 (route.ts:177-180); the page treats this as no data.
- No permission:** a user without `audit.auditables:view` will not see the "Audit Universe" nav item and the API request is rejected by `withAuth`.

## System Behaviour

- Read-only / no writes:** the page performs no create, update, or delete. It issues a single `GET` on load and re-issues it when the engagement detail modal is closed (page.tsx:151-167, 583-587).
- Tenant scoping:** the API filters all queries by the session's customer account and audit-head context ( `tenantWhere` , route.ts:36-39), so users only see their own organization's universe.
- Audit-list aggregation:** each category's Audits list is de-duplicated across two sources — engagements reached via a category-linked risk ( `risk.engagement` ) and engagements linked directly to the category ( `auditCategoryId` ) — using a Map keyed by engagement id (route.ts:82-138). "Total Audits" counts unique engagement ids across all categories (route.ts:166-168; page.tsx:94-98).
- Effective dates:** "Last Audit Date" / End uses `actualEndDate` then `endDate`; Start uses `actualStartDate` then `startDate` (route.ts:20-27, 113, 134).
- Dynamic translation:** category, process, risk, and department names/descriptions are passed through the dynamic-translation hooks ( `useTranslatedData` ) for display in the current language; this only reads existing translations (page.tsx:129-149).
- No audit-trail logging and no notifications** are generated by viewing this page or opening the detail modal.

## Notes / Warnings / Tips

- This is a coverage map, not a data-entry screen.** To add or change auditable entities, use **Audit Settings** (categories) and the Internal Audit Processes / Risks modules, and create/maintain engagements in Planning/Fieldwork. Changes there appear here after reload.
- Auditors (Auditee role) cannot access this page** by design — it is intended for the Audit Head and Audit Manager.
- The **"Audit Frequency (Years)"** and **"Notes"** columns currently display "—" for all rows; no data source populates them.
- If the page looks empty but you expect data, confirm: (1) categories exist in Audit Settings, (2) processes/risks are linked to a category, and (3) engagements are linked to a category (directly or via a category-linked risk).
- Audit-node colors reflect **planned-vs-actual hours and status**, not just status alone — an over-budget engagement is shown in red regardless of whether it is in progress or completed.

# Risk Identification

## Overview — Purpose, Business Objective

The **Risk Identification** page is an AI-assisted tool that helps the audit team generate candidate risks for a selected audit area before they are formally recorded in the Risk Register. The user chooses an **Audit Category** and a dependent **Audit / Process**, optionally adds a **Specific Audit Focus** and **Supporting Documents**, and clicks **Suggest Risks with AI**. The system sends this context to an external AI backend (RunPod `/api/assess-risks`) and displays the generated risks under **Recent Searches**, each with a title, description, risk level, and inherent likelihood / impact. From there, an Audit Head can push selected High/Medium risks into the Internal Audit Risk Register with one click.

Business objective: accelerate risk identification by using AI to propose risks for an audit area, while keeping the Audit Head as the gatekeeper who decides which suggestions become register entries.

**Note on scope of this chapter.** The page file is `src/app/(protected)/internal-audit/risk-identification/page.tsx`. Its two live actions call `POST /api/internal-audit/risk-identification/suggest` (AI suggestion) and `POST /api/internal-audit/risks` (add to register). The APIs named in the assignment brief — `api/internal-audit/risk-factors/**` and `api/internal-audit/risks/ai-recommended-audits` — exist in the codebase but are **not** called by this page. The risk-factors CRUD endpoints are consumed by the Settings area (`audit.settings`), and `ai-recommended-audits` is an `audit.planning` endpoint not referenced from this page. They are summarised at the end of this chapter for completeness, marked as not part of this page.

## Access — Which roles can use it + exact permissions

Page visibility (sidebar + route) is gated by the navigation permission `audit.risk-identification:view` (`src/lib/navigation.ts:305`).

| Role (display) | Internal key              | <code>audit.risk-identification</code> permission      | Can open page | Can use AI / Add to Register |
|----------------|---------------------------|--------------------------------------------------------|---------------|------------------------------|
| Audit Head     | <code>AuditHead</code>    | <code>['*']</code> ( <code>permissions.ts:437</code> ) | Yes           | Yes — see below              |
| Audit Manager  | <code>AuditManager</code> | <code>['*']</code> ( <code>permissions.ts:462</code> ) | Yes           | No (UI gated to Audit Head)  |
| Auditor        | <code>Auditee</code>      | none granted ( <code>permissions.ts:532-539</code> )   | No            | No                           |

Important behaviour inside the page: the two write actions are gated **only by a client-side role check**, not by the page-level permission. The component sets `isAuditHead` from the session roles (`page.tsx:88-90`) and:

- Suggest Risks with AI** — if the user is not Audit Head, clicking the button shows the error toast `Only Audit Head can suggest risks with AI` and aborts (`page.tsx:202-205`).
- Add to Register** — the button is rendered only when `isAuditHead` is true *and* the risk level is High or Medium (`page.tsx:702`); the handler also re-checks and shows `Only Audit Head can add risks to register` if not Audit Head (`page.tsx:293-296`).

So although **Audit Manager** can open the page (permission `*`), only **Audit Head** can run the AI suggestion or add risks to the register through this UI.

**Not verified:** The `POST /api/internal-audit/risk-identification/suggest` route only checks for an authenticated session (`auth()`), not a specific role (`suggest/route.ts:22-26`). The Audit-Head restriction on suggesting is enforced in the browser, not the API. The `POST /api/internal-audit/risks` route is protected by `audit.risk-register:create` (`risks/route.ts:232`), which Audit Head and Audit Manager both hold.

## Prerequisites

Before this page can produce useful results, the following must already exist:

- At least one Audit Category** — loaded from `/api/internal-audit/categories` (`page.tsx:112-118`). If none exist, the **Audit Category** dropdown is empty and no suggestion can be run.
- At least one Audit (engagement) or Process linked to the chosen category** — loaded from `/api/internal-audit/categories/{id}/entities` (`page.tsx:132`), which returns processes (`InternalAuditProcess` by `categoryId`) and audits (`AuditEngagement` by `auditCategoryId`) (`categories/[id]/entities/route.ts:17-32`). The **Audit / Process** field is required, so a category with no linked entity cannot be submitted.
- The external AI backend must be reachable and configured** — the suggest route requires the `PYTHON_API_SECRET` server secret; if it is missing the API returns `Server misconfiguration: missing API secret` (`suggest/route.ts:75-82`).
- A signed-in user** (any authenticated session for the API; Audit Head role for the actual actions in the UI).

**Screenshot:** *Insert screenshot here*

The page shows, top to bottom:

- Breadcrumb** — `Internal Audit > (Dashboard, shown only if the user can view the dashboard) > Risk Identification` (`page.tsx:411-426`).
- Page header** — title **Risk Identification** (`page.tsx:430`).
- Risk Assessment Parameters card** — header with an **AI-Powered** pill (sparkles icon), containing the input fields and the submit button.
- Recent Searches card** — appears only after at least one suggestion has run; lists each search and its generated risks with optional **Add to Register** buttons.

While categories are loading, the page shows a centered spinner with the text **Loading...** instead of the form (`page.tsx:371-405`).

## Page Layout

### Risk Assessment Parameters card ( page.tsx:434-632 )

- Card header: title **Risk Assessment Parameters** and a pill labelled **AI-Powered** with a sparkles icon ( page.tsx:436-440 ).
- **Audit Category** field (required, red asterisk) — a Select with placeholder **Select audit category...** listing audit categories ( page.tsx:447-465 ).
- **Audit / Process** field (required, red asterisk) — a dependent Select, disabled until a category is chosen or while its entities load ( page.tsx:468-533 ). Options are grouped under two non-selectable headers: **Audits** (engagements) and **Processes**. Each option shows `code - name` when a code exists. Placeholders vary by state: **Select a category first...**, **No entities available**, or **Select audit or process...** ( page.tsx:485-492 ). While loading it shows a spinner with **Loading...** ( page.tsx:478-482 ).
- **Specific Audit Focus** field — optional (label suffix **(Optional)**); a single-row Textarea with placeholder **e.g. Payroll processing, Third-party management...** ( page.tsx:537-549 ).
- **Supporting Documents** field — optional; a drag-and-drop / click upload zone reading **Drag and drop files here, or click to upload** and the hint **PDF, DOC, DOCX, XLS, XLSX, CSV, TXT (max 10 files)** ( page.tsx:552-578 ). Selected files are listed below with file name, size in KB, and an **X** remove button each ( page.tsx:581-607 ).
- **Card footer** — right-aligned (LTR) button **Suggest Risks with AI** with a sparkles icon; while running it shows a spinner and the text **Analyzing...** ( page.tsx:611-631 ).

### Recent Searches card ( page.tsx:635-739 ) — rendered only when at least one search exists.

- Card header: title **Recent Searches** and a counter **N result(s)** ( page.tsx:637-640 ).
- One row per search showing a sparkles avatar, the search **query** string ( `Category / Entity / Focus` joined with `/` ), a result summary line, and a formatted timestamp ( page.tsx:643-660 ).
- Under each search, a list of generated risk cards. Each card shows the risk **title**, **description**, a level **Badge** (color-coded High/Medium/Low), and **Likelihood: / Impact:** labels ( page.tsx:663-700 ).
- For Audit Head and only for High/Medium risks, an **Add to Register** button (or **Added** confirmation chip once added) appears on the right of the card ( page.tsx:701-728 ).

There are no summary cards, tabs, search box, pagination controls, side panels, or modal dialogs on this page.

## Field Reference

| Field                | Required | Type                                                | Default | Validation                                                                                                                                                                                                                                                                                                                                                                  | Editable                        | Description                                                                      |
|----------------------|----------|-----------------------------------------------------|---------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------|----------------------------------------------------------------------------------|
| Audit Category       | Yes      | Single-select dropdown                              | empty   | Must be selected; error <b>Please select an audit category</b> if missing ( page.tsx:195 )                                                                                                                                                                                                                                                                                  | Yes                             | Audit category that scopes the AI assessment and the dependent entity list.      |
| Audit / Process      | Yes      | Single-select dropdown (grouped: Audits, Processes) | empty   | Must be selected; error <b>Please select an audit or process</b> if missing ( page.tsx:196 ). Disabled until a category is selected ( page.tsx:475 )                                                                                                                                                                                                                        | Yes (once a category is chosen) | The specific audit engagement or process providing department context to the AI. |
| Specific Audit Focus | No       | Multi-line text (Textarea)                          | empty   | None (free text; trimmed before send)                                                                                                                                                                                                                                                                                                                                       | Yes                             | Optional free-text focus area, e.g. a sub-process or theme.                      |
| Supporting Documents | No       | File upload (multiple)                              | none    | Accepts <code>.pdf</code> , <code>.doc</code> , <code>.docx</code> , <code>.xls</code> , <code>.xlsx</code> , <code>.csv</code> , <code>.txt</code> ; max 10 files in UI ( page.tsx:58-59 ); server also enforces max 20 MB per file and max 10 files ( <code>suggest/route.ts:6-8,100-105</code> ); zero-byte and duplicate files are skipped client-side ( page.tsx:165 ) | Yes (add/remove individually)   | Optional documents passed to the AI for context.                                 |

## Tables

This page has **no data table** in the conventional sense (no sortable columns, no pagination, no row filtering). Instead it renders a **Recent Searches** list of card items.

- **Recent Searches list** — newest first; capped at the 10 most recent searches ( page.tsx:261, `.slice(0, 10)` ). It is persisted in browser `sessionStorage` under the key `riskIdentificationSearches` ( page.tsx:57, 263-268 ) and is **cleared when the user navigates away** from the page (cleanup on unmount, page.tsx:107-109 ). There is no server-side history.
- **Generated risk cards** — under each search; no sorting, filtering, or pagination. The only row action is **Add to Register** (Audit Head, High/Medium only). There are no bulk actions.

## Buttons & Actions

| Control                      | Permission                                                                                                                 | Visible To                                                                | Action                                                                                                      | API                                                  | Success Msg                                                                                                           | Failure Msg                                                                                                                                                                                                                                                | Audit Trail                                                              | Notification                                                                                            |
|------------------------------|----------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------|------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------|
| <b>Suggest Risks with AI</b> | Page: audit.risk-identification:view; action gated client-side to Audit Head ( page.tsx:202-205 )                          | All who can open page (Audit Head, Audit Manager); enforced to Audit Head | Validates category + entity, builds FormData, posts for AI suggestions, stores result under Recent Searches | POST /api/internal-audit/risk-identification/suggest | Generated {n} risk(s) successfully (or Risk assessment completed (no risks generated) when none) ( page.tsx:270-274 ) | Field errors<br><b>Please select an audit category / Please select an audit or process;</b> role error <b>Only Audit Head can suggest risks with AI;</b> API error text or <b>Failed to generate risk suggestions</b> ( page.tsx:229, 277 )                | Not verified — no audit-log write found in the suggest route             | None — no notification sent                                                                             |
| <b>X</b> (remove file)       | None                                                                                                                       | Anyone viewing the form                                                   | Removes a selected file from the upload list before submit ( page.tsx:172-174 )                             | None (client only)                                   | —                                                                                                                     | —                                                                                                                                                                                                                                                          | —                                                                        | —                                                                                                       |
| <b>Add to Register</b>       | audit.risk-register:create on API ( risks/route.ts:232 ); rendered only for Audit Head + High/Medium risk ( page.tsx:702 ) | Audit Head                                                                | Creates an Internal Audit Risk from the generated risk and triggers translation                             | POST /api/internal-audit/risks                       | <b>Risk added to register successfully</b> ( page.tsx:347 ); button then shows <b>Added</b>                           | Role error <b>Only Audit Head can add risks to register</b> ( page.tsx:294 ); missing-category error <b>Category information missing. Please regenerate risks.</b> ( page.tsx:299 ); generic <b>Failed to add risk. Please try again.</b> ( page.tsx:350 ) | Not verified — no explicit audit-log write found in the risks POST route | None found in code; on success triggerTranslation('Int ...') runs to translate the new ( page.tsx:343 ) |

## Step-by-Step Instructions

### Task A — Generate AI risk suggestions (Audit Head):

1. Open **Internal Audit > Risk Identification** from the sidebar.
2. In **Audit Category**, select the category to assess. The **Audit / Process** dropdown becomes enabled and loads its entities.
3. In **Audit / Process**, select an audit (under **Audits**) or a process (under **Processes**).
4. (Optional) Enter a **Specific Audit Focus** (e.g. "Payroll processing").
5. (Optional) Add **Supporting Documents** by dragging files onto the upload zone or clicking it. Remove any file with its **X** button. Allowed types: PDF, DOC, DOCX, XLS, XLSX, CSV, TXT; up to 10 files.
6. Click **Suggest Risks with AI**. The button shows **Analyzing...** while the request runs.
7. On success a toast confirms how many risks were generated, and a new entry appears at the top of **Recent Searches** with the generated risk cards.

### Task B — Add a suggested risk to the Risk Register (Audit Head):

1. In a **Recent Searches** entry, find a generated risk with level **High** or **Medium** (Low-level risks have no add button).
2. Click **Add to Register** on that risk card. The button shows **Adding....**
3. On success the button is replaced by an **Added** chip and a toast confirms **Risk added to register successfully**. The risk now exists in the Risk Register with status **Open**.

## Workflow

### Generate suggestions (Suggest Risks with AI):

Current Status: *no record* → User Action: select category + entity, optional focus/files, click **Suggest Risks with AI** → Validation: category and entity required (client) → API: POST /api/internal-audit/risk-identification/suggest, which resolves the category and entity names and forwards department, audit\_category, target\_language, optional specific\_audit\_focus, and files to RunPod /api/assess-risks ( suggest/route.ts:84-120 ) → DB Update: **none** (no record is persisted; results are held in browser sessionStorage only) → Audit Trail: not verified → Notification: none → Next Status: suggestions shown under Recent Searches → Next User: Audit Head reviews suggestions.

### Add to Register (Add to Register):

Current Status: suggestion displayed → User Action: Audit Head clicks **Add to Register** on a High/Medium risk → Validation: must be Audit Head; categoryId present in the stored search → API: POST /api/internal-audit/risks with body riskName (title truncated to 100 chars), riskDescription, categoryId, riskLevel, residualScore, status: "Open", auditComment: "Source: AI Suggested Risk", and processIds when the entity is a process ( page.tsx:316-328 ) → DB Update: a new InternalAuditRisk row is created with a generated riskId (RID###) and re-derived riskLevel ( risks/route.ts:100, 141-208 ); a process link is created if

`processId` is supplied ( `risks/route.ts:211-219` ) → Audit Trail: not verified → Notification: none found; translation of the new risk is triggered ( `page.tsx:343` ) → Next Status: risk **Open** in the Risk Register → Next User: audit team manages it via the Risk Register.

## Status Reference

This page does not implement a multi-status workflow of its own.

- AI suggestions carry a **level** value of **High**, **Medium**, or **Low**, rendered as a color-coded badge (red / yellow / slate) ( `page.tsx:682-692` ). This is a classification of the suggestion, not a workflow status.
- When a suggestion is added to the register, the created risk is given status **Open** ( `page.tsx:322` ). The card-side state then shows **Added** for that risk (a UI marker, not a stored status) ( `page.tsx:704-708` ). Lifecycle of the **Open** status thereafter is managed in the Risk Register module, not here.

## Validation Rules

- Audit Category required** — missing selection shows **Please select an audit category** and blocks submission ( `page.tsx:195, 197-200` ).
- Audit / Process required** — missing selection shows **Please select an audit or process** and blocks submission ( `page.tsx:196` ).
- Audit-Head-only actions** — suggesting and adding are blocked for non-Audit- Head users with toast errors ( `page.tsx:202-205, 293-296` ).
- File constraints** — UI accepts only the listed extensions and at most 10 files; zero-byte and duplicate files are skipped ( `page.tsx:159-169` ). The suggest API additionally filters by extension and ≤20 MB per file and rejects more than 10 valid files with **Maximum 10 files allowed** ( `suggest/route.ts:10-15, 97-105` ).
- Add-to-Register guard** — the stored search must include `categoryId`, else **Category information missing. Please regenerate risks.** ( `page.tsx:298-301` ).
- Idempotency guard** — a risk that is already added or currently being added cannot be added again ( `page.tsx:291` ).
- Server (suggest) validation** — `auditCategoryId` is required (**Audit Category is required**) and must resolve to an existing category (**Audit Category not found**) ( `suggest/route.ts:39-57` ).
- Risk-Register (create) processing** — the risks POST route re-derives `inherentScore`, `residualScore`, and `riskLevel` from tenant scoring config / ranges; if the body supplies `riskLevel` / `residualScore` directly (as this page does) those map through the scoring logic and the generated `riskId` is assigned ( `risks/route.ts:100-208` ).

## Success Scenarios and Failure Scenarios

**Success — AI suggestion returns risks:** Toast **Generated {n} risk(s) successfully**; a Recent Searches entry appears with the generated risk cards.

**Success — AI suggestion returns no risks:** Toast **Risk assessment completed (no risks generated)**; the search entry records `No risks generated for {category}`. ( `page.tsx:249-250, 273` ).

**Success — Add to Register:** Toast **Risk added to register successfully**; button changes to **Added**; a new **Open** risk exists in the register.

**Failure — missing required field:** Inline field errors under the dropdowns; the request is not sent ( `page.tsx:197-200` ).

**Failure — non-Audit-Head attempts to suggest/add:** Toast **Only Audit Head can suggest risks with AI** or **Only Audit Head can add risks to register**. *Resolve:* sign in as Audit Head.

**Failure — AI backend error / unreachable:** The API returns an error body and the page shows the returned `error` text or **Failed to generate risk suggestions** ( `page.tsx:229, 277` ). Underlying server causes include missing `PYTHON_API_SECRET` (**Server misconfiguration: missing API secret**), a non-OK RunPod response (**AI risk assessment failed** or RunPod's own error/detail), or invalid JSON from RunPod (**Invalid JSON response from RunPod**) ( `suggest/route.ts:75-82, 126-145` ). *Resolve:* confirm AI backend availability and configuration, then retry.

**Failure — Add to Register fails:** Toast **Failed to add risk. Please try again.** ( `page.tsx:350` ) or **Category information missing. Please regenerate risks.** ( `page.tsx:299` ). *Resolve:* regenerate the suggestion and retry; verify risk-register create permission.

## System Behaviour

- No persistence of AI suggestions.** Suggestions are kept only in browser `sessionStorage` (key `riskIdentificationSearches`, max 10 entries) and are cleared on navigation away ( `page.tsx:57, 107-109, 261-268` ). Nothing is written to the database by the suggest action.
- External AI processing.** The suggest route proxies to RunPod `/api/assess-risks` using the `PYTHON_API_SECRET` and forwards the selected category/entity context, optional focus, target language (from form or the `NEXT_LOCALE` cookie, default `en`), and uploaded files ( `suggest/route.ts:84-120` ).
- Add to Register creates a real record.** A new `InternalAuditRisk` is created with a generated `RID###` id, status **Open**, `auditComment`: "Source: AI Suggested Risk", and (for process entities) a process link ( `page.tsx:316-328, risks/route.ts:100-219` ).
- Automatic translation.** After a successful add, the new risk is queued for dynamic translation via `triggerTranslation('InternalAuditRisk', ...)` ( `page.tsx:342-344` ).
- Read-only display logic.** The **Add to Register** control appears only for Audit Head and only for High/Medium risks; Low risks display with no add option ( `page.tsx:702` ).
- Audit-trail logging / notifications.** No audit-trail write or notification dispatch was found in the suggest or risks-POST handlers for actions taken on this page — marked **Not verified**.

## Notes / Warnings / Tips

- Suggestions are not saved.** If you leave the page, the Recent Searches list is wiped. Use **Add to Register** to persist any risk you want to keep.
- Only High and Medium suggestions can be added.** Low-level suggestions have no **Add to Register** button by design ( `page.tsx:702` ).
- Audit Manager can view but not act.** Audit Manager can open this page but the AI suggestion and add buttons are restricted to Audit Head in the UI.
- Risk titles are truncated.** When adding to the register, the risk title is cut to the first 100 characters ( `page.tsx:317` ).
- The AI step depends on an external service.** If the RunPod backend or its secret is unavailable, suggestions will fail with an error toast even though the rest of the page works.

---

## Related APIs not used by this page (for reference)

The following endpoints exist in the codebase and were named in the assignment, but are **not** invoked by the Risk Identification page. They are listed here only so this chapter is complete; their UI lives elsewhere.

- **Risk Factors CRUD** — `GET/POST /api/internal-audit/risk-factors` and `GET/PUT/DELETE /api/internal-audit/risk-factors/{id}`. These manage `AuditRiskFactor` records (a single `label` field; tenant- and Audit-Head- scoped) and are protected by `audit.settings` `view/create/edit/delete` (`risk-factors/route.ts:31,86`; `risk-factors/[id]/route.ts:39,102,142`). Duplicate labels are rejected with **Risk factor with this label already exists** (`risk-factors/route.ts:60-65`). This is part of the Settings area, not Risk Identification.
  - **AI-recommended audits** — `GET /api/internal-audit/risks/ai-recommended-audits`, protected by `audit.planning:view` (`ai-recommended-audits/route.ts:166`). It analyses existing `InternalAuditRisk` records grouped by department and category and returns up to 10 recommended audits with a summary; it does **not** read the AI suggestions produced on this page and is not called from this page.
-



# Risk Register

## Overview — Purpose, Business Objective

The Risk Register is the central inventory of audit risks for the Internal Audit module. Each entry captures a risk's identity (auto-generated Risk ID, name, description), its organizational context (department, category, sub-category, audit type, section/process, sub-process, activity), its drivers and consequences, linked processes, control information, related law/regulation references, and a risk assessment (likelihood, impact dimensions, control effectiveness, residual score and risk level).

The register supports the full risk lifecycle used downstream by audit planning: risks are created/imported, assessed through a guided 5-step Assessment Wizard, and the highest-priority risks (High/Medium, not yet linked to an audit plan, status Open) can be fed into AI-assisted audit-plan generation per department.

The list is auto-sorted by residual risk so the highest-priority risks appear at the top ( `src/app/api/internal-audit/risks/route.ts:56-60` — `orderBy residualScore desc, nulls last, then createdAt desc` ).

The module is reached from the Internal Audit sidebar entry labelled **"RiskRegister"** ( `src/lib/navigation.ts:306` ), routed to `/internal-audit/risk-register` , gated on `audit.risk-register:view` .

## Access — Which of the three roles can use it + the exact permission(s) required

All API routes and the page are guarded by the resource `audit.risk-register` with actions `view / create / edit / delete` ( `src/app/api/internal-audit/risks/route.ts:72,232` , `src/app/api/internal-audit/risks/[id]/route.ts:44,207,248` , `src/app/api/internal-audit/risks/[id]/assess/route.ts:95` , `src/app/api/internal-audit/risks/next-id/route.ts:36` , `src/app/api/internal-audit/risks/import/route.ts:174` ).

| Role          | Internal key              | <code>audit.risk-register</code> permission                  | Source                              |
|---------------|---------------------------|--------------------------------------------------------------|-------------------------------------|
| Audit Head    | <code>AuditHead</code>    | <code>['*']</code> (view, create, edit, delete, approve)     | <code>permissions.ts:438</code>     |
| Audit Manager | <code>AuditManager</code> | <code>['*']</code> (view, create, edit, delete, approve)     | <code>permissions.ts:463</code>     |
| Auditor       | <code>Auditee</code>      | <b>No <code>audit.risk-register</code> entry</b> — no access | <code>permissions.ts:532-539</code> |

Notes:

- The Auditor role (internal key `Auditee`) is department-scoped to Fieldwork, CAPA, and Reports only; it has **no** Risk Register permission and the nav item is hidden for it (`permissions.ts:526-539`).
- Other (non-documented) roles that the code references for this resource: `CustomerAdministrator` has `['view', 'create', 'edit', 'delete']` (`permissions.ts:406`); `AuditUser` and `DepartmentReviewer / DepartmentContributor` have `view` only — the last two at `scope: 'department'` (`permissions.ts:488, 675, 715`).
- **Read-only mode:** the page detects `DepartmentReviewer` and `DepartmentContributor` session roles and hides Import / Add Risk / Edit / Delete controls and disables the search & filter inputs (`page.tsx:295-297, 1420-1431, 1447, 1452, 1561, 1274` of view footer `3274`).

## Export action — separate from permissions

There is **no export permission action**. The Export button is an unconditional UI control on the page header (`page.tsx:1416-1419`) and its API `/api/internal-audit/risks/export` has **no `withAuth` wrapper at all** ( `src/app/api/internal-audit/risks/export/route.ts:5` — a bare `GET` ). The same applies to the template download endpoint ( `template/route.ts:4` ).

## Prerequisites — what must already exist before using this module

- A user signed in with a role granting `audit.risk-register:view` (Audit Head or Audit Manager among the three documented roles).
- Reference data fetched on page load (`page.tsx:499-523`), used to populate dropdowns and scoring:
  - **Departments** ( `/api/departments` )
  - **Categories** ( `/api/internal-audit/categories` ) — Category is a **required** field on create/edit
  - **Sub-categories** ( `/api/internal-audit/sub-categories` ) — filtered by the selected category
  - **Audit types** ( `/api/internal-audit/audit-types` )
  - **Probability and Impact** scales ( `/api/internal-audit/probability` , `/impact` ) — used by the Assessment Wizard mean calculations and heat map
  - **Scoring config** ( `/api/internal-audit/scoring-config` ) — calculation method ( `Product of all` / `Addition of all` / `High of all` )
  - **Scoring ranges** ( `/api/internal-audit/scoring-ranges` ) — map a score to a risk-level label
  - **IA processes** ( `/api/internal-audit/ia-processes` ) — for the Linked Processes multi-select
- For AI audit-plan generation: at least one department, plus eligible (High/Medium, Open, unlinked) risks; the fieldwork plan endpoint ( `/api/internal-audit/fieldwork-audit-plan` ) and add-to-plan endpoint ( `/api/internal-audit/audit-planning/from-ai` ) must be reachable.

**Screenshot:** *Insert screenshot here*

The Risk Register list page ( `page.tsx` ) shows, top to bottom:

- **Breadcrumb:** Home icon + "Internal Audit" > (optional) "Dashboard" link (shown only if the user has `audit.dashboard:view`) > "Risk Register" (`page.tsx:1394-1409`).
- **Page header:** title "Risk Register" and a button group: **Export**, **Import** (hidden in read-only mode), **Add Risk** (hidden in read-only mode) (`page.tsx:1411-1433`).
- **Search & filter bar:** a "Search risks..." text box; **Year** select (All Years + current year and 5 prior years); **Department** select (All Departments
  - each department); **Status** select (All Status / Assessed / Not Assessed) (`page.tsx:1438-1488`).



- **Table** of risks with the columns listed below, plus a per-row action group (page.tsx:1489-1596).
- **Pagination** footer (20 per page) (page.tsx:1599-1605).
- Dialogs (opened by user actions): Delete confirmation, Import, AI Recommended Audits, AI Audit – Risk Selection, Generated Audit Plan, Add Risk, Edit Risk, Risk Details (view), and the Risk Assessment Wizard.

## Page Layout

**Header / breadcrumb / buttons** — described under Screenshot above.

**Filters & search** (page.tsx:1438-1488)

- Search box "Search risks..." — sends `search` query param; server matches `riskId`, `riskName`, `riskDescription` (route.ts:39-45).
- Year select — sends `year`; server filters `creationDate` to that calendar year (route.ts:20-26).
- Department select — sends `departmentId` (route.ts:29-31).
- Status select — **client-side only**; filters the already-fetched list by `assessmentStatus` ("Assessed" / "Not Assessed"), defaulting blank to "Not Assessed" (page.tsx:427-429, 1477-1486).

**Table** — see Tables section.

**Dialogs / modals:**

- **Confirm Delete** (AlertDialog, title "Confirm Delete") — page.tsx:1609-1622.
- **Import Risks** (Dialog, title "Import Risks") — file picker (.csv/.xlsx/.xls), "Browse", "Download Template", Cancel, Import — page.tsx:1625-1697.
- **AI Recommended Audits** (Dialog, title "AI Recommended Audits") — summary cards (Total Risks / Extreme Risks / High Risks / Recommendations) and a list of recommended audits with a "Create Audit" button per item. Note: this dialog is wired in code ( `fetchAIRecommendations` , page.tsx:639-653) but no button on the page currently calls it — see Notes. (page.tsx:1699-1838).
- **AI Audit – Risk Selection** (Dialog) — eligible risks grouped by department; a "Generate Audit Plan" button per department (shown only to Audit Head). Opened by `openAIAuditSelection` (page.tsx:1280-1282); no visible page button calls it — see Notes. (page.tsx:1840-1969).
- **Generated Audit Plan** (Dialog, title "Generated Audit Plan") — AI plan items with "Add to Audit Plan" buttons — page.tsx:1971-2061.
- **Add Risk** (Dialog, title "Add Risk") — full form, see Field Reference — page.tsx:2063-2465.
- **Edit Risk** (Dialog, title "Edit Risk - {Risk ID}") — page.tsx:2467-2882.
- **Risk Details** (Dialog, title "Risk Details - {Risk ID}") — read-only view with heat map and an "Edit" button (hidden in read-only mode) — page.tsx:2884-3286.
- **Risk Assessment** wizard (Dialog, title "Risk Assessment") — 5-step wizard — page.tsx:3288-3558.

**Sub-pages (separate routes, not opened by the list page's row actions):**

- `/internal-audit/risk-register/add` — standalone Add Risk page with Inherent & Residual Risk Assessment sections (add/page.tsx).
- `/internal-audit/risk-register/[id]` — standalone View Risk page ( `[id]/page.tsx` ).
- `/internal-audit/risk-register/[id]/edit` — standalone Edit Risk page ( `[id]/edit/page.tsx` ).
- `/internal-audit/risk-register/ai-recommended` — "AI Recommended Risks" page: one card per department with a "Generate Audit Plan" button (ai-recommended/page.tsx).

The list page's Add/Edit/View row actions open **modal dialogs**, not these sub-pages. The sub-pages are reachable by direct URL and use a different field set (they include editable inherent/residual likelihood & impact and a free-text Control Effectiveness of Effective/Partially Effective/Ineffective).

## Field Reference

Fields on the modal **Add Risk** / **Edit Risk** forms (page.tsx:2063-2882). The POST/PUT handler sends `inherent*` / `residual*` as `null` from these modals (page.tsx:894-899, 982-987), so scoring is driven by the Assessment Wizard, not these forms.

| Field                                       | Required  | Type                   | Default               | Validation                                                                                                    | Editable | Description                                                                                                                                                        |
|---------------------------------------------|-----------|------------------------|-----------------------|---------------------------------------------------------------------------------------------------------------|----------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Risk ID                                     | No (auto) | Text (disabled)        | Auto-generated RID### | Read-only; server generates as RID + zero-padded max+1                                                        | No       | Identifier; pre-filled from /risks/next-id (page.tsx:475-485)                                                                                                      |
| Risk Name                                   | Yes       | Text                   | empty                 | Non-empty; must pass isValidName ("Only letters, spaces, and hyphens are allowed")                            | Yes      | page.tsx:862-866                                                                                                                                                   |
| Department                                  | No        | Select                 | empty                 | —                                                                                                             | Yes      | From Departments list                                                                                                                                              |
| Category                                    | Yes       | Select                 | empty                 | Non-empty ("Risk category is required")                                                                       | Yes      | page.tsx:873-876                                                                                                                                                   |
| Sub-Category                                | No        | Select                 | empty                 | Disabled until a Category is chosen; filtered by category                                                     | Yes      | page.tsx:2144-2158                                                                                                                                                 |
| Audit Type                                  | No        | Select                 | empty                 | —                                                                                                             | Yes      | From Audit Types                                                                                                                                                   |
| Section/Process                             | No        | Text                   | empty                 | —                                                                                                             | Yes      |                                                                                                                                                                    |
| Sub Process                                 | No        | Text                   | empty                 | —                                                                                                             | Yes      |                                                                                                                                                                    |
| Activity                                    | No        | Text                   | empty                 | —                                                                                                             | Yes      |                                                                                                                                                                    |
| Risk Description                            | Yes       | Textarea               | empty                 | Non-empty ("Risk description is required")                                                                    | Yes      | page.tsx:868-871                                                                                                                                                   |
| Risk Driver(s) / Cause(s)                   | No        | Textarea               | empty                 | —                                                                                                             | Yes      | Maps to riskDrivers                                                                                                                                                |
| Risk Consequence(s)                         | No        | Textarea               | empty                 | —                                                                                                             | Yes      | Maps to riskConsequences                                                                                                                                           |
| Processes (Linked Processes)                | No        | Multi-select checklist | none                  | —                                                                                                             | Yes      | Sends processIds[] ; "{n} process(es) selected"                                                                                                                    |
| Control Description (#n)                    | No        | Textarea               | one empty row         | Only rows with a non-empty description are saved (page.tsx:907)                                               | Yes      | Repeatable via "Add Control"; stored as JSON in controlsData                                                                                                       |
| Control Effectiveness                       | No        | Select 1–5             | empty                 | Options: 1 – Very Ineffective, 2 – Ineffective, 3 – Moderately Effective, 4 – Effective, 5 – Highly Effective | Yes      | Per control row; highest value auto-populates the wizard                                                                                                           |
| Related Law / Regulation / Policy Reference | No        | Textarea               | empty                 | —                                                                                                             | Yes      | Maps to relatedLawRegulation                                                                                                                                       |
| Creation Date                               | No        | DatePicker             | today                 | —                                                                                                             | Yes      | Defaults to today's date (page.tsx:407)                                                                                                                            |
| Status                                      | No        | Select                 | "Open"                | Options: Open / Under Review / Closed                                                                         | Yes      |                                                                                                                                                                    |
| Audit Comment                               | No        | Textarea               | empty                 | —                                                                                                             | Yes      |                                                                                                                                                                    |
| Attachments                                 | No        | File drop/upload       | none                  | Accept .pdf, .doc, .docx, .xls, .xlsx, .csv, .txt, .png, .jpg, .jpeg ; uploaded via /api/upload               | Yes      | <b>Not verified</b> that the uploaded file IDs are persisted with the risk — the form body sent on save does not include the uploaded file list (page.tsx:888-910) |

Standalone **add/page.tsx** and **[id]/edit/page.tsx** forms differ:

- Add an **Inherent Risk Assessment** section: Likelihood (required) and Impact (required), each a select of probability/impact scale values (add/page.tsx:273-291, 564-619).
- Add a **Residual Risk Assessment** section: Likelihood (required) and Impact (required) (add/page.tsx:283-291, 656-713).
- **Control Effectiveness** here is a 3-option select: Effective / Partially Effective / Ineffective (add/page.tsx:646-651; edit page 698-701).
- Edit page shows computed, disabled **Inherent Score** and **Residual Score** fields (edit/page.tsx:662-669, 763-770).
- These pages do **not** include Sub-Category, Linked Processes, multi-control rows, Risk Drivers/Consequences, or Related Law fields.

## Tables

Columns (page.tsx:1491-1503), all sortable label not present — there is no clickable column-sort UI:

| Column           | Source                                                                                                                                                                       |
|------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Risk ID          | <code>riskId</code>                                                                                                                                                          |
| Risk Description | <code>riskDescription</code> or fallback <code>riskName</code> , truncated                                                                                                   |
| Department       | translated department name or <code>department.name</code>                                                                                                                   |
| Creation Date    | localized <code>creationDate</code>                                                                                                                                          |
| Category         | translated category name or <code>category.name</code>                                                                                                                       |
| Inherent Score   | computed client-side: <code>assessmentLikelihood × max(strategicImpact, financialImpact, complianceRisk, operationalRisk, itDataRisk)</code> , else "-" (page.tsx:1513-1518) |
| Residual Score   | <code>assessmentResidualScore.toFixed(2)</code> if status Assessed, else "-" (page.tsx:1519-1523)                                                                            |
| Risk Level       | badge: Extreme / High / Medium / Low / Minimal, else "-" (page.tsx:1042-1058)                                                                                                |
| Status           | assessment-status badge: "Assessed" (green) or "Not Assessed" (page.tsx:1525-1529)                                                                                           |
| Action           | per-row buttons (see Buttons & Actions)                                                                                                                                      |

- **Sorting:** no user sort control. The server pre-sorts by residual score descending then created date descending (route.ts:56-60).
- **Searching:** the "Search risks..." box filters by Risk ID / Name / Description server-side (route.ts:39-45).
- **Filtering:** Year, Department (server-side); Status (client-side, on `assessmentStatus`).
- **Pagination:** 20 rows per page, client-side slicing of the filtered list (page.tsx:290-291, 426-436, 1599-1605).
- **Empty state:** "No risks found." (read-only role) or "No risks found. Click "Add Risk" to create your first risk. (page.tsx:1587-1593).
- **No bulk actions / no row selection checkboxes.**

## Buttons & Actions

| Control                                            | Permission                               | Visible To                             | Action                                                     | API                                                                | Success Msg                                         | Failure Msg                                                                                                                    | Audit Trail  | Notification |
|----------------------------------------------------|------------------------------------------|----------------------------------------|------------------------------------------------------------|--------------------------------------------------------------------|-----------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------|--------------|--------------|
| Export                                             | None enforced (no auth on endpoint)      | All (always shown)                     | Downloads <code>risk-register-<br/>&lt;date&gt;.csv</code> | GET <code>/api/internal-audit/risks/export</code>                  | none (no toast)                                     | none (logged to console)                                                                                                       | Not verified | None         |
| Import                                             | <code>create</code>                      | Not read-only role                     | Opens Import Risks dialog                                  | —                                                                  | —                                                   | —                                                                                                                              | —            | None         |
| Import → Import (in dialog)                        | <code>create</code>                      | —                                      | Uploads CSV, creates rows                                  | POST <code>/api/internal-audit/risks/import</code>                 | none (no toast; list refreshes, dialog closes)      | none surfaced (console only)                                                                                                   | Not verified | None         |
| Import → Download Template                         | None enforced                            | —                                      | Downloads <code>risk-import-template.csv</code>            | GET <code>/api/internal-audit/risks/template</code>                | none                                                | none                                                                                                                           | Not verified | None         |
| Add Risk                                           | <code>create</code>                      | Not read-only role                     | Opens Add Risk dialog                                      | —                                                                  | —                                                   | —                                                                                                                              | —            | None         |
| Add Risk → Save                                    | <code>create</code>                      | —                                      | Creates risk                                               | POST <code>/api/internal-audit/risks</code>                        | "Success" / "Risk created successfully."            | "Error" / server error or "Failed to create risk."                                                                             | Not verified | None         |
| View (eye icon)                                    | <code>view</code>                        | All with view                          | Opens Risk Details dialog                                  | GET <code>/api/internal-audit/risks/{id}</code>                    | —                                                   | "Error" / "Failed to load risk details."                                                                                       | Not verified | None         |
| Initiate Assessment / Resume / Re-assess           | <code>edit</code> (assess endpoint)      | All with view (button always rendered) | Opens Assessment Wizard                                    | PATCH <code>/api/internal-audit/risks/{id}/assess</code> (on save) | "Success" / "Risk assessed successfully"            | "Error" / "Failed to save assessment"                                                                                          | Not verified | None         |
| Edit (pencil icon)                                 | <code>edit</code>                        | Not read-only role                     | Opens Edit Risk dialog                                     | GET then PUT <code>/api/internal-audit/risks/{id}</code>           | "Success" / "Risk updated successfully."            | "Error" / server error or "Failed to update risk."                                                                             | Not verified | None         |
| Delete (trash icon)                                | <code>delete</code>                      | Not read-only role                     | Opens Confirm Delete dialog                                | —                                                                  | —                                                   | —                                                                                                                              | —            | None         |
| Confirm Delete → Delete                            | <code>delete</code>                      | —                                      | Deletes risk                                               | DELETE <code>/api/internal-audit/risks/{id}</code>                 | none (no toast; list refreshes)                     | none surfaced (console only)                                                                                                   | Not verified | None         |
| Generate Audit Plan (in AI Audit – Risk Selection) | Button gated by <code>isAuditHead</code> | Audit Head only                        | Generates fieldwork plan for a department                  | POST <code>/api/internal-audit/fieldwork-audit-plan</code>         | "Success" / "Audit plan generated"                  | "Error" / server error or "Failed to generate audit plan"                                                                      | Not verified | None         |
| Add to Audit Plan (in Generated Audit Plan)        | Not verified (separate endpoint's auth)  | —                                      | Adds AI plan to Audit Planning                             | POST <code>/api/internal-audit/audit-planning/from-ai</code>       | "Success" / "Successfully added to Audit Planning!" | 409 → "Warning" / "This audit plan has already been added to Audit Planning."; other → "Error" / "Failed to add to audit plan" | Not verified | None         |

Audit-trail logging: none of the risk routes call an audit-log helper in the code read — marked "Not verified" above. No in-app notifications are emitted by these routes.

## Step-by-Step Instructions

### View the register

1. Open Internal Audit → "RiskRegister" ( `/internal-audit/risk-register` ).
2. The table loads, sorted by residual score (highest first).
3. Optionally type in "Search risks...", or pick a Year / Department / Status to narrow the list. Use the pagination footer to move between pages.

### Add a risk (modal)

1. Click **Add Risk** (header). The Add Risk dialog opens; Risk ID is auto-filled and disabled.
2. Enter **Risk Name** (letters/spaces/hyphens only) and **Risk Description** (both required); select a **Category** (required).
3. Optionally set Department, Sub-Category (after picking a Category), Audit Type, Section/Process, Sub Process, Activity.
4. Optionally fill Risk Driver(s)/Cause(s) and Risk Consequence(s).
5. Optionally select Linked Processes (click items to toggle).
6. Optionally add one or more Controls (description + Control Effectiveness 1–5); use "Add Control" for more rows.
7. Optionally enter Related Law / Regulation / Policy Reference.
8. Optionally set Creation Date, Status (Open/Under Review/Closed), Audit Comment, and drag/drop or browse Attachments.
9. Click **Save**. On success a "Risk created successfully." toast appears, the dialog closes, and the list refreshes.

### Assess a risk (Assessment Wizard)

1. In the row's Action group, click **Initiate Assessment** (first time), **Resume** (if an in-progress draft exists), or **Re-assess** (if already Assessed). Re-assess always starts fresh.
2. **Step 1 – Risk Context:** review Risk ID/Name, Category, Type, Department, Risk Sources (read-only). Click **Next**.
3. **Step 2 – Likelihood:** select a value 1–5 (required to proceed). Click Next.
4. **Step 3 – Impact:** rate all five dimensions (Strategic Impact, Financial Impact, Compliance Risk, Operational Risk, IT / Data Risk) 1–5 (all required). Click Next.
5. **Step 4 – Risk Rating:** Control Effectiveness is auto-populated from the risk's controls (highest value); if none is set, choose 1–5 (required). Review the calculated Mean Probability, Mean Impact, Calculated Risk Score, and Risk Rating. Click Next.
6. **Step 5 – Summary:** review all entries and the Risk Score / Risk Rating.
7. Click **Save Assessment**. On success a "Risk assessed successfully" toast appears, the list refreshes (Status becomes "Assessed"), and the dialog closes. Use **Back** / **Cancel** to navigate; progress is auto-saved per step to the browser (localStorage) for first-time assessments.

### Edit a risk

1. Click the pencil (Edit) icon, or open View and click **Edit**.
2. The Edit Risk dialog loads current values. Update fields (same validation as Add). Click **Save** → "Risk updated successfully."

### Delete a risk

1. Click the trash (Delete) icon.
2. In "Confirm Delete", click **Delete**. The risk is removed and the list refreshes (no success toast).

### Import risks

1. Click **Import** → in the dialog click **Download Template** to get the expected CSV columns.
2. Click **Browse**, choose a `.csv/.xlsx/.xls` file, then click **Import**.
3. The list refreshes and the dialog closes on success.

### Export risks

1. Click **Export** (header). A CSV `risk-register-<date>.csv` downloads.

## Workflow

Two distinct status fields exist on a risk: a lifecycle **Status** (Open/Under Review/Closed) set by the user on the form, and an **assessmentStatus** (Not Assessed / Assessed) driven by the Assessment Wizard.

Assessment flow:

| Current Status | User Action                       | Validation                                                           | API                                      | DB Update                                                                                                                                                                                                                    | Audit Trail  | Notification | Next Status | Next User                 |
|----------------|-----------------------------------|----------------------------------------------------------------------|------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------|--------------|-------------|---------------------------|
| Not Assessed   | Complete wizard + Save Assessment | Likelihood, all 5 impacts, control effectiveness required (per-step) | PATCH<br><code>/risks/{id}/assess</code> | Sets impact dims, <code>assessmentLikelihood</code> , <code>controlEffectivenessScore</code> , <code>assessmentResidualScore</code> , <code>riskLevel</code> (from scoring ranges), <code>assessmentStatus="Assessed"</code> | Not verified | None         | Assessed    | Same / any user with view |
| Assessed       | Re-assess + Save Assessment       | Same                                                                 | PATCH<br><code>/risks/{id}/assess</code> | Recomputes the same fields                                                                                                                                                                                                   | Not verified | None         | Assessed    | —                         |

Create/Edit flow: the user-selected lifecycle Status (Open / Under Review / Closed) is stored as entered; there is no automatic status transition between these three values, and no approval step (no `approve` action is invoked anywhere in these routes).

AI plan flow (Audit Head, from the AI Audit – Risk Selection dialog): eligible risks → "Generate Audit Plan" (POST fieldwork-audit-plan) → review → "Add to Audit Plan" (POST audit-planning/from-ai), which creates an Audit Planning entry in another module.

### Status Reference

**Lifecycle Status** (form field, options Open / Under Review / Closed — page.tsx:2367-2369, 2783-2785):

| Status       | Meaning                                                                                | How reached              | Who can change                  | Next statuses        |
|--------------|----------------------------------------------------------------------------------------|--------------------------|---------------------------------|----------------------|
| Open         | Default for a new risk (page.tsx:409; server default <code>"Open"</code> route.ts:197) | Set on create, or chosen | Any role with <code>edit</code> | Under Review, Closed |
| Under Review | User-selected intermediate state                                                       | Chosen on form           | Any role with <code>edit</code> | Open, Closed         |
| Closed       | User-selected closed state                                                             | Chosen on form           | Any role with <code>edit</code> | Open, Under Review   |

(Status badge styling: Open=info, Under Review=warning, Closed=success — page.tsx:1060-1072. These three are free transitions; no enforced workflow.)

**Assessment Status** (derived, shown in the Status column and used by the Status filter):

| Status       | Meaning                                                                      | How reached                                                                                                     | Who can change            | Next statuses |
|--------------|------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------|---------------------------|---------------|
| Not Assessed | No assessment saved yet (default when <code>assessmentStatus</code> is null) | Initial state                                                                                                   | Run the Assessment Wizard | Assessed      |
| Assessed     | Assessment scores saved                                                      | Save Assessment in the wizard (PATCH assess sets <code>assessmentStatus="Assessed"</code> , assess/route.ts:84) | Re-assess re-saves        | Assessed      |

**Risk Level** values that can appear: Extreme, High, Medium, Low, Minimal (badge map, page.tsx:1045-1051). On create/edit the level is derived from the residual score via configured scoring ranges, or fallback thresholds (Extreme  $\geq 250$ , High  $\geq 100$ , Medium  $\geq 50$ , else Low — route.ts:161-164). On assessment it is derived from `assessmentResidualScore` via scoring ranges, or fallback thresholds (Critical  $\geq 15$ , High  $\geq 10$ , Medium  $\geq 5$ , else Low — assess/route.ts:66-69). The CSV import uses its own fallback thresholds (Extreme  $\geq 20$ , High  $\geq 15$ , Medium  $\geq 10$ , else Low — import/route.ts:109-112).

### Validation Rules

Modal Add/Edit forms (page.tsx:857-885, 942-974):

- **Risk Name** — required; must satisfy `isValidName` else "Only letters, spaces, and hyphens are allowed".
- **Risk Description** — required ("Risk description is required").
- **Category** — required ("Risk category is required").
- Errors render inline beneath each field; the form does not submit while any error is present.

Standalone add/edit pages additionally require Inherent Likelihood, Inherent Impact, Residual Likelihood, Residual Impact (add/page.tsx:273-291; edit/page.tsx:331-349).

Assessment Wizard per-step validation (page.tsx:3524-3538):

- Step 2: a likelihood value must be selected ("Please select a likelihood value before proceeding.").
- Step 3: all impact dimensions must be rated ("Please rate all impact dimensions before proceeding.").
- Step 4: control effectiveness must be selected ("Please select a control effectiveness score before proceeding.").

Import validation (import/route.ts):

- File required, else 400 "No file provided".
- At least a header + one data row, else 400 "CSV file must have at least a header and one data row".
- Per row, "Risk Description" is required, else that row is skipped with error `Row N: Risk Description is required`.

Tenant/permission checks: every `[id]` route revalidates that the risk belongs to the caller's tenant ( `validateTenantAccess` ), returning 403 "Access denied" if not ( `[id]/route.ts:67-69, 229-231` ; assess/route.ts:20-22); a missing risk returns 404. There is no duplicate Risk ID check on create — IDs are generated server-side.

### Success Scenarios and Failure Scenarios

**Success:**

- Create → 201, toast "Risk created successfully.", list refreshes, dynamic translation triggered for `riskName / riskDescription`.
- Edit → 200, toast "Risk updated successfully.", list refreshes.
- Delete → 200, list refreshes (no toast).
- Assess → 200, toast "Risk assessed successfully", Status column shows "Assessed", residual score populated; if the View dialog is open for the same risk it reloads to refresh the heat map (page.tsx:1222-1225).
- Export → CSV file downloads.
- Import → list refreshes, dialog closes (the endpoint returns counts `{imported, errors, details}` but the page does not display them — see Notes).

**Failures:**

- Missing required field (Name/Description/Category) → inline red error text; no API call. Resolve by completing the field.
- Risk Name with invalid characters → "Only letters, spaces, and hyphens are allowed". Resolve by removing digits/symbols.
- Create/Edit server error → toast "Error" with the server's `error` message or "Failed to create risk." / "Failed to update risk." Resolve by retrying; persistent failures indicate a server/DB issue.
- Load risk details fails (View/Edit) → toast "Error" / "Failed to load risk details." (the View dialog closes).
- Assessment save fails → toast "Error" / "Failed to save assessment." Resolve by retrying; wizard stays open.
- Cross-tenant access (manipulated id) → 403 "Access denied".
- Not found id → 404.
- Import with no file / malformed CSV → 400 with the messages above; note the current UI does not surface these — the dialog simply does not refresh on a non-OK response (page.tsx:600-605).
- Generate Audit Plan failure → toast "Error" / "Failed to generate audit plan".
- Add to Audit Plan duplicate → warning toast "This audit plan has already been added to Audit Planning." (HTTP 409).

## System Behaviour

- **Auto Risk ID:** server generates `RID` + zero-padded (max existing numeric suffix + 1), scoped to the tenant (route.ts:86-100; next-id/route.ts:11-25). The Add modal pre-fills this from `/risks/next-id`.
- **Auto sorting:** list is server-sorted by residual score desc (nulls last) then created date desc.
- **Score & level derivation:** inherent/residual scores and risk level computed server-side from the configured calculation method and scoring ranges on create/edit; assessment residual score and level computed on assess.
- **Assessment draft autosave:** for a first-time assessment, the current step and entered values are saved to browser `localStorage` (`ia-assess-<riskId>`), enabling "Resume"; cleared on save or when starting a Re-assess (page.tsx:1142-1145, 1172-1173, 1218).
- **Control effectiveness auto-fill:** the wizard's Control Effectiveness is pre-set to the highest numeric effectiveness among the risk's controls (page.tsx:1156-1165).
- **Dynamic translation:** on create/edit the server calls `translateRecord` and the client calls `triggerTranslation` for `riskName` / `riskDescription`; on delete, `deleteRecordTranslations` is called. List/dropdown display uses translated names where available.
- **Read-only behavior:** DepartmentReviewer / DepartmentContributor sessions hide Import/Add/Edit/Delete and disable search & filter inputs.
- **Audit-trail logging / in-app notifications:** none observed in the risk routes read — marked Not verified / None.

## Notes / Warnings / Tips

- **Two different "Status" concepts.** The Status **column** in the table reflects *assessmentStatus* (Assessed / Not Assessed), while the Status **field** on the form is the lifecycle Status (Open / Under Review / Closed). The Status **filter** above the table filters by *assessmentStatus*.
- **List modals vs. standalone pages diverge.** The Add/Edit dialogs opened from the list send inherent/residual scores as `null` and rely on the Assessment Wizard for scoring, whereas the standalone `/add` and `/[id]/edit` pages capture inherent/residual likelihood & impact directly and use a 3-value Control Effectiveness. Document/train on one consistent path to avoid confusion.
- **No visible entry point to some dialogs.** `fetchAIRecommendations` (AI Recommended Audits dialog) and `openAIAuditSelection` (AI Audit – Risk Selection dialog) are implemented but no button on the current Risk Register page invokes them (verified by absence of `onClick` callers in page.tsx). AI audit-plan generation is instead exposed on the separate `/risk-register/ai-recommended` page. Treat the in-page AI dialogs as not user-reachable unless a launcher is added.
- **Export and template endpoints are unauthenticated** (no `withAuth`). Anyone who can reach the URL can download the CSV. Flag for security review.
- **Import errors are silent in the UI.** The import endpoint returns imported/error counts, but the page does not display them; a partially failed import looks the same as a clean one. Verify imported rows after importing.
- **Attachment persistence is unconfirmed.** Files are uploaded to `/api/upload`, but the create/edit request body does not include the uploaded-file list, so it is not verified that attachments are linked to the saved risk.
- The sidebar label is the single token "RiskRegister" (no space) in navigation.ts:306, while the page H1 and breadcrumb read "Risk Register".

# Risk Universe

## Overview — Purpose, Business Objective

The **Risk Universe** page presents a single, read-only visual map of all audit risks recorded in the Internal Audit module, organized by the department that owns each risk. It renders a tree (the **Risk Map**) whose root node is labelled **Risk Universe**, branching out to every department, and then to the individual risks under each department.

The business objective is to give Internal Audit users an at-a-glance, hierarchical overview of where risk is concentrated across the organization — how many departments exist, how many risks are registered, and how those risks distribute across the **Extreme**, **High**, **Medium**, and **Low** risk levels. It is a reporting / visualization view only; risks are not created or edited here. Each risk node links the user back to the **Risk Register** for detailed work.

Source data is the `InternalAuditRisk` table joined to `Department`; the page is served by `GET /api/internal-audit/risk-universe` (`src/app/api/internal-audit/risk-universe/route.ts`).

## Access — Roles and Required Permission

The page and its API both require the permission resource `audit.risk-universe` with action `view`.

- The API enforces `{ resource: 'audit.risk-universe', action: 'view' }` (`src/app/api/internal-audit/risk-universe/route.ts:96`).
- The route is mapped to `/internal-audit/risk-universe` (`src/lib/permissions.ts:122`).

Of the three documented roles:

| Role (display) | Internal key              | <code>audit.risk-universe</code> grant                                        | Can use Risk Universe? |
|----------------|---------------------------|-------------------------------------------------------------------------------|------------------------|
| Audit Head     | <code>AuditHead</code>    | <code>actions: ['*'], scope: 'all'</code> ( <code>permissions.ts:449</code> ) | Yes                    |
| Audit Manager  | <code>AuditManager</code> | <code>actions: ['*'], scope: 'all'</code> ( <code>permissions.ts:475</code> ) | Yes                    |
| Auditor        | <code>Auditee</code>      | (none — not granted)                                                          | No                     |

The **Auditor** role (internal key `Auditee`) is department-scoped and is **not** granted `audit.risk-universe`; its permission block contains only `organization.department`, `audit.fieldwork`, `audit.reports`, `audit.capa`, and `audit.audit-trail` (`permissions.ts:532-539`). The role comment explicitly excludes "Risk Universe" for this role (`permissions.ts:529`). An Auditor therefore cannot view this page.

Note: The page contains all five permission actions (`view`, `create`, `edit`, `delete`, `approve`) for the grant holders because the grant uses `['*']`, but the page itself only ever performs a **view** (read) operation — there are no `create/edit/delete/approve` controls. There is **no Export** action and no export button on this page.

## Prerequisites

Before the Risk Map shows meaningful content:

1. **Departments must exist** for the tenant. The API loads departments via `prisma.department.findMany` filtered by tenant (`route.ts:30-33`). Departments appear as branches even when they have no risks.
2. **Risks must exist in the Risk Register** (`InternalAuditRisk` records). When none exist, the page shows the empty state (see below).
3. **Each risk must be assigned to a department** (`departmentId`) to appear under a department branch. A risk whose `departmentId` is null or does not match a loaded department is **not placed on the map** — the API only adds a risk when `deptId && departmentMap[deptId]` is true (`route.ts:68-78`). (It still counts toward **Total Risks**; see Tables note.)
4. The signed-in user must hold `audit.risk-universe:view` (see Access).

**Screenshot:** *Insert screenshot here*

Visible areas of the page, top to bottom:

- **Breadcrumb** — `Internal Audit` → (`Dashboard`, shown only if the user has `audit.dashboard.view`) → **Risk Universe** (current page, highlighted).
- **Page header** — the title **Risk Universe**.
- **Summary stat cards** — a row of four cards: **Departments**, **Total Risks**, **Extreme / High**, **Medium / Low**.
- **Risk Map card** — titled **Risk Map**, with an inline color legend (Extreme / High / Medium / Low) in its header, and the tree visualization in its body: a root **Risk Universe** node, department boxes, and risk cards.
- **Empty state** (only when there are no departments/risks on the map) — an icon, the message **No risks in the risk register yet**, the hint **Add risks to the Risk Register to see them here**, and a **Go to Risk Register** button.
- **Loading state** — while data loads, a spinner with the text **Loading risk universe...** appears in place of the cards and map.

## Page Layout

**Breadcrumb** (`page.tsx:137-152`): `Internal Audit` (Home icon, static text) > `Dashboard` (link to `/internal-audit/dashboard`, rendered only when the user can view `audit.dashboard`) > **Risk Universe** (current, non-clickable, highlighted).

**Header** (`page.tsx:155-157`): single `<h1>` reading **Risk Universe**. No action buttons in the header.

Summary stat cards ( page.tsx:160-205 ): four cards in a responsive grid:

| Card label     | Value shown                                                 | Source              |
|----------------|-------------------------------------------------------------|---------------------|
| Departments    | data.totalDepartments (count of departments)                | route.ts:85         |
| Total Risks    | data.totalRisks (count of all risks for the tenant)         | route.ts:86         |
| Extreme / High | computed extremeCount + highCount (risks placed on the map) | page.tsx:92-93, 190 |
| Medium / Low   | computed mediumCount + lowCount (risks placed on the map)   | page.tsx:94-95, 201 |

Risk Map card ( page.tsx:208-353 ):

- Card header: title **Risk Map** plus an inline **legend** showing four colored dots with labels **Extreme** (red), **High** (orange), **Medium** (amber), **Low** (emerald).
- Card body: a top-down tree —
  - Root node**: a primary-colored box labelled **Risk Universe** with a shield icon.
  - Department branches**: one box per department, showing the department name, a building icon, and a count line reading `N risk(s)` when it has risks or **No risks** when it has none. Departments with no risks are drawn with a dashed, muted box.
  - Risk cards**: under each department, one card per risk showing the **riskId** (e.g. `RID001`) and the **risk level** text. The card is color-coded by level (Extreme=red, High=orange, Medium=amber, Low=emerald, anything else=slate). Each card is a **link to** `/internal-audit/risk-register`.
  - Tooltip** (on hover of a risk card): shows the **risk name**, a line `Risk Level: <level>`, and the hint **Click to view in Risk Register**.
- The department row is horizontally scrollable when wide.

**Empty state** ( page.tsx:334-350 ): shown when no departments are present on the map — icon, **No risks in the risk register yet, Add risks to the Risk Register to see them here**, and a **Go to Risk Register** outline button linking to `/internal-audit/risk-register`.

There are no tabs, no filters, no search box, no forms, no side panels, no dialogs, no row-action menus, no bulk actions, and no footer on this page.

## Field Reference

This page has **no input form** — it does not collect or edit any field. The values it displays come from the `InternalAuditRisk` and `Department` records and are read-only. For completeness, the data fields rendered are:

| Field                    | Required   | Type   | Default                                                                                           | Validation                                              | Editable | Description                                                      |
|--------------------------|------------|--------|---------------------------------------------------------------------------------------------------|---------------------------------------------------------|----------|------------------------------------------------------------------|
| Department name          | n/a (read) | string | —                                                                                                 | none on this page                                       | No       | Department branch label ( route.ts:62, page.tsx:273 ).           |
| Risk ID ( riskId )       | n/a (read) | string | Auto-generated (e.g. <code>RID001</code> ) per schema comment ( <code>schema.prisma:3122</code> ) | none on this page                                       | No       | Shown on the risk card ( page.tsx:299 ).                         |
| Risk name ( riskName )   | n/a (read) | string | —                                                                                                 | none on this page                                       | No       | Shown in the hover tooltip ( page.tsx:308 ).                     |
| Risk level ( riskLevel ) | n/a (read) | string | API defaults to <code>Low</code> when null ( route.ts:7 )                                         | normalized to Extreme/High/Medium/Low ( route.ts:6-21 ) | No       | Drives card color and the level text ( page.tsx:285, 302, 311 ). |

## Tables

This page does **not** use a tabular grid. Data is presented as the **Risk Map** tree (root → departments → risk cards), not as a sortable/filterable table.

- Sorting**: fixed, server-side only. Departments are returned alphabetically by name ( route.ts:32, 81 ); risks are queried ordered by `riskId` ascending ( route.ts:43 ). The user cannot re-sort.
- Searching / Filtering / Pagination**: none. There is no search box, no filter control, and no pagination — the full universe is rendered at once.
- Row actions / Bulk actions**: none. The only interactive element on a risk card is the link to the Risk Register (see Buttons & Actions).

**Counting note**: the **Total Risks** card counts **all** tenant risks returned by the query ( route.ts:86 ), whereas the **Extreme / High** and **Medium / Low** cards are computed client-side from only the risks that were **placed on the map** (risks whose `departmentId` matched a loaded department). If some risks have no/unmatched department, **Total Risks** can exceed the sum of the Extreme/High + Medium/Low cards.

## Buttons & Actions

| Control                                                    | Permission                                              | Visible To                                   | Action                                                  | API                                      | Success Msg | Failure Msg | Audit Trail | Notification |
|------------------------------------------------------------|---------------------------------------------------------|----------------------------------------------|---------------------------------------------------------|------------------------------------------|-------------|-------------|-------------|--------------|
| <b>Risk card</b> (each, shows <code>riskId</code> + level) | <code>audit.risk-universe:view</code> (to see the page) | Audit Head, Audit Manager                    | Navigates to <code>/internal-audit/risk-register</code> | None (client-side <a href="#">Link</a> ) | None        | None        | None        | None         |
| <b>Go to Risk Register</b> (empty-state button)            | <code>audit.risk-universe:view</code>                   | Audit Head, Audit Manager                    | Navigates to <code>/internal-audit/risk-register</code> | None (client-side <a href="#">Link</a> ) | None        | None        | None        | None         |
| <b>Dashboard</b> (breadcrumb link)                         | <code>audit.dashboard:view</code> (controls visibility) | Holders of <code>audit.dashboard</code> view | Navigates to <code>/internal-audit/dashboard</code>     | None                                     | None        | None        | None        | None         |



There are no Create / Edit / Delete / Approve / Export / Save controls on this page. No toast/success/failure messages are emitted by the page (it has no mutating actions).

## Step-by-Step Instructions

### Task — View the Risk Universe map

1. Sign in as an **Audit Head** or **Audit Manager**.
2. Open the page at `/internal-audit/risk-universe` (the breadcrumb shows `Internal Audit > Dashboard > Risk Universe`).
3. Wait for loading to finish — while loading you will see a spinner and **Loading risk universe....**
4. Read the four summary cards (**Departments**, **Total Risks**, **Extreme / High**, **Medium / Low**) for the totals.
5. In the **Risk Map** card, use the legend (Extreme/High/Medium/Low) to interpret the colors.
6. Scroll horizontally across the department row if there are more departments than fit on screen.
7. Locate a department box; read its `N risk(s)` count (or **No risks**).

### Task — Inspect a specific risk

1. Hover the pointer over a risk card to reveal the tooltip showing the **risk name**, **Risk Level**, and the hint **Click to view in Risk Register**.
2. Click the risk card to open the **Risk Register** (`/internal-audit/risk-register`) for full details and any edits.

### Task — Reach the Risk Register when no risks exist

1. If the page shows **No risks in the risk register yet**, click the **Go to Risk Register** button.
2. Add risks in the Risk Register; once a risk has a department, return to Risk Universe to see it on the map.

## Workflow

This page is a **read-only visualization** with no state machine. There is no create/edit/approve flow, no DB write, no status change, and no notification originating from this page. The only "workflow" is data retrieval:

Page mount → `GET /api/internal-audit/risk-universe` → API applies tenant filter, loads departments + risks, normalizes each risk level, groups risks by department → returns `{ departments, totalDepartments, totalRisks }` → page renders the map. No DB update, no audit-trail entry, no next status, no next user.

Risks themselves are created and progress through their lifecycle in the **Risk Register / Risk Identification** module, not here.

## Status Reference

The Risk Universe page does **not** display or change the `InternalAuditRisk` `status` field (`Open` / `Closed` / `Under Review`, per `schema.prisma:3155`). The only status-like attribute shown is the **risk level**:

| Risk level (displayed) | Meaning                                                                                                               | How reached                                                                                                                  | Who can change it                     |
|------------------------|-----------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------|---------------------------------------|
| <b>Extreme</b>         | Highest severity band; rendered red                                                                                   | Set/derived in the Risk Register; API also maps <code>critical</code> → <code>Extreme</code> ( <code>route.ts:11-13</code> ) | In the Risk Register module, not here |
| <b>High</b>            | High severity; rendered orange                                                                                        | Set/derived in the Risk Register ( <code>route.ts:14-16</code> )                                                             | In the Risk Register module           |
| <b>Medium</b>          | Medium severity; rendered amber; API maps <code>moderate</code> → <code>Medium</code> ( <code>route.ts:17-19</code> ) | Set/derived in the Risk Register                                                                                             | In the Risk Register module           |
| <b>Low</b>             | Lowest band; rendered emerald; API default when level is null/unrecognized ( <code>route.ts:7, 20</code> )            | Set/derived in the Risk Register                                                                                             | In the Risk Register module           |

Risk levels are **not editable** on this page; they are read-only and normalized for display only.

## Validation Rules

This page performs **no input validation** — it has no form and no Zod schema. The only data handling on the server is normalization, not validation:

- **Risk-level normalization** (`route.ts:6-21`): the raw `riskLevel` string is lowercased and mapped — `extreme` / `critical` → **Extreme**; `high` → **High**; `medium` / `moderate` → **Medium**; everything else (including null/empty) → **Low**.
- **Permission check**: `audit.risk-universe:view` is required; without it the API returns the standard authorization failure from `withAuth` and the page does not render data.
- **Tenant isolation**: both queries are filtered by `getTenantFilter(session)` so a user only sees their own tenant's departments and risks (`route.ts:27, 31, 37`).
- **No duplicate / approval checks** apply (nothing is created or approved here).

## Success Scenarios and Failure Scenarios

### Success scenarios:

- **Map renders with data** — the API returns `200` with departments and risks; the four summary cards show counts and the Risk Map draws root → departments → risk cards.

- **Empty universe** — there are no departments/risks to place; the page shows **No risks in the risk register yet** with the **Go to Risk Register** button. (Note: the empty state is driven by the rendered department array being empty.)
- **Departments without risks** — such departments still render as dashed, muted boxes labelled **No risks**.

#### Failure scenarios:

- **Not authorized** — a user lacking `audit.risk-universe:view` (e.g. the Auditor role) is blocked by `withAuth`; the page is not accessible to them.
- **API error / fetch fails** — if the response is not OK or the fetch throws, the page logs `Failed to fetch risk universe` to the console and leaves `data` as null. The component stops the loading spinner ( `finally` sets `loading=false` ). With null data the summary cards fall back to `0` and the map shows the empty state. There is **no on-screen error toast or banner** — the user simply sees zeros / the empty map. To resolve: confirm permissions, confirm departments/risks exist, and check server logs (the API returns `{ error: 'Failed to fetch risk universe' }` with HTTP 500 on server-side errors, `route.ts:88-93` ).

## System Behaviour

---

- **Read-only page.** No automatic record creation, no status updates, no DB writes occur from this page.
- **No notifications** are sent or received here.
- **No audit-trail logging.** Viewing the Risk Universe does not create an audit-trail entry (the GET handler does no logging; `audit.audit-trail` is a separate resource).
- **Tenant scoping is automatic** via `getTenantFilter(session)` on both queries.
- **Risk-level normalization is automatic** on the server (see Validation Rules).
- **Dynamic (user-data) translation:** department names and risk fields are passed through the translation hooks `useTranslatedData(..., { modelName: 'Department' })` and `useTranslatedData(..., { modelName: 'InternalAuditRisk' })` ( `page.tsx:77, 79` ). This only **reads** existing translations for the active language; it does not trigger new translations.
- **Static i18n:** all labels use the `t()` function and follow the app's English/Arabic/Latvian localization.
- **Ordering is fixed:** departments alphabetical, risks by `riskId`.

## Notes / Warnings / Tips

---

- **Tip:** Click any risk card (or use the empty-state button) to jump straight to the **Risk Register**, where risks are actually created and edited. This page is for visualization only.
  - **Note:** A risk only appears on the map if it has a `departmentId` that matches an existing department. Risks with no department still increase the **Total Risks** card but will not show as a branch — reconcile the **Total Risks** count against the per-level cards if numbers seem inconsistent.
  - **Note:** The page is **not listed in the Internal Audit sidebar navigation** ( `src/lib/navigation.ts` has no Risk Universe entry); it is reached via its route / the in-app links (e.g. from the Risk Register area). Confirm with your deployment how users are expected to navigate to it.
  - **Warning:** The Auditor role (internal `Auditee` ) does **not** have access; do not document this page in Auditor-facing guidance.
  - **Note:** There is no Export capability on this page.
-

# Risk Assessment

## Overview — Purpose, Business Objective

The **Risk Assessment** page is a dedicated workspace for scoring the Internal Audit risks that were captured in the Risk Register / Risk Identification. It presents every Internal Audit risk in a single table and lets an authorised user walk through a **5-step assessment wizard** per risk — Risk Context → Likelihood → Impact → Risk Rating → Summary — and persist the resulting scores and a calculated residual risk score.

The business objective is to turn raw risks into a comparable, rated set:

- capture a single **Likelihood** value (1–5),
- capture five **Impact** dimensions (Strategic, Financial, Compliance, Operational, IT / Data — each 1–5),
- capture a **Control Effectiveness** rating (1–5),
- compute a **Risk Score** / **Residual Score** and derive a **Risk Level** (Critical / High / Medium / Low),
- and stamp the risk's **Status** to `Assessed`.

Source for all behaviour described here: `src/app/(protected)/internal-audit/risk-assessment/page.tsx` and `src/app/api/internal-audit/risks/[id]/assess/route.ts`.

## Access — Roles and Permission

The page is gated client-side by the permission resource `audit.risk-register` (`page.tsx:56` — `usePermissions("audit.risk-register")`). It uses two checks:

- `canView` — controls whether the page renders at all. If the user lacks view, the page shows: *"You do not have permission to view this page."* (`page.tsx:406-414`).
- `canEdit` — controls whether the assessment action button is shown in each row. Without edit, the Action cell renders a dash (–) instead of a button (`page.tsx:530, 560-562`).

The save API also enforces edit: `PATCH /api/internal-audit/risks/[id]/assess` is wrapped with `{ resource: "audit.risk-register", action: "edit" }` (`assess/route.ts:95`).

For the three documented roles (`audit.risk-register` grants, from `permissions.ts`):

| Role (display) | Internal key              | View page | Run assessment (edit) | Source                                                                                                                                                                                                    |
|----------------|---------------------------|-----------|-----------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Audit Head     | <code>AuditHead</code>    | Yes       | Yes                   | <code>permissions.ts:438</code> (actions: <code>['*']</code> )                                                                                                                                            |
| Audit Manager  | <code>AuditManager</code> | Yes       | Yes                   | <code>permissions.ts:463</code> (actions: <code>['*']</code> )                                                                                                                                            |
| Auditor        | <code>Auditee</code>      | No        | No                    | <code>Auditee</code> has <b>no</b> <code>audit.risk-register</code> grant ( <code>permissions.ts:532-539</code> ); Risk Register is explicitly excluded for this role ( <code>permissions.ts:528</code> ) |

**Note:** The Auditor (internal `Auditee`) role is department-scoped to Fieldwork, CAPA, Reports and own Audit Trail only, and therefore cannot reach this page.

## Prerequisites

Before this page is useful:

- Internal Audit risks must already exist.** The table is populated from `GET /api/internal-audit/risks` (`page.tsx:115`). If no risks exist, the table shows *"No risks found."* (`page.tsx:570`). Risks are created in Risk Identification / Risk Register.
- Probability and Impact master data should be configured** in Internal Audit Settings, because the saved residual score is computed from the *mean* of the configured probability values and the *mean* of the configured impact values (see Workflow). These are loaded from `GET /api/internal-audit/probability` and `GET /api/internal-audit/impact` (`page.tsx:116-117`). If either list is empty, the corresponding mean is `0` and the calculated/saved score is `null` (`page.tsx:256-272, assess/route.ts:42-44`).
- Scoring ranges (optional)** configured in Settings allow the saved **Risk Level** to be derived from the configured `AuditScoringRange` rows; if none exist, the API falls back to fixed thresholds (see Status / Workflow).
- Categories and Departments** are loaded for display only (`GET /api/internal-audit/categories, GET /api/departments` — `page.tsx:118, 131`).

**How this page is reached:** It is **not** a direct item in the Internal Audit sidebar (no `risk-assessment` entry exists in `src/lib/navigation.ts`). The page supports a `riskId` query parameter (`/internal-audit/risk-assessment?riskId=...`) that auto-opens the assessment wizard for that risk on load (`page.tsx:57-58, 151-197`). The equivalent assessment workflow is also embedded directly inside the Risk Register page itself (which has its own in-page wizard). No in-product link that navigates to this standalone page was found in the searched source — treat the URL / `riskId` deep-link as the entry path. (*Not verified: which UI control, if any, links here.*)

**Screenshot:** *Insert screenshot here*

Visible areas of the page (`page.tsx:434-1031`):

- **Breadcrumb** (top): Home icon → **Internal Audit** → **Dashboard** → **Risk Assessment** (current). The first two links point to `/internal-audit/dashboard` ( `page.tsx:437-453` ).
- **Page title: Risk Assessment** ( `page.tsx:456` ).
- **Risk table** in a white rounded card, horizontally scrollable, with columns Risk ID, Risk Name, Department, Category, Risk Level, Status, Residual Score, Action ( `page.tsx:459-577` ).
- **Per-row action button** in the Action column: **Initiate Assessment** / **Resume** / **Re-assess** (plus an **In Progress** chip when a draft exists).
- **Risk Assessment wizard dialog** (modal) that opens when an action button is clicked — a 5-step stepper with header (risk ID + name), step content, and a footer with Cancel/Back, Next and Save Assessment buttons.

## Page Layout

### Header / breadcrumb / title

- Breadcrumb as above; the active crumb **Risk Assessment** is styled in the brand colour ( `page.tsx:452` ).
- `<h1>` page title **Risk Assessment** ( `page.tsx:456` ).

### Summary cards

None. The page has no summary/stat cards.

### Tabs / filters / search

None on the list page. There is **no** search box, **no** column filter, **no** status filter, and **no** pagination control on this page. All risks are rendered in one table.

### Loading state

While data or permissions load, the page shows a centred spinner with *"Loading risks..."* ( `page.tsx:417-431` ).

### Table

A single table (described under **Tables**).

### Dialog (assessment wizard)

A modal **Risk Assessment** dialog (max width 780px) containing:

- **Header:** title **Risk Assessment**, a subtitle line showing `{riskId} - {riskName}`, and a 5-circle step progress indicator labelled **Risk Context**, **Likelihood**, **Impact**, **Risk Rating**, **Summary** ( `page.tsx:621-670` ).
- **Step body** (scrollable) — content differs per step (see Step-by-Step).
- **Footer:** left side shows *"Step {n} of 5"*; right side shows **Cancel** (step 1) / **Back** (steps 2–5), then **Next** (steps 1–4) or **Save Assessment** (step 5) ( `page.tsx:977-1025` ).

### Footer

No page-level footer outside the dialog.

## Field Reference

These are the inputs collected by the wizard ( `AssessmentRow`, `page.tsx:40-48` ). All are entered via radio buttons / pill buttons on a 1–5 scale; none are free-text. "Required" reflects actual code behaviour (the wizard does **not** block navigation or saving on missing values — see Validation).

| Field                                                               | Required          | Type                 | Default                                                                                 | Validation                                                                      | Editable     | Description                                                                                                                                                    |
|---------------------------------------------------------------------|-------------------|----------------------|-----------------------------------------------------------------------------------------|---------------------------------------------------------------------------------|--------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Likelihood<br>( <code>assessmentLikelihood</code> )                 | No (not enforced) | Integer 1–5 (radio)  | Pre-filled from the risk's existing value, else empty ( <code>page.tsx:184-192</code> ) | None enforced; value rounded to int on save ( <code>assess/route.ts:29</code> ) | Yes (step 2) | Probability the risk will occur. Step 2 prompt: <i>"Select the probability that this risk will occur based on historical data and current controls."</i>       |
| Strategic Impact<br>( <code>strategicImpact</code> )                | No (not enforced) | Integer 1–5 (pill)   | From existing value, else empty                                                         | Rounded to int on save ( <code>assess/route.ts:24</code> )                      | Yes (step 3) | Impact dimension.                                                                                                                                              |
| Financial Impact<br>( <code>financialImpact</code> )                | No (not enforced) | Integer 1–5 (pill)   | From existing value, else empty                                                         | Rounded to int on save                                                          | Yes (step 3) | Impact dimension.                                                                                                                                              |
| Compliance Risk ( <code>complianceRisk</code> )                     | No (not enforced) | Integer 1–5 (pill)   | From existing value, else empty                                                         | Rounded to int on save                                                          | Yes (step 3) | Impact dimension.                                                                                                                                              |
| Operational Risk<br>( <code>operationalRisk</code> )                | No (not enforced) | Integer 1–5 (pill)   | From existing value, else empty                                                         | Rounded to int on save                                                          | Yes (step 3) | Impact dimension.                                                                                                                                              |
| IT / Data Risk ( <code>itDataRisk</code> )                          | No (not enforced) | Integer 1–5 (pill)   | From existing value, else empty                                                         | Rounded to int on save                                                          | Yes (step 3) | Impact dimension.                                                                                                                                              |
| Control Effectiveness<br>( <code>controlEffectivenessScore</code> ) | No (not enforced) | Integer 1–5 (button) | From existing value, else empty                                                         | Rounded to int on save                                                          | Yes (step 4) | 1 = Very Ineffective, 2 = Ineffective, 3 = Moderately Effective, 4 = Effective, 5 = Highly Effective ( <code>page.tsx:274-280</code> , <code>842-844</code> ). |

Read-only context shown in Step 1 (Risk Context), not edited here: Category, Type, Owner (always shows `-`), Department, Risk Sources ( `riskDrivers` , falling back to `riskDescription` ) ( `page.tsx:690-731` ).

## Tables

The risk list table ( `page.tsx:461-575` ).

**Columns** (header labels exactly):

| Column         | Content / source                                                                                                                                                   |
|----------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Risk ID        | <code>risk.riskId</code> shown as a mono badge ( <code>page.tsx:465</code> , <code>496-500</code> )                                                                |
| Risk Name      | <code>risk.riskName</code> , truncated ( <code>page.tsx:467</code> , <code>501-503</code> )                                                                        |
| Department     | Translated department name, else <code>risk.department?.name</code> , else <code>-</code> ( <code>page.tsx:471</code> , <code>504-506</code> )                     |
| Category       | Translated category name, else <code>risk.category?.name</code> , else <code>-</code> ( <code>page.tsx:473</code> , <code>507-509</code> )                         |
| Risk Level     | Coloured badge (Critical/High/Medium/Low; otherwise grey) ( <code>page.tsx:475</code> , <code>388-403</code> , <code>510-512</code> )                              |
| Status         | Assessed (green) or the raw <code>assessmentStatus</code> , defaulting to <code>Not Assessed</code> (grey) ( <code>page.tsx:479</code> , <code>513-523</code> )    |
| Residual Score | <code>assessmentResidualScore</code> to 2 decimals when status is <code>Assessed</code> , else <code>-</code> ( <code>page.tsx:482</code> , <code>524-528</code> ) |
| Action         | Assessment button (see Buttons & Actions), or <code>-</code> if no edit permission ( <code>page.tsx:485</code> , <code>529-563</code> )                            |

- **Sorting:** none implemented (no sort handlers / clickable headers).
- **Searching:** none.
- **Filtering:** none.
- **Pagination:** none — all rows render.
- **Row actions:** the single Action-cell button per row (no row context menu, no bulk actions).
- **Empty state:** *"No risks found."* across all 8 columns ( `page.tsx:567-572` ).

## Buttons & Actions

| Control                                                                        | Permission               | Visible To                | Action                                                                                                                           | API                                         | Success Msg                                                                                    | Failure Msg                                                                                               | Audit Trail                                                                                                           | Notification |
|--------------------------------------------------------------------------------|--------------------------|---------------------------|----------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------|------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------|--------------|
| <b>Initiate Assessment</b><br>(row, when status ≠ Assessed and no saved draft) | audit.risk-register:edit | Audit Head, Audit Manager | Opens the wizard at step 1 with blank/existing values<br>( page.tsx:537-557 , 290-334 )                                          | None (opens dialog only)                    | —                                                                                              | —                                                                                                         | None                                                                                                                  | None         |
| <b>Resume</b><br>(row, when a localStorage draft exists and not yet Assessed)  | audit.risk-register:edit | Audit Head, Audit Manager | Opens the wizard restored to the saved step/values from localStorage key ia-assess-{riskId}<br>( page.tsx:291-331 , 554-555 )    | None                                        | —                                                                                              | —                                                                                                         | None                                                                                                                  | None         |
| <b>Re-assess</b><br>(row, when status = Assessed)                              | audit.risk-register:edit | Audit Head, Audit Manager | Opens the wizard to re-score an already-assessed risk<br>( page.tsx:547-551 )                                                    | None                                        | —                                                                                              | —                                                                                                         | None                                                                                                                  | None         |
| <b>Next</b> (dialog footer, steps 1–4)                                         | audit.risk-register:edit | Audit Head, Audit Manager | Advances one step and saves draft to localStorage<br>( page.tsx:997-1007 )                                                       | None                                        | —                                                                                              | —                                                                                                         | None                                                                                                                  | None         |
| <b>Back</b> (dialog footer, steps 2–5)                                         | audit.risk-register:edit | Audit Head, Audit Manager | Goes back one step and saves draft<br>( page.tsx:985-989 )                                                                       | None                                        | —                                                                                              | —                                                                                                         | None                                                                                                                  | None         |
| <b>Cancel</b> (dialog footer, step 1)                                          | audit.risk-register:edit | Audit Head, Audit Manager | Closes the dialog (draft remains in localStorage)<br>( page.tsx:990-992 )                                                        | None                                        | —                                                                                              | —                                                                                                         | None                                                                                                                  | None         |
| <b>Save Assessment</b><br>(dialog footer, step 5)                              | audit.risk-register:edit | Audit Head, Audit Manager | Persists scores, sets status to Assessed, clears the local draft, refreshes the table, closes the dialog<br>( page.tsx:336-385 ) | PATCH /api/internal-audit/risks/{id}/assess | Toast title <b>Success</b> , description <b>Risk assessed successfully</b><br>( page.tsx:361 ) | Toast title <b>Error</b> , description <b>Failed to save assessment</b><br>( page.tsx:371-374 , 378-382 ) | <b>None</b> — the assess route does not write any audit-log record ( assess/route.ts ) — <i>Not verified to exist</i> | None         |

While saving, the Save button shows a spinner with **Saving...** and is disabled ( page.tsx:1012-1021 ).

## Step-by-Step Instructions

### Task A — Assess a not-yet-assessed risk

1. Open the Risk Assessment page (e.g. via /internal-audit/risk-assessment, or via a deep link with ?riskId=...).
2. Locate the risk row; its **Status** shows **Not Assessed**.
3. Click **Initiate Assessment** in the Action column. The wizard opens at **Step 1 – Risk Context**.
4. **Step 1 (Risk Context)**: review the read-only context (Risk ID, Risk Name, Category, Type, Owner, Department, Risk Sources). Click **Next**.
5. **Step 2 (Likelihood)**: select one radio option **1–5**. Click **Next**.
6. **Step 3 (Impact)**: for each of **Strategic Impact**, **Financial Impact**, **Compliance Risk**, **Operational Risk**, **IT / Data Risk**, click a value **1–5**. Click **Next**.
7. **Step 4 (Risk Rating)**: click a **Control Effectiveness** value **1–5**. The panel shows **Mean Probability**, **Mean Impact**, **Control Effectiveness**, **Calculated Risk Score**, and **Risk Rating** (derived from settings means). Click **Next**.
8. **Step 5 (Summary)**: review Likelihood, each impact dimension, **Mean Impact**, **Control Effectiveness**, **Risk Score**, and **Risk Rating**.
9. Click **Save Assessment**. On success a **Risk assessed successfully** toast appears, the dialog closes, the row Status changes to **Assessed**, and the **Residual Score** populates.

### Task B — Resume an in-progress assessment

1. Rows with an unsaved draft show an amber **In Progress** chip and a **Resume** button.
2. Click **Resume**; the wizard reopens at the saved step with your saved values.
3. Continue and click **Save Assessment** as in Task A.

### Task C — Re-assess an already-assessed risk

1. Rows with Status **Assessed** show a **Re-assess** button.
2. Click **Re-assess**; the wizard opens pre-filled with the existing scores.
3. Change values as needed and click **Save Assessment**; the row is updated.

## Navigation within the wizard

- Use **Next** / **Back** to move between steps; use **Cancel** (step 1) or close the dialog to exit. Progress is saved to the browser at each step and on each field change ( page.tsx:221-225 , 282-288 ).

## Workflow

| Stage     | Current Status                     | User Action                                                             | Validation                                             | API                                                          | DB Update                                                                                                                                                                                                                                 | Audit Trail | Notification | Next Status | Next User                                                 |
|-----------|------------------------------------|-------------------------------------------------------------------------|--------------------------------------------------------|--------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------|--------------|-------------|-----------------------------------------------------------|
| Assess    | Not Assessed (or any non-Assessed) | Audit Head / Manager completes wizard and clicks <b>Save Assessment</b> | None enforced (missing values allowed; see Validation) | PATCH /api/internal-audit/risks/{id}/assess ( page.tsx:342 ) | Sets strategicImpact , financialImpact , complianceRisk , operationalRisk , itDataRisk , assessmentLikelihood , controlEffectivenessScore , assessmentResidualScore , assessmentStatus = "Assessed" , riskLevel ( assess/route.ts:73-87 ) | None        | None         | Assessed    | Same/other Audit Head / Manager (for downstream planning) |
| Re-assess | Assessed                           | <b>Re-assess</b> → re-save                                              | None enforced                                          | Same endpoint                                                | Same fields overwritten; status stays Assessed                                                                                                                                                                                            | None        | None         | Assessed    | —                                                         |

**Score calculation (saved value):** The frontend computes the saved residual score from the **settings means**, not from the per-risk impact entries:  $\text{meanProbability}(\text{settings}) \times \text{meanImpact}(\text{settings}) \times ((6 - \text{controlEffectiveness})/5)$ , rounded to 2 decimals ( page.tsx:266-272 , 340 , 355 ). It is sent as `assessmentResidualScore`. The API prefers this provided value; if it is absent it recomputes using `assessmentLikelihood` as the mean probability and the mean of the five entered impacts ( assess/route.ts:34-45 ). If any required factor is `0` /empty, the saved score is `null`.

**Risk Level derivation (server):** From the saved `assessmentResidualScore`, the API matches configured `AuditScoringRange` rows (ordered by `lowValue desc`); the first range where `score >= lowValue` and (`highValue` is null or `score <= highValue`) supplies the label. If no ranges exist, it falls back to:  $\geq 15 \rightarrow$  Critical,  $\geq 10 \rightarrow$  High,  $\geq 5 \rightarrow$  Medium, else Low ( assess/route.ts:47-71 ).

**Note on the dialog's displayed rating vs. saved value:** Steps 4 and 5 display ratings using a fixed scale ( $\geq 15$  Critical,  $\geq 10$  High,  $\geq 5$  Medium, else Low — page.tsx:248-254 ). The **Risk Score** shown on the Summary step (step 5) is computed from the *entered* impact values ( $\text{meanProbability}=\text{likelihood} \times \text{meanImpact}(\text{entered}) \times \text{controlEffectiveness factor}$ , page.tsx:240-246 ), whereas the **saved** Residual Score uses the settings means (step 4 "Calculated Risk Score"). These two displayed numbers can differ; the saved value is the step-4 settings-based one.

## Status Reference

The `assessmentStatus` field has these implemented values:

| Status       | Meaning                                                                                                                                | How reached                                                           | Who can change                                                                      | Next status        |
|--------------|----------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------|-------------------------------------------------------------------------------------|--------------------|
| Not Assessed | No assessment saved yet. Displayed as the default when <code>assessmentStatus</code> is empty ( page.tsx:521 ). Shown as a grey badge. | Initial state of a risk (set elsewhere on creation).                  | Audit Head / Audit Manager (by saving an assessment).                               | Assessed           |
| Assessed     | Scores saved; Residual Score and Risk Level populated. Green badge.                                                                    | <b>Save Assessment</b> completes successfully ( assess/route.ts:84 ). | Audit Head / Audit Manager (via <b>Re-assess</b> → save, which keeps it Assessed ). | Assessed (re-save) |

There is no client-side "in progress" *status* — **In Progress** is only a UI chip driven by a `localStorage` draft ( page.tsx:532-536 ), not a stored status.

**Risk Level values** (separate from status): **Critical, High, Medium, Low** (and the grey/ – fallback when unset) ( page.tsx:389-394 , assess/route.ts:66-69 ).

## Validation Rules

- **No mandatory-field enforcement.** The wizard lets you click **Next** and **Save Assessment** even with missing Likelihood, Impact, or Control Effectiveness values — there is no blocking validation in the page ( page.tsx:336-385 , 997-1023 ).
- **Numeric coercion:** On save, each value is parsed ( `parseInt` ) on the client ( page.tsx:346-354 ) and rounded to an integer on the server ( `Math.round(Number(...))` , assess/route.ts:24-30 ). Empty values become `null`.
- **Score is null when incomplete:** If `meanProbability`, `meanImpact`, or control effectiveness is `0` /missing, the calculated/saved score is `null` ( page.tsx:270-271 , assess/route.ts:42-44 ).
- **Tenant / permission checks (server):** The risk must exist (else 404 Risk not found ) and must belong to the caller's tenant ( `validateTenantAccess` , else 403 Access denied ) ( assess/route.ts:16-22 ). The endpoint requires `audit.risk-register:edit` ( assess/route.ts:95 ).
- **No duplicate check** applies (assessment overwrites existing scores).

## Success Scenarios and Failure Scenarios

### Success

- Save returns `200` with the updated risk → toast **Success / Risk assessed successfully**, the local draft ( `ia-assess-{riskId}` ) is removed, the table is re-fetched, the dialog closes, the row's **In Progress** chip is cleared, and Status shows **Assessed** with a populated **Residual Score** ( `page.tsx:358-369` ).

## Failures

| Failure                            | Why it happens                                                             | What the user sees                                                                                                  | How to resolve                                                                    |
|------------------------------------|----------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------|
| Save fails (non-OK response)       | Server returns an error status (e.g. risk not found / access denied / 500) | Toast <b>Error / Failed to save assessment</b> ( <code>page.tsx:371-375</code> ); dialog stays open; draft retained | Verify the risk exists and you have edit permission; retry.                       |
| Network/exception during save      | <code>fetch</code> throws                                                  | Same <b>Error / Failed to save assessment</b> toast ( <code>page.tsx:377-383</code> )                               | Check connectivity and retry.                                                     |
| <b>403 Access denied</b> (server)  | Risk belongs to another tenant or insufficient permission                  | Surfaced as the generic <b>Failed to save assessment</b> toast                                                      | Use an account with <code>audit.risk-register:edit</code> for the correct tenant. |
| <b>404 Risk not found</b> (server) | The <code>id</code> no longer exists                                       | Generic <b>Failed to save assessment</b> toast                                                                      | Reload the page so the table reflects current risks.                              |
| No view permission                 | <code>canView</code> false                                                 | Page body: <i>"You do not have permission to view this page."</i> ( <code>page.tsx:410</code> )                     | Request <code>audit.risk-register:view</code> .                                   |
| No edit permission                 | <code>canEdit</code> false                                                 | Action cells show <code>-</code> ; no assessment can be started ( <code>page.tsx:560-562</code> )                   | Request <code>audit.risk-register:edit</code> .                                   |

## System Behaviour

- **Automatic record creation:** None on this page beyond updating the existing risk row. (Note: the scoring-config endpoint auto-creates a default config when none exists, but that is the Settings API, not this page — `scoring-config/route.ts:20-30`.)
- **Auto status update:** Saving sets `assessmentStatus` = "Assessed" automatically ( `assess/route.ts:84` ).
- **Auto risk-level update:** `riskLevel` is recomputed and saved on every assess ( `assess/route.ts:47-87` ).
- **Draft persistence (browser):** In-progress wizard state is stored per risk in `localStorage` under `ia-assess-{riskId}` on each step change and field edit, and removed on successful save ( `page.tsx:221-225` , `359-360` ). This drives the **In Progress** chip and the **Resume** button. Drafts are per-browser and not stored server-side.
- **Auto-open via query param:** Loading the page with `?riskId=...` auto-opens the wizard for that risk once ( `page.tsx:151-197` ).
- **Audit-trail logging:** The assess endpoint does **not** write an audit-log entry — *Not verified to exist*.
- **Notifications:** None are emitted by this page or the assess endpoint.
- **Read-only behaviour:** Users without edit permission can view the list but cannot open the wizard (Action shows `-`).
- **Background processing:** None.

## Notes / Warnings / Tips

- **Two different score numbers can appear in the wizard.** Step 4 shows the **Calculated Risk Score** computed from the configured *settings* means; Step 5 shows a **Risk Score** computed from the *entered* impact values. The value **saved** as the Residual Score is the **settings-based** one (Step 4). Expect the saved Residual Score to reflect configured Probability/Impact means rather than the individual impact ratings entered in Step 3.
- **Configure Probability and Impact master data first.** If those Settings lists are empty, their means are `0` , so the saved Residual Score will be `null` and the Risk Level falls back to the existing value or the default thresholds.
- **Configure Scoring Ranges** in Settings to control how Residual Score maps to Risk Level; otherwise the fixed thresholds ( $\geq 15$  /  $\geq 10$  /  $\geq 5$ ) apply.
- **Drafts are browser-local.** A **Resume** option only appears on the same browser where the draft was created; clearing site data loses in-progress work.
- **No required-field guardrails.** Saving with missing values is allowed and may produce a `null` score — double-check Likelihood, all five Impact dimensions, and Control Effectiveness before saving.
- **This page is not in the sidebar.** Reach it via its URL / a `riskId` deep link; the same assessment can also be performed inside the Risk Register page.



# Strategic Plan

## Overview — Purpose, Business Objective

The **Strategic Audit Plan** is the multi-year, risk-based audit strategy for the organization. The page header describes it as *"Multi-year, risk-based audit strategy"* ( `page.tsx:441` ).

Its purpose is to take risks that have been fully assessed in the Internal Audit risk assessment process and schedule them as planned audits across a 3-, 4-, or 5-year horizon, with the highest-risk audits placed in the earliest years. Each strategic plan year automatically seeds an Operational (Annual) Plan for that year ( `add-risk/route.ts:145-209` ).

The plan supports a manual sign-off workflow: the approving authority signs the plan outside the system, and uploading the signed copy records that approval and marks the plan **Approved**. Once approved, the plan and its audits are locked from further edits ( `[id]/route.ts:54-59` , `items/[itemId]/route.ts:22-24` ).

## Access — Roles and Required Permissions

All actions on this page are governed by the `audit.strategic-plan` resource. The permission ACTIONS available in this system are exactly: `view` , `create` , `edit` , `delete` , `approve` (there is no `export` action).

| Role (display) | Internal key                                                                                                                 | strategic-plan permission                                                                    | What they can do here                                                                                                 |
|----------------|------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------|
| Audit Head     | <code>AuditHead</code>                                                                                                       | <code>['*']</code> — view, create, edit, delete, approve ( <code>permissions.ts:441</code> ) | Full access: add audits to the plan, edit/remove audits, approve (upload signed copy), revoke approval, delete a plan |
| Audit Manager  | <code>AuditManager</code>                                                                                                    | <code>['view']</code> only ( <code>permissions.ts:466</code> )                               | View only — cannot add, edit, delete, or approve                                                                      |
| Auditor        | <code>Auditee</code> (displayed as "Auditor" via <code>ROLE_DISPLAY_OVERRIDES</code> , <code>permissions.ts:319-321</code> ) | <code>['view']</code> only ( <code>permissions.ts:511</code> )                               | View only                                                                                                             |

- **Audit Head is the only documented role with `create` , `edit` , `delete` , and `approve` on `audit.strategic-plan` .** Audit Manager and Auditor are view-only.
- Page-level visibility of action controls is driven by the client hook `usePermissions("audit.strategic-plan")` , which exposes `canCreate` , `canDelete` , and `canApprove` ( `page.tsx:129` ).
- The route is reached via the navigation item **Strategic Plan** under the Internal Audit section, permission `audit.strategic-plan:view` ( `navigation.ts:307` ). Path: `/internal-audit/strategic-plan` .

## Prerequisites

Before this page is useful, the following must already exist:

- **Assessed risks.** The Risk Assessment table only lists Internal Audit risks whose `assessmentStatus` equals `"Assessed"` (set by the risk assessment wizard) and that are **not already added to a strategic plan** ( `assessed-risks/route.ts:21-42` ). Legacy inherent/residual scores alone do **not** make a risk eligible.
- **Audit Types (optional).** The "Add Plan" dialog's Audit Type dropdown is populated from `/api/internal-audit/audit-types` (Audit Settings). If none exist the dropdown shows *"No audit types found"* ( `page.tsx:627-630` ); audit type is optional.
- A **customer account** must be associated with the user; the create/add-risk APIs reject the request with *"No customer account associated with this user"* / *"No customer account associated"* otherwise ( `route.ts:66` , `add-risk/route.ts:36-37` ).

**Screenshot:** *Insert screenshot here*

The page renders the following visible areas (top to bottom):

1. **Breadcrumb** — `Internal Audit > Strategic Plan` ( `page.tsx:424-431` ).
2. **Page header** — calendar icon + title **"Strategic Audit Plan"** and the subtitle **"Multi-year, risk-based audit strategy"** ( `page.tsx:436-442` ). Note: there is no "Create" or "New Plan" button in this header.
3. **Risk Assessment section** — heading **"Risk Assessment"**, a **Risk Level** filter dropdown, and a table of assessed risks each with an **Add Plan** button ( `page.tsx:446-515` ).
4. **Strategic Plan section** — heading **"Strategic Plan"** and a flat table of all planned audits across all plans, with row edit/remove actions ( `page.tsx:517-590` ).
5. **Dialogs** (open on demand) — Add Plan, Edit Audit, Remove Audit confirm. (See *System Behaviour* for dialogs present in code but with no on-page trigger.)

## Page Layout

### Breadcrumb

`Internal Audit > Strategic Plan` ( `page.tsx:424-431` ).

### Header

- Title: **Strategic Audit Plan** with a `CalendarRange` icon.
- Subtitle: **Multi-year, risk-based audit strategy**.

### Section 1 — Risk Assessment

- Section heading: **Risk Assessment**.
- Filter control: label **Risk Level** + a dropdown with options **All Levels, Extreme, High, Medium, Low** ( `page.tsx:457-461` ). This filters the table client-side by risk level.
- Table columns: **Risk ID, Risk, Department, Risk Level, Actions** ( `page.tsx:471-475` ).
- Each row's Actions cell shows an **Add Plan** button (only when `canCreate` ).
- Empty states: "*No assessed risks available to plan*" (no rows at all) or "*No risks match the selected risk level.*" (filter excludes all) ( `page.tsx:482-484` ).

Section 2 — Strategic Plan

- Section heading: **Strategic Plan**.
- While loading, a spinner is shown ( `page.tsx:520-523` ).
- Empty state: "*No audits yet. Use Add Plan on an assessed risk above.*" ( `page.tsx:530` ).
- The table is **flat** — it merges every plan's items into one list (no per-plan grouping header). Columns: **#, Audit, Type, Duration, Actions** ( `page.tsx:540-544` ). Duration is rendered as `{durationYears} Years` .
- Row Actions (only when the parent plan's status is **not** "Approved", `page.tsx:557` ): a **Pencil** edit icon (when `canCreate` ) and a **Trash** remove icon (when `canDelete` ). Approved-plan rows show no actions.

Dialogs

- **Add Plan** ( `DialogTitle` = "Add Plan", `page.tsx:593-689` ).
- **Create Strategic Plan** ( `DialogTitle` = "Create Strategic Plan", `page.tsx:692-746` ) — present in code; no on-page button opens it (see *System Behaviour*).
- **View / Approval** dialog ( `page.tsx:749-940` ) — present in code; no on-page control opens it.
- **Edit Audit** ( `DialogTitle` = "Edit Audit", `page.tsx:943-982` ).
- **Remove Audit** confirm ( `AlertDialogTitle` = "Remove Audit", `page.tsx:985-1001` ).
- **Delete Strategic Plan** confirm ( `AlertDialogTitle` = "Delete Strategic Plan", `page.tsx:1004-1019` ) — present in code; no on-page control opens it.

Footer

No page footer is present.

Field Reference

Add Plan dialog ( `page.tsx:593-689` )

Read-only risk context shown at top: **Risk ID, Risk Level, Risk, Department** ( `page.tsx:600-618` ).

| Field                 | Required          | Type                         | Default                      | Validation                                                                                                 | Editable | Description                                                                                                       |
|-----------------------|-------------------|------------------------------|------------------------------|------------------------------------------------------------------------------------------------------------|----------|-------------------------------------------------------------------------------------------------------------------|
| Audit Type            | No                | Select (from Audit Settings) | empty (placeholder "Select") | Optional; falls back to the risk's linked audit type if blank ( <code>add-risk/route.ts:30-31,113</code> ) | Yes      | Audit type for the planned audit                                                                                  |
| Duration              | Yes (preselected) | Select: 3/4/5 Years          | <b>3 Years</b>               | Server accepts only 3, 4, 5; else defaults to 3 ( <code>add-risk/route.ts:25-27</code> )                   | Yes      | Determines which plan (by duration) the audit is routed to; a new plan of that duration is created if none exists |
| Reason for Scheduling | No                | Textarea (2 rows)            | empty                        | Trimmed; stored as null if blank ( <code>add-risk/route.ts:114-117</code> )                                | Yes      | "Why is this audit being scheduled?"                                                                              |
| Notes                 | No                | Textarea (2 rows)            | empty                        | Trimmed; stored as null if blank ( <code>add-risk/route.ts:118</code> )                                    | Yes      | Free-text notes                                                                                                   |

Edit Audit dialog ( `page.tsx:943-982` )

| Field       | Required | Type                   | Default       | Validation                                                                                   | Editable | Description                                                |
|-------------|----------|------------------------|---------------|----------------------------------------------------------------------------------------------|----------|------------------------------------------------------------|
| Audit Title | No       | Text input             | current title | If sent empty/blank, server keeps existing title ( <code>items/[itemId]/route.ts:38</code> ) | Yes      | The planned audit's title                                  |
| Audit Type  | No       | Text input (free text) | current type  | Trimmed; null if blank ( <code>items/[itemId]/route.ts:39</code> )                           | Yes      | Audit type (free text here, unlike the Select in Add Plan) |
| Notes       | No       | Textarea (2 rows)      | current notes | Trimmed; null if blank ( <code>items/[itemId]/route.ts:40</code> )                           | Yes      | Free-text notes                                            |

Note: the Edit Audit dialog form also carries a `year` value ( `editItemForm.year` , `page.tsx:207,263` ), and the PATCH API supports clamping `year` to the plan range ( `items/[itemId]/route.ts:41-45` ), but the Edit Audit dialog does **not** render a Year input.

Create Strategic Plan dialog (in code; no on-page trigger) ( `page.tsx:692-746` )

| Field       | Required          | Type                | Default               | Validation                                                         | Editable | Description          |
|-------------|-------------------|---------------------|-----------------------|--------------------------------------------------------------------|----------|----------------------|
| Duration    | Yes (preselected) | Select: 3/4/5 Years | <b>3 Years</b>        | Server accepts only 3/4/5, else 3 ( <code>route.ts:73-75</code> )  | Yes      | Plan length in years |
| Start Year  | No                | Number input        | current calendar year | If blank, server uses current year ( <code>route.ts:76-78</code> ) | Yes      | First year covered   |
| Description | No                | Textarea (2 rows)   | empty                 | None                                                               | Yes      | Plan description     |

The Plan Title is **not** a field; on submit the client auto-derives it as `"{durationYears}-Year Internal Audit Strategy"` ( `page.tsx:313` ). `generateFromRisk` is hard-coded to `true` in form state ( `page.tsx:143` ).

**Approval section (in View dialog; no on-page trigger)** ( `page.tsx:896-913` )

| Field       | Required | Type       | Default                              | Validation                                                                                                                                  | Editable | Description                                                             |
|-------------|----------|------------|--------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------|----------|-------------------------------------------------------------------------|
| Approved By | No       | Text input | existing <code>approvedByName</code> | Sent as-is; stored (null if empty) ( <code>approve/route.ts:29</code> )                                                                     | Yes      | Name of approving authority (placeholder "Name of approving authority") |
| Signed Copy | Yes      | File input | none                                 | Client blocks submit if no file (toast); API returns 400 if no file ( <code>page.tsx:361-364</code> , <code>approve/route.ts:31-33</code> ) | Yes      | The signed document to upload                                           |

**Tables**

**Risk Assessment table**

- **Columns:** Risk ID, Risk, Department, Risk Level, Actions.
- **Source:** `GET /api/internal-audit/strategic-plans/assessed-risks` — risks with `assessmentStatus = "Assessed"` not already in any plan, ordered by `assessmentResidualScore desc` , then `residualScore desc` ( `assessed-risks/route.ts:41` ).
- **Filtering:** the **Risk Level** dropdown filters client-side by `riskLevel1` (All / Extreme / High / Medium / Low) ( `page.tsx:174-179` ).
- **Searching / sorting / pagination:** none implemented.
- **Row action:** **Add Plan** (visible only when `canCreate` ).
- **Bulk actions:** none.

**Strategic Plan table**

- **Columns:** # (sequential index), Audit (item title), Type ( `auditType` or "—"), Duration ( `{plan.durationYears} Years` ), Actions.
- **Source:** all plans from `GET /api/internal-audit/strategic-plans` , flattened into one list of items across plans ( `page.tsx:526` ).
- **Row actions:** Pencil (edit, `canCreate` ) and Trash (remove, `canDelete` ), shown only when the parent plan status is not "Approved".
- **Searching / sorting / filtering / pagination:** none implemented on this table.
- **Bulk actions:** none.

**Buttons & Actions**

"Notification" — no in-app or email notification code exists in any of these routes, so all are "None". "Audit Trail" — none of these routes write an explicit audit-log entry; marked "Not verified".

| Control                               | Permission                      | Visible To                         | Action                                                                                                      | API                                                                    | Success Msg               | Failure Msg                       | Audit Trail  | Notification |
|---------------------------------------|---------------------------------|------------------------------------|-------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------|---------------------------|-----------------------------------|--------------|--------------|
| <b>Add Plan</b> (Risk Assessment row) | <code>canCreate</code> (create) | Audit Head                         | Opens Add Plan dialog                                                                                       | —                                                                      | —                         | —                                 | —            | None         |
| <b>Save</b> (Add Plan dialog)         | <code>create</code>             | Audit Head                         | Adds risk to a plan of the chosen duration (creates plan if needed), re-ranks, auto-syncs operational plans | <code>POST /api/internal-audit/strategic-plans/add-risk</code>         | "Added to strategic plan" | "Failed to add to strategic plan" | Not verified | None         |
| <b>Cancel</b> (Add Plan dialog)       | —                               | Audit Head                         | Closes dialog                                                                                               | —                                                                      | —                         | —                                 | —            | None         |
| <b>Pencil / Edit</b> (plan row)       | <code>canCreate</code> (create) | Audit Head                         | Opens Edit Audit dialog                                                                                     | —                                                                      | —                         | —                                 | —            | None         |
| <b>Save</b> (Edit Audit dialog)       | <code>edit</code>               | Audit Head                         | Updates the plan item (title/type/notes/year)                                                               | <code>PATCH /api/internal-audit/strategic-plans/items/{itemId}</code>  | "Audit updated"           | "Failed to update audit"          | Not verified | None         |
| <b>Trash / Remove</b> (plan row)      | <code>canDelete</code> (delete) | Audit Head                         | Opens Remove Audit confirm                                                                                  | —                                                                      | —                         | —                                 | —            | None         |
| <b>Remove</b> (Remove Audit confirm)  | <code>delete</code>             | Audit Head                         | Deletes the plan item                                                                                       | <code>DELETE /api/internal-audit/strategic-plans/items/{itemId}</code> | "Audit removed from plan" | "Failed to remove audit"          | Not verified | None         |
| <b>Risk Level</b> filter              | <code>view</code>               | Audit Head, Audit Manager, Auditor | Client-side filter of Risk Assessment table                                                                 | —                                                                      | —                         | —                                 | —            | None         |

The following controls exist in the component but have **no on-page trigger** that opens their dialogs in the current render (see *System Behaviour*). They are listed for completeness:

| Control                                         | Permission           | Action                                                                | API                                                      | Success Msg               | Failure Msg                       |
|-------------------------------------------------|----------------------|-----------------------------------------------------------------------|----------------------------------------------------------|---------------------------|-----------------------------------|
| <b>Create</b> (Create Strategic Plan dialog)    | create               | Creates a plan, auto-generates audits from the risk register          | POST /api/internal-audit/strategic-plans                 | "Strategic plan created"  | "Failed to create strategic plan" |
| <b>Print</b> (View dialog)                      | view                 | window.print()                                                        | —                                                        | —                         | —                                 |
| <b>Signed Copy</b> download (View dialog)       | view                 | Downloads the signed copy (shown only if hasSignedCopy )              | GET /api/internal-audit/strategic-plans/{id}/signed-copy | —                         | —                                 |
| <b>Open Annual Plan</b> (View dialog, per year) | view                 | Navigates to /internal-audit/operational-plan?planId={id}&year={year} | —                                                        | —                         | —                                 |
| <b>Upload &amp; Approve</b> (View dialog)       | canApprove (approve) | Uploads signed copy, sets status Approved                             | POST /api/internal-audit/strategic-plans/{id}/approve    | "Strategic plan approved" | "Failed to approve plan"          |
| <b>Revoke Approval</b> (View dialog)            | canApprove (approve) | Clears signed copy, sets status back to Draft                         | DELETE /api/internal-audit/strategic-plans/{id}/approve  | "Approval revoked"        | "Failed to revoke approval"       |
| <b>Delete</b> (Delete Strategic Plan confirm)   | delete               | Deletes the plan (items cascade)                                      | DELETE /api/internal-audit/strategic-plans/{id}          | "Strategic plan deleted"  | "Failed to delete strategic plan" |

## Step-by-Step Instructions

### Add an assessed risk to the strategic plan

1. Open **Internal Audit > Strategic Plan**.
2. In the **Risk Assessment** section, optionally use the **Risk Level** dropdown to filter (All Levels / Extreme / High / Medium / Low).
3. On the target risk row, click **Add Plan** (Audit Head only).
4. In the **Add Plan** dialog, review the read-only risk context (Risk ID, Risk Level, Risk, Department).
5. Optionally choose an **Audit Type** from the dropdown.
6. Choose a **Duration** (3, 4, or 5 Years). The note explains: *"The audit is added to the plan of this duration (a new plan is created if needed)."*
7. Optionally enter **Reason for Scheduling** and **Notes**.
8. Click **Save**. On success a toast shows **"Added to strategic plan"**, the dialog closes, and both tables refresh. The risk leaves the Risk Assessment list and the audit appears in the Strategic Plan table.

### Edit a planned audit

1. In the **Strategic Plan** table, on a non-approved plan's row, click the **Pencil** icon (Audit Head only).
2. In the **Edit Audit** dialog, change **Audit Title**, **Audit Type**, and/or **Notes**.
3. Click **Save**. Toast **"Audit updated"** on success; the table refreshes.

### Remove a planned audit

1. In the **Strategic Plan** table, on a non-approved plan's row, click the **Trash** icon (Audit Head only).
2. In the **Remove Audit** confirmation ("Are you sure you want to remove '...' from the strategic plan?"), click **Remove**.
3. Toast **"Audit removed from plan"** on success; both tables refresh.

The Create, Approve/Revoke, Print, Signed Copy download, Open Annual Plan, and plan-level Delete controls are implemented in the component but are not wired to any visible trigger in the current page render. Step-by-step instructions for those are intentionally omitted because there is no on-page path to invoke them.

## Workflow

### Add-risk → plan + operational-plan sync (the implemented end-to-end flow)

| Current Status               | User Action                                       | Validation                                                                                                    | API            | DB Update                                                                                                                                                                                                                              | Audit Trail  | Notification | Next Status                       | Next User  |
|------------------------------|---------------------------------------------------|---------------------------------------------------------------------------------------------------------------|----------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------|--------------|-----------------------------------|------------|
| (risk Assessed, not planned) | Click <b>Add Plan</b> → fill dialog → <b>Save</b> | riskId required; risk must exist in tenant and have assessmentStatus = "Assessed" ; duration coerced to 3/4/5 | POST /add-risk | Finds/creates an AuditStrategicPlan of the chosen duration (status <b>Draft</b> ); creates an AuditStrategicPlanItem (skips if same risk already present); re-ranks items per year; creates/extends AuditOperationalPlan rows per year | Not verified | None         | Plan <b>Draft</b> (with new item) | Audit Head |

### Approval flow (implemented in API + View dialog; not reachable from the current page render)

| Current Status | User Action                                    | Validation                                                    | API                              | DB Update                                                                                                                                                                                       | Audit Trail  | Notification | Next Status     | Next User  |
|----------------|------------------------------------------------|---------------------------------------------------------------|----------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------|--------------|-----------------|------------|
| Draft          | <b>Upload &amp; Approve</b> (with signed file) | File required (client toast + API 400); tenant access checked | POST <code>/id}/approve</code>   | status → <b>Approved</b> , sets <code>approvedByName</code> , <code>approvedAt = now</code> , <code>signedCopyPath</code> , <code>signedCopyName</code> , encrypted <code>signedCopyData</code> | Not verified | None         | <b>Approved</b> | Audit Head |
| Approved       | <b>Revoke Approval</b>                         | Tenant access checked                                         | DELETE <code>/id}/approve</code> | status → <b>Draft</b> , clears <code>approvedByName</code> , <code>approvedAt</code> , <code>signedCopyPath</code> , <code>signedCopyName</code> , <code>signedCopyData</code>                  | Not verified | None         | <b>Draft</b>    | Audit Head |

While **Approved**: editing or deleting any item, and editing the plan metadata, are blocked with HTTP 409 "*Approved plans cannot be edited*" (`items/[itemId]/route.ts:22-24`, `[id]/route.ts:54-59`).

## Status Reference

The schema default is **Draft**; the documented status values are **Draft**, **Pending Approval**, **Approved** ( `schema.prisma:3992` ).

| Status                  | Meaning                                                                                                       | How reached                                                                                                                                                    | Who can change                                    | Next statuses               |
|-------------------------|---------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------|-----------------------------|
| <b>Draft</b>            | Plan is editable; audits can be added/edited/removed                                                          | Set on plan creation ( <code>route.ts:152</code> , <code>add-risk/route.ts:93</code> ); also set when approval is revoked ( <code>approve/route.ts:80</code> ) | Audit Head (approve action moves it to Approved)  | Approved                    |
| <b>Approved</b>         | Locked; signed copy on file. Item edit/delete and plan PUT return 409                                         | POST <code>/id}/approve</code> after a signed copy upload ( <code>approve/route.ts:41</code> )                                                                 | Audit Head (revoke action moves it back to Draft) | Draft (via Revoke Approval) |
| <b>Pending Approval</b> | Listed as a valid status in the schema comment and styled in the UI (amber badge, <code>page.tsx:121</code> ) | <b>Not verified</b> — no API path in the reviewed routes sets this status                                                                                      | —                                                 | —                           |

## Validation Rules

- **Add Plan:** `riskId` is required ( `add-risk/route.ts:21-23` ); the risk must exist within the user's tenant ( `add-risk/route.ts:41-47` ) and must have `assessmentStatus = "Assessed"`, otherwise HTTP 400 "*Risk is not fully assessed.*" ( `add-risk/route.ts:55-60` ). Duration is coerced to one of 3/4/5, otherwise treated as undefined → default 3 ( `add-risk/route.ts:25-27,66` ).
- **Duplicate guard:** the same risk is not added twice to the same plan — a duplicate item is silently skipped ( `add-risk/route.ts:101-105` ).
- **Edit item / Delete item:** the parent plan must not be **Approved** (HTTP 409 "*Approved plans cannot be edited*"); the item must exist (404) and belong to the tenant ( `items/[itemId]/route.ts:14-26` ). On edit, blank title keeps the existing title; `year` is clamped to `[startYear, startYear + durationYears - 1]` ( `items/[itemId]/route.ts:38-45` ).
- **Approve:** a signed-copy file is required. The client shows "*Please select the signed copy to upload*" if none is chosen ( `page.tsx:361-363` ); the API returns HTTP 400 "*No signed copy file provided*" if the file is missing ( `approve/route.ts:31-33` ).
- **Plan PUT (edit metadata):** blocked when status is Approved (409); duration coerced to 3/4/5 ( `[id]/route.ts:54-64` ).
- **Tenant isolation:** every mutating route validates tenant access and returns 403 "*Access denied*" on mismatch; lists are filtered by tenant and Audit Head.
- **Permission gate:** the route wrappers enforce the resource/action; Audit Manager and Auditor (view-only) cannot reach create/edit/delete/approve endpoints.

## Success Scenarios and Failure Scenarios

### Success

- **Risk added to plan:** toast "**Added to strategic plan**"; risk disappears from Risk Assessment; audit appears in the Strategic Plan table; an operational plan is created/extended for the affected year(s).
- **Audit edited:** toast "**Audit updated**"; row reflects new title/type.
- **Audit removed:** toast "**Audit removed from plan**"; the audit's risk reappears in Risk Assessment (both tables refresh).
- **Approved** (API path): status badge becomes **Approved** (green, with a check icon), `Approved by {name}` and the approval date show, and the **Signed Copy** download appears.

### Failure

| Scenario                    | Why                                                                                                | What the user sees                                                                                                         | Resolution                                                                                      |
|-----------------------------|----------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------|
| Add Plan fails              | Network error, or any non-OK response (e.g. risk not Assessed → 400 "Risk is not fully assessed.") | Toast <b>"Failed to add to strategic plan"</b>                                                                             | Confirm the risk has completed assessment ( <code>assessmentStatus = "Assessed"</code> ); retry |
| Edit audit fails            | Plan is Approved (409), item not found (404), or tenant mismatch (403)                             | Toast <b>"Failed to update audit"</b>                                                                                      | If the plan is approved, revoke approval first (Audit Head); verify access                      |
| Remove audit fails          | Plan Approved / item not found / tenant mismatch                                                   | Toast <b>"Failed to remove audit"</b>                                                                                      | Same as above                                                                                   |
| Plans list fails to load    | API error                                                                                          | Toast <b>"Failed to load strategic plans"</b>                                                                              | Retry / check connectivity                                                                      |
| Assessed risks fail to load | API error                                                                                          | (Non-fatal — silently ignored; section may appear empty)                                                                   | Refresh the page                                                                                |
| Approve fails (API path)    | No file, tenant mismatch, server error                                                             | Toast <b>"Failed to approve plan"</b> (or client toast <i>"Please select the signed copy to upload"</i> if no file chosen) | Select a signed copy and retry                                                                  |
| Revoke fails (API path)     | Tenant mismatch / server error                                                                     | Toast <b>"Failed to revoke approval"</b>                                                                                   | Retry / verify access                                                                           |

## System Behaviour

- **Automatic plan creation:** "Add Plan" routes the risk to an existing plan whose `durationYears` matches the chosen value; if none exists it **creates a new strategic plan** of that duration with status **Draft** and an auto-generated plan code `SAP001`, `SAP002`, ... (tenant-scoped) ( `add-risk/route.ts:62-98` ). Separate durations (e.g. a 3-year and a 4-year plan) coexist independently.
- **Automatic re-ranking:** after adding an item, all items are re-ranked within each year by residual score (highest first) and `priorityRank` is recalculated; years outside the plan range are clamped to the last year ( `add-risk/route.ts:126-143` ).
- **Automatic operational-plan sync:** for each strategic-plan year, the system creates a matching `AuditOperationalPlan` (code `OAP001`, ...) if missing, or appends new audits (matched by `riskId`) to an existing one without disturbing existing edits ( `add-risk/route.ts:145-209` ).
- **Risk-register generation (Create path):** when a plan is created with `generateFromRisk` `true`, audits are populated from Internal Audit risks that have **both** `inherentScore` and `residualScore` set, ordered by residual score descending and spread across the plan years (highest risk in earliest years) ( `route.ts:98-127` ).
- **Approved-plan lock:** in the Strategic Plan table, edit/remove icons are hidden for any item whose parent plan status is **Approved** ( `page.tsx:557` ); the item and plan-metadata APIs also reject edits with 409.
- **Signed-copy storage & encryption:** on approval the file is saved (disk + DB) and the binary `signedCopyData` is stored via raw SQL and **encrypted** with `maybeEncryptBytes` ( `approve/route.ts:50-51` ); download decrypts via `maybeDecryptBytes` and falls back to disk ( `signed-copy/route.ts:25-55` ). The signed-copy binary is never included in JSON payloads — the API returns only a `hasSignedCopy` boolean ( `[id]/route.ts:28-30` ).
- **No notifications / no explicit audit-trail writes:** none of the reviewed Strategic Plan routes send notifications or write a dedicated audit-log entry (audit-trail logging is "Not verified" here).
- **Controls present in code but with no on-page trigger:** the **Create Strategic Plan** dialog ( `setCreateOpen(true)` is never called), the **View / Approval** dialog ( `openView` is never called from a visible control), and the plan-level **Delete Strategic Plan** confirm ( `setDeleteTarget(...)` is never called) exist in `page.tsx` but cannot be opened from the rendered page. As a result, on this page the create, approve/revoke, print, signed-copy download, and plan-delete flows are not reachable through the UI even though their APIs exist and function. (Verified: `openView`, `setCreateOpen`, and `setDeleteTarget` have no invoking caller — `page.tsx:135,156,343` definitions with no triggering `onClick`.)

## Notes / Warnings / Tips

- **Warning — approval locks the plan.** Once a plan is **Approved**, its audits cannot be edited or removed (409). To change an approved plan, an Audit Head must revoke approval first (returns it to **Draft** and clears the signed copy).
- **Tip — only fully assessed risks appear.** If a risk you expect is missing from the Risk Assessment section, confirm its `assessmentStatus` is **Assessed**; legacy inherent/residual scores alone are not sufficient ( `assessed-risks/route.ts:24-28` ).
- **Note — duration determines the target plan.** Choosing a different Duration in the Add Plan dialog routes the audit into a separate plan of that duration (creating it if needed); it does not change any existing plan's duration ( `add-risk/route.ts:62-66` ).
- **Note — the Strategic Plan table is flat.** It shows audits from all plans combined, with a per-row Duration column rather than per-plan grouping.
- **Note — Audit Manager and Auditor are view-only here.** Only Audit Head sees Add Plan / edit / remove controls ( `permissions.ts:441,466,511` ).

# Operational Plan

## Overview — Purpose, Business Objective

The Operational Plan module turns a multi-year **Strategic Plan** into concrete, year-by-year **Operational Audit Plans**. Each operational plan covers one financial year of its parent strategic plan and organizes that year's planned audits into quarters (Q1–Q4). For each quarter the user can capture Annual-Audit-Plan planning fields (Residual Risk Score, Risk Classification, Proposed Periodical, Estimated Hours, Auditor in Charge), assign an Audit Manager to each audit, upload quarterly reports, and finally upload the signed approval document.

When the approval document is uploaded, the plan is marked **Approved** and the system automatically converts each planned audit into a concrete **Audit Engagement** so the team can begin the engagement lifecycle (fieldwork, findings, report). This is the bridge from planning to execution.

Business objective: maintain a documented, risk-prioritized annual audit plan derived from the strategic plan, obtain formal sign-off, and seed the year's audit engagements from the approved plan.

## Access — Roles and Permissions

The module is governed by the permission resource `audit.operational-plan` (mapped to route `/internal-audit/operational-plan`, `navigation.ts:308, 114`).

| Role (display) | Internal key                                                                                                   | Permission granted (permissions.ts)                                                  | Effective capability                                 |
|----------------|----------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------|------------------------------------------------------|
| Audit Head     | <code>AuditHead</code>                                                                                         | <code>audit.operational-plan actions ['*'], scope all</code> (permissions.ts:442)    | Full: view, create (generate), edit, delete, approve |
| Audit Manager  | <code>AuditManager</code>                                                                                      | <code>audit.operational-plan actions ['*'], scope all</code> (permissions.ts:468)    | Full: view, create (generate), edit, delete, approve |
| Auditor        | <code>Auditee</code> (displayed as "Auditor" via <code>ROLE_DISPLAY_OVERRIDES</code> , permissions.ts:319-321) | <code>audit.operational-plan actions ['view'], scope all</code> (permissions.ts:512) | View only                                            |

Navigation visibility requires `audit.operational-plan:view` (`navigation.ts:308`).

The client page uses `usePermissions("audit.operational-plan")` and gates UI on `canCreate`, `canEdit`, `canDelete` (`[id]/page.tsx:144`). Each API enforces a specific action:

- `view` — GET list / detail (`operational-plans/route.ts:63`; `[id]/route.ts:36`)
- `create` — POST generate (`operational-plans/route.ts:170`)
- `edit` — PUT plan; items POST; item PATCH; quarter-plan PUT; approval POST/DELETE; quarter-reports POST (`[id]/route.ts:73`; `items/route.ts:67`; `items/[itemId]/route.ts:67`; `quarter-plan/route.ts:55`; `approval/route.ts:68,102`; `quarter-reports/route.ts:76`)
- `delete` — DELETE plan; DELETE item (`[id]/route.ts:97`; `items/[itemId]/route.ts:98`)

Note: There is no separate `approve` action used here. Approval is implemented as an **edit** operation (uploading the approval document), so any role with `edit` on `audit.operational-plan` can approve.

The Annual Audit Plan PDF download and stats endpoints ( `audit-plan/download`, `audit-plan/stats` ) are guarded by a **different** resource — `audit.planning`, action `view` (`download/route.ts:434`; `stats/route.ts:98`). These are not directly wired into the Operational Plan pages reviewed.

## Prerequisites

Before generating or working with an operational plan, the following must already exist:

- A **Strategic Plan** with its `durationYears` and `startYear` set, and audit **items** scheduled into specific years. The list page explicitly states: *"No audits yet. Add audits from the Strategic Plan first."* (`page.tsx:119`). Generating an operational plan seeds its items from the strategic plan items whose `year` matches the selected year (`operational-plans/route.ts:130-141`).
- A **customer account** associated with the user — generation fails with *"No customer account associated with this user"* otherwise (`operational-plans/route.ts:88`).
- Audit categories** (from Audit Settings) — required to populate the **Audit Category** dropdown in the Add Audit dialog. If none exist the dropdown shows *"No audit categories found"* (`[id]/page.tsx:946`).
- Auditors / Audit Managers** — fetched from `/api/internal-audit/users?role=auditors` to populate the Assign Audit Managers dialog and the per-quarter **Auditor in Charge** dropdown. If none exist the assign dialog shows *"No auditors found"* (`[id]/page.tsx:1021`).

**Screenshot:** *Insert screenshot here*

**List page** ( `/internal-audit/operational-plan` )

Visible areas (`page.tsx`):

- Breadcrumb:** Internal Audit > Operational Plan.
- Header:** title **"Operational Audit Plan"** (with a calendar-clock icon) and subtitle *"Year-wise audit plans derived from a Strategic Plan"*.



- **Table** with columns: **#**, **Audit**, **Type**, **Duration**, **Actions**. Each row is one strategic-plan item (flattened across all strategic plans). Rows are clickable; the **Actions** cell has an Edit (pencil) icon button (title *"Edit"*). Clicking a row or the pencil opens the year-wise detail page for that plan.
- **Empty state**: *"No audits yet. Add audits from the Strategic Plan first."*
- A loading spinner while data loads.

**Detail page ( /internal-audit/operational-plan/[id] )**

Visible areas ([id]/page.tsx):

- **Breadcrumb**: Internal Audit > Operational Plan > [strategic plan title].
- **Header**: back arrow, the strategic plan title (fallback **"Operational Audit Plan"**), subtitle *"Year-wise audit plans derived from a Strategic Plan"*, and a **year filter** dropdown (**All Years**, then **Year 1 ... Year N**).
- One **year card** per year in the strategic plan's duration. Each card has a header (**Year N** label + status **Badge** when a plan exists) and action buttons.
- For a year **without** a generated plan: message *"No operational plan generated for this year yet."* and (for `canCreate`) a **Generate Operational Plan** button.
- For a year **with** a plan: four **quarter sections** (Q1–Q4) plus an **Unscheduled** section (only when items have no/unknown quarter), each listing its audits and a per-quarter planning-fields panel; and a **Quarterly Reports** footer block with one tile per quarter.
- Dialogs: **Add Audit**, **Assign Audit Managers**, and a **Delete Operational Plan** confirmation.

**Page Layout**

**List page**

- Breadcrumb, header, single table (described above). No summary cards, search, or filters on the list page.

**Detail page — year card header**

- **Year N** heading and a status **Badge**: green with a check icon when status is **Approved**, otherwise gray ([id]/page.tsx:667-678).
- Action buttons (shown only when a plan exists for the year):
  - **Generate Annual Report** (FileText icon) — opens `/api/internal-audit/operational-plans/{id}/annual-report` in a new tab ([id]/page.tsx:682-694).
  - **Assign Audit Managers** (Users icon) — visible when `canEdit` and the plan has at least one item ([id]/page.tsx:695-704).
  - **Upload Approval / Replace Approval** (Upload icon) — file picker; label is **Replace Approval** when an approval doc already exists, else **Upload Approval**. Visible when `canEdit` ([id]/page.tsx:705-721).
  - **Approval** (Download icon) — visible only when `hasApprovalDoc`; downloads the approval document ([id]/page.tsx:722-733).
  - **Delete** (trash icon) — visible when `canDelete`; opens the delete confirmation ([id]/page.tsx:734-742).

**Detail page — quarter sections**

- Each quarter (Q1–Q4) shows a quarter chip, an audit count (*"N audit" / "N audits"*), and (when `canEdit`) an **Add Audit** button ([id]/page.tsx:769-787).
- Audit list table per quarter — columns **#**, **Audit**, **Category**, **Audit Manager**, and **Actions** (Actions column shown only when `canDelete`; row action is a delete/trash button) ([id]/page.tsx:330-369).
- Empty quarter text: *"No audits in this quarter."*
- A per-quarter planning-fields panel (the "Annual-Audit-Plan fields") below each quarter's audits.
- **Unscheduled** section (amber chip) listing items whose `plannedQuarter` is not one of Q1–Q4 ([id]/page.tsx:800-818).

**Detail page — Quarterly Reports footer**

- Heading **"Quarterly Reports"**, with one tile per quarter (Q1–Q4). Each tile shows the quarter label and either the uploaded report file name (a download link) or *"No report"*. Per-tile controls: **Generate Report** (sparkles icon, opens quarter-summary), **Download uploaded report** (when a report exists), **Upload / Replace** (file picker, when `canEdit`), and a delete button (when a report exists and `canDelete`) ([id]/page.tsx:822-906).

**Dialogs**

- **Add Audit** dialog — title **"Add Audit"** plus a quarter chip; fields **Audit Title**, **Audit Category** (Select; placeholder *"Select"*), **Notes**; footer **Cancel / Add** ([id]/page.tsx:914-977).
- **Assign Audit Managers** dialog — title **"Assign Audit Managers"**, helper text *"Assign an auditor to each audit. On plan approval, the audit is sent to that auditor."*; one row per audit with a Select (**Unassigned** + auditor list; placeholder *"Select audit manager"*); footer **Cancel / Save** ([id]/page.tsx:980-1034).
- **Delete Operational Plan** alert dialog — title **"Delete Operational Plan"**, description *"Are you sure you want to delete this year's operational plan? This action cannot be undone."*; **Cancel / Delete** ([id]/page.tsx:1037-1052).

**Field Reference**

**Generate Operational Plan (POST body)**

| Field           | Required | Type   | Default | Validation                                                  | Editable              | Description                    |
|-----------------|----------|--------|---------|-------------------------------------------------------------|-----------------------|--------------------------------|
| strategicPlanId | Yes      | string | —       | Must belong to tenant (else 404 "Strategic plan not found") | n/a (system-supplied) | Parent strategic plan          |
| year            | Yes      | int    | —       | Both required else 400; unique per (plan, year) else 409    | n/a                   | The financial year to generate |

System-set on creation: `planCode` (auto `OAP001`, `OAP002` ...), `title` ( `Operational Audit Plan {year}` ), `status` = **Draft**, `auditHeadId`, `createdById` (operational-plans/route.ts:127-152).

**Add Audit dialog / item (POST)**



| Field                                         | Required            | Type                   | Default                        | Validation                                                                                              | Editable    | Description                       |
|-----------------------------------------------|---------------------|------------------------|--------------------------------|---------------------------------------------------------------------------------------------------------|-------------|-----------------------------------|
| Audit Title ( <code>title</code> )            | Yes                 | text                   | empty                          | Non-empty: client " <i>Please enter an audit title</i> "; server 400 " <i>Audit title is required</i> " | Yes (PATCH) | Audit name                        |
| Audit Category ( <code>auditCategory</code> ) | No                  | select (category name) | empty                          | From Audit Settings categories                                                                          | Yes         | Category label stored on the item |
| Notes ( <code>notes</code> )                  | No                  | textarea               | empty                          | —                                                                                                       | Yes         | Free text                         |
| <code>plannedQuarter</code>                   | No (set by section) | Q1/Q2/Q3/Q4            | quarter of the clicked section | —                                                                                                       | Yes         | Quarter the audit belongs to      |

Additional item fields supported by the item APIs (not all exposed in the Add dialog): `departmentId`, `auditableEntityId`, `riskId`, `auditType`, `assignedAuditorId` (Audit Manager), `auditorInChargeId`, `residualScore` (int/null), `riskLevel`, `proposedPeriodical`, `estimatedHours` (int/null), `priorityRank` (auto-incremented = max+1 on create) (items/route.ts:34-58; schema.prisma:4101-4119).

Per-quarter planning fields (quarter-plan PUT)

Stored as JSON on the plan's `quarterPlans` field, keyed by quarter ([id]/page.tsx:376-459; quarter-plan/route.ts:36-42; schema.prisma:4064-4066).

| Field (label)                                           | Required | Type       | Default | Validation                                                   | Editable                                    | Description                         |
|---------------------------------------------------------|----------|------------|---------|--------------------------------------------------------------|---------------------------------------------|-------------------------------------|
| Residual Risk Score ( <code>residualScore</code> )      | No       | number ≥ 0 | empty   | Coerced to number or null; saved on blur                     | Yes (disabled if not <code>canEdit</code> ) | Residual risk score for the quarter |
| Risk Classification ( <code>riskLevel</code> )          | No       | select     | —       | Options: Low / Medium / High / Extreme                       | Yes                                         | Risk classification                 |
| Proposed Periodical ( <code>proposedPeriodical</code> ) | No       | text       | empty   | Placeholder " <i>e.g. Annual, Quarterly</i> "; saved on blur | Yes                                         | Cadence                             |
| Estimated Hours ( <code>estimatedHours</code> )         | No       | number ≥ 0 | empty   | Coerced to number or null; saved on blur                     | Yes                                         | Estimated hours                     |
| Auditor in Charge ( <code>auditorInChargeId</code> )    | No       | select     | —       | From auditor list                                            | Yes                                         | Auditor in charge                   |

Assign Audit Managers dialog

| Field                                                 | Required | Type   | Default                            | Validation | Editable | Description                                              |
|-------------------------------------------------------|----------|--------|------------------------------------|------------|----------|----------------------------------------------------------|
| Per-audit assignee ( <code>assignedAuditorId</code> ) | No       | select | current value or <b>Unassigned</b> | —          | Yes      | Audit Manager assigned to the audit (stored on the item) |

Approval / Quarterly report uploads

| Field                                     | Required | Type  | Validation                                                    | Description                             |
|-------------------------------------------|----------|-------|---------------------------------------------------------------|-----------------------------------------|
| Approval file ( <code>file</code> )       | Yes      | file  | 400 " <i>No approval document provided</i> " if missing       | Sign-off document; sets status Approved |
| Quarter report file ( <code>file</code> ) | Yes      | file  | 400 " <i>No report document provided</i> " if missing         | Per-quarter report                      |
| <code>quarter</code> (quarter report)     | Yes      | Q1–Q4 | 400 " <i>A valid quarter (Q1–Q4) is required</i> " if invalid | Target quarter                          |

Tables

List page table

- Columns: **#**, **Audit**, **Type**, **Duration** (shown as `{durationYears} Years` ), **Actions**.
- Rows: flattened strategic-plan items. **No sorting controls, no search, no filtering, no pagination** in the UI. Row action: Edit (pencil) opens the detail page; the whole row is also clickable (page.tsx:124-149).

Detail page audit tables (per quarter / unscheduled)

- Columns: **#**, **Audit**, **Category**, **Audit Manager**, **Actions** (Actions only when `canDelete` ).
- Ordering: items are returned ordered by `priorityRank` ascending from the API ([id]/route.ts:19; operational-plans/route.ts:29), then filtered by quarter on the client. No client-side sorting, search, or pagination. Row action: delete (trash) per item ([id]/page.tsx:353-364).
- Bulk actions: none.

Year filter

- Dropdown options: **All Years** plus **Year 1 ... Year N** (N = `durationYears` ). Filters which year cards are displayed ([id]/page.tsx:633-646, 268).

Buttons & Actions

| Control                                        | Permission                         | Visible To                         | Action                                                   | API                                                             | Success Msg                                                                                | Failure Msg                                                                                                                                                                         | Audit Trail  | Notification                                                                         |
|------------------------------------------------|------------------------------------|------------------------------------|----------------------------------------------------------|-----------------------------------------------------------------|--------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------|--------------------------------------------------------------------------------------|
| Row / Edit (pencil), list page                 | view                               | Audit Head, Audit Manager, Auditor | Open detail page                                         | — (navigation)                                                  | —                                                                                          | —                                                                                                                                                                                   | Not verified | —                                                                                    |
| Generate Operational Plan                      | create                             | Audit Head, Audit Manager          | Generate plan for a year                                 | POST /operational-plans                                         | "Operational plan generated"                                                               | "An operational plan already exists for this year" (409) / "Strategic plan not found" (404) / "strategicPlanId and year are required" (400) / "Failed to generate operational plan" | Not verified | —                                                                                    |
| Add Audit (per quarter)                        | edit                               | Audit Head, Audit Manager          | Add an item to the plan                                  | POST /operational-plans/{id}/items                              | "Audit added"                                                                              | "Please enter an audit title" (client) / "Audit title is required" (400) / "Failed to add audit"                                                                                    | Not verified | —                                                                                    |
| Delete (item, trash in table)                  | delete                             | Audit Head, Audit Manager          | Delete an audit item                                     | DELETE /operational-plans/{id}/items/{itemId}                   | "Audit deleted"                                                                            | "Failed to delete audit"                                                                                                                                                            | Not verified | —                                                                                    |
| Per-quarter fields (blur/change)               | edit                               | Audit Head, Audit Manager          | Save quarter planning JSON                               | PUT /operational-plans/{id}/quarter-plan                        | (no toast on success)                                                                      | "Failed to save quarter plan" / "Invalid quarter" (400)                                                                                                                             | Not verified | —                                                                                    |
| Assign Audit Managers → Save                   | edit                               | Audit Head, Audit Manager          | PATCH each changed item's assignee                       | PATCH /operational-plans/{id}/items/{itemId} (per changed item) | "Auditors assigned"                                                                        | "Failed to assign auditors"                                                                                                                                                         | Not verified | On later approval, assigned auditor is notified (see System Behaviour)               |
| Upload Approval / Replace Approval             | edit                               | Audit Head, Audit Manager          | Upload sign-off, set Approved, auto-generate engagements | POST /operational-plans/{id}/approval                           | "Approval document uploaded" (+ "N audit engagement(s) generated from this plan" when N>0) | "Failed to upload approval document" / "No approval document provided" (400)                                                                                                        | Not verified | Engagement-created + assignment notifications (Inbox + Email) — see System Behaviour |
| Approval (download)                            | view                               | Audit Head, Audit Manager, Auditor | Download approval doc                                    | GET /operational-plans/{id}/approval-doc                        | (file download)                                                                            | "Approval document not found" (404) / "File not found on server" (404)                                                                                                              | Not verified | —                                                                                    |
| Generate Annual Report                         | view (page); endpoint not verified | Audit Head, Audit Manager, Auditor | Open annual report                                       | GET /operational-plans/{id}/annual-report                       | (opens new tab)                                                                            | Not verified                                                                                                                                                                        | Not verified | —                                                                                    |
| Quarterly Reports — Upload / Replace           | edit                               | Audit Head, Audit Manager          | Upload/replace quarter report                            | POST /operational-plans/{id}/quarter-reports                    | "Quarterly report uploaded"                                                                | "Failed to upload quarterly report" / "A valid quarter (Q1-Q4) is required" (400) / "No report document provided" (400)                                                             | Not verified | —                                                                                    |
| Quarterly Reports — Generate Report (sparkles) | view (page)                        | Audit Head, Audit Manager, Auditor | Open quarter summary                                     | GET /operational-plans/{id}/quarter-summary/{q}                 | (opens new tab)                                                                            | Not verified                                                                                                                                                                        | Not verified | —                                                                                    |
| Quarterly Reports — Download (uploaded)        | view (page)                        | Audit Head, Audit Manager, Auditor | Download report                                          | GET /operational-plans/{id}/quarter-reports/{reportId}/doc      | (file download)                                                                            | Not verified                                                                                                                                                                        | Not verified | —                                                                                    |
| Quarterly Reports — Delete                     | delete                             | Audit Head, Audit Manager          | Remove quarter report                                    | DELETE /operational-plans/{id}/quarter-reports/{reportId}       | "Quarterly report removed"                                                                 | "Failed to remove quarterly report"                                                                                                                                                 | Not verified | —                                                                                    |
| Delete Operational Plan                        | delete                             | Audit Head, Audit Manager          | Delete the year's plan (items cascade)                   | DELETE /operational-plans/{id}                                  | "Operational plan deleted"                                                                 | "Failed to delete operational plan"                                                                                                                                                 | Not verified | —                                                                                    |

Audit Trail: No audit-trail write was found in any of the operational-plan route handlers reviewed; therefore audit-trail logging for these actions is "Not verified".

## Step-by-Step Instructions

### A. Generate an operational plan for a year

1. Open **Internal Audit > Operational Plan**.
2. Click a row (or the pencil) to open the detail page for the parent strategic plan.
3. Locate the **Year N** card for the year you want.
4. Click **Generate Operational Plan**. (Button shows a spinner while generating.)
5. On success you see *"Operational plan generated"* and the card now shows quarter sections seeded with that year's strategic-plan audits.

### B. Add an audit to a quarter

1. In a generated year card, find the target quarter (Q1–Q4).
2. Click **Add Audit** for that quarter.
3. Enter **Audit Title** (required), optionally pick an **Audit Category** and enter **Notes**.
4. Click **Add**. On success: *"Audit added"*. The dialog closes and the audit appears in that quarter.

### C. Fill per-quarter Annual-Audit-Plan fields

1. Under a quarter's audit list, in the planning panel set **Residual Risk Score**, **Risk Classification**, **Proposed Periodical**, **Estimated Hours**, and/or **Auditor in Charge**.
2. Text/number fields save automatically when you click away (on blur); selects save on change. There is no explicit Save button and no success toast; a failure shows *"Failed to save quarter plan"*.

### D. Assign Audit Managers

1. In the year card header click **Assign Audit Managers** (requires at least one audit).
2. For each audit, choose an auditor from the dropdown (or **Unassigned**).
3. Click **Save**. On success: *"Auditors assigned"*. Only changed rows are sent.

### E. Upload quarterly reports

1. Scroll to the **Quarterly Reports** block.
2. On the target quarter tile, click the **Upload** (or **Replace**) icon and pick a file.
3. On success: *"Quarterly report uploaded"*. The file name appears as a download link.
4. To remove: click the tile's delete icon and confirm *"Remove Quarterly Report?"*; success: *"Quarterly report removed"*.

### F. Approve the plan (upload approval document)

1. In the year card header click **Upload Approval** (or **Replace Approval**) and choose the signed file.
2. On success: *"Approval document uploaded"*. The plan badge changes to **Approved** (green).
3. If audits were converted, an additional toast shows *"N audit engagement(s) generated from this plan"*.
4. The **Approval** download button appears.

### G. Remove approval (revert to Draft)

- Sending DELETE to the approval endpoint resets status to **Draft** and clears the approval document. (No dedicated UI button was found on the page for removing approval; the Replace flow re-uploads instead.)

### H. Delete the operational plan

1. Click the **Delete** (trash) icon in the year card header.
2. Confirm in the **Delete Operational Plan** dialog by clicking **Delete**.
3. On success: *"Operational plan deleted"*. Items cascade-delete.

## Workflow

Status → action chain (only stages that exist):

1. **(No plan)** → user clicks **Generate Operational Plan** → validation (strategicPlanId + year present; tenant ownership; not duplicate) → POST `/operational-plans` → DB: new `AuditOperationalPlan` (status **Draft**, planCode `OAP###`) with items seeded from strategic-plan items for that year → Audit Trail: Not verified → Notification: none → **Status = Draft**.
2. **Draft** → user edits items / quarter fields / assigns managers / uploads quarter reports → PATCH/PUT/POST edit endpoints → DB updates on items, `quarterPlans`, quarter reports → status unchanged (**Draft**).
3. **Draft** → user **uploads approval document** → validation (file present; tenant ownership) → POST `/operational-plans/{id}/approval` → DB: status **Approved**, `approvedAt` set, `approvalDocPath` / `approvalDocName` set, `approvalDocData` stored (encrypted) → auto-generation: each not-yet-converted item becomes an `AuditEngagement` (status **Planned**), item linked via `engagementId` → Notifications: Audit Head ("Audit Engagement Auto-Created") and assigned auditor (engagement assigned), Inbox + Email → **Status = Approved** → Next user: assigned auditor / Audit Head working the engagement in Fieldwork.

4. **Approved** → user **removes approval** (DELETE approval) → DB: status **Draft**, `approvedAt` /doc fields cleared → **Status = Draft**. (Note: previously generated engagements are not removed by this action.)

## Status Reference

Operational plan `status` (schema default **Draft**; only Draft and Approved are implemented — schema.prisma:4054):

| Status          | Meaning                                                               | How reached                                                        | Who can change                       | Next statuses              |
|-----------------|-----------------------------------------------------------------------|--------------------------------------------------------------------|--------------------------------------|----------------------------|
| <b>Draft</b>    | Plan generated, still editable; not signed off                        | On generation (POST), or after removing approval (DELETE approval) | Audit Head, Audit Manager (via edit) | Approved (upload approval) |
| <b>Approved</b> | Approval document uploaded and signed off; engagements auto-generated | Upload approval document (POST approval)                           | Audit Head, Audit Manager (via edit) | Draft (remove approval)    |

UI badge: **Approved** renders green with a check icon; any other status renders gray ([id]/page.tsx:667-678).

Quarterly report `status`: schema default **Submitted**; set to **Submitted** on upload/upsert (schema.prisma:4084; quarter-reports/route.ts:48,56). No other report status is implemented.

## Validation Rules

- **Generate plan:** `strategicPlanId` and `year` required (400 if missing). Strategic plan must belong to the tenant (404 "Strategic plan not found"). Only one operational plan per (strategicPlan, year) — duplicate returns 409 "An operational plan already exists for this year". A customer account is required (400) (operational-plans/route.ts:75-112).
- **Add audit:** title required — client blocks with "Please enter an audit title"; server returns 400 "Audit title is required" (items/route.ts:24).
- **Quarter plan:** `quarter` must be one of Q1–Q4, else 400 "Invalid quarter". Numeric fields are coerced to number or null (quarter-plan/route.ts:19,35).
- **Approval upload:** `file` required (400 "No approval document provided") (approval/route.ts:28).
- **Quarter report upload:** valid quarter Q1–Q4 (400) and `file` required (400) (quarter-reports/route.ts:32-37).
- **Tenant / permission checks:** every detail/sub-resource handler validates tenant access via `validateTenantAccess`; mismatch returns **403 "Access denied"**. Permission resource/action is enforced by `withAuth` (see Access).
- **Duplicate audits:** no duplicate-title check exists for audit items — duplicates are allowed.

## Success Scenarios and Failure Scenarios

### Success

- **Plan generated** — toast "Operational plan generated"; the year card populates with quarter sections and seeded audits.
- **Audit added / deleted** — "Audit added" / "Audit deleted".
- **Quarter fields saved** — no toast; the value persists (optimistic update).
- **Auditors assigned** — "Auditors assigned".
- **Quarterly report uploaded / removed** — "Quarterly report uploaded" / "Quarterly report removed".
- **Approval uploaded** — "Approval document uploaded"; status becomes **Approved**; if engagements were created, also "N audit engagement(s) generated from this plan".
- **Plan deleted** — "Operational plan deleted".

### Failure

- **Duplicate year (409)** — "An operational plan already exists for this year". Why: a plan already exists for that (strategicPlan, year). Resolution: edit the existing year card instead of regenerating.
- **Missing strategic plan / wrong tenant (404)** — "Strategic plan not found". Resolution: confirm the strategic plan exists for your account.
- **Missing parameters (400)** — "strategicPlanId and year are required".
- **No customer account (400)** — "No customer account associated with this user". Resolution: ensure the user is linked to a customer account.
- **Missing audit title** — client toast "Please enter an audit title"; or 400 "Audit title is required".
- **Missing/invalid upload** — "No approval document provided" / "No report document provided" / "A valid quarter (Q1-Q4) is required".
- **Generic save failures** — "Failed to ..." toasts (add audit, delete audit, save quarter plan, assign auditors, upload/remove approval, upload/remove quarterly report, delete operational plan).
- **Access denied (403)** — when the plan/item belongs to another tenant.

## System Behaviour

- **Auto record creation on generation:** generating a plan seeds items from the strategic plan's items for that year (only those with matching `year`). `planCode` is auto-assigned (`OAP###`, tenant-scoped max+1) and `priorityRank` is carried from the source items (operational-plans/route.ts:115-153).
- **Auto status change on approval:** uploading the approval document sets `status` = "Approved" and `approvedAt`; removing it reverts to **Draft** (approval/route.ts:36-42, 87-93).
- **Auto engagement generation:** on approval, `generateEngagementsFromOperationalPlan` creates one `AuditEngagement` per not-yet-converted item (idempotent via `item.engagementId`). Engagements are created with `status` = "Planned", `auditId` auto-numbered `AUD###`, `auditType` defaulting to "Internal Audit", priority derived from `riskLevel` (high/extreme/critical → High; low/minimal → Low; else Medium), and planned start/end dates derived from the plan year + quarter. The source risk (if any) is linked to the engagement (audit-engagement-from-plan.ts:68-187). Engagement generation failure does **not** fail the approval (approval/route.ts:50-59).
- **Notifications on engagement generation:**
  - The plan's Audit Head (if not the actor) receives "Audit Engagement Auto-Created" via Inbox + Email.

- The item's assigned auditor (if not the actor) receives an engagement-assigned notification via Inbox + Email (audit-engagement-from-plan.ts:150-183).
- **Translation:** each generated engagement is queued for dynamic translation ( `translateRecord` for `engagementTitle` ) (audit-engagement-from-plan.ts:146-148).
- **Encryption at rest:** approval and quarterly-report binaries ( `approvalDocData` , `reportDocData` ) are stored via raw SQL with manual `maybeEncryptBytes` , and decrypted on download with `maybeDecryptBytes` . List/detail payloads strip the binary and expose `hasApprovalDoc` instead (operational-plans/route.ts:48-52; approval/route.ts:44-45; approval-doc/route.ts:26-31; quarter-reports/route.ts:65-70).
- **Download fallback:** the approval-doc download tries the encrypted DB blob first, then falls back to disk ( `uploads/...` or `/tmp/uploads/...` ) (approval-doc/route.ts:23-57).
- **Cascade delete:** deleting an operational plan cascades to its items and quarter reports (schema relations; [id]/route.ts:90). Deleting a strategic plan cascades to its operational plans (schema.prisma:4050).
- **Read-only behavior:** when the user lacks edit/delete, the Add Audit, Assign, Upload, and Delete controls are hidden, and per-quarter fields are disabled ( `disabled={!canEdit}` ).
- **Audit Trail logging:** not found in these handlers — Not verified.

---

## Notes / Warnings / Tips

- **Removing approval does not delete engagements.** The DELETE approval handler reverts the plan to Draft and clears the approval document, but engagements already generated remain. Re-uploading approval will not duplicate them (idempotent via `engagementId` ).
  - **Per-quarter fields auto-save with no confirmation toast.** Click away from a text/number field to persist it; verify the value remains after the page reloads.
  - **Engagement generation is best-effort.** If it fails, the plan is still marked Approved and you see only "*Approval document uploaded*" (no engagement count). Check the Audit Engagement module to confirm engagements exist.
  - **"Assign Audit Managers" dropdown is populated from the auditors endpoint** ( `/api/internal-audit/users?role=auditors` ); the same list feeds **Auditor in Charge**. If empty, set up auditor users first.
  - The **Annual Audit Plan PDF** ( `audit-plan/download` ) and **stats** endpoints use the `audit.planning` permission and are separate from the per-plan **Generate Annual Report** / **Generate Report** links on this page; the latter endpoints' exact output was not verified in this review.
-

# Audit Engagement

## Overview — Purpose, Business Objective

The **Audit Engagement** module is the operational heart of an internal audit. It is where an approved planned audit becomes a live engagement and is then driven through its full lifecycle — from the formal audit announcement, through the Audit Planning Memorandum (APM), opening meeting, audit program, fieldwork, findings, discussion and closing meeting — until the engagement is completed and an audit report is generated.

The landing page is titled **"Annual Audit Plan"** ( `page.tsx:1594, 1630` ) and lists every audit engagement for the organization alongside any operational-plan audits that have not yet been converted into engagements. From a row you open the **engagement workflow hub** ( `internal-audit/engagement/[id]/page.tsx` ), a stepper that walks the team through each lifecycle stage.

Two stages are documented in detail in this chapter:

- **Announcement** — the formal notice sent to management with the preliminary information request ( `audit-engagement-stages.ts:39-45` ).
- **Audit Planning Memorandum (APM)** — scope, objectives, methodology, timeline and an attached/printable 17-section memorandum ( `audit-engagement-stages.ts:46-52` ).

Supporting features include free-text engagement **comments**, an **APM print / Save-as-PDF** view, and a read-only **Annual Audit Plan Report** preview with PDF download.

Note: Internally the engagement model is `AuditEngagement` and the navigation/permission resource is `audit.planning` ( `navigation.ts:309` , `permissions.ts:115` ). The page component is exported as `AuditPlanningPage` . UI labels say "Audit Engagement" and "Annual Audit Plan".

## Access — Roles and Required Permissions

Navigation item **"Audit Engagement"** ( `/internal-audit/audit-engagement` ) is gated on `audit.planning:view` ( `navigation.ts:309` ).

| Capability                                                      | Permission required                       | Role behavior                                                                                                                                                         |
|-----------------------------------------------------------------|-------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| View engagement list / open list page                           | <code>audit.planning:view</code>          | AuditHead, AuditManager have full <code>*</code> ; Auditor (key <code>Auditee</code> ) is <b>not</b> granted <code>audit.planning</code> and cannot see this nav item |
| List engagements API ( <code>GET /engagements</code> )          | <code>audit.fieldwork:view</code>         | Auditee-only users are filtered to engagements where they are the assigned auditee or have evidence requests ( <code>engagements/route.ts:34-73, 146</code> )         |
| Create engagement ( <code>POST /engagements</code> )            | <code>audit.planning:create</code>        | AuditHead, AuditManager                                                                                                                                               |
| Update engagement ( <code>PUT /engagements/[id]</code> )        | <code>audit.planning:edit</code>          | AuditHead, AuditManager                                                                                                                                               |
| Change status / stage ( <code>PATCH /engagements/[id]</code> )  | <code>audit.fieldwork:edit</code>         | AuditHead, AuditManager, Auditor (Auditee key edits in department scope)                                                                                              |
| Delete engagement ( <code>DELETE /engagements/[id]</code> )     | <code>audit.planning:delete</code>        | AuditHead, AuditManager                                                                                                                                               |
| View engagement detail ( <code>GET /engagements/[id]</code> )   | <code>audit.fieldwork:view</code>         | All audit roles incl. Auditee (department scope)                                                                                                                      |
| Get/Save APM ( <code>GET / PUT /apm</code> )                    | <code>audit.fieldwork:view / :edit</code> | Edit blocked once a report exists (UI lock, see Workflow)                                                                                                             |
| Get/Save announcement ( <code>GET / PUT /announcement</code> )  | <code>audit.fieldwork:view / :edit</code> | —                                                                                                                                                                     |
| Send announcement ( <code>POST /announcement/send</code> )      | <code>audit.fieldwork:edit</code>         | —                                                                                                                                                                     |
| Read/Add comments ( <code>GET / POST /[id]/comments</code> )    | <code>audit.fieldwork:view / :edit</code> | —                                                                                                                                                                     |
| Engagement years lookup ( <code>GET /engagements/years</code> ) | <code>audit.planning:view</code>          | —                                                                                                                                                                     |

Permission cite: AuditHead `audit.planning` and `audit.fieldwork` = `['*']` ( `permissions.ts:443, 445` ); AuditManager identical ( `permissions.ts:469, 471` ); Auditor (key `Auditee`) has `audit.fieldwork` `['view','edit']` scope `department` and **no** `audit.planning` entry ( `permissions.ts:532-539` ).

The three documented roles are Audit Head ( `AuditHead` ), Audit Manager ( `AuditManager` ) and Auditor (internal key `Auditee` , displayed as "Auditor"). The list page is therefore usable by Audit Head and Audit Manager; Auditor users primarily reach engagement detail/fieldwork via their assigned work.

The permission action set is `view, create, edit, delete, approve` . There is **no export action** — the list-page **Export** button (CSV) is a client-side UI control, not a permission-gated action.

## Prerequisites

Before creating or working an engagement, the following must already exist:

- **Departments** — at least one department; selection is mandatory ( `/api/departments` ).
- **Audit Categories** — at least one configured category; the field is required in the dialog ( `page.tsx:720-722` ). If none exist the dropdown shows "No audit categories configured".
- **Users in the role lists** — auditors (Audit Managers, fetched via `users?role=auditors` ) and auditees (Auditors, fetched via `users?role=Auditee` ) for the chosen department. If none, the card shows "No auditors found in this department".
- **Optional reference data** — Audit Types ( `Settings > Audit Type` ), Audit Ratings / Scoring Ranges ( `Settings > Risk Assessment` ), Processes, and open Internal-Audit Risks for the department.
- For the **AI plan** path ( `audit-planning/from-ai` ) and **fieldwork audit plan generator** ( `fieldwork-audit-plan` ), the Python backend must be reachable and `PYTHON_API_SECRET` configured.

## Page Layout — Annual Audit Plan (list page)

**Screenshot:** *Insert screenshot here*

Visible areas of `audit-engagement/page.tsx` :

- **Breadcrumb** ( `page.tsx:1611-1626` ): Home icon · "Internal Audit" > (if the user can view the audit dashboard) "Dashboard" > **"Audit Engagement"** (current).
- **Page header** ( `page.tsx:1629-1637` ): title **"Annual Audit Plan"** on the left; on the right an **"Export"** button (upload icon) that downloads a CSV.
- **Search & filter bar** ( `page.tsx:1642-1693` ):
  - Search input with placeholder **"Search By Audit ID, Name"**.
  - **Department** filter (default "All Departments").
  - **Status** filter: "All Status", "Pending Approval", "Planned", "In Progress", "Completed".
  - **Year** filter ("All Years" plus years returned by `/engagements/years` ).
- **Table** ( `page.tsx:1696-1804` ) — columns: **Audit ID, Engagement Name, Department, Audit Type, Assigned Audit Managers, Status, Action**. Empty state row reads **"No audit engagements found"**.
- **Dialogs** present on this page:
  - **Confirmation** delete dialog ( `page.tsx:1808-1821` ).
  - **Generate Annual Plan Report** filter dialog ( `page.tsx:1824-1910` ).
  - **Add Engagement** dialog ( `page.tsx:1913-1949` ).
  - **Edit Audit Plan** dialog ( `page.tsx:1952-1988` ).
  - **Add Task / Edit Task** dialog ( `page.tsx:1991-2101` ).
  - **Annual Audit Plan Report** preview modal ( `page.tsx:2104-2255` ).

The "Generate Annual Plan Report" dialog ( `openReportDialog` ) and "Add Engagement" dialog ( `openAddDialog` ) handlers exist in the component, but no visible button on the rendered header invokes them — the only header action wired in the current render is **Export**. (Engagement creation in practice is reached via the dedicated **Add Audit Plan** page, below.)

## Engagement form (Add Engagement dialog and the /add page)

Both the in-page **Add Engagement** dialog ( `renderEngagementFormContent` , `page.tsx:1048+` ) and the standalone **/add** page (titled **"New Audit Plan"**, `add/page.tsx:533` ) render the same engagement fields. The standalone page is reached at `/internal-audit/audit-engagement/add` ; breadcrumb: Internal Audit > Audit Engagement > **"Add Audit Plan"** ( `add/page.tsx:513-524` ).

Visible areas of the form: Engagement Title, Engagement Objective, Engagement Scope, Audit Category (dialog only), **Select Departments** multi-select, per-department configuration cards (Audit Manager, Auditor, Link Open Risks), Process, Audit Rating, Audit Type, Start Date, Target Date, **Attach File and Upload Workpaper** drag-drop zones, and a tabbed/collapsible **Observation / Testing Procedure / Policies & Procedures** section. The `/add` page uses Collapsible sections ("Initial Audit Observation", "Audit Testing Procedure", "Related Policies & Procedures"); the dialog uses Tabs ("Observation", "Testing Procedure", "Policies & Procedures").

## Engagement workflow hub (engagement/[id])

**Screenshot:** *Insert screenshot here*

Visible areas of `engagement/[id]/page.tsx` :

- **Breadcrumb** ( `:240-249` ): Home > Audit Engagement > *AuditID*.
- **Header** ( `:251-290` ): engagement title (or Audit ID); subtext line `AuditID · Department · Status` ; a **"{completed}/{total} steps complete"** outline badge; and on the right either a **"Report generated — read only"** badge (with file icon) once a report exists, or a **"Generate Report"** button (only when the engagement status is "Completed" and the user has edit rights).
- **Stepper** ( `:293-328` ): one button per lifecycle stage (see Status Reference). Each shows a check (completed), a dot (current), or its position number (pending); selecting a stage opens its panel.
- **Selected stage panel** ( `:331-446` ): "Step N" label, optional "Completed"/"Current" badge, stage title, stage description, the stage's embedded component (announcement, APM, meeting, audit program, fieldwork, findings), and action buttons **"Set as current step"** and **"Mark complete & continue"** (edit users only). A "stub" stage shows "This step will be available in a future update."
- **Generate Report dialog** ( `:449-483` ): explanatory text, an **Overall Result** select (Pass / Fail), Cancel and **Generate Report** buttons.

## APM print page (engagement/[id]/apm-print)



`apm-print/page.tsx` renders a print-optimized **"Audit Planning Memorandum"** document: a **"Print / Save as PDF"** button ( `:177-180` ), a header (title, Audit Title, Department, Period), all non-removed APM sections renumbered, a Risk & Control framework table, trigger-factors list, and an **"Audit Program"** working-paper entries block. A print stylesheet hides app chrome on print.

### Report preview page (audit-engagement/report-preview)

`report-preview/page.tsx` is a standalone read-only **Annual Audit Plan Report** with a **"Download Report"** button and the same metadata/overview/scope/risk-count/approvals layout as the in-page preview modal. It reads `filterType`, `year`, `startDate`, `endDate` from the URL query string.

## Field Reference — Engagement form

| Field                              | Required     | Type         | Default | Validation                                                                                                                                                              | Editable | Description                                                                                                               |
|------------------------------------|--------------|--------------|---------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------|---------------------------------------------------------------------------------------------------------------------------|
| Engagement Title                   | Yes          | Text         | empty   | Non-empty; dialog also enforces <code>isValidName</code> (letters, spaces, hyphens) → "Only letters, spaces, and hyphens are allowed" ( <code>page.tsx:709-713</code> ) | Yes      | Audit engagement name                                                                                                     |
| Engagement Objective               | Yes          | Textarea     | empty   | Non-empty ( <code>page.tsx:714-716</code> )                                                                                                                             | Yes      | Audit objective                                                                                                           |
| Engagement Scope                   | Yes          | Textarea     | empty   | Non-empty ( <code>page.tsx:717-719</code> )                                                                                                                             | Yes      | Scope of the audit                                                                                                        |
| Audit Category                     | Yes (dialog) | Select       | empty   | Required in dialog only ( <code>page.tsx:720-722</code> ); not present on /add page                                                                                     | Yes      | Category from settings                                                                                                    |
| Select Departments                 | Yes          | Multi-select | empty   | At least one ( <code>page.tsx:723-725</code> )                                                                                                                          | Yes      | One engagement created per department                                                                                     |
| Audit Manager (per dept)           | Yes          | Multi-select | empty   | Each selected department must have $\geq 1$ (error "Auditor is required (Dept)") ( <code>page.tsx:727-733</code> )                                                      | Yes      | First selected = primary <code>assignedAuditor</code> ; rest = team members ( <code>engagements/route.ts:393-394</code> ) |
| Auditor (per dept)                 | No           | Multi-select | empty   | —                                                                                                                                                                       | Yes      | First selected = primary <code>auditee</code> ( <code>engagements/route.ts:397</code> )                                   |
| Link Open Risks in this Department | No           | Multi-select | empty   | —                                                                                                                                                                       | Yes      | Links open Internal-Audit risks to the engagement                                                                         |
| Process                            | No           | Select       | empty   | —                                                                                                                                                                       | Yes      | Related process                                                                                                           |
| Audit Rating                       | No           | Select       | empty   | —                                                                                                                                                                       | Yes      | From scoring ranges                                                                                                       |
| Audit Type                         | No           | Select       | empty   | —                                                                                                                                                                       | Yes      | Defaults server-side to "Internal Audit" if blank ( <code>engagements/route.ts:189</code> )                               |
| Start Date                         | Yes          | Date         | empty   | Required ( <code>page.tsx:734-736</code> )                                                                                                                              | Yes      | Planned start ( <code>plannedStartDate</code> + <code>startDate</code> )                                                  |
| Target Date                        | Yes          | Date         | empty   | Required ( <code>page.tsx:737-739</code> )                                                                                                                              | Yes      | Planned end ( <code>plannedEndDate</code> + <code>endDate</code> )                                                        |
| Attach File                        | No           | File drop    | —       | None (client-side list only; not persisted by create API)                                                                                                               | Yes      | Supporting documents                                                                                                      |
| Upload Workpaper                   | No           | File drop    | —       | None (client-side list only)                                                                                                                                            | Yes      | Audit workpapers                                                                                                          |
| Auditor's Initial Observation      | No           | Textarea     | empty   | —                                                                                                                                                                       | Yes      | Stored as <code>initialObservation</code>                                                                                 |
| Related Policies / Procedures      | No           | Textarea     | empty   | —                                                                                                                                                                       | Yes      | Stored as <code>relatedPolicies</code>                                                                                    |

**Testing Procedure tasks** (per-row): Task Description (required to save a task, `page.tsx:683, 2094` ), Status (Done / Pending checkbox), Planned Hours (number), Actual Hours (number), Assigned Audit Manager, Comments. The /add and /edit pages seed six default rows: "Audit Preparation & Update", "Documentation Review", "Sample Selection", "Result of Previous Audit", "Related Policies", "Related Procedures" ( `add/page.tsx:111-118` ).

Note: Attached files and workpapers are tracked only in client state on the create/edit forms — the `POST /engagements` body sends `tasks` and `plannedHours` but no file payload ( `page.tsx:760-765` , `add/page.tsx:429-434` ). The forms do not upload files at engagement creation.

## Tables

**Annual Audit Plan list table** ( `page.tsx:1696-1804` ):

- **Columns:** Audit ID, Engagement Name, Department, Audit Type, Assigned Audit Managers, Status, Action.
- **Two row types:**
  1. **Engagements** — real `AuditEngagement` rows.
  2. **Planned audits** — operational-plan items not yet converted to engagements; shown with Audit ID "—", title plus `planCode` · `year` · `quarter`, a **"Pending Approval"** amber pill, and no actions ("—") ( `page.tsx:1777-1794` ).
- **Searching:** client passes the search term to the API ( `auditId` or `engagementTitle`, case-insensitive, `engagements/route.ts:93-100` ); planned audits filter on title client-side ( `page.tsx:333` ).
- **Filtering:** Department, Status, Year (server-side for engagements via query params; year matches start/end date falling in that calendar year, `engagements/route.ts:83-91` ).
- **Sorting:** engagements returned newest first ( `orderBy: createdAt desc` ); no clickable column sort.
- **Pagination:** none (all rows rendered).



- **Row actions** ( `page.tsx:1721-1773` ):
  - **View** (eye) or **Edit** (pencil) link to `/internal-audit/engagement/{id}` — labelled "View" when a report exists, otherwise "Edit".
  - **"Report generated"** emerald pill when a report exists (row is then locked — no further actions).
  - **"Generate Report"** button — only when `status === "Completed"` and no report yet.
  - **Delete** (trash) — only when no report yet.

**Testing Procedure task table** inside the engagement form ( `page.tsx:1493-1568` ): columns #, Task Description, Status, Planned, Actual, Audit Manager, Actions; footer shows **Total Hours** (Planned / Actual). Row actions: Edit (pencil), Delete (trash). "No tasks added yet" empty state.

### Buttons & Actions

---

| Control                                               | Permission                                     | Visible To                       | Action                                                                                                 | API                                                             | Success Msg                                                                  | Failure Msg                                                                                                                                                 |
|-------------------------------------------------------|------------------------------------------------|----------------------------------|--------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------|------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Export (list header)                                  | UI control (no perm)                           | List viewers                     | Build CSV (Audit ID, Engagement Title, Department, Audit Type, Assigned Auditors, Status) and download | none (client)                                                   | "Export completed"                                                           | "Failed to export"                                                                                                                                          |
| Save (Add Engagement dialog / New Audit Plan)         | audit.planning:create                          | AuditHead, AuditManager          | Create one engagement per selected department                                                          | POST /api/internal-audit/engagements                            | "Engagement created successfully" / "{n} engagements created successfully"   | "Failed to create engagement" (or API error)                                                                                                                |
| Update (Edit Audit Plan dialog / Edit page)           | audit.planning:edit                            | AuditHead, AuditManager          | Update existing engagement; newly added depts create additional engagements                            | PUT /api/internal-audit/engagements/[id] (+ POST for new depts) | "Engagement updated successfully" (+ "{n} engagements created successfully") | "Failed to update engagement"                                                                                                                               |
| Delete (row trash) → Confirmation dialog "Delete"     | audit.planning:delete                          | AuditHead, AuditManager          | Delete engagement + its translations                                                                   | DELETE /api/internal-audit/engagements/[id]                     | "Engagement deleted successfully"                                            | "Failed to delete engagement"                                                                                                                               |
| Generate Report (list row)                            | audit.fieldwork:edit (via report generate API) | When status Completed, no report | Generate report (overallResult "Pass"), then lock row                                                  | POST /api/internal-audit/report/generate                        | "Report generated. It is now available in the Report section."               | "Failed to generate report"                                                                                                                                 |
| View / Edit (row)                                     | audit.fieldwork:view                           | All who can list                 | Open engagement workflow hub                                                                           | n/a (link)                                                      | —                                                                            | —                                                                                                                                                           |
| Mark complete & continue (stage panel)                | audit.fieldwork:edit                           | Edit users, report not generated | Mark stage completed, advance current stage                                                            | PATCH /api/internal-audit/engagements/[id]                      | "Step marked complete"                                                       | "Failed to update workflow"                                                                                                                                 |
| Set as current step                                   | audit.fieldwork:edit                           | Edit users                       | Set currentStage                                                                                       | PATCH /api/internal-audit/engagements/[id]                      | "Current step updated"                                                       | "Failed to update workflow"                                                                                                                                 |
| Generate Report (hub header) → dialog Generate Report | audit.fieldwork:edit                           | Edit users, status Completed     | Mark all steps complete + status Completed, then generate report                                       | PATCH ../[id] then POST /report/generate                        | "Report generated. Opening the Report section."                              | "Failed to complete engagement" / "Failed to generate report"                                                                                               |
| Save Draft (Announcement)                             | audit.fieldwork:edit                           | Edit users                       | Upsert announcement (status Draft)                                                                     | PUT /api/internal-audit/engagements/[id]/announcement           | "Announcement saved"                                                         | "Failed to save announcement" / "Enter a valid email address"                                                                                               |
| Send Announcement → confirm "Send"                    | audit.fieldwork:edit                           | Edit users                       | Mark Sent, email recipients, notify auditee                                                            | POST /api/internal-audit/engagements/[id]/announcement/send     | "Announcement sent"                                                          | "Failed to send announcement"                                                                                                                               |
| Add External Recipient (Announcement)                 | audit.fieldwork:edit                           | Edit users                       | Add name+email recipient to list                                                                       | none (client)                                                   | —                                                                            | "Enter a valid email address"                                                                                                                               |
| Save (APM)                                            | audit.fieldwork:edit                           | Edit users                       | Upsert APM (status defaults "Draft")                                                                   | PUT /api/internal-audit/engagements/[id]/apm                    | Not verified                                                                 | Not verified                                                                                                                                                |
| Print / Save as PDF (APM print page)                  | audit.fieldwork:view                           | Viewers                          | Browser print of memorandum                                                                            | none (window.print)                                             | —                                                                            | —                                                                                                                                                           |
| Show Report (Generate Annual Plan Report dialog)      | UI control                                     | —                                | Open the report preview modal + fetch stats                                                            | GET /api/internal-audit/audit-plan/stats                        | —                                                                            | "Please select a filter type" / "Please select a year" / "Please select a start date" / "Please select an end date" / "Start date cannot be after end date" |

| Control                                               | Permission           | Visible To | Action                             | API                                                | Success Msg                      | Failure Msg                                               |
|-------------------------------------------------------|----------------------|------------|------------------------------------|----------------------------------------------------|----------------------------------|-----------------------------------------------------------|
| Download Report (preview modal / report-preview page) | UI control           | —          | Download PDF                       | GET /api/internal-audit/audit-plan/download        | "Report downloaded successfully" | "Failed to download report"                               |
| Add Task / Save Changes (task dialog)                 | client               | Form users | Add/update a testing-procedure row | none (in form state)                               | —                                | (Save disabled until Task Description non-empty)          |
| Add comment (engagement comments)                     | audit.fieldwork:edit | Edit users | Add a comment                      | POST /api/internal-audit/engagements/{id}/comments | Not verified (component-level)   | "Comment cannot be empty" (API, comments/route.ts:48-53 ) |

## Step-by-Step Instructions

### A. Create an engagement (Add Audit Plan)

1. Open **Audit Engagement** from the Internal Audit sidebar.
2. Go to the **Add Audit Plan** page ( /internal-audit/audit-engagement/add ) — title "New Audit Plan". (Alternatively, the Add Engagement dialog renders the same fields.)
3. Enter **Engagement Title** (required).
4. Enter **Engagement Objective** (required) and **Engagement Scope** (required).
5. In the dialog, choose an **Audit Category** (required there).
6. In **Select Departments**, pick one or more departments. A configuration card appears per department.
7. In each card, select at least one **Audit Manager** (required); optionally select an **Auditor** and **Link Open Risks in this Department**.
8. Optionally set **Process**, **Audit Rating**, **Audit Type**.
9. Set **Start Date** and **Target Date** (both required).
10. Optionally drop files into **Attach File** / **Upload Workpaper**, and fill the Observation / Testing Procedure / Policies tabs (use **Add Task** / **Add Task Row** to add procedure rows).
11. Click **Save**. The system creates one engagement per department (status "Planned") and returns to the list with a success toast.

### B. Edit an engagement

1. From the list, on a row with no report yet, click **Edit** (pencil) to open the workflow hub, or use the **Edit Audit Plan** dialog / **Edit** page.
2. Adjust fields. If you add new departments, the system updates the original engagement and creates a new engagement per added department, suffixing the Audit ID (e.g. AUD012 → AUD012.2).
3. Click **Update**.

### C. Send the audit announcement

1. Open the engagement (workflow hub) and select the **Announcement** stage (first step).
2. Review the auto-generated draft (recipient, subject, body, commence date).
3. Add recipients from the user list or use **Add External Recipient** (name + valid email).
4. Edit Subject / Message / Commence Date as needed.
5. Click **Save Draft** to persist, or **Send Announcement** → confirm **Send**. On send, the announcement is marked **Sent**, emailed to all valid recipients, and the auditee is notified.

### D. Complete the Audit Planning Memorandum (APM)

1. Select the **Audit Planning Memorandum** stage.
2. Fill scope, objectives, methodology, timeline, the program overview and the 17-section memorandum content; attach detailed program documents as needed.
3. Click **Save** (the APM is upserted with status defaulting to "Draft").
4. To print, open /internal-audit/engagement/{id}/apm-print and click **Print / Save as PDF**.

### E. Advance the engagement and generate the report

1. For each stage, complete its work then click **Mark complete & continue** (or **Set as current step**).
2. When all stages are complete, the engagement is auto-marked **Completed**.
3. Click **Generate Report** (hub header or list row), choose **Overall Result** (Pass / Fail), then confirm. The engagement is locked (read-only) and the report appears in the Report section.

## Workflow

| Current Status     | User Action                           | Validation                                            | API                            | DB Update                                                                | Audit Trail  | Notification                                                  | Next Status       |
|--------------------|---------------------------------------|-------------------------------------------------------|--------------------------------|--------------------------------------------------------------------------|--------------|---------------------------------------------------------------|-------------------|
| (none)             | Save new engagement                   | Required fields + ≥1 dept + ≥1 Audit Manager/dept     | POST /engagements              | Create AuditEngagement (status "Planned"), generate Audit ID, link risks | Not verified | AUDIT_CREATED to Audit Head; assigned to auditor/auditee/team | Planned           |
| Planned            | Work stages; Mark complete & continue | Valid stage key ( engagements/[id]/route.ts:206-211 ) | PATCH /engagements/[id]        | Update stageProgress , currentStage                                      | Not verified | None                                                          | Planned Complete  |
| Planned            | Send announcement                     | Recipient emails valid                                | POST /announcement/send        | Announcement → status "Sent", sentAt/By                                  | Not verified | AUDIT_PLAN_SCHEDULED to auditee                               | Planned           |
| Planned            | All stages completed                  | All stages "completed"                                | PATCH /engagements/[id] (auto) | status → "Completed", actualEndDate set ( [id]/route.ts:201-203 )        | Not verified | None                                                          | Complete          |
| Completed          | Generate Report                       | status Completed, no report                           | POST /report/generate          | Report record created                                                    | Not verified | Not verified                                                  | Complete (locked) |
| Completed + report | (locked)                              | —                                                     | —                              | Engagement read-only ( engagement/[id]/page.tsx:102-103 )                | —            | —                                                             | —                 |

## Status Reference

### Engagement statuses (list page Status filter, page.tsx:1672-1677 )

| Status           | Meaning                                                                                                         | How reached                                                 | Who changes it                     | Next statuses           |
|------------------|-----------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------|------------------------------------|-------------------------|
| Pending Approval | A planned (operational-plan) audit not yet converted to an engagement; shown as an amber pill on synthetic rows | From operational plan (planned audits feed)                 | Becomes an engagement when created | Planned                 |
| Planned          | Engagement created; default on creation ( engagements/route.ts:203 )                                            | On POST /engagements                                        | System on create                   | In Progress / Completed |
| In Progress      | Engagement underway (filter option)                                                                             | Set via PATCH status                                        | Edit users                         | Completed               |
| Completed        | All workflow stages complete; report can be generated                                                           | Auto when all stages completed, or PATCH status="Completed" | System / edit users                | (locked after report)   |

### Lifecycle stages (workflow hub stepper, audit-engagement-stages.ts:38-99 )

Per-stage progress is tracked in `stageProgress` with values **completed** or **in progress** ( `audit-engagement-stages.ts:105-107` ). Ordered stages:

1. **Announcement** — send the formal audit announcement with the PBC list ( `kind: announcement` ).
2. **Audit Planning Memorandum** — scope, objectives, methodology, timeline, program attachments ( `apm` ).
3. **Opening Meeting** — minutes of meeting ( `meeting` , `opening` ).
4. **Audit Program** — detailed program ( `audit-program` ).
5. **Fieldwork** — walkthroughs, testing, workpapers, evidence ( `fieldwork` ).
6. **Findings** — record findings ( `findings` ).
7. **Findings Discussion** — validate facts, agree actions ( `meeting` , `discussion` ).
8. **Closing Meeting** — final observations, action plans ( `meeting` , `closing` ).

A stage is **completed** (check), **current** (dot, equals `currentStage` ), or **pending** ( `engagement/[id]/page.tsx:107-111` ).

### Announcement statuses

| Status | Meaning                      | How reached                                                                      |
|--------|------------------------------|----------------------------------------------------------------------------------|
| Draft  | Saved but not sent (default) | Auto-generated default, or Save Draft ( <code>announcement/route.ts:171</code> ) |
| Sent   | Issued to recipients         | Send Announcement ( <code>announcement/send/route.ts:66, 80</code> )             |

### APM status

`status` defaults to "**Draft**" on first save ( `apm/route.ts:146` ). Other values are accepted only when explicitly provided by the caller; no other named status is hard-coded in the documented APIs.

### Reporting mode (PATCH-only field)

`reportingMode` accepts only "**Continuous**" or "**Aggregated**" ( `engagements/[id]/route.ts:213-218` ). No UI control on the documented pages sets this; it is API-level.

## Validation Rules

- **Engagement create/edit (client)**: Engagement Title, Objective, Scope, Start Date, Target Date required; ≥1 department; each department needs ≥1 Audit Manager. Add Engagement **dialog** also enforces Audit Category and `isValidName` on the title ( `page.tsx:706-743` ). The **/add** and **/edit** pages validate via

toasts and do not enforce Audit Category or `isValidName` ( `add/page.tsx:381-414` , `[id]/edit/page.tsx:405-432` ).

- **AI plan create** ( `audit-planning/from-ai` ): `audit_title` and `departmentId` required; duplicate (same title + department) returns 409 "This audit plan has already been added to Audit Planning."
- **Fieldwork audit plan generator** ( `fieldwork-audit-plan` ): requires `auth`; `department_name` (string) and non-empty `risks` array, else 400.
- **Announcement send**: only syntactically valid emails (regex `^[^\s@]+@[^\s@]+\.[^\s@]+`) are emailed ( `announcement/send/route.ts:7, 88-94` ); the UI blocks adding an external recipient with an invalid email ("Enter a valid email address").
- **Comment add**: empty/whitespace comment rejected with "Comment cannot be empty" (400).
- **Stage PATCH**: invalid `currentStage` key → 400 "Invalid stage key"; invalid `reportingMode` → 400 "Invalid reporting mode"; `stageProgress` is sanitized to recognized keys with allowed statuses only.
- **Tenant/ownership**: every `[id]` route verifies the engagement belongs to the caller's tenant ( `getTenantFilter` ), returning 404 "Engagement not found" otherwise.
- **Report generated lock**: once a report exists, the engagement hub sets `canEdit = false` and shows a read-only badge ( `engagement/[id]/page.tsx:102-103, 267-271` ); list rows hide Edit/Delete/Generate.

## Success Scenarios and Failure Scenarios

### Success

- Single-department save → one engagement, toast "Engagement created successfully", list refreshed.
- Multi-department save → N engagements (suffixed Audit IDs), toast "{N} engagements created successfully".
- Edit with added departments → "Engagement updated successfully + {N} engagements created successfully".
- Announcement sent → status "Sent", recipients emailed, auditee notified, toast "Announcement sent".
- All stages complete → engagement auto-set "Completed"; Generate Report locks the engagement.

### Failure

- *Missing required field* → inline error (dialog) or toast (e.g. "Engagement Title is required", "At least one department must be selected", "Auditor is required (Dept)"). Resolve: complete the field.
- *Invalid title characters (dialog)* → "Only letters, spaces, and hyphens are allowed". Resolve: remove digits/symbols.
- *Duplicate AI plan* → 409 "This audit plan has already been added to Audit Planning." Resolve: it already exists; open the existing engagement.
- *Create/update server error* → toast "Failed to create engagement" / "Failed to update engagement" (500). Resolve: retry; check server logs.
- *Engagement not found / wrong tenant* → 404 "Engagement not found". Resolve: confirm the engagement belongs to your account.
- *Invalid recipient email* → "Enter a valid email address" (UI). Resolve: correct the email.
- *Empty comment* → "Comment cannot be empty". Resolve: enter text.
- *Generate report when one exists* → API "already exists" is treated as success (no error shown) ( `page.tsx:241-244` ).

## System Behaviour

- **Automatic record creation**: `POST /engagements` creates one `AuditEngagement` per department; the first selected Audit Manager becomes the primary `assignedAuditor`, remaining managers become `teamMembers`, and the first selected Auditor becomes `auditee` ( `engagements/route.ts:393-420` ). Linked risks are attached by setting their `engagementId`. The AI path additionally creates `AiWorkpaper` records from the AI tasks ( `from-ai/route.ts:101-118` ).
- **Audit ID generation**: new base IDs are `AUD###` (zero-padded); adding departments to an existing group suffixes `.n` (e.g. `AUD012.2`) ( `engagements/route.ts:334-390` ).
- **Auto status update**: completing all workflow stages auto-PATCHes status to "Completed" and sets `actualEndDate` ( `engagement/[id]/page.tsx:162-181` , `engagements/[id]/route.ts:201-203` ).
- **Notifications**: on create — `AUDIT_CREATED` to the Audit Head and engagement-assigned notifications to auditor, auditee and team members (Inbox + Email). On edit — assignment notifications only when the auditor/auditee actually changed. On announcement send — `AUDIT_PLAN_SCHEDULED` to the auditee plus emails to all valid recipients.
- **Translations**: engagement text fields are auto-translated on create/edit via `translateRecord` / `triggerTranslation`; translations are deleted on delete ( `engagements/[id]/route.ts:278` ).
- **Read-only after report**: a generated report makes the engagement read-only across the hub and list.
- **Background processing**: the fieldwork audit-plan generator proxies to the external Python backend (RunPod) with the user's locale; failures surface the backend status/detail.
- **Auditee scoping**: the engagements list for Auditee-only users is filtered to engagements where they are the assigned auditee or have evidence requests ( `engagements/route.ts:34-73` ).
- **Attachment privacy**: APM attachment blobs (encrypted `fileData`) are stripped from API responses; only metadata is returned ( `apm/route.ts:6-28, 63-68` ).

## Notes / Warnings / Tips

- **Tip — multi-department**: selecting multiple departments creates a *group* of engagements sharing the same details but separate Audit IDs (suffixed). Manage them individually from the list.
- **Warning — files at creation**: Attach File / Upload Workpaper on the create/edit forms are held in client state only and are **not** uploaded by the create API. Use the APM attachments / fieldwork workpapers features to persist documents.
- **Warning — irreversible lock**: after **Generate Report**, the engagement becomes read-only. Verify all stages and details before generating.
- **Note — terminology**: the UI label "Audit Manager" in the per-department card maps to the engagement's primary auditor ( `assignedAuditor` ); the label "Auditor" maps to the `auditee`. This reflects the role-display conventions used across the module.
- **Note — Audit Category** is required only in the in-page Add Engagement dialog, not on the standalone Add/Edit pages.

# Engagement Meetings (Opening, Discussion, Closing)

## Overview — Purpose, Business Objective

The Engagement Meetings feature lets the audit team capture the **Minutes of Meeting (MoM)** for the three formal meetings that bracket an audit engagement:

- **Opening Meeting** — walk through objectives, scope, timeline and key contacts; capture the Minutes of Meeting. ( `src/lib/audit-engagement-stages.ts:54-60` )
- **Findings Discussion** (Discussion / preliminary-observations meeting) — validate facts, agree on action plans and finalize management responses; capture the Minutes of Meeting. ( `src/lib/audit-engagement-stages.ts:84-90` )
- **Closing Meeting** — discuss final observations and action plans; capture the Minutes of Meeting. ( `src/lib/audit-engagement-stages.ts:92-98` )

Each meeting is one **stage (step)** of the engagement workflow on the engagement detail page. The meetings document who attended, what was discussed, and the actions/decisions agreed, so that the engagement file carries an auditable record of management’s awareness and commitments.

**Important — two different meeting implementations exist in the code.** The engagement detail page renders **structured MoM forms** for each of the three meeting types via dedicated components ( `OpeningMeeting` , `FindingsDiscussionMeeting` , `ClosingMeeting` ) backed by their own API routes ( `.../opening-meeting` , `.../findings-discussion-meeting` , `.../closing-meeting` ). ( `src/app/(protected)/internal-audit/engagement/[id]/page.tsx:350-369` ) The generic meetings API named in this assignment — `api/internal-audit/engagements/[id]/meetings` and `.../meetings/[meetingId]` — backs the `MeetingMinutes` component, which is only the **fallback** branch (the final `else` in the same conditional, `page.tsx:364-368` ). With the current `ENGAGEMENT_STAGES` definition, all three meeting stages match one of the three structured branches, so the generic `MeetingMinutes` UI is **not reached** for the standard opening/discussion/closing stages. Both implementations are documented below: the structured forms (what users see today) and the generic meetings API/ `MeetingMinutes` component (the underlying meetings model that the assignment references).

## Access — Roles and Permissions

All meeting functionality is gated on the `audit.fieldwork` resource. ( `src/app/api/internal-audit/engagements/[id]/meetings/route.ts:52,130` ; `.../meetings/[meetingId]/route.ts:32,83,119` ; structured forms use the same resource via the page-level `canEdit` derived from `usePermissions("audit.fieldwork")` , `page.tsx:72` )

- **Viewing** a meeting requires `audit.fieldwork:view` .
- **Creating / editing / deleting** (saving MoM) requires `audit.fieldwork:edit` .

| Role          | Internal key                     | Can view | Can edit/save | Scope      | Citation                                                                                                             |
|---------------|----------------------------------|----------|---------------|------------|----------------------------------------------------------------------------------------------------------------------|
| Audit Head    | AuditHead                        | Yes      | Yes           | all        | <code>permissions.ts:445</code> ( <code>audit.fieldwork</code> actions <code>['*']</code> , scope <code>all</code> ) |
| Audit Manager | AuditManager                     | Yes      | Yes           | all        | <code>permissions.ts:471</code> ( <code>['*']</code> , scope <code>all</code> )                                      |
| Auditor       | Auditee (displayed as "Auditor") | Yes      | Yes           | department | <code>permissions.ts:534</code> ( <code>['view','edit']</code> , scope <code>department</code> )                     |

Notes:

- The "Auditor" displayed role (internal `Auditee` ) has `audit.fieldwork` `view` + `edit` but **scoped to department** ( `permissions.ts:534` ), so it can record/edit meeting minutes for engagements within its department scope. There is no `approve` action involved in meetings.
- On the engagement page, the Save / Add Row / edit / delete controls are shown only when `canEdit` is true, where `canEdit = canEditPerm && !reportGenerated` ( `page.tsx:103` ). Once the engagement report has been generated, editing is locked even for roles that otherwise have edit permission (read-only).

## Prerequisites

- An **Audit Engagement** must already exist; the engagement detail page is `/internal-audit/engagement/[id]` . The API verifies the engagement exists and belongs to the user’s tenant before listing or creating meetings, returning **"Engagement not found"** (HTTP 404) otherwise. ( `meetings/route.ts:15-25,64-74` )
- The user must have a **customer account** assigned. Creating a meeting via the generic API without one returns **"User does not have a customer account assigned"** (HTTP 400). ( `meetings/route.ts:95-100` )
- The engagement **report must not yet be generated** for editing to be enabled ( `canEdit` becomes false after report generation). ( `page.tsx:103` )

**Screenshot:** *Insert screenshot here*

The engagement detail page shows: a page header with engagement title and a **Generate Report** button area; a **steps-complete counter** ("X/Y steps complete", `page.tsx:265` ); a horizontal **stepper** of all engagement stages, including the three meeting stages — **Opening Meeting**, **Findings Discussion**, **Closing Meeting** — each rendered as a clickable button with a status indicator (number, current `CircleDot` , or completed `Check` ) ( `page.tsx:293-327` ); and a **selected-stage panel** (a `Card` ) showing the step number, an optional **Completed/Current** badge, the stage label, the stage description, and the meeting form for the selected meeting stage ( `page.tsx:330-371` ).

## Page Layout

The meetings are not a standalone page; they are panels inside the engagement detail page. For each of the three meeting stages, when selected, the panel renders a structured MoM form.

Stepper and stage panel ( page.tsx:292-348 )

- **Stepper buttons** — one per stage; meeting stages are labelled "Opening Meeting", "Findings Discussion", "Closing Meeting". Selecting a button shows that stage's panel.
- **Stage panel header** — "Step N", optional **Completed** or **Current** badge, stage label (h2), and the stage description text.

Opening Meeting form — OpeningMeeting ( src/components/internal-audit/OpeningMeeting.tsx )

Title: **Audit Task Opening Meeting Minutes** (with a `FileText` icon). Header actions: **Export PDF** button (always shown) and **Save** button (shown only when `canEdit` ). Sections:

- **Meeting Details** — six input fields: Management, Department, Audit Task Number, Assignment Title, History, Meeting Venue.
- **Objective of the meeting** — a multi-line text area.
- **Attendees** — table with columns Name, Job Title, Management, Signature; **Add Row** button (when editable); per-row delete (trash) action; empty state "No rows. Use Add Row."
- **Topics discussed** — table with columns #, Subject, Details/Notes; **Add Row**; per-row delete.
- **Agreed actions** — table with columns #, Action required, Official, Implementation Date (date input); **Add Row**; per-row delete.

Findings Discussion form — FindingsDiscussionMeeting ( src/components/internal-audit/FindingsDiscussionMeeting.tsx )

Title: **Findings Discussion Meeting Minutes**. Header actions: **Export PDF**, **Save** (when editable). Sections:

- **Meeting Details** — Management, Department, Audit Task Number, Assignment Title, History, Meeting Venue.
- **Attendees** — Name, Job Title, Management, Signature; **Add Row**; per-row delete.
- **Notes Discussed** — table with columns #, Note, Degree of Risk, Management Response, Proposed Action; **Add Row**; per-row delete.
- **Agreed Actions** — table with columns Implementation Date, Official, Procedure; **Add Row**; per-row delete.

Closing Meeting form — ClosingMeeting ( src/components/internal-audit/ClosingMeeting.tsx )

Title: **Closing Meeting Minutes**. Header actions: **Export PDF**, **Save** (when editable). Sections:

- **Meeting Details** — Management, Department, Audit Task Number, Assignment Title, History, Meeting Venue.
- **Attendees** — Name, Job Title, Management, Signature; **Add Row**; per-row delete.
- **Summary of Audit Results** — table with columns #, Key Note, Degree of Risk, Recommendation, Management Response; **Add Row**; per-row delete.
- **Decisions taken** — table with columns Implementation Date, Official, Decision; **Add Row**; per-row delete.

Generic meetings UI — MeetingMinutes (fallback; src/components/internal-audit/MeetingMinutes.tsx )

Heading: "{Meeting type label} — Minutes of Meeting", where the type label is **Opening Meeting**, **Findings Discussion**, or **Closing Meeting** ( `MeetingMinutes.tsx:111-125,244` ). Layout:

- **Add Minutes** button (when editable).
- A list of meeting **cards**, each showing: title (or "{type} · {date}" if no title), meeting date ( `Calendar` icon), location ( `MapPin` ), attendees ( `Users` ), a **status badge** (Draft / Finalized), edit ( `Pencil` ) and delete ( `Trash2` ) actions (when editable), then Agenda, Minutes, and "Decisions & Action Plans" blocks, and a footer "Recorded by {name}".
- Empty state: "No minutes recorded yet".
- **Add / Edit dialog** titled "Add Minutes — {type}" or "Edit Minutes — {type}" with fields Title, Meeting Date (date picker), Location, Attendees, Agenda, Minutes, Decisions & Action Plans, and a Status select (Draft / Finalized); footer Cancel / Add (or Save).
- **Delete confirm** dialog titled "Delete Minutes".

Field Reference

Structured forms — header fields (Opening, Discussion, Closing all share these)

| Field                    | Required | Type       | Default | Validation | Editable                  | Description                                                             |
|--------------------------|----------|------------|---------|------------|---------------------------|-------------------------------------------------------------------------|
| Management               | No       | Text input | ""      | None       | When <code>canEdit</code> | Management/area name                                                    |
| Department               | No       | Text input | ""      | None       | When <code>canEdit</code> | Department                                                              |
| Audit Task Number        | No       | Text input | ""      | None       | When <code>canEdit</code> | Audit task reference                                                    |
| Assignment Title         | No       | Text input | ""      | None       | When <code>canEdit</code> | Engagement/assignment title                                             |
| History                  | No       | Text input | ""      | None       | When <code>canEdit</code> | Version/history note                                                    |
| Meeting Venue            | No       | Text input | ""      | None       | When <code>canEdit</code> | Location of the meeting                                                 |
| Objective of the meeting | No       | Textarea   | ""      | None       | When <code>canEdit</code> | <b>Opening Meeting only</b> ( <code>OpeningMeeting.tsx:257-270</code> ) |

Structured forms — Attendees rows (all three forms)

| Field      | Required | Type       | Default | Validation | Editable     | Description                |
|------------|----------|------------|---------|------------|--------------|----------------------------|
| Name       | No       | Text input | ""      | None       | When canEdit | Attendee name              |
| Job Title  | No       | Text input | ""      | None       | When canEdit | Attendee job title         |
| Management | No       | Text input | ""      | None       | When canEdit | Attendee's management/area |
| Signature  | No       | Text input | ""      | None       | When canEdit | Signature (free text)      |

### Opening Meeting — Topics discussed / Agreed actions

| Field               | Required | Type       | Default                       | Validation | Editable     | Description          |
|---------------------|----------|------------|-------------------------------|------------|--------------|----------------------|
| # (Subject row)     | No       | Text input | auto-set to row number on add | None       | When canEdit | Sequence number      |
| Subject             | No       | Text input | ""                            | None       | When canEdit | Topic subject        |
| Details/Notes       | No       | Textarea   | ""                            | None       | When canEdit | Topic detail         |
| # (Action row)      | No       | Text input | auto-set to row number        | None       | When canEdit | Sequence number      |
| Action required     | No       | Textarea   | ""                            | None       | When canEdit | Agreed action        |
| Official            | No       | Text input | ""                            | None       | When canEdit | Responsible official |
| Implementation Date | No       | Date input | ""                            | HTML date  | When canEdit | Target date          |

### Findings Discussion — Notes Discussed / Agreed Actions

| Field               | Required | Type       | Default         | Validation | Editable     | Description                  |
|---------------------|----------|------------|-----------------|------------|--------------|------------------------------|
| #                   | No       | Text input | auto row number | None       | When canEdit | Sequence number              |
| Note                | No       | Textarea   | ""              | None       | When canEdit | Preliminary observation      |
| Degree of Risk      | No       | Text input | ""              | None       | When canEdit | Risk degree (free text)      |
| Management Response | No       | Textarea   | ""              | None       | When canEdit | Auditee response             |
| Proposed Action     | No       | Textarea   | ""              | None       | When canEdit | Proposed action              |
| Implementation Date | No       | Date input | ""              | HTML date  | When canEdit | Action date (Agreed Actions) |
| Official            | No       | Text input | ""              | None       | When canEdit | Responsible official         |
| Procedure           | No       | Textarea   | ""              | None       | When canEdit | Procedure/action description |

### Closing Meeting — Summary of Audit Results / Decisions taken

| Field               | Required | Type       | Default         | Validation | Editable     | Description                     |
|---------------------|----------|------------|-----------------|------------|--------------|---------------------------------|
| #                   | No       | Text input | auto row number | None       | When canEdit | Sequence number                 |
| Key Note            | No       | Textarea   | ""              | None       | When canEdit | Key result/observation          |
| Degree of Risk      | No       | Text input | ""              | None       | When canEdit | Risk degree                     |
| Recommendation      | No       | Textarea   | ""              | None       | When canEdit | Recommendation                  |
| Management Response | No       | Textarea   | ""              | None       | When canEdit | Auditee response                |
| Implementation Date | No       | Date input | ""              | HTML date  | When canEdit | Decision date (Decisions taken) |
| Official            | No       | Text input | ""              | None       | When canEdit | Responsible official            |
| Decision            | No       | Textarea   | ""              | None       | When canEdit | Decision taken                  |

**Generic meetings model** ( MeetingMinutes + meetings API; prisma/schema.prisma:3371-3392 )



| Field                       | Required  | Type                                    | Default                                                | Validation                                                                                | Editable                             | Description                           |
|-----------------------------|-----------|-----------------------------------------|--------------------------------------------------------|-------------------------------------------------------------------------------------------|--------------------------------------|---------------------------------------|
| meetingType                 | Yes (API) | String — opening   discussion   closing | —                                                      | Must be one of opening , discussion , closing ; else HTTP 400 ( meetings/route.ts:88-93 ) | Set by component, not editable in UI | Meeting category                      |
| title                       | No        | Text input                              | null                                                   | trimmed → null if empty ( MeetingMinutes.tsx:181 )                                        | Yes                                  | Meeting title                         |
| meetingDate                 | No        | Date (picker)                           | null                                                   | Parsed to Date if present ( meetings/route.ts:109 )                                       | Yes                                  | Meeting date                          |
| location                    | No        | Text input                              | null                                                   | trimmed → null if empty                                                                   | Yes                                  | Location                              |
| attendees                   | No        | Textarea (free text)                    | null                                                   | trimmed → null if empty                                                                   | Yes                                  | Free-text / comma-separated attendees |
| agenda                      | No        | Textarea                                | null                                                   | trimmed → null if empty                                                                   | Yes                                  | Agenda                                |
| minutes                     | No        | Textarea                                | null                                                   | trimmed → null if empty                                                                   | Yes                                  | The MoM body                          |
| decisions                   | No        | Textarea                                | null                                                   | trimmed → null if empty                                                                   | Yes                                  | Agreed action plans / decisions       |
| status                      | No        | Select (Draft / Finalized)              | "Draft" ( schema.prisma:3384 , meetings/route.ts:115 ) | None enforced; only Draft/Finalized offered in UI                                         | Yes                                  | Meeting status                        |
| createdById / createdByName | —         | Auto (server)                           | session id / name                                      | —                                                                                         | No                                   | Recorder (shown as "Recorded by")     |

## Tables

### Structured-form row tables (Attendees, Topics/Notes/Summary, Actions/Decisions)

These are editable in-form tables, not data grids.

- **Columns** — as listed in the Field Reference per form.
- **Sorting / searching / filtering / pagination** — none. Rows display in entry order.
- **Row actions** — per-row **delete** (trash icon, when `canEdit` ).
- **Bulk actions** — none.
- **Add** — **Add Row** button per table (when `canEdit` ); newly added Topic/Note/Summary/Action rows get an auto-incremented "#" where applicable.
- **Empty state** — "No rows. Use Add Row."

### Generic meetings list ( MeetingMinutes )

- Renders as **cards**, not a table. List is fetched filtered by `type` and ordered by `meetingDate` desc, then `createdAt` desc ( meetings/route.ts:37-40 ).
- **Sorting / searching / filtering / pagination** — no UI controls; filtering is by meeting type only (passed as `?type=` ).
- **Row actions** — per-card **edit** and **delete** (when `canEdit` ).
- **Bulk actions** — none.

## Buttons & Actions

| Control                          | Permission            | Visible To                    | Action                                           | API                                                      | Success Msg                         | Failure Msg                                  | Audit Trail  | Notification |
|----------------------------------|-----------------------|-------------------------------|--------------------------------------------------|----------------------------------------------------------|-------------------------------------|----------------------------------------------|--------------|--------------|
| Save (Opening)                   | audit.fieldwork:edit  | Roles with edit, when canEdit | PUT opening-meeting form                         | PUT /api/internal-audit/engagements/[id]/opening-meeting | "Opening meeting form saved"        | "Failed to save opening meeting form"        | Not verified | Not verified |
| Export PDF (Opening)             | view (no edit needed) | All with view                 | Save then open PDF                               | PUT then GET .../opening-meeting/download                | (uses Save success)                 | "Failed to print" (print path)               | Not verified | Not verified |
| Save (Findings Discussion)       | audit.fieldwork:edit  | edit roles, canEdit           | PUT form                                         | PUT .../findings-discussion-meeting                      | "Findings discussion minutes saved" | "Failed to save findings discussion minutes" | Not verified | Not verified |
| Export PDF (Findings Discussion) | view                  | All with view                 | Save then open PDF                               | PUT then GET .../findings-discussion-meeting/download    | (uses Save success)                 | "Failed to print"                            | Not verified | Not verified |
| Save (Closing)                   | audit.fieldwork:edit  | edit roles, canEdit           | PUT form                                         | PUT .../closing-meeting                                  | "Closing meeting minutes saved"     | "Failed to save closing meeting minutes"     | Not verified | Not verified |
| Export PDF (Closing)             | view                  | All with view                 | Save then open PDF                               | PUT then GET .../closing-meeting/download                | (uses Save success)                 | "Failed to print"                            | Not verified | Not verified |
| Add Row (any structured table)   | audit.fieldwork:edit  | edit roles, canEdit           | Append empty row to client state                 | None (client only)                                       | —                                   | —                                            | No           | No           |
| Delete row (trash)               | audit.fieldwork:edit  | edit roles, canEdit           | Remove row from client state (persisted on Save) | None (client only)                                       | —                                   | —                                            | No           | No           |
| Add Minutes (generic)            | audit.fieldwork:edit  | edit roles                    | Open Add dialog                                  | (POST on submit)                                         | "Minutes added"                     | "Failed to save minutes"                     | Not verified | Not verified |
| Save/Add in dialog (generic)     | audit.fieldwork:edit  | edit roles                    | Create or update meeting                         | POST .../meetings or PATCH .../meetings/[meetingId]      | "Minutes added" / "Minutes updated" | "Failed to save minutes"                     | Not verified | Not verified |
| Edit (pencil, generic)           | audit.fieldwork:edit  | edit roles                    | Open Edit dialog                                 | PATCH .../meetings/[meetingId]                           | "Minutes updated"                   | "Failed to save minutes"                     | Not verified | Not verified |
| Delete (generic)                 | audit.fieldwork:edit  | edit roles                    | Delete meeting after confirm                     | DELETE .../meetings/[meetingId]                          | "Minutes deleted"                   | "Failed to delete minutes"                   | Not verified | Not verified |

Audit-trail logging and notifications are not implemented in the meeting API routes reviewed ( `meetings/route.ts` , `meetings/[meetingId]/route.ts` ) or the form components — hence "Not verified" / "No" above.

## Step-by-Step Instructions

### Record / edit an Opening Meeting

1. Open the engagement at `/internal-audit/engagement/[id]` .
2. In the stepper, click the **Opening Meeting** step.
3. The **Audit Task Opening Meeting Minutes** form loads (existing values, if any, are fetched on open).
4. Fill in the **Meeting Details** fields (Management, Department, Audit Task Number, Assignment Title, History, Meeting Venue).
5. Enter the **Objective of the meeting**.
6. Under **Attendees**, click **Add Row** and fill Name, Job Title, Management, Signature for each attendee. Use the trash icon to remove a row.
7. Under **Topics discussed**, click **Add Row** and enter Subject and Details/Notes (the # auto-fills).
8. Under **Agreed actions**, click **Add Row** and enter Action required, Official, Implementation Date.
9. Click **Save**. On success the toast "Opening meeting form saved" appears.
10. (Optional) Click **Export PDF** to save the form and open the generated PDF in a new tab.

### Record / edit a Findings Discussion meeting

1. Click the **Findings Discussion** step.
2. Complete **Meeting Details** and **Attendees** as above.
3. Under **Notes Discussed**, add rows with Note, Degree of Risk, Management Response, Proposed Action.
4. Under **Agreed Actions**, add rows with Implementation Date, Official, Procedure.
5. Click **Save** ("Findings discussion minutes saved").

### Record / edit a Closing Meeting

1. Click the **Closing Meeting** step.
2. Complete **Meeting Details** and **Attendees**.
3. Under **Summary of Audit Results**, add rows with Key Note, Degree of Risk, Recommendation, Management Response.
4. Under **Decisions taken**, add rows with Implementation Date, Official, Decision.
5. Click **Save** ("Closing meeting minutes saved").

**Generic meetings (only if the `MeetingMinutes` fallback is reached)**

1. Click **Add Minutes** to open the dialog.
2. Enter Title, Meeting Date, Location, Attendees, Agenda, Minutes, Decisions & Action Plans, and choose Status (Draft / Finalized).
3. Click **Add** ("Minutes added"). To change later, click the pencil (Edit) icon, edit, and click **Save** ("Minutes updated").
4. To remove, click the trash icon, then confirm in the **Delete Minutes** dialog ("Minutes deleted").

## Workflow

The structured forms use a single-document **PUT (upsert/save)** model — there is no multi-status transition workflow.

| Current Status | User Action        | Validation                | API                                                                                                                    | DB Update                       | Audit Trail  | Notification | Next Status    | Next User            |
|----------------|--------------------|---------------------------|------------------------------------------------------------------------------------------------------------------------|---------------------------------|--------------|--------------|----------------|----------------------|
| (form, any)    | Edit fields + Save | None enforced client-side | PUT <code>.../opening-meeting</code>   <code>.../findings-discussion-meeting</code>   <code>.../closing-meeting</code> | Saves the meeting form document | Not verified | Not verified | (same — saved) | Same/any team member |

Generic meetings model status flow:

| Current Status    | User Action                | Validation                                                                                    | API                                          | DB Update                                                                 | Audit Trail  | Notification | Next Status      | Next User |
|-------------------|----------------------------|-----------------------------------------------------------------------------------------------|----------------------------------------------|---------------------------------------------------------------------------|--------------|--------------|------------------|-----------|
| (none)            | Add Minutes                | <code>meetingType</code> must be opening/discussion/closing; tenant + customer account checks | POST <code>.../meetings</code>               | Create <code>AuditEngagementMeeting</code> (status default <b>Draft</b> ) | Not verified | Not verified | <b>Draft</b>     | Same      |
| Draft             | Edit, set status Finalized | Tenant/ownership check                                                                        | PATCH <code>.../meetings/[meetingId]</code>  | Update fields incl. status                                                | Not verified | Not verified | <b>Finalized</b> | Same      |
| Draft / Finalized | Delete                     | Tenant/ownership check                                                                        | DELETE <code>.../meetings/[meetingId]</code> | Hard delete                                                               | Not verified | Not verified | (removed)        | —         |

The engagement-level stepper marks a stage as **completed** / **current** based on the engagement progress state ( `page.tsx:294-327` ); completion of a meeting stage is driven by the engagement progress mechanism, not by the meeting form itself.

## Status Reference

The **structured** Opening / Findings Discussion / Closing forms have **no status field** — they are saved documents.

The **generic meetings model** has two implemented statuses ( `schema.prisma:3384` ; `MeetingMinutes.tsx:453-454` ):

| Status           | Meaning                                         | How reached                                                      | Who can change                               | Next statuses           |
|------------------|-------------------------------------------------|------------------------------------------------------------------|----------------------------------------------|-------------------------|
| <b>Draft</b>     | Default on create; minutes still being prepared | On create (default) or by selecting Draft in the Status dropdown | Roles with <code>audit.fieldwork:edit</code> | Finalized               |
| <b>Finalized</b> | Minutes completed; badge shown green            | Select <b>Finalized</b> in the Status dropdown and save          | Roles with <code>audit.fieldwork:edit</code> | Draft (can be set back) |

(There is no enforced one-way transition; the dropdown allows either value at any time. `MeetingMinutes.tsx:443-457` )

## Validation Rules

- **Structured forms:** no required-field, duplicate, or business validation. All fields are optional; arrays default to empty. The only date inputs use the browser's HTML date control. Permission to **save** requires `audit.fieldwork:edit` ; the Save button is hidden when not editable.
- **Generic meetings API (POST):** `meetingType` is required and must be one of `opening` , `discussion` , `closing` , else **HTTP 400** "meetingType is required and must be one of: opening, discussion, closing" ( `meetings/route.ts:88-93` ). User must have a customer account assigned, else **HTTP 400** "User does not have a customer account assigned" ( `meetings/route.ts:95-100` ). The engagement must exist in the user's tenant, else **HTTP 404** "Engagement not found" ( `meetings/route.ts:64-74` ).
- **Generic meetings API (PATCH/DELETE):** the meeting must exist within the engagement and tenant, else **HTTP 404** "Meeting not found" ( `meetings/[meetingId]/route.ts:49-54,99-104` ). PATCH applies only the fields present in the body (partial update); empty strings from the form are sent as `null` after trimming ( `MeetingMinutes.tsx:179-189` ).
- **No approval check** applies to meetings (the `approve` action is not used here).

## Success Scenarios and Failure Scenarios

### Success

- Saving a structured form → toast "Opening meeting form saved" / "Findings discussion minutes saved" / "Closing meeting minutes saved".

- Export PDF → after a successful save, the generated PDF opens in a new browser tab ( `.../download` ).
- Generic create/update/delete → "Minutes added" / "Minutes updated" / "Minutes deleted".

## Failure

- **Load failure** (GET non-OK): the form/list resets to empty and a toast is shown — "Failed to load opening meeting form", "Failed to load findings discussion", "Failed to load closing meeting", or "Failed to load meeting minutes". *Resolution:* refresh; verify the engagement exists and you have `audit.fieldwork:view`.
- **Save failure** (PUT/POST/PATCH non-OK): toast "Failed to save opening meeting form" / "Failed to save findings discussion minutes" / "Failed to save closing meeting minutes" / "Failed to save minutes". *Resolution:* confirm you have edit permission and the engagement still exists; retry.
- **Invalid meeting type (generic API only):** HTTP 400 with the meetingType message above. *Resolution:* this is a system-level guard; the UI always supplies a valid type.
- **No customer account (generic create):** HTTP 400. *Resolution:* ensure the user is assigned to a customer account.
- **Engagement / meeting not found:** HTTP 404. *Resolution:* verify the URL/engagement and tenant.
- **Delete failure:** toast "Failed to delete minutes". *Resolution:* retry; confirm permission.
- **Print failure:** toast "Failed to print".

## System Behaviour

- **Read-only mode:** When the engagement report has been generated, `canEdit` is false ( `page.tsx:103` ), hiding Save / Add Row / edit / delete; all inputs render disabled.
- **Auto-population:** structured forms load existing saved values on open; new Topic/Note/Summary/Action rows auto-set the "#" to the next sequence number.
- **Default status:** generic meetings are created with status **Draft** (server default).
- **Recorder capture:** the generic create stores `createdById` and `createdByName` from the session, shown as "Recorded by {name}" (or "Unknown").
- **Tenant isolation:** all meeting reads/writes are filtered by tenant ( `getTenantFilter` ), and meetings cascade-delete with their engagement ( `schema.prisma:3375`, `onDelete: Cascade` ).
- **Audit-trail logging / notifications: not implemented** in the meeting routes or components reviewed.
- **Export/print:** Export PDF first performs a Save, then fetches `.../download`; the print path fetches the PDF blob and opens it for printing.

## Notes / Warnings / Tips

- **Structured vs generic:** Users normally interact with the three **structured MoM forms**, not the generic Add/Edit Minutes dialog. The generic `meetings` API still exists and stores `AuditEngagementMeeting` rows, but with the current stage configuration the `MeetingMinutes` fallback UI is not displayed for the standard stages.
- **Save before exporting:** Export PDF and Print both save first; unsaved edits are persisted as part of exporting.
- **Department scope:** the "Auditor" role (internal `Auditee`) is department-scoped for `audit.fieldwork`; it can record/edit meeting minutes only within its department scope.
- **No required fields:** because nothing is mandatory, an empty meeting can be saved — encourage teams to at least record Attendees and the Minutes/Notes for a meaningful audit record.

# Fieldwork

## Overview — Purpose, Business Objective

The Fieldwork module is where the audit team executes the audit work for a specific **Audit Engagement**. Within a single engagement it lets the team:

- Maintain and download **Workpapers** (uploaded supporting files).
- Generate, edit, and download **AI-Generated Workpapers** (an audit program of procedures: Task / Evidences / Steps / Question Checklist / Comments, with an *Executed* flag).
- Build an **Audit Engagement Task List** (numbered tasks with an attached document, an *Executed* checkbox, and comments).
- Raise **Evidence Requests** to Auditors, collect their uploaded attachments, run an AI Review on the submitted evidence, and (for Audit Head / Audit Manager) approve or return them for clarification.
- Record **Findings** (a short form and a full CCCE form with CAPA fields) against the engagement.
- Store **Other Documents** (titled reference documents).
- Add free-text **Engagement Comments**.
- Mark the engagement **Completed**, which locks the page to read-only.

Business objective: provide a single working area where audit procedures are performed, evidence is gathered and assessed (assisted by AI), and findings are captured — feeding the downstream Findings, CAPA, and Report modules.

## Access — Which of the three roles can use it + the exact permission(s) required

All Fieldwork pages and APIs are gated on the resource `audit.fieldwork` ( `permissions.ts:117` maps the resource to `/internal-audit/fieldwork` ). Actions used by the APIs are exactly `view`, `create`, `edit`, `delete` (no `approve`, no `export` ).

| Role (display) | Internal key                                  | <code>audit.fieldwork</code> grant          | Scope      | Source                          |
|----------------|-----------------------------------------------|---------------------------------------------|------------|---------------------------------|
| Audit Head     | <code>AuditHead</code>                        | <code>*</code> (view, create, edit, delete) | all        | <code>permissions.ts:445</code> |
| Audit Manager  | <code>AuditManager</code>                     | <code>*</code> (view, create, edit, delete) | all        | <code>permissions.ts:471</code> |
| Auditor        | <code>Auditee</code> (displayed as "Auditor") | <code>view</code> , <code>edit</code>       | department | <code>permissions.ts:534</code> |

Notes from the page logic ( `fieldwork/[id]/page.tsx:196-208` ): the page treats `AuditHead` and the legacy `Auditor` key as the "audit team" ( `isAuditTeam` ); a user who holds only `Auditee` is `isAuditeeOnly` and sees a reduced, card-based view. Many create/delete controls are guarded in the UI behind `isAuditTeam`, while the department-scoped Auditor ( `Auditee` key) is limited to `view` / `edit` server-side.

The single-evidence-request GET/PUT route additionally blocks an Auditee-only user from accessing a request that is not assigned to them, returning **403** with "You do not have access to this evidence request" / "...to update this evidence request" ( `[id]/route.ts:55-60`, `97-103` ).

## Prerequisites — what must already exist before using this module

- An **Audit Engagement** must already exist (created under Audit Engagement / planning). Fieldwork operates per engagement; the list page reads engagements from `/api/internal-audit/engagements` ( `fieldwork/page.tsx:154` ).
- To assign an Evidence Request or a Finding's Responsible Person, eligible **Auditors / auditees** must exist (loaded via `/api/users/my-auditees`, filtered by the engagement's department — `fieldwork/[id]/page.tsx:610-627` ).
- For **AI Review, AI-Generated Workpapers**, and AI queries, the external AI service must be configured (server-side `PYTHON_API_SECRET`; if missing the AI Review route returns "Server misconfiguration: missing API secret" — `ai-review/route.ts:117-123` ).

**Screenshot:** *Insert screenshot here*

The Fieldwork **list page** ( `/internal-audit/fieldwork` ) shows:

- A **breadcrumb**: Internal Audit > (Dashboard link, only if the user can view the dashboard) > **Fieldwork**.
- A page **header** titled **Fieldwork**.
- A white card containing a **search box** (placeholder *Search engagements...*) and three filter dropdowns (**All Status**, **All Auditors**, **All Departments**), a sortable **table** of engagements, and **pagination** at the bottom.

The Fieldwork **detail page** ( `/internal-audit/fieldwork/[id]` ) shows a breadcrumb (ending in the engagement's Audit ID), a header with the engagement title and Audit ID, a **Completed** badge when applicable, and a stack of collapsible sections (Engagement Details, Workpapers, AI-Generated Workpapers, Evidence Request — plus Task List in the embedded modal view).

## Page Layout

### Fieldwork list page ( `fieldwork/page.tsx` )

- **Breadcrumb** ( Internal Audit > Dashboard \* > Fieldwork ).
- **Header**: Fieldwork .
- **Search & filters bar**: text search; **Status** select (All Status, Planned, In Progress, Completed); **Auditor** select (All Auditors + list); **Department** select (All Departments + list).
- **Table** with sortable headers (see Tables).
- **Pagination** (10 rows per page).
- **Loading** state (spinner with *Loading...*); **Unauthorized** state when the user lacks `audit.fieldwork:view` (You don't have permission to access Fieldwork.).

- Row action opens the **Fieldwork Detail Modal** (in-page modal, not a route).

**Fieldwork detail page** ( `fieldwork/[id]/page.tsx` )

Collapsible sections, each a card with a chevron toggle:

1. **Engagement Details : {Audit ID} - {Title}** — header actions: **Comments** button (hidden for Auditee-only), **Mark as Completed** button (hidden for Auditee-only and when already Completed). Body shows read-only fields: *Engagement ID, Title, Audit Manager, Timeline* (start to end), *Status, Department*.
2. **Workpapers** (hidden for Auditee-only) — **Upload Workpaper** button (audit team); list of files each with **View, Download, and Delete** (audit team) actions; empty text *No workpapers uploaded yet*.
3. **AI-Generated Workpapers** (hidden for Auditee-only) — overview count (*N procedure(s)*), **Download Audit Program** button (when any exist), **Generate Workpaper with AI** button (audit team). Table columns: *Task* (with *Executed* checkbox), *Evidences, Steps, Question Checklist, Comments, Action* (Edit / Delete, audit team). Empty text *No AI-generated workpapers available*.
4. **Evidence Request — AI Review (N)** button (audit team, when rows selected), **Add Evidence Request** button (audit team). Auditors-only see a card-based layout; the audit team sees a table. Empty text *No evidence requests found*.

The **Task List** (*Audit Engagement Task List*) is rendered in the embedded **Fieldwork Detail Modal** as a tab ( `FieldworkDetailModal.tsx:1317-1431` ) with an **Add Task** button and columns *Ref No, Task, Document, Executed, Comments, Action* (Save / Delete).

**Dialogs present on the detail page**

Comments (*Engagement Comments*), Upload (*Upload Workpaper/Document*), Add Finding, Add Finding (full CCCE form), Add Evidence Request, plus view/edit/delete dialogs for documents, evidence requests, attachments, AI workpapers, and a **Generate AI Workpapers** preview dialog, an **AI Review** result dialog, a **Need Clarification** dialog, and an Auditor **Submit Response** dialog.

**Add Evidence Request page** ( `fieldwork/add/page.tsx` )

A full-page form titled **New Evidence Request** with breadcrumb ending in *Add Fieldwork*. Fields: Audit Engagement, Evidence Title, Description, Request Type, Sample Size, Control Reference, Priority, Status, Assign to Auditor, Due Date; collapsible **Testing Procedure Details** and **Auditor Notes**; a drag-and-drop **Attach Reference Documents** area; **Cancel** and **Create Evidence Request** buttons.

**Add Finding page** ( `fieldwork/[id]/add-finding/page.tsx` )

A full-page form (header crumb *Add New Findings*). Fields: Finding Title, Severity, Criteria (What should be), Condition (What is), Cause (Why it happened), Effect (The consequence), Recommendation, Upload Attachment, then a **Corrective & Preventive Actions (CAPA)** section (Responsible Person, Status, Target Closure Date). **Cancel / Save**.

**Field Reference**

**Add Evidence Request — full page** ( `fieldwork/add/page.tsx` )

| Field                      | Required | Type     | Default  | Validation                                                                                                                | Editable | Description                             |
|----------------------------|----------|----------|----------|---------------------------------------------------------------------------------------------------------------------------|----------|-----------------------------------------|
| Audit Engagement           | Yes      | Select   | —        | Must be selected ( <i>Please select an Audit Engagement</i> )                                                             | Yes      | Engagement the request belongs to       |
| Evidence Title             | Yes      | Text     | —        | Non-empty ( <i>Evidence Title is required</i> )                                                                           | Yes      | Title of the evidence requested         |
| Description                | No       | Textarea | —        | —                                                                                                                         | Yes      | Free text                               |
| Request Type               | No       | Select   | — (none) | One of Document, Screenshot, System Export, Report, Log File, Policy Document, Procedure Document, Interview Notes, Other | Yes      | Type of evidence                        |
| Sample Size                | No       | Text     | —        | —                                                                                                                         | Yes      | e.g. "25 samples", "Full population"    |
| Control Reference          | No       | Text     | —        | —                                                                                                                         | Yes      | e.g. CTRL-001                           |
| Priority                   | No       | Select   | Medium   | Low / Medium / High / Critical                                                                                            | Yes      | Request priority                        |
| Status                     | No       | Select   | Pending  | Pending / In Progress / Submitted / Reviewed                                                                              | Yes      | Initial status                          |
| Assign to Auditor          | No       | Select   | —        | —                                                                                                                         | Yes      | Auditee/Auditor user                    |
| Due Date                   | Yes      | Date     | —        | Required ( <i>Due Date is required</i> )                                                                                  | Yes      | When evidence is due                    |
| Testing Procedure          | No       | Textarea | —        | —                                                                                                                         | Yes      | In collapsible section                  |
| Expected Evidence          | No       | Textarea | —        | —                                                                                                                         | Yes      | In collapsible section                  |
| Auditor Notes (Internal)   | No       | Textarea | —        | —                                                                                                                         | Yes      | Internal notes (not visible to Auditor) |
| Attach Reference Documents | No       | File(s)  | —        | Accepts .pdf,.doc,.docx,.xls,.xlsx,.png,.jpg,.jpeg                                                                        | Yes      | Drag/drop or browse                     |

Note: although the page sends all fields to `POST /api/internal-audit/fieldwork`, the server only persists `engagementId`, `title`, `description`, `sampleSize`, `dueDate`, `auditeeId`, `auditeeName`, and `status` ( `fieldwork/route.ts:158-168` ). Files attached on this page are held client-side; this page does not have a documented upload-after-create step for them.

**Add Evidence Request — in-page dialog** ( `fieldwork/[id]/page.tsx` )

| Field                      | Required | Type     | Default | Validation                                                           | Editable | Description                                                                         |
|----------------------------|----------|----------|---------|----------------------------------------------------------------------|----------|-------------------------------------------------------------------------------------|
| Title                      | Yes      | Text     | —       | Non-empty; must be unique (case-insensitive) among existing requests | Yes      | <i>Evidence title is required / Evidence request with this title already exists</i> |
| Description                | No       | Textarea | —       | —                                                                    | Yes      | Free text                                                                           |
| Auditor                    | Yes      | Select   | —       | Required ( <i>Auditor is required</i> )                              | Yes      | Assigned auditee                                                                    |
| (Sample/Number of samples) | No       | Text     | —       | —                                                                    | Yes      | numberOfSamples                                                                     |

#### Add Finding — short dialog ( `fieldwork/[id]/page.tsx` )

| Field          | Required | Type     | Default | Validation                                                                                   | Editable | Description   |
|----------------|----------|----------|---------|----------------------------------------------------------------------------------------------|----------|---------------|
| Title          | Yes      | Text     | —       | Non-empty; <i>Only letters, spaces, and hyphens are allowed</i> ( <code>isValidName</code> ) | Yes      | Finding title |
| Description    | No       | Textarea | —       | —                                                                                            | Yes      | —             |
| Severity       | No       | Select   | Medium  | Low / Medium / High / Critical                                                               | Yes      | —             |
| Recommendation | No       | Textarea | —       | —                                                                                            | Yes      | —             |

Created with `status: "Open"` .

#### Add Finding — full CCCE dialog ( `fieldwork/[id]/page.tsx` )

| Field                     | Required | Type     | Default           | Validation                                         | Editable | Description                           |
|---------------------------|----------|----------|-------------------|----------------------------------------------------|----------|---------------------------------------|
| Finding Title             | Yes      | Text     | —                 | Non-empty; letters/spaces/hyphens only             | Yes      | —                                     |
| Severity                  | No       | Select   | (Medium if blank) | Low / Medium / High / Critical                     | Yes      | —                                     |
| Finding Type              | No       | Select   | —                 | From <code>FINDING_TYPES</code>                    | Yes      | —                                     |
| Criteria (What should be) | No       | Textarea | —                 | —                                                  | Yes      | —                                     |
| Condition (What is)       | No       | Textarea | —                 | —                                                  | Yes      | —                                     |
| Cause (Why it happened)   | No       | Textarea | —                 | —                                                  | Yes      | —                                     |
| Effect (The consequence)  | No       | Textarea | —                 | —                                                  | Yes      | —                                     |
| Recommendation            | No       | Textarea | —                 | —                                                  | Yes      | —                                     |
| Upload Attachment         | No       | File(s)  | —                 | —                                                  | Yes      | Uploaded after the finding is created |
| Responsible Person        | Yes      | Select   | —                 | Required ( <i>Responsible person is required</i> ) | Yes      | CAPA owner                            |
| Status                    | No       | Select   | (Open if blank)   | Open / Under Review / Closed                       | Yes      | —                                     |
| Target Closure Date       | No       | Date     | —                 | —                                                  | Yes      | —                                     |

#### Add Finding — full page ( `add-finding/page.tsx` )

Same fields as above (Title, Severity, Criteria, Condition, Cause, Effect, Recommendation, Upload Attachment, Responsible Person, Status, Target Closure Date). Only **Finding Title** is validated as required (*Finding title is required*). Status options on this page are **Open / In Progress / Closed / Overdue**; Severity defaults to "Medium" if left at "Select severity".

#### Task (Task List)

| Field    | Required | Type      | Default         | Validation                                                                        | Editable         | Description               |
|----------|----------|-----------|-----------------|-----------------------------------------------------------------------------------|------------------|---------------------------|
| Ref No   | —        | Number    | auto (last + 1) | Server-assigned, read-only                                                        | No               | Sequential per engagement |
| Task     | No       | Text      | empty           | <i>Special characters are not allowed</i> ( <code>isValidNameWithNumbers</code> ) | Yes (audit team) | Task description          |
| Document | No       | File link | none            | Accepts .pdf,.doc,.docx,.xls,.xlsx,.png,.jpg,.jpeg                                | Yes (audit team) | Uploaded document         |
| Executed | No       | Checkbox  | false           | —                                                                                 | Yes (audit team) | Done flag                 |
| Comments | No       | Text      | empty           | —                                                                                 | Yes (audit team) | —                         |

#### Other Document (Upload Document dialog)

| Field          | Required | Type        | Default | Validation                                                  | Editable | Description |
|----------------|----------|-------------|---------|-------------------------------------------------------------|----------|-------------|
| Document title | Yes      | Text        | —       | Non-empty ( <i>Document title is required</i> )             | Yes      | —           |
| Document Type  | No       | Text/Select | —       | —                                                           | Yes      | —           |
| Description    | No       | Textarea    | —       | —                                                           | Yes      | —           |
| File           | Yes      | File        | —       | At least one file ( <i>Please select a file to upload</i> ) | Yes      | —           |

### Tables

**Engagement list table ( `fieldwork/page.tsx` )**

- **Columns** (all sortable except Action): *Audit ID, Name, Audit Manager, Start Date, Target Date, Status, Action*.
- **Sorting**: click a header to toggle ascending/descending (client-side).
- **Search**: client-side across Audit ID, engagement title, auditor name, department.
- **Filtering**: Status and Department filters are sent to the engagements API; Auditor filter is applied client-side.
- **Pagination**: 10 items per page ( `itemsPerPage = 10` ).
- **Row action**: when status is **Completed**, an **Eye / View Details** icon opens the detail modal in view mode; otherwise a **Pencil / Edit** icon opens it in edit mode.
- Empty state: *No fieldwork items found*.

**AI-Generated Workpapers table**

Columns: *Task, Evidences, Steps, Question Checklist, Comments, Action* (audit team only). No sorting/pagination. Evidences/Steps/Question Checklist render as bullet lists when stored as JSON arrays.

**Evidence Request table (audit team view)**

Columns: a select-all checkbox, *Title, Description, Auditor, Samples, Status* (colored chip), *AI Review, Action* (View / Add Attachment / Edit / Delete). Auditors (Auditee-only) instead see a **card** per request with a checkbox, title/sample/description, AI Review status, and **View Details / Add Attachment** icons.

**Task List table**

Columns: *Ref No, Task, Document, Executed, Comments, Action* (Save / Delete). For Auditee-only users the Action column is hidden and fields are read-only. Empty state: *No tasks yet (Click "Add Task" to create one for the audit team)*.

**Buttons & Actions**

---



| Control                                 | Permission | Visible To                         | Action                                     | API                                                      | Success Msg                                      | Failure Msg                                                     | Audit Trail  | Notification |
|-----------------------------------------|------------|------------------------------------|--------------------------------------------|----------------------------------------------------------|--------------------------------------------------|-----------------------------------------------------------------|--------------|--------------|
| Create Evidence Request (add page)      | create     | Audit team                         | Create evidence request                    | POST /fieldwork                                          | Evidence Request created successfully            | Failed to create evidence request / server error                | Not verified | Not verified |
| Add Evidence Request (dialog)           | create     | Audit team                         | Create request                             | POST /fieldwork/{id}/evidence-requests                   | Evidence request added successfully              | Failed to add evidence request                                  | Not verified | Not verified |
| Edit (evidence) → Save                  | edit       | Audit team                         | Update request                             | PATCH /fieldwork/{id}/evidence-requests/{rid}            | Evidence request updated successfully            | Failed to update evidence request                               | Not verified | Not verified |
| Delete (evidence)                       | delete     | Audit team                         | Delete request                             | DELETE /fieldwork/{id}/evidence-requests/{rid}           | Evidence request deleted successfully            | Failed to delete evidence request                               | Not verified | Not verified |
| Add Attachment / Upload (evidence)      | edit       | Audit team; Auditor on own request | Upload file(s)                             | POST /fieldwork/{id}/evidence-requests/{rid}/attachments | Attachment uploaded successfully                 | Failed to upload attachment                                     | Not verified | Not verified |
| Approve evidence (set Reviewed)         | edit       | Audit team                         | Set status Reviewed                        | PATCH /fieldwork/{id}/evidence-requests/{rid}            | Evidence request approved                        | Failed to approve evidence request                              | Not verified | Not verified |
| Send clarification (Need Clarification) | edit       | Audit team                         | Return for clarification                   | PATCH /fieldwork/{id}/evidence-requests/{rid}            | The document has been returned for clarification | Failed to request clarification                                 | Not verified | Not verified |
| Submit Response (Auditor)               | edit       | Auditor (auditee)                  | Upload + set Submitted on pending requests | attachments POST + PATCH .../evidence-requests/{rid}     | Response submitted successfully                  | Failed to send response                                         | Not verified | Not verified |
| AI Review (N)                           | edit/view  | Audit team                         | Run AI review on selected                  | POST /fieldwork/{id}/ai-review                           | AI Review generated successfully                 | Failed to generate AI review                                    | Not verified | Not verified |
| Upload Workpaper → Upload               | create     | Audit team                         | Upload files (category workpapers)         | POST /fieldwork/{id}/upload                              | Files uploaded successfully                      | Failed to upload files                                          | Not verified | Not verified |
| Delete (workpaper)                      | delete     | Audit team                         | Delete workpaper                           | DELETE /fieldwork/{id}/workpapers/{wid}                  | Workpaper deleted successfully                   | Failed to delete workpaper                                      | Not verified | Not verified |
| Generate Workpaper with AI              | create     | Audit team                         | Generate proposals                         | POST /fieldwork/{id}/ai-workpapers/generate              | (adds via next step)                             | Failed to generate AI workpapers                                | Not verified | Not verified |
| Add selected (generated WPs)            | create     | Audit team                         | Persist selected                           | POST /fieldwork/{id}/ai-workpapers/add                   | Workpapers added successfully                    | Failed to add workpapers / Please select at least one workpaper | Not verified | Not verified |
| Edit AI workpaper → Save                | edit       | Audit team                         | Update                                     | PATCH /fieldwork/{id}/ai-workpapers/{wid}                | AI Workpaper updated successfully                | Failed to update AI Workpaper / Task is required                | Not verified | Not verified |
| Delete AI workpaper                     | delete     | Audit team                         | Delete                                     | DELETE /fieldwork/{id}/ai-workpapers/{wid}               | AI Workpaper deleted successfully                | Failed to delete AI Workpaper                                   | Not verified | Not verified |
| Executed checkbox (AI WP)               | edit       | Audit team                         | Toggle executed                            | PATCH /fieldwork/{id}/ai-workpapers/{wid}                | (silent)                                         | (logged to console)                                             | Not verified | Not verified |
| Download Audit Program                  | view       | All viewers                        | Download program                           | GET /fieldwork/{id}/ai-workpapers/download               | —                                                | —                                                               | Not verified | Not verified |
| Add Task                                | create     | Audit team                         | Create blank task (auto Ref No)            | POST /fieldwork/{id}/tasks                               | (refreshes list)                                 | Failed to add task                                              | Not verified | Not verified |
| Save task                               | edit       | Audit team                         | Update task fields                         | PATCH /fieldwork/{id}/tasks                              | Task saved successfully                          | Failed to save task / Special characters are not allowed        | Not verified | Not verified |
| Upload (task document)                  | create     | Audit team                         | Upload task file                           | POST /fieldwork/{id}/tasks/{tid}/document                | Document uploaded successfully                   | Failed to upload document                                       | Not verified | Not verified |

| Control                        | Permission | Visible To  | Action                                  | API                                                | Success Msg                    | Failure Msg                                    | Audit Trail  | Notification |
|--------------------------------|------------|-------------|-----------------------------------------|----------------------------------------------------|--------------------------------|------------------------------------------------|--------------|--------------|
| Delete task                    | delete     | Audit team  | Delete task (confirm dialog)            | DELETE /fieldwork/{id}/tasks?taskId=               | Task deleted successfully      | Failed to delete task                          | Not verified | Not verified |
| Add Finding (short)            | create     | Audit team  | Create finding (status Open)            | POST /fieldwork/{id}/findings                      | Finding added successfully     | Failed to add finding / validation toasts      | Not verified | Not verified |
| Save (full finding)            | create     | Audit team  | Create finding + attachments            | POST /fieldwork/{id}/findings (+ attachments POST) | Finding added successfully     | server error / Failed to add finding           | Not verified | Not verified |
| Delete finding                 | delete     | Audit team  | Delete finding                          | DELETE /fieldwork/{id}/findings/{fid}              | Finding deleted successfully   | Failed to delete finding                       | Not verified | Not verified |
| Add Document (Other Documents) | create     | Audit team  | Upload titled document (category other) | POST /fieldwork/{id}/upload                        | Document uploaded successfully | Failed to upload document / validation         | Not verified | Not verified |
| Edit document → Save           | edit       | Audit team  | Update metadata                         | PATCH /fieldwork/{id}/other-documents/{docId}      | Document updated successfully  | Failed to update document                      | Not verified | Not verified |
| Delete document                | delete     | Audit team  | Delete                                  | DELETE /fieldwork/{id}/other-documents/{docId}     | Document deleted successfully  | Failed to delete document                      | Not verified | Not verified |
| Add Comment                    | view*      | Non-auditee | Add engagement comment                  | POST /engagements/{id}/comments                    | Comment added successfully     | Failed to add comment / Please enter a comment | Not verified | Not verified |
| Mark as Completed              | edit       | Audit team  | Set engagement Completed                | PATCH /engagements/{id}                            | Engagement marked as completed | Failed to mark engagement as completed         | Not verified | Not verified |

(\*Comments use the engagements API, not the fieldwork resource; the button is simply hidden for Auditee-only users in the UI.)

Audit Trail and Notification cells are marked **Not verified** because the Fieldwork route handlers reviewed do not themselves write audit-trail entries or send notifications; any such behavior would originate elsewhere and was not confirmed in these files.

## Step-by-Step Instructions

### Open an engagement for fieldwork

1. Open **Fieldwork** (the engagement list).
2. Optionally search or filter by **Status**, **Auditor**, or **Department**.
3. In the row's **Action** column, click the **Pencil** (Edit) icon to open the detail modal in edit mode, or the **Eye** (View Details) icon if the engagement is **Completed** (read-only).

### Upload a workpaper

1. Expand **Workpapers**.
2. Click **Upload Workpaper**.
3. Drag files into the drop zone or click to browse (PDF, DOC, DOCX, XLS, XLSX, PNG, JPG).
4. Click **Upload**. On success: *Files uploaded successfully*.

### Generate AI workpapers

1. Expand **AI-Generated Workpapers**.
2. Click **Generate Workpaper with AI**; wait for the **Generating...** state.
3. In the preview dialog, select the proposed workpapers you want.
4. Click to add the selected ones; on success: *Workpapers added successfully*.
5. Optionally click **Download Audit Program** to export the program.

### Add and run AI Review on evidence

1. Expand **Evidence Request**; click **Add Evidence Request**.
2. Enter **Title** (unique) and **Auditor** (required); add Description / samples; save. On success: *Evidence request added successfully*.
3. Ask the Auditor to upload attachments (or use **Add Attachment** yourself).
4. Select one or more requests with the checkboxes; click **AI Review (N)**.
5. Review the result in the **AI Review** dialog. On success: *AI Review generated successfully*. If a selected request has no attachment, you are blocked with *Attachment not present. Please add attachments for: "..."*.

### Approve or return evidence (Audit Head / Audit Manager)

- To approve: set the request status to **Reviewed** (sets `aiReviewStatus` Satisfactory); on success: *Evidence request approved*.
- To return: open **Need Clarification**, enter a comment / document name, and send; on success: *The document has been returned for clarification* (request goes back to **Pending** with `aiReviewStatus` Needs Attention).

Auditor: submit a response

- 1. Open the engagement; in the **Evidence Request** card list, review your assigned requests.
- 2. Optionally attach files via **Add Attachment**.
- 3. Click **Submit Response**; on success: *Response submitted successfully* — all your **Pending** requests move to **Submitted** and any clarification fields are cleared.

Maintain the Task List

- 1. Open the **Tasks** tab (in the engagement modal).
- 2. Click **Add Task** (a new row with the next **Ref No** appears).
- 3. Fill in **Task** and **Comments**, upload a **Document**, tick **Executed** as needed.
- 4. Click **Save** (per row); on success: *Task saved successfully*. Use the trash icon to **Delete** (confirmation: *Delete Task?*).

Add a finding

- 1. Use the short **Add Finding** dialog (Title required) or the full CCCE form (Finding Title and Responsible Person required), or the full **Add Finding** page.
- 2. Optionally attach files.
- 3. Save; on success: *Finding added successfully*.

Complete the engagement

- 1. In **Engagement Details**, click **Mark as Completed**.
- 2. On success: *Engagement marked as completed*; the page becomes read-only.

Workflow

Evidence Request lifecycle

| Current Status | User Action                       | Validation                                    | API                                                  | DB Update                                              | Audit Trail  | Notification | Next Status | Next User  |
|----------------|-----------------------------------|-----------------------------------------------|------------------------------------------------------|--------------------------------------------------------|--------------|--------------|-------------|------------|
| (none)         | Audit team creates request        | Title required + unique; Auditor required     | POST .../evidence-requests                           | New row, status <b>Pending</b>                         | Not verified | Not verified | Pending     | Auditor    |
| Pending        | Auditor uploads + Submit Response | At least one pending request exists           | attachments POST + PATCH status Submitted            | status <b>Submitted</b> ; clarification fields cleared | Not verified | Not verified | Submitted   | Audit team |
| Submitted      | Audit team runs AI Review         | Each selected request must have an attachment | POST .../ai-review                                   | aiReviewStatus / aiReviewComment set                   | Not verified | Not verified | (unchanged) | Audit team |
| Submitted      | Audit team approves               | —                                             | PATCH status Reviewed, aiReviewStatus Satisfactory   | status <b>Reviewed</b>                                 | Not verified | Not verified | Reviewed    | (done)     |
| Submitted      | Audit team requests clarification | —                                             | PATCH status Pending, aiReviewStatus Needs Attention | status <b>Pending</b> + clarification fields set       | Not verified | Not verified | Pending     | Auditor    |

Engagement completion

Current Status (any non-Completed) → **Mark as Completed** → PATCH /engagements/{id} → engagement status **Completed** → page becomes read-only for everyone.

Status Reference

Engagement status (shown/filtered on the list)

- **Planned** — engagement not started. Reached at engagement creation (outside Fieldwork). Row opens in edit mode.
- **In Progress** — work underway. Row opens in edit mode.
- **Completed** — locked. Reached via **Mark as Completed** (audit team). Page becomes read-only ( isCompleted → isReadOnly , [id]/page.tsx:232-235 ); row shows the **View Details** (Eye) icon.

Evidence Request status

- **Pending** — default at creation; also the state after a clarification request is sent. Changed by the audit team (edit) or the Auditor's submit.
- **In Progress** — selectable on the add page; intermediate.
- **Submitted** — set when the Auditor submits a response.
- **Reviewed** — set by the audit team when approving (with aiReviewStatus Satisfactory).

AI Review status values surfaced in the UI include *Relevant* (green check), *Irrelevant* (red X), *Partial / Needs Attention* (amber), and any other string (info icon) — [id]/page.tsx:211-226 .

Finding status

- Short dialog creates findings as **Open**.
- Full dialog status options: **Open / Under Review / Closed**.
- Full page status options: **Open / In Progress / Closed / Overdue** (defaults to Open).

## Validation Rules

- **Add Evidence Request (page):** Audit Engagement, Evidence Title, and Due Date are required (inline messages).
- **Add Evidence Request (dialog):** Title required and must be unique (case-insensitive); Auditor required.
- **Findings:** title required; *Only letters, spaces, and hyphens are allowed* ( `isValidName` ). Full dialog additionally requires a Responsible Person.
- **Tasks:** Task text must pass `isValidNameWithNumbers` (*Special characters are not allowed*).
- **Other Documents:** Document title and at least one file required.
- **AI Review:** at least one evidence request selected; every selected request must have an attachment, otherwise blocked with *Attachment not present...*
- **Permission / access checks (server):** all routes require `audit.fieldwork` (view/create/edit/delete as listed). The single-request route returns **403** if an Auditee-only user targets a request not assigned to them. `POST /fieldwork` returns **400** for missing engagement (*Engagement is required*) or missing title (*Evidence title is required*), and **404** if the engagement does not exist (*Engagement not found*).
- The PUT route restricts Auditee-only users to changing status to **Submitted** only; audit roles may update all fields ( `[id]/route.ts:106-126` ).

## Success Scenarios and Failure Scenarios

**Success** (toasts): *Files uploaded successfully, Workpapers added successfully, AI Workpaper updated/deleted successfully, Evidence request added/updated/deleted successfully, Attachment uploaded successfully, Evidence request approved, The document has been returned for clarification, Response submitted successfully, AI Review generated successfully, Task saved/deleted successfully, Document uploaded/ updated/deleted successfully, Finding added/deleted successfully, Comment added successfully, Engagement marked as completed.*

**Failures** and resolution:

- *Evidence request with this title already exists* — choose a different title.
- *Auditor is required / Evidence title is required* — fill the required field.
- *Attachment not present. Please add attachments for: "..."* — upload files to the named requests before running AI Review.
- *Special characters are not allowed* — remove special characters from a task.
- *Only letters, spaces, and hyphens are allowed* — correct the finding title.
- *Responsible person is required* — select a Responsible Person in the full finding form.
- *Failed to generate AI review / Failed to generate AI workpapers* — usually an AI service error; the route also returns *Server misconfiguration: missing API secret* when the AI secret is not configured.
- *You don't have permission to access Fieldwork.* — the user lacks `audit.fieldwork:view`.
- **403** *You do not have access to this/update this evidence request* — an Auditor opening a request not assigned to them.

## System Behaviour

- **Auto record creation:** **Add Task** creates a blank task whose **Ref No** is auto-assigned (last Ref No + 1 per engagement, `tasks/route.ts:65-83`).
- **Auto status updates:** approving an evidence request sets status **Reviewed** + `aiReviewStatus` Satisfactory; sending clarification sets status back to **Pending** + `aiReviewStatus` Needs Attention; the Auditor's submit sets all pending requests to **Submitted** and clears the clarification fields.
- **AI Review background processing:** `POST .../ai-review` reads the selected requests' attachments from disk, calls the external AI service (ingest → poll status → fetch result → query), and returns the review text; it stores `aiReviewStatus` / `aiReviewComment` on the requests ( `ai-review/route.ts:73-166` ). Related proxy routes exist for `audit-ingest`, `audit-ingest/status`, `audit-ingest/result`, `audit-query`, and `simple-query` (all `audit.fieldwork` view/create), and an evidence-request-level `ai-review` (edit).
- **Read-only behavior:** opening a row whose engagement is **Completed**, or opening the detail page with `?mode=view`, sets `isReadOnly`, which disables create/edit/delete controls across all sections.
- **Dynamic translation:** creating/editing evidence requests and findings triggers background translation ( `triggerTranslation` / `FieldworkEvidenceRequest`, `InternalAuditFinding` ).
- **Auditee scoping:** Auditee-only users see only their assigned evidence requests (filtered both client-side and server-side) and a reduced UI (Workpapers, AI Workpapers, Comments, and Mark as Completed are hidden); they cannot add/edit/delete tasks.
- **Audit-trail / notifications:** not confirmed in the Fieldwork route handlers reviewed (marked Not verified above).

## Notes / Warnings / Tips

- **Fieldwork is not a top-level sidebar item.** The Internal Audit navigation ( `navigation.ts:295-316` ) has no "Fieldwork" entry; the page is reached via the Audit Engagement workflow / the engagement list at `/internal-audit/fieldwork`.
- The displayed column **Audit Manager** and the **Auditor** filter on the list both derive from the engagement's assigned auditor; terminology in the UI mixes "Audit Manager" (list/details labels) and "Auditor" (evidence assignment).
- Files attached on the standalone **Add Evidence Request** page are collected in the form but the persisted record only stores the textual fields; attach evidence via **Add Attachment** on the request afterward.
- **Mark as Completed locks the engagement** — confirm all workpapers, tasks, evidence, and findings are final before completing, since the page then becomes read-only.

# Findings

## Overview — Purpose, Business Objective

The **Findings** chapter covers the two pages used to record and maintain an individual audit finding raised during fieldwork:

- **Add New Findings** — `internal-audit/fieldwork/[id]/add-finding/page.tsx` — creates a new finding against an engagement, capturing the finding statement, severity, the four classic audit dimensions (Criteria / Condition / Cause / Effect), a recommendation, optional attachments, and an initial CAPA assignment (Responsible Person, Status, Target Closure Date).
- **Finding Details** — `internal-audit/fieldwork/[id]/findings/[findingId]/page.tsx` — views a single finding in read-only mode and (with the `Edit` button) switches to an editable form for updating the same fields and managing attachments.

Business objective: to formally document deficiencies identified during an audit engagement in a structured, defensible format (criteria vs. condition, root cause, consequence, and corrective recommendation), assign accountability for remediation (Responsible Person), and attach supporting evidence. Findings created here feed downstream CAPA tracking and the AI review workflows.

## Access — Which of the three roles can use it + the exact permission(s) required

Both pages and all their finding/attachment APIs are gated on the resource `audit.fieldwork`. Permissions ( `src/lib/permissions.ts` ):

- **Audit Head** ( `AuditHead` ) — `audit.fieldwork` actions `['*']`, scope `all` (permissions.ts:445). Full create / view / edit / delete.
- **Audit Manager** ( `AuditManager` ) — `audit.fieldwork` actions `['*']`, scope `all` (permissions.ts:471). Full create / view / edit / delete.
- **Auditor** (internal key `Auditee`, displayed as "Auditor" via `ROLE_DISPLAY_OVERRIDES`, permissions.ts:319-321) — `audit.fieldwork` actions `['view', 'edit']`, scope `department` (permissions.ts:534). Department-scoped: can view and edit findings, but **cannot create or delete** (no `create` / `delete` action).

API action requirements (verified in route files):

| Operation                       | API                                                                                               | Required action                                                               |
|---------------------------------|---------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------|
| View finding / view attachments | <code>GET .../findings/[findingId]</code> ; <code>GET .../findings/[findingId]/attachments</code> | <code>view</code> (findings/[findingId]/route.ts:66; attachments/route.ts:47) |
| Create finding                  | <code>POST .../fieldwork/[id]/findings</code>                                                     | <code>create</code> (findings/route.ts:252)                                   |
| Create-time file upload         | <code>POST .../fieldwork/[id]/findings/upload</code>                                              | <code>create</code> (upload/route.ts:72)                                      |
| Edit finding                    | <code>PATCH .../findings/[findingId]</code>                                                       | <code>edit</code> (findings/[findingId]/route.ts:192)                         |
| Upload attachment (detail page) | <code>POST .../findings/[findingId]/attachments</code>                                            | <code>edit</code> (attachments/route.ts:125)                                  |
| Delete attachment               | <code>DELETE .../findings/[findingId]/attachments</code>                                          | <code>delete</code> (attachments/route.ts:169)                                |

Note: because the Add Finding page calls the `create`-gated finding endpoint, the **Auditor** role (view/edit only) cannot create findings. On the detail page, deleting an attachment requires the `delete` action, which the Auditor role does not have.

The Responsible Person dropdown is populated from `/api/users/my-auditees`. The detail page tolerates a `403` from that endpoint (sets the list empty and continues), so a user without access to that endpoint can still load the page (page.tsx:175-179).

## Prerequisites — what must already exist before using this module

- An **Audit Engagement** must exist; both pages are reached under `/internal-audit/fieldwork/{engagementId}/...` and the APIs return `404` Engagement not found if it does not (findings/route.ts:42-47; upload/route.ts:21-26).
- The user's account must have a `customerAccountId`; finding creation returns `400` "User account not properly configured. Please contact administrator." if it is missing (findings/route.ts:104-112).
- For the Responsible Person dropdown to be populated, eligible **auditees** must exist (returned by `/api/users/my-auditees`, optionally filtered by the engagement's department).
- For the Finding Details page, the finding ( `findingId` ) must already exist and belong to the engagement and tenant; otherwise the page shows `Finding not found` and redirects back to the engagement (page.tsx:156-158), or the API returns `403` on tenant mismatch.

## Add New Findings page

**Screenshot:** *Insert screenshot here*

Visible areas of `add-finding/page.tsx`:

- **Breadcrumb nav** (top): `Internal Audit` (home icon) > `Fieldwork` > `Add Finding`.
- **Sub-header bar**: a **Back** button (arrow icon), then a separator and the labels `Audit Plan` | `Add New Findings`. Back navigates to `/internal-audit/fieldwork/{engagementId}`.
- **Form card** containing, in order: `Finding Title` (text input); `Severity` (dropdown); `Criteria` (What should be), `Condition` (What is), `Cause` (Why it happened), `Effect` (The consequence), `Recommendation` (multi-line textareas); `Upload Attachment` (drag-and-drop / click file picker).

- **Corrective & Preventive Actions (CAPA)** section heading, with `Responsible Person` (dropdown), `Status` (dropdown), and `Target Closure Date` (date picker).
- **Footer action buttons:** `Cancel` (outline) and `Save` (filled; shows `Saving...` spinner while submitting).
- While the engagement is loading, the card area is replaced by a centred spinner.

Finding Details page

**Screenshot:** *Insert screenshot here*

Visible areas of `findings/[findingId]/page.tsx`:

- **Breadcrumb nav:** `Internal Audit > Fieldwork > Finding Details`.
- **Sub-header bar:** `Back` button, separator, `Audit Plan | Finding Details - {findingId}` (e.g. `Finding Details - FND001`). On the right, an **Edit** button (pencil icon) appears only when not already editing.
- **Form card:** same field set as the Add page. In view mode each field renders as a read-only grey panel; `Severity` and `Status` render as colour-coded badges. In edit mode the fields become inputs/dropdowns/date picker. `Finding Title` and `Responsible Person` show a red `*` (required).
- **Upload Attachment** area: in view mode lists existing attachments (paperclip icon, file name) with **View** (eye) and **Download** buttons; shows `No attachments` when empty. In edit mode it also shows a **Choose Files** button, a staged "Files to upload" list with remove (X) buttons, an **Upload (n)** button, and a **Delete** (trash) button on each existing attachment.
- **Corrective & Preventive Actions (CAPA)** section: `Responsible Person`, `Status`, `Target Closure Date`.
- **Footer action buttons** (edit mode only): `Cancel` (reloads original values) and `Save` (with `Saving...` spinner).
- While loading, the card area is replaced by a centred spinner.

Page Layout

| Area         | Add New Findings                                                | Finding Details                                                                      |
|--------------|-----------------------------------------------------------------|--------------------------------------------------------------------------------------|
| Breadcrumb   | Internal Audit > Fieldwork > Add Finding                        | Internal Audit > Fieldwork > Finding Details                                         |
| Header label | Audit Plan   Add New Findings                                   | Audit Plan   Finding Details - {findingId}                                           |
| Back button  | Yes (→ engagement)                                              | Yes (→ engagement)                                                                   |
| Edit toggle  | n/a (always editable)                                           | Edit button (view → edit)                                                            |
| Form card    | Single card, all fields                                         | Single card, view/edit toggle per field                                              |
| CAPA section | Yes                                                             | Yes                                                                                  |
| Attachments  | Drag-and-drop / click picker (staged only, uploaded after Save) | Existing-attachment list with View/Download; Choose Files/Upload/Delete in edit mode |
| Footer       | Cancel, Save                                                    | Cancel, Save (edit mode only)                                                        |

No summary cards, tabs, search, filters, pagination, bulk actions, side panels, or footer beyond the action buttons are present on either page.

Field Reference

Fields are identical on both pages unless noted. "Editable" = editable on the Finding Details page in edit mode (on the Add page everything is editable).

| Field                     | Required                                                       | Type                                     | Default                                                                                                    | Validation                                                                                                          | Editable | Description                                                                                                                                   |
|---------------------------|----------------------------------------------------------------|------------------------------------------|------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------|----------|-----------------------------------------------------------------------------------------------------------------------------------------------|
| Finding Title             | Yes                                                            | Text input                               | empty                                                                                                      | Add page: non-empty (trimmed). Detail page: non-empty AND isValidName (only letters, spaces, hyphens).              | Yes      | The finding statement; stored as finding in DB.                                                                                               |
| Severity                  | No (UI)                                                        | Dropdown: Low , Medium , High , Critical | Add page UI: Select severity (sentinel none ); if left as none , submitted as Medium . DB default Medium . | One of the four values                                                                                              | Yes      | Risk/impact rating. View mode renders as colour badge.                                                                                        |
| Criteria (What should be) | No                                                             | Textarea (4 rows)                        | empty                                                                                                      | None                                                                                                                | Yes      | Expected/required state. DB criteria .                                                                                                        |
| Condition (What is)       | No                                                             | Textarea (4 rows)                        | empty                                                                                                      | None                                                                                                                | Yes      | Actual observed state. DB condition .                                                                                                         |
| Cause (Why it happened)   | No                                                             | Textarea (4 rows)                        | empty                                                                                                      | None                                                                                                                | Yes      | Root cause. Sent as null when blank. DB cause .                                                                                               |
| Effect (The consequence)  | No                                                             | Textarea (4 rows)                        | empty                                                                                                      | None                                                                                                                | Yes      | Impact/consequence. DB effect .                                                                                                               |
| Recommendation            | No                                                             | Textarea (4 rows)                        | empty                                                                                                      | None                                                                                                                | Yes      | Recommended corrective action. DB recommendation .                                                                                            |
| Upload Attachment         | No                                                             | File drop / picker                       | none                                                                                                       | Add page accepts .pdf , .doc , .docx , .xls , .xlsx , .png , .jpg , .jpeg ; detail-page picker has no accept filter | Yes      | Supporting files. See Tables/System Behaviour for storage differences.                                                                        |
| Responsible Person        | Add page: not enforced by UI; <b>Detail page: Yes</b> (red * ) | Dropdown of auditees                     | Select person (sentinel none )                                                                             | Add page: server requires it ( 400 if absent). Detail page client also requires it.                                 | Yes      | CAPA owner. Sent as user id, or null if none . Server resolves and stores the person's name.                                                  |
| Status                    | No (UI)                                                        | Dropdown                                 | Select status (sentinel none ); if none , submitted as Open                                                | See Status Reference                                                                                                | Yes      | Lifecycle status. <b>Add page</b> options: Open , In Progress , Closed , Overdue . <b>Detail page</b> options: Open , Under Review , Closed . |
| Target Closure Date       | No                                                             | Date picker                              | empty                                                                                                      | None                                                                                                                | Yes      | CAPA target date. DB targetDate . Sent null when blank.                                                                                       |

Fields not exposed on these pages but present in the API/DB: description , findingType (Absence of Control / Lack of Operational Effectiveness / Best Practices / Non-Compliance), departmentId , identifiedDate (defaults to now on create), closedDate (set automatically), and the AI review fields (see System Behaviour).

## Tables

There are no data tables on these two pages. The only list-like UI is the **attachment list**:

- **Add New Findings — staged files list**: appears below the drop zone after files are chosen. Each row shows a file icon, file name, and human-readable size (e.g. "1.2 MB"), with a red **X** to remove the staged file before saving. No sorting, search, filtering, or pagination.
- **Finding Details — attachments list**: each row shows a paperclip icon and the file name. Row actions: **View** (eye — opens /api{filePath} in a new tab), **Download** (anchor with download ), and in edit mode **Delete** (trash, with per-row spinner while deleting). A separate "Files to upload" staged list (yellow rows) appears in edit mode with per-row remove (X). Empty state: No attachments . No sorting, search, filtering, pagination, or bulk actions.

## Buttons & Actions

"Visible To" reflects the audit.fieldwork permission gating described in **Access**. Audit Trail and Notification columns reflect only what the code emits.

| Control                            | Permission | Visible To                         | Action                                           | API                                                              | Success Msg                       | Failure Msg                                                                                                                                        | Audit Trail                                         | Notification                                                                                                                                                           |
|------------------------------------|------------|------------------------------------|--------------------------------------------------|------------------------------------------------------------------|-----------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Save</b> (Add page)             | create     | Audit Head, Audit Manager          | Creates finding; then uploads any staged files   | POST .../fieldwork/[id]/findings , then POST .../findings/upload | Finding added successfully        | Finding title is required (client); else API error text or Failed to add finding                                                                   | Not verified (no explicit audit-log write in route) | FINDINGS_CREATED to Audit Head (if not the actor); CAPA_ASSIGNED to Responsible Person (if set and not the actor); Channels: Inbox + Email (findings/route.ts:185-221) |
| <b>Cancel</b> (Add page)           | —          | All with page access               | Navigates to engagement page (discards)          | none                                                             | —                                 | —                                                                                                                                                  | —                                                   | —                                                                                                                                                                      |
| <b>Back</b>                        | —          | All with page access               | Navigates to engagement page                     | none                                                             | —                                 | —                                                                                                                                                  | —                                                   | —                                                                                                                                                                      |
| File drop zone / picker (Add)      | create     | Audit Head, Audit Manager          | Stages files locally (uploaded on Save)          | none until Save                                                  | —                                 | —                                                                                                                                                  | —                                                   | —                                                                                                                                                                      |
| <b>Edit</b> (Detail)               | edit       | Audit Head, Audit Manager, Auditor | Switches form to edit mode                       | none                                                             | —                                 | —                                                                                                                                                  | —                                                   | —                                                                                                                                                                      |
| <b>Save</b> (Detail)               | edit       | Audit Head, Audit Manager, Auditor | Updates finding                                  | PATCH .../findings/[findingId]                                   | Finding updated successfully      | Finding title is required / Only letters, spaces, and hyphens are allowed / Responsible person is required (client); else Failed to update finding | Not verified (no explicit audit-log write in route) | CAPA_ASSIGNED to new Responsible Person if changed by a different user (and not the actor); Channels: Inbox + Email (findings/[findingId]/route.ts:157)                |
| <b>Cancel</b> (Detail)             | —          | All with page access               | Exits edit mode and reloads original finding     | re-fetch GET                                                     | —                                 | —                                                                                                                                                  | —                                                   | —                                                                                                                                                                      |
| <b>Choose Files</b> (Detail, edit) | edit       | Audit Head, Audit Manager, Auditor | Stages files for upload                          | none                                                             | —                                 | —                                                                                                                                                  | —                                                   | —                                                                                                                                                                      |
| <b>Upload (n)</b> (Detail, edit)   | edit       | Audit Head, Audit Manager, Auditor | Uploads staged files, creates attachment records | POST .../findings/[findingId]/attachments                        | Attachments uploaded successfully | Failed to upload attachments ; API: No files provided (400), Finding not found (404)                                                               | Not verified                                        | None (translation of file name only, fire-and-forget)                                                                                                                  |
| <b>View</b> (attachment)           | view       | Audit Head, Audit Manager, Auditor | Opens file in new tab ( /api{filePath} )         | served file path                                                 | —                                 | —                                                                                                                                                  | —                                                   | —                                                                                                                                                                      |
| <b>Download</b> (attachment)       | view       | Audit Head, Audit Manager, Auditor | Downloads file                                   | served file path                                                 | —                                 | —                                                                                                                                                  | —                                                   | —                                                                                                                                                                      |
| <b>Delete</b> (attachment, edit)   | delete     | Audit Head, Audit Manager          | Confirms then deletes attachment                 | DELETE .../findings/[findingId]/attachments? attachmentId=...    | Attachment deleted successfully   | Failed to delete attachment ; API: Attachment                                                                                                      | Not verified                                        | None                                                                                                                                                                   |



| Control | Permission | Visible To | Action | API | Success Msg | Failure Msg                                      | Audit Trail | Notification |
|---------|------------|------------|--------|-----|-------------|--------------------------------------------------|-------------|--------------|
|         |            |            |        |     |             | ID is required (400), Attachment not found (404) |             |              |

There is **no Delete-finding button** on either of these two pages (the `DELETE` finding API exists but is not invoked from these pages). There is no Export button on either page.

### Step-by-Step Instructions

#### Task A — Create a new finding

1. From the engagement's Fieldwork page, open the **Add New Findings** page ( `/internal-audit/fieldwork/{engagementId}/add-finding` ).
2. Enter the **Finding Title** (required).
3. Select a **Severity** ( `Low` / `Medium` / `High` / `Critical` ). If left unselected, the system submits `Medium` .
4. Fill **Criteria (What should be)**, **Condition (What is)**, **Cause (Why it happened)**, **Effect (The consequence)**, and **Recommendation** as applicable (all optional).
5. (Optional) Add attachments: drag files onto the **Upload Attachment** box or click it to choose files ( `.pdf`, `.doc`, `.docx`, `.xls`, `.xlsx`, `.png`, `.jpg`, `.jpeg` ). Remove a staged file with the red X.
6. Under **Corrective & Preventive Actions (CAPA)**, select a **Responsible Person**. (The server requires this — see Validation Rules.)
7. (Optional) Set a **Status** ( `Open` / `In Progress` / `Closed` / `Overdue` ); default `Open` .
8. (Optional) Set a **Target Closure Date**.
9. Click **Save**. On success a toast `Finding added successfully` appears and you are redirected to the engagement page. Any staged files are uploaded after the finding is created.
10. To abandon, click **Cancel** or **Back**.

#### Task B — View a finding

1. Open the **Finding Details** page for the finding ( `/internal-audit/fieldwork/{engagementId}/findings/{findingId}` ).
2. Review the read-only fields, severity/status badges, and the existing attachments.
3. To open an attachment, click **View**; to save it locally, click **Download**.

#### Task C — Edit a finding

1. On the Finding Details page (view mode), click **Edit**.
2. Update any field. Ensure **Finding Title** contains only letters, spaces, and hyphens, and that a **Responsible Person** is selected (both required).
3. Change **Status** if needed ( `Open` / `Under Review` / `Closed` ).
4. Click **Save**. On success a toast `Finding updated successfully` appears, edit mode closes, and the finding reloads. Click **Cancel** to discard and restore original values.

#### Task D — Manage attachments on an existing finding

1. On the Finding Details page, click **Edit**.
2. Click **Choose Files** and select one or more files. They appear in the yellow "Files to upload" list; remove any with the X.
3. Click **Upload (n)**. On success: `Attachments uploaded successfully` ; the list refreshes.
4. To delete an existing attachment, click its **Delete** (trash) icon and confirm the "Delete Attachment?" dialog ("This action cannot be undone."). On success: `Attachment deleted successfully` .

### Workflow

Current Status → User Action → Validation → API → DB Update → Audit Trail → Notification → Next Status → Next User

1. **(no finding)** → Audit Head/Manager clicks **Save** on Add page → client: title non-empty; server: `responsiblePersonId` present, engagement exists, account configured → `POST .../findings` → creates `InternalAuditFinding` (auto `findingId` `FND00n`, `identifiedDate` = `now`, `status` = `Open` unless set) → Audit Trail: not verified → `FINDINGS_CREATED` to Audit Head + `CAPA_ASSIGNED` to Responsible Person (Inbox + Email) → status **Open** (or chosen) → Responsible Person / Audit Head.
2. **Open / In Progress / Under Review** → Audit Head/Manager/Auditor edits and **Save** → client: title valid name + Responsible Person set; server: tenant access → `PATCH .../findings/{findingId}` → updates fields; if status becomes `Closed`, sets `closedDate` ; if status moves off `Closed`, clears `closedDate` → Audit Trail: not verified → `CAPA_ASSIGNED` if responsible person changed → next status = chosen → same roles.
3. Attachment upload (edit mode) → `POST .../findings/{findingId}/attachments` → creates `FindingAttachment` rows → no status change.

The AI review steps (CAPA evidence review and AI Findings Review) are not initiated from these two pages — see System Behaviour and Status Reference for how the AI fields are populated elsewhere.

### Status Reference

Status is stored on the finding ( `status` , DB default `Open` ). The selectable values differ by page.

| Status       | Meaning                                                      | How reached                                 | Who can set                                  | Next statuses                                 |
|--------------|--------------------------------------------------------------|---------------------------------------------|----------------------------------------------|-----------------------------------------------|
| Open         | Finding raised, remediation not started                      | Default on create; selectable on both pages | Audit Head, Audit Manager (Auditor via edit) | In Progress / Under Review / Closed / Overdue |
| In Progress  | Remediation underway                                         | Add page dropdown                           | Audit Head, Audit Manager                    | Closed / Overdue / Open                       |
| Under Review | Under review (rendered with a primary-colour badge)          | Detail page dropdown                        | Audit Head, Audit Manager, Auditor           | Open / Closed                                 |
| Closed       | Finding resolved; sets <code>closedDate</code> automatically | Both pages dropdown                         | Audit Head, Audit Manager, Auditor           | Reopening clears <code>closedDate</code>      |
| Overdue      | Past target date                                             | Add page dropdown                           | Audit Head, Audit Manager                    | —                                             |

Notes: the **Add page** offers `Open` , `In Progress` , `Closed` , `Overdue` ; the **Detail page** edit dropdown offers `Open` , `Under Review` , `Closed` . The DB schema comment lists all five ( `Open` , `In Progress` , `Closed` , `Overdue` , `Under Review` ). When status changes to `Closed` , the API sets `closedDate = now` ; when it moves away from `Closed` , `closedDate` is cleared (findings/[findingId]/route.ts:104-110).

### AI review status fields (populated by other modules, not these pages)

These are stored on the finding but are **not edited on the Add/Details pages**:

- `aiReviewStatus` — CAPA evidence verdict: `Satisfactory` or `Unsatisfactory` (set by `POST ../capa-tracking/[findingId]/ai-review` , which also writes `aiReviewDescription` , `aiReviewedAt` , and resets `aiReviewApproved` / `aiApprovedAt` / `aiApprovedBy` ). Requires the finding to have at least one attachment, otherwise it returns `Finding has no attachments. Upload files before running AI Review.`
- `aiFindingReviewStatus` — AI Findings Review verdict badge: `Compliant` , `Non-Compliant` , `Partially Compliant` , or `Insufficient Evidence` (consumed from the external `findings_review` API and stored alongside the full `aiFindingReview` JSON; schema.prisma:3674-3676).

## Validation Rules

### Add page (client):

- `Finding Title` must be non-empty after trim, else toast `Finding title is required` .

### Add finding API (server, findings/route.ts):

- `customerAccountId` must resolve, else `400 "User account not properly configured..."` .
- Engagement must exist for the tenant, else `404 "Engagement not found or access denied"` .
- `responsiblePersonId` is **required**, else `400 "Responsible person is required"` .
- `findingId` auto-generated as `FND` + zero-padded next number, scoped per customer account.

### Detail page (client, on Save):

- `Finding Title` non-empty → else `Finding title is required` .
- `Finding Title` must pass `isValidName` (letters, spaces, hyphens) → else `Only letters, spaces, and hyphens are allowed` .
- `Responsible Person` must be set (not `none` /empty) → else `Responsible person is required` .

### Edit finding API (server):

- Finding must exist and belong to the engagement, else `404 Finding not found` .
- Tenant access enforced via `validateTenantAccess` , else `403 "Access denied to this finding"` .

### Attachment APIs:

- Upload requires the finding to exist ( `404` ) and at least one file ( `400 No files provided` ).
- Delete requires `attachmentId` query param ( `400` ) and that it belongs to the finding ( `404` ).

## Success Scenarios and Failure Scenarios

### Success:

- Create finding → `201` , toast `Finding added successfully` , redirect to engagement page; finding gets an auto `FND000` id, `identifiedDate = now` , status `Open` (unless set); notifications sent.
- Update finding → `200` , toast `Finding updated successfully` ; on status `Closed` , `closedDate` set.
- Upload attachments → `201` , toast `Attachments uploaded successfully` ; list refreshes.
- Delete attachment → `200` , toast `Attachment deleted successfully` ; list refreshes.

### Failure scenarios:

| Failure                        | Why                                                    | What the user sees                                                                      | Resolution                       |
|--------------------------------|--------------------------------------------------------|-----------------------------------------------------------------------------------------|----------------------------------|
| Empty title (Add)              | Title blank                                            | Finding title is required                                                               | Enter a title                    |
| Invalid title (Detail)         | Title has characters other than letters/spaces/hyphens | Only letters, spaces, and hyphens are allowed                                           | Remove disallowed characters     |
| No responsible person (Add)    | Server-required responsiblePersonId missing            | API 400 "Responsible person is required" surfaced via Failed to add finding /error text | Select a Responsible Person      |
| No responsible person (Detail) | Client check                                           | Responsible person is required                                                          | Select a Responsible Person      |
| Account not configured         | Session lacks customerAccountId                        | 400 "User account not properly configured. Please contact administrator."               | Contact administrator            |
| Engagement missing             | Wrong/inaccessible engagement                          | 404 Engagement not found (Add)                                                          | Verify the engagement URL/access |
| Finding missing (Detail load)  | Finding not found                                      | Toast Finding not found , redirect to engagement                                        | Verify finding exists            |
| Generic create/update error    | Server error                                           | Failed to add finding / Failed to update finding                                        | Retry; check server logs         |
| Upload error                   | No file / finding missing / server error               | Failed to upload attachments                                                            | Choose at least one file; retry  |
| Delete error                   | Missing/foreign attachment / server error              | Failed to delete attachment                                                             | Refresh and retry                |

## System Behaviour

- **Auto record creation:** A new finding is auto-assigned findingId ( FND001 , FND002 , ..., numbering derived from the max trailing number across the customer account's existing findings, findings/route.ts:12-28). identifiedDate defaults to the creation time. If only a responsiblePersonId is provided, the server resolves and stores the person's display name.
- **Auto status side-effect:** Setting status to Closed sets closedDate; moving off Closed clears it (findings/[findingId]/route.ts:104-110).
- **Notifications:** On create, FINDINGS\_CREATED to the Audit Head (if different from the actor) and CAPA\_ASSIGNED to the Responsible Person (if set and not the actor). On edit, CAPA\_ASSIGNED is sent when the Responsible Person changes to a different (non-actor) user. All via Inbox + Email.
- **Two different attachment upload paths (important):**
  - **Add page** uses POST ../fieldwork/[id]/findings/upload . This endpoint saves the files to disk and returns metadata **but does not create FindingAttachment records** (upload/route.ts:42-58). Files uploaded at create time via this route are therefore not listed by the Finding Details attachments panel (which reads FindingAttachment rows).
  - **Finding Details page (edit)** uses POST ../findings/[findingId]/attachments , which **does** create FindingAttachment DB rows and is the source for the attachments list and the AI review flows. To have attachments persist as listed records, upload them from the Finding Details page.
- **Dynamic translation:** After create/edit, the client and server fire-and-forget triggerTranslation / translateRecord for InternalAuditFinding (title, description, recommendation, criteria, condition, cause, effect). Uploaded attachment file names are also translated ( FindingAttachment ). The Details page displays translated values via useTranslatedRecord .
- **Read-only behaviour:** The Finding Details page is read-only until **Edit** is pressed; the ?edit=true query parameter opens it directly in edit mode.
- **Background AI processing (elsewhere):** The CAPA evidence AI review ( POST ../capa-tracking/[findingId]/ai-review ) ingests the finding's attachments to the external Python backend, polls until completed (2-second interval, 5-minute timeout), runs a query, and writes aiReviewStatus ( Satisfactory / Unsatisfactory ), aiReviewDescription , and aiReviewedAt , resetting the Audit Head approval fields. It requires at least one attachment. The AI Findings Review writes aiFindingReview\* . Neither is triggered from the Add/Details pages.
- **Audit trail logging:** No explicit audit-log write was found in the finding or attachment route handlers; marked "Not verified" in the Buttons & Actions table.

## Notes / Warnings / Tips

- **Tip — make attachments stick:** Attachments added during finding creation (Add page) are saved to disk but not recorded as FindingAttachment rows, so they will not appear in the Details attachment list and will not be available to AI review. To create listed, reviewable attachments, open the finding, click **Edit**, and upload via **Choose Files → Upload**.
- **Note — different status options per page:** The Add page offers In Progress and Overdue ; the Details edit form offers Under Review instead. All five values are valid in the database.
- **Note — Responsible Person is effectively mandatory** on both create (server) and edit (client).
- **Warning — attachment delete is permanent:** The confirmation dialog states "This action cannot be undone." Only Audit Head and Audit Manager have the delete action.
- **Note — Auditor role limits:** Auditors (internal Auditee ) can view and edit findings within their department but cannot create findings or delete attachments.

# Recommendations

## Overview — Purpose, Business Objective

In this system, "recommendations" are not a single standalone module. The word appears in three distinct, code-confirmed places in the Internal Audit module:

1. **Per-finding recommendation** — a single free-text **Recommendation** field captured on each audit finding (created in Fieldwork / Findings, viewable and editable in CAPA Tracking). This is the corrective action the auditor proposes for that finding.
  - Source: `src/app/(protected)/internal-audit/fieldwork/[id]/add-finding/page.tsx:389`, `src/app/(protected)/internal-audit/fieldwork/[id]/findings/[findingId]/page.tsx:527`, `src/app/(protected)/internal-audit/capa-tracking/page.tsx:875` and `:1098`. DB field `InternalAuditFinding.recommendation` (`prisma/schema.prisma:3655`).
2. **Report Recommendations section** — a single multi-line free-text **Recommendations** block on the audit report. Source: `src/app/(protected)/internal-audit/report/[id]/page.tsx:530` (`TextSection label="Recommendations"`); DB field `AuditReport.recommendations` (`prisma/schema.prisma:3550`).
3. **Follow-up Meeting Form — Status of Implementation of Recommendations** — a dedicated, repeatable grid that tracks each recommendation's implementation status, responsible official, due date, progress, and notes, one form per engagement. Source: `src/app/(protected)/internal-audit/follow-up/[id]/page.tsx`; DB field `AuditFollowUpMeeting.recommendations` (`prisma/schema.prisma:3753`).

This chapter documents item 3 — the **Follow-up Meeting Form** — in full, because it is the only standalone, navigable page whose primary purpose is managing the lifecycle of recommendations. Items 1 and 2 are sub-fields documented in the Findings, CAPA Tracking, and Report chapters; their location is stated here for cross-reference but their full field/workflow detail belongs to those chapters.

**Business objective of the Follow-up Meeting Form:** record a follow-up meeting per engagement and track, recommendation by recommendation, whether agreed audit recommendations have been implemented — including the responsible official, the implementation (due) date, an implementation status, a percent-complete progress value, and an overdue flag. The page title is **"Follow-up Meeting Form for the Implementation of the Recommendations"** (`follow-up/[id]/page.tsx:242`).

## Access — Roles and Required Permissions

The Follow-up feature is gated entirely by the `audit.capa` resource (no separate "recommendations" resource exists).

- **Navigation visibility:** the top-level **Follow-up** menu item requires `audit.capa:view` (`src/lib/navigation.ts:327`). It is a standalone top-level menu, sibling to Internal Audit (`navigation.ts:319-328`).
- **View the form (GET):** resource: "audit.capa", action: "view" (`follow-up-meeting/route.ts:93`).
- **Save the form (PUT):** resource: "audit.capa", action: "edit" (`follow-up-meeting/route.ts:164`). The **Save** button is only rendered when the client-side `canEdit` for `audit.capa` is true (`follow-up/[id]/page.tsx:102, :254`).

Permission matrix for `audit.capa` across the three documented roles (`src/lib/permissions.ts`):

| Role (display) | Internal key              | <code>audit.capa</code> permission                                            | Effect on Follow-up Form                       |
|----------------|---------------------------|-------------------------------------------------------------------------------|------------------------------------------------|
| Audit Head     | <code>AuditHead</code>    | <code>* (all), scope all</code> ( <code>permissions.ts:447</code> )           | Can view and save the form for any engagement  |
| Audit Manager  | <code>AuditManager</code> | <code>* (all), scope all</code> ( <code>permissions.ts:473</code> )           | Can view and save the form for any engagement  |
| Auditor        | <code>Auditee</code>      | <code>view, edit, scope department</code> ( <code>permissions.ts:536</code> ) | Can view and save the form (department-scoped) |

(There is no `approve` step and no `export` permission action for this feature; Print / Export PDF are UI buttons, documented under Buttons & Actions.)

## Prerequisites

- An **Audit Engagement** must exist; the form is keyed by `engagementId` and the page is reached at `/internal-audit/follow-up/[id]` (`follow-up-meeting/route.ts:43-49` returns 404 "Engagement not found" if it does not exist).
- The engagement is reached from the **Follow-up** list page, which lists engagements (`follow-up/page.tsx:75`).
- For the recommendation grid to auto-populate on first open, the engagement should already have **findings with a non-empty Recommendation field**. When no form has been saved yet, the grid is pre-filled from those findings (`follow-up-meeting/route.ts:63-87`, `buildRecommendationsFromFindings` at `:10-32`). If there are none, the grid starts empty.

**Screenshot:** *Insert screenshot here*

The Follow-up feature has two pages.

**A. Follow-up list page** (`/internal-audit/follow-up`, `follow-up/page.tsx`):

- **Breadcrumb:** Internal Audit > Follow-up.
- **Page header:** a list icon and the title **"Follow-up"**.
- **Search & filter bar:** a search input with placeholder **"Search engagements..."**; a **Status** select (options: **All Statuses**, **Pending**, **In Progress**, **Completed**); a **Department** select (**All Departments** plus each department).
- **Table** with columns: **Audit ID**, **Engagement**, **Department**, **Audit Manager**, **Status** (colored badge), **Action**. The Action column has an **Open** button (right arrow) linking to the form for that engagement. Empty state: **"No engagements found."**

**B. Follow-up Meeting Form page** (`/internal-audit/follow-up/[id]`, `follow-up/[id]/page.tsx`):

- **Breadcrumb:** Internal Audit > Follow-up > (the engagement's Audit Task Number, or "Meeting Form" if blank).

- **Page header:** back arrow + title **"Follow-up Meeting Form for the Implementation of the Recommendations"**, with action buttons **Print**, **Export PDF**, and **Save** (Save only if `canEdit` ).
- **Meeting Details** card: fields Audit Task Number, Assignment Title, Department, Management, Meeting Venue, History.
- **Attendees** card: a table (Name, Job Title, Management, Signature, delete) with an **Add Row** button (only if `canEdit` ).
- **Status of Implementation of Recommendations** card: the recommendation grid plus, when at least one row exists, a summary chip strip (Total, Implemented, Overdue, Avg. Progress). **Add Row** button only if `canEdit` .

Page Layout (Follow-up Meeting Form)

- **Header / breadcrumb / buttons:** as described above ( `follow-up/[id]/page.tsx:218-265` ).
- **Loading state:** while loading, the body shows a centered spinner ( `:267-270` ).
- **Meeting Details card** ( `:274-322` ): two-column grid of six text inputs.
- **Attendees card** ( `:325-384` ): a min-width table with per-row delete (trash icon) and an Add Row button.
- **Status of Implementation of Recommendations card** ( `:387-544` ):
  - Card header with title and (if editable) Add Row.
  - **Summary chips** shown only when `recommendations.length > 0` ( `:400-421` ): **Total**, **Implemented** (count of rows whose status = "Implemented"), **Overdue** (count of rows for which `isOverdue` is true), **Avg. Progress** (rounded mean of the numeric `progress` values, shown as %).
  - **Recommendations grid** (table, min-width 900px) — see Tables below. Overdue rows are highlighted ( `bg-red-50` ) and their date input border turns red with an inline **"Overdue"** label.
- **No footer.**

Field Reference

Meeting Details fields ( `follow-up/[id]/page.tsx:278-321` )

| Field             | Required | Type       | Default                                                                                            | Validation    | Editable | Description                              |
|-------------------|----------|------------|----------------------------------------------------------------------------------------------------|---------------|----------|------------------------------------------|
| Audit Task Number | No       | Text input | Pre-filled from engagement <code>auditId</code> on first open ( <code>route.ts:82</code> )         | None enforced | Yes      | Audit task / engagement reference number |
| Assignment Title  | No       | Text input | Pre-filled from engagement <code>engagementTitle</code> on first open ( <code>route.ts:81</code> ) | None enforced | Yes      | Title of the audit assignment            |
| Department        | No       | Text input | Empty                                                                                              | None enforced | Yes      | Department covered                       |
| Management        | No       | Text input | Empty                                                                                              | None enforced | Yes      | Management line                          |
| Meeting Venue     | No       | Text input | Empty                                                                                              | None enforced | Yes      | Where the follow-up meeting was held     |
| History           | No       | Text input | Empty                                                                                              | None enforced | Yes      | History note                             |

Attendee row fields ( `follow-up/[id]/page.tsx:356-363` )

| Field      | Required | Type       | Default | Validation    | Editable | Description                |
|------------|----------|------------|---------|---------------|----------|----------------------------|
| Name       | No       | Text input | Empty   | None enforced | Yes      | Attendee name              |
| Job Title  | No       | Text input | Empty   | None enforced | Yes      | Attendee job title         |
| Management | No       | Text input | Empty   | None enforced | Yes      | Attendee's management line |
| Signature  | No       | Text input | Empty   | None enforced | Yes      | Signature text             |

Recommendation row fields ( `follow-up/[id]/page.tsx:447-535` ; `row shape` :47-55 )

| Field                 | Required | Type                          | Default                                                                                                                                         | Validation                                                                                                  | Editable | Description                                 |
|-----------------------|----------|-------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------|----------|---------------------------------------------|
| # (number)            | No       | Text input                    | Sequential string set on Add Row ( <code>String(length+1)</code> , :190 ) or row index+1 when seeded from findings ( <code>route.ts:22</code> ) | None enforced; free text                                                                                    | Yes      | Row number / sequence                       |
| Recommendation        | No       | Textarea (2 rows)             | Empty on Add Row; seeded from finding <code>recommendation</code> when pre-filled ( <code>route.ts:23</code> )                                  | None enforced                                                                                               | Yes      | The recommendation text                     |
| Official              | No       | Text input                    | Empty on Add Row; seeded from finding <code>responsiblePerson</code> ( <code>route.ts:24</code> )                                               | None enforced                                                                                               | Yes      | Responsible official                        |
| Due Date              | No       | Date input                    | Empty on Add Row; seeded from finding <code>targetDate</code> (YYYY-MM-DD) ( <code>route.ts:25</code> )                                         | None enforced; drives overdue detection                                                                     | Yes      | Implementation / due date                   |
| Implementation Status | No       | Select                        | "Open" ( :194 , :484 ); seeded from finding <code>status</code> if it is one of the four values, else "Open" ( <code>route.ts:26-28</code> )    | One of Open / In Progress / Implemented / Closed ( :80 )                                                    | Yes      | Implementation status of the recommendation |
| Progress              | No       | Number input (min 0, max 100) | "0" on Add Row; "100" when seeded from a finding whose status is "Closed", else "0" ( <code>route.ts:29</code> )                                | <code>min={0} max={100}</code> on the input; non-numeric treated as 0 in <code>Avg.Progress</code> ( :415 ) | Yes      | Percent complete                            |
| Notes                 | No       | Text input                    | Empty                                                                                                                                           | None enforced                                                                                               | Yes      | Free-text notes                             |

Stored as a JSON array in `AuditFollowUpMeeting.recommendations` ( `prisma/schema.prisma:3753` ).

## Tables

### Follow-up list table ( `follow-up/page.tsx:167-227` )

- **Columns:** Audit ID, Engagement, Department, Audit Manager, Status, Action.
- **Search:** client-side, matches Audit ID or Engagement title ( :96-99 ).
- **Filtering:** Status (All Statuses / Pending / In Progress / Completed) and Department ( :140-163 , applied at :100-101 ).
- **Sorting:** none implemented.
- **Pagination:** none implemented.
- **Row action:** **Open** button -> navigates to `/internal-audit/follow-up/[id]` .
- **Bulk actions:** none.
- **Status badge colors:** Completed = green, In Progress = blue, Pending = yellow, otherwise slate ( :40-51 ).

### Attendees table ( `follow-up/[id]/page.tsx:336-382` )

- **Columns:** Name, Job Title, Management, Signature, plus a delete column.
- **Row action:** trash icon deletes the row (client-side only until Save).
- **Add:** Add Row button (if editable). No sorting, search, filtering, pagination, or bulk actions. Empty state: **"No rows. Use Add Row."**

### Recommendations grid ( `follow-up/[id]/page.tsx:423-541` )

- **Columns:** #, Recommendation, Official, Due Date, Implementation Status, Progress, Notes, plus a delete column.
- **Row action:** trash icon deletes the row (client-side only until Save).
- **Add:** Add Row button (if editable). No sorting, search, filtering, or pagination. No bulk actions. Empty state: **"No rows. Use Add Row."**
- **Conditional formatting:** overdue rows highlighted red; overdue date cells get a red border and an inline "Overdue" label ( :447 , :476-480 ).

## Buttons & Actions

| Control                                | Permission                                                               | Visible To                         | Action                                                                                          | API                                                                                         | Success Msg                                           | Failure Msg                                                                                                              | Audit Trail                                 | Notification |
|----------------------------------------|--------------------------------------------------------------------------|------------------------------------|-------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------|-------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------|---------------------------------------------|--------------|
| <b>Open</b> (list row)                 | <code>audit.capa:view</code><br>(page access)                            | All three roles                    | Navigates to <code>/internal-audit/follow-up/[id]</code>                                        | None (client nav)                                                                           | —                                                     | —                                                                                                                        | None observed                               | None         |
| <b>Save</b>                            | <code>audit.capa:edit</code><br>(rendered only if <code>canEdit</code> ) | Audit Head, Audit Manager, Auditor | PUT entire form (upsert)                                                                        | PUT <code>/api/internal-audit/engagements/[id]/follow-up-meeting</code> ( route.ts:97-165 ) | Toast: <b>"Follow-up meeting form saved"</b> ( :145 ) | Toast: <b>"Failed to save follow-up meeting form"</b> ( :148 )                                                           | None observed in route (no audit-log write) | None         |
| <b>Export PDF</b>                      | <code>audit.capa:view</code><br>(always rendered)                        | All three roles                    | Saves the form first, then opens the download URL in a new tab ( :155-161 )                     | Save (PUT) then GET <code>.../follow-up-meeting/download</code>                             | (Save toast)                                          | Toast: <b>"Failed to save follow-up meeting form"</b> if the pre-save fails ( :148 ); download itself opens in a new tab | None observed                               | None         |
| <b>Print</b>                           | <code>audit.capa:view</code><br>(always rendered)                        | All three roles                    | Saves the form first, fetches the PDF, opens it and calls the browser print dialog ( :163-176 ) | Save (PUT) then GET <code>.../follow-up-meeting/download</code>                             | (Save toast)                                          | Toast: <b>"Failed to print"</b> ( :174 )                                                                                 | None observed                               | None         |
| <b>Add Row</b><br>(Attendees)          | rendered only if <code>canEdit</code>                                    | Audit Head, Audit Manager, Auditor | Appends a blank attendee row ( :178-182 )                                                       | None (client state)                                                                         | —                                                     | —                                                                                                                        | None                                        | None         |
| <b>Add Row</b><br>(Recommendations)    | rendered only if <code>canEdit</code>                                    | Audit Head, Audit Manager, Auditor | Appends a blank recommendation row with number, status "Open", progress "0" ( :184-199 )        | None (client state)                                                                         | —                                                     | —                                                                                                                        | None                                        | None         |
| <b>Delete row</b> (trash, both tables) | always rendered when row visible                                         | All who can see the form           | Removes the row from client state ( :368-373 , :526-531 ) — persisted only on next Save         | None (client state)                                                                         | —                                                     | —                                                                                                                        | None                                        | None         |

Note: the page does not disable Add Row / delete based on `canEdit` for those controls beyond what is shown; only the Save button and the Add Row headers are guarded by `canEdit`. All row edits are in-memory until **Save** persists them.

## Step-by-Step Instructions

### Open the follow-up form for an engagement:

1. In the sidebar, click **Follow-up**.
2. Optionally type in **"Search engagements..."** or set the **Status / Department** filters to narrow the list.
3. In the engagement's row, click **Open**.

**Fill in meeting details:** 4. In the **Meeting Details** card, edit any of: Audit Task Number, Assignment Title, Department, Management, Meeting Venue, History (Audit Task Number and Assignment Title may be pre-filled from the engagement).

**Record attendees:** 5. In the **Attendees** card, click **Add Row** for each attendee. 6. Enter Name, Job Title, Management, Signature. Use the trash icon to remove a row.

**Manage recommendations:** 7. In **Status of Implementation of Recommendations**, review any rows pre-filled from the engagement's findings (recommendation text, official, due date, status). Add more with **Add Row**. 8. For each recommendation, set/adjust: # (number), Recommendation text, Official, Due Date, Implementation Status (Open / In Progress / Implemented / Closed), Progress (0-100%), Notes. 9. Watch the summary chips (Total / Implemented / Overdue / Avg. Progress) and the red highlight on overdue rows to gauge implementation status.

**Save / output:** 10. Click **Save** to persist all changes (toast "Follow-up meeting form saved"). 11. Click **Export PDF** to save and open the PDF in a new tab, or **Print** to save, fetch the PDF, and open the browser print dialog.

## Workflow

The follow-up form has **no record-level status field and no approval workflow**. Its only persistence event is a single upsert. Per-recommendation status is tracked inside the JSON grid, not as a system status of the form.

| Stage      | Current Status    | User Action                | Validation                                                     | API                          | DB Update                                                                         | Audit Trail   | Notification | Next Status | Next User                    |
|------------|-------------------|----------------------------|----------------------------------------------------------------|------------------------------|-----------------------------------------------------------------------------------|---------------|--------------|-------------|------------------------------|
| First open | No saved form     | Open the engagement's form | Engagement must exist (else 404)                               | GET<br>.../follow-up-meeting | None (read-only; grid seeded from findings)                                       | None          | None         | —           | —                            |
| Save       | Draft (in-memory) | Click Save                 | audit.capa:edit ; engagement and customer account must resolve | PUT<br>.../follow-up-meeting | Upsert AuditFollowUpMeeting , sets createdById / updatedById ( route.ts:139-152 ) | None observed | None         | Saved       | Same or any role with access |

Per-recommendation lifecycle (within the grid, manual): a recommendation row's **Implementation Status** moves through **Open -> In Progress -> Implemented / Closed** entirely by user selection — there is no automatic transition. The **Overdue** indicator is computed, not stored (see Status Reference).

## Status Reference

There is **no status on the Follow-up Meeting record itself**.

Per-recommendation **Implementation Status** values ( follow-up/[id]/page.tsx:80 ):

| Status      | Meaning                                  | How reached                                                                                       | Who can change                 | Next statuses                    |
|-------------|------------------------------------------|---------------------------------------------------------------------------------------------------|--------------------------------|----------------------------------|
| Open        | Recommendation not yet started (default) | Default on Add Row; default when seeded from a finding whose status is not one of the four values | Any user who can edit the form | In Progress, Implemented, Closed |
| In Progress | Implementation underway                  | User selects it                                                                                   | Same                           | Open, Implemented, Closed        |
| Implemented | Recommendation has been implemented      | User selects it; counted in the <b>Implemented</b> summary chip                                   | Same                           | Open, In Progress, Closed        |
| Closed      | Recommendation closed                    | User selects it; seeded as "Closed" with progress 100 when the source finding status was "Closed" | Same                           | Open, In Progress, Implemented   |

**Overdue (computed, not a stored status):** a row is overdue when it has a Due Date that is in the past **and** its status is **not** Implemented and **not** Closed ( isOverdue , :84-96 ). Overdue rows are highlighted and counted in the **Overdue** summary chip; the status value itself is unchanged.

The **engagement Status** shown on the list page (Pending / In Progress / Completed badge, follow-up/page.tsx:40-51 ) is the engagement's own status, not a recommendation status.

## Validation Rules

- **No required fields** on the follow-up form. Every Meeting Details field, attendee field, and recommendation field is optional and unvalidated on the client; the page has no zod schema.
- **Progress input** is constrained to min=0, max=100 on the number input; non-numeric values are treated as 0 when computing Avg. Progress ( :415 ).
- **Implementation Status** is restricted to the four enum values by the Select control ( :493-497 ).
- **Server-side checks (PUT):**
  - Permission: audit.capa:edit (enforced by withAuth ).
  - The engagement must exist within the caller's tenant filter, else **404 "Engagement not found"** ( route.ts:103-109 ).
  - A customer account must resolve from the session, else **400 "No customer account associated"** ( route.ts:111-114 ).
  - attendees and recommendations are only stored if they are arrays; otherwise stored as null ( route.ts:135-136 ).
- **No duplicate checks** and **no approval checks** exist for this form.

## Success Scenarios and Failure Scenarios

### Success:

- Save succeeds -> toast **"Follow-up meeting form saved"**; the form is upserted (one record per engagement).
- Export PDF -> the form is saved, then the PDF download opens in a new tab.
- Print -> the form is saved, the PDF is fetched and opened, and the browser print dialog is invoked.

### Failures:

- **Load fails** (GET non-OK or error) -> toast **"Failed to load follow-up meeting form"**, and the form resets to the empty shell ( :126-128 ). Cause: engagement not found / not in tenant, or server error. Resolution: confirm the engagement exists and you have audit.capa:view .
- **Save fails** (PUT non-OK) -> toast **"Failed to save follow-up meeting form"** ( :148 ). Causes include: lacking audit.capa:edit , engagement missing (404), or no customer account (400). Resolution: confirm edit permission and that the engagement is valid for your account.
- **Export PDF fails to save first** -> the export does not proceed; the save-failure toast is shown (the export only runs after a successful save, :155-156 ).
- **Print fails** -> toast **"Failed to print"** ( :174 ).

## System Behaviour



- **Auto pre-fill from findings:** on first open (no saved form), the recommendation grid is auto-populated from the engagement's findings that have a non-empty Recommendation — mapping recommendation text, responsible person -> Official, target date -> Due Date, finding status -> Implementation Status (when it matches one of the four), and progress 100 for Closed findings ( `route.ts:10-32` , `:63-87` ). This is a one-time seed for display; it is only persisted once the user clicks Save.
- **Upsert:** Save creates the form if none exists for the engagement, otherwise updates it; keyed by `engagementId` (unique). It stamps `createdById` on create and `updatedById` on every save ( `route.ts:139-152` ).
- **Computed values:** the Total / Implemented / Overdue / Avg. Progress chips and the overdue row highlighting are computed on the client from the current grid ( `:400-419` , `:84-96` ); they are not stored.
- **No audit-trail logging** is performed by the follow-up GET/PUT route (no audit-log write observed in `route.ts` ).
- **No notifications** are sent by this feature.
- **Read-only behavior:** when the user lacks `audit.capa:edit` , the **Save** button and the **Add Row** buttons are hidden; the form is effectively view-only (the page does not separately disable individual inputs for that case). Print and Export PDF remain available.

## Notes / Warnings / Tips

---

- **Edits are not saved until you click Save.** Adding/deleting rows and editing fields only change in-memory state; navigating away without Save discards changes.
  - **Export PDF and Print save first.** Both buttons perform a Save before producing the PDF, so using them will persist your current edits.
  - The per-recommendation grid here is **independent** of the per-finding Recommendation field and the Report Recommendations section — editing a row here does not write back to the underlying finding. The grid is only seeded from findings on first open.
  - "Recommendation" as a per-finding field is documented in the **Findings / CAPA Tracking** chapters; the report-level **Recommendations** text block is documented in the **Audit Report** chapter.
  - There is **no Audit Manager assignment, approval, or status workflow** on this form — it is a record-keeping and tracking tool, not an approval gate.
-

# Audit Report

## Overview — Purpose, Business Objective

The **Report** module produces the formal **Internal Audit Report** for each completed audit engagement. From a single list of completed engagements, an audit-team user generates a structured report (pre-populated with document-standard section templates), refines every section inline, assigns the responsible Auditor, sets an Overall Audit Opinion, finalizes the report, and downloads it as a PDF for distribution.

The business objective is to deliver the standard internal-audit deliverable — executive summary, objectives, scope, methodology, opinion, recommendations, management-attention areas, and a detailed findings section — in a consistent, repeatable format that mirrors the organization's internal-audit report document. Findings recorded during fieldwork are automatically rolled into the report (counts, summary chart, index, and detailed notes), so the report stays synchronized with the engagement's findings without re-keying.

The module is reached from the Internal Audit sidebar item **"Report"** ( `href: /internal-audit/report` , `navigation.ts:310` ).

## Access — Roles and Required Permissions

Navigation visibility for the **Report** menu item is gated by `audit.reports:view` ( `navigation.ts:310` ).

Permissions for the three documented roles ( `permissions.ts` ):

| Role (internal key)                         | <code>audit.reports</code>                                            | <code>audit.fieldwork</code>                                            | Scope      |
|---------------------------------------------|-----------------------------------------------------------------------|-------------------------------------------------------------------------|------------|
| Audit Head ( <code>AuditHead</code> )       | * (view/create/edit/delete/approve) — <code>permissions.ts:446</code> | * — <code>permissions.ts:445</code>                                     | all        |
| Audit Manager ( <code>AuditManager</code> ) | * — <code>permissions.ts:472</code>                                   | * — <code>permissions.ts:471</code>                                     | all        |
| Auditor ( <code>Auditee</code> )            | <code>view</code> — <code>permissions.ts:535</code>                   | <code>view</code> , <code>edit</code> — <code>permissions.ts:534</code> | department |

**Important — the APIs that actually power this page are protected by `audit.fieldwork` , not `audit.reports` :**

- `GET /api/internal-audit/report/completed-engagements` → `audit.fieldwork:view` ( `completed-engagements/route.ts:118` )
- `POST /api/internal-audit/report/generate` → `audit.fieldwork:create` ( `generate/route.ts:202` )
- `GET /api/internal-audit/report/[id]` → `audit.fieldwork:view` ( `report/[id]/route.ts:86` )
- `PATCH /api/internal-audit/report/[id]` → `audit.fieldwork:edit` ( `report/[id]/route.ts:263` )
- `GET /api/internal-audit/report/[id]/download` → `audit.fieldwork:view` ( `download/route.ts:416` )

The `audit.reports` permission protects a separate, unused-by-this-page pair of routes under `/api/internal-audit/reports/` (note the plural). The list page calls only the **singular** `report/` endpoints, so effective access is governed by `audit.fieldwork` .

Because the displayed role **"Auditor"** maps to the internal key `Auditee` (via `ROLE_DISPLAY_OVERRIDES` , `permissions.ts:319` ), and `Auditee` has only `audit.fieldwork:view`, `edit` and `audit.reports: view` (department scope):

- Audit Head / Audit Manager** (audit team): full use — open, generate, edit, finalize, download.
- Auditor (Auditee)** (department-scoped): can open existing reports and edit only the **Auditor Comment**; cannot generate, cannot edit report sections. In the list, the "Pending" (no-report) rows are non-clickable for Auditee-only users.

Note: the client page uses `useHasRole("Auditee")` for the comment editor and `useHasRole("Auditor")` / `useHasRole("AuditHead")` for edit/finalize. The legacy internal `"Auditor"` key is retired and is not assignable; users acting as auditors hold the `Auditee` key.

## Prerequisites

Before this module can be used:

- An audit engagement must exist and be in status `Completed`** . The list shows only engagements whose status is `Completed` / `completed` / `COMPLETED` ( `completed-engagements/route.ts:31-36` ). Report generation is rejected for any other status with `"Only completed engagements can have reports generated"` ( `generate/route.ts:81-86` ).
- No report may already exist for that engagement**. A second generation attempt returns `"Report already exists for this engagement"` ( `generate/route.ts:89-94` ). Each engagement has at most one report ( `engagementId` is unique — `schema.prisma:3540` ).
- To populate the auto-derived sections (observation counts, summary chart, Index of Audit Notes, Detailed Notes), the engagement should have **findings** recorded during fieldwork. With none, those sections show `"No observations recorded"`.
- To assign a responsible **Auditor** in the report, the current user must have auditees returned by `/api/users/my-auditees` ( `report/[id]/page.tsx:178` ).

## Page Layout

List page — `/internal-audit/report`

**Screenshot:** *Insert screenshot here*

Visible areas ( `report/page.tsx` ):

- **Breadcrumb** (top): Home icon + "Internal Audit" > (if the user can view the dashboard) "Dashboard" link > **"Reports"** (current). Lines 169-186.
- **Page title:** `Reports` (h1, line 209).
- **Engagements card** containing:
  - **Toolbar** (line 214): filter tabs and a search box.
    - **Filter tabs** with live counts: **All**, **Draft**, **Final** (lines 163-167). "Draft" counts engagements that have a report whose status is not `Final`; "Final" counts those whose report status is `Final`.
    - **Search box** with placeholder `Search engagements...` (line 235).
  - **List** of engagement rows (lines 244-293). Each row shows the engagement title and a subtitle line `Department · Audit Type · Auditor name`, plus a status pill on the right:
    - **Pending** (amber) — no report yet.
    - **Final** (green) — report status is `Final`.
    - **Draft** (blue) — report exists but status is not `Final`. A chevron appears on clickable rows.
  - **Empty state** (lines 284-292): a file icon, `No engagements found`, and `Try adjusting your search or filter`.
  - **Pagination** control at the bottom (10 rows per page; lines 295-301).
- **Generate Audit Report dialog** (rendered only for audit-team users; lines 305-342) — see Buttons & Actions and Step-by-Step.
- **Loading state:** spinner with `Loading reports...` (lines 188-204).

## Detail page — `/internal-audit/report/[id]`

The `[id]` segment is the **engagement ID**, not the report ID (`report/[id]/page.tsx:110`, fetch at line 162).

**Screenshot:** *Insert screenshot here*

Visible areas (`report/[id]/page.tsx`):

- **Breadcrumb:** "Internal Audit" > "Reports" > **"Report Details"** (lines 379-390).
- **Header bar** (lines 393-407): a **Back** link (arrow), the label **"Internal Audit Report"**, and a status pill on the right — **Final** (green) or **Draft** (amber).
- **Report body** (white card, lines 410-751):
  - Centered title **"INTERNAL AUDIT REPORT"**.
  - **Metadata block** (lines 414-469): Audit Title, Report Number, Report Date, Fieldwork Period, Department, Audit Manager, Distribution, Auditor (the Auditor row becomes a dropdown in edit mode).
  - Narrative sections, each with a heading and either read-only text or an editable textarea (in edit mode): **Executive Summary**, **Audit Objectives**, **Scope of Work**, **Exclusion from the Scope of Work**, **Audit Methodology**.
  - **Opinion block** (lines 482-527): "Overall Audit Opinion" badge/selector, opinion summary text, and a 4-card auto count row — **Total Observations**, **High Risk**, **Medium Risk**, **Low Risk**.
  - More narrative sections: **Recommendations**, **Top Messages for Senior Management**, **Key Risks**, **Summary of Key Audit Findings**.
  - **Areas Requiring Management's Attention** (lines 540-560): two sub-fields — **Immediate Action** and **Medium-Term Improvement**.
  - **Follow up** section.
  - **DETAILED REPORT** divider, then:
    - **Priorities for the Implementation of Audit Recommendations** table (static definitions: High/Medium/Low/Minor).
    - **Definition of Finding Types** table (static: Absence of Control, Lack of Operational Effectiveness, Best Practices, Non-Compliance).
    - **Summary of Audit Findings** bar chart (findings by type × risk level).
    - **Index of Audit Notes** table (# / Summary of Findings / Priority).
    - **Detailed Notes** — one card per finding (Criteria, Condition, Cause, Effect, Recommendation, Responsible Person, Target Date).
  - **Auditor Comment** section (lines 721-750) with an inline **Edit** control for the Auditee.
- **Footer actions** (lines 753-789): **Download Report**, and conditionally **Finalize Report / Revert to Draft** (Audit Head only) and **Edit / Cancel + Save** (audit team).
- **Loading state:** spinner. **Not-found state:** `Report Not Found` with a back link to `/internal-audit/report` (lines 329-331).

## Field Reference

Editable report fields (detail page edit form, `report/[id]/page.tsx`; backing columns schema:prisma:3543-3575). All narrative fields are free text, optional, and stored as nullable strings. Defaults shown are the document-standard templates injected at generation (`generate/route.ts`).

| Field                                              | Required  | Type       | Default (at generate)                                      | Validation                                               | Editable                                                                       | Description                                                            |
|----------------------------------------------------|-----------|------------|------------------------------------------------------------|----------------------------------------------------------|--------------------------------------------------------------------------------|------------------------------------------------------------------------|
| Audit Title                                        | — (auto)  | text       | engagement title                                           | none                                                     | No (display)                                                                   | Report title; set to engagement title at generation                    |
| Report Number                                      | — (auto)  | text       | RPT-NNNN                                                   | unique serial per tenant                                 | No                                                                             | Auto-generated report code                                             |
| Report Date                                        | — (auto)  | date       | report.updatedAt                                           | none                                                     | No                                                                             | Displayed from updatedAt                                               |
| Fieldwork Period                                   | — (auto)  | date range | actual/planned start–end                                   | none                                                     | No                                                                             | Derived from engagement dates                                          |
| Department                                         | — (auto)  | text       | engagement department                                      | none                                                     | No                                                                             | From engagement                                                        |
| Audit Manager                                      | — (auto)  | text       | engagement assigned auditor                                | none                                                     | No                                                                             | From engagement.assignedAuditor                                        |
| Distribution                                       | — (fixed) | text       | Audit Committee, CFO, Controller, IT Head                  | none                                                     | No (hard-coded)                                                                | Hard-coded string (report/[id]/page.tsx:337; download/route.ts:220)    |
| Auditor (auditeeld)                                | No        | select     | empty                                                      | must be one of the user's auditees                       | Yes (audit team)                                                               | Assigns responsible Auditor; auditeeName is derived from the selection |
| Executive Summary                                  | No        | textarea   | standard template                                          | none                                                     | Yes (audit team)                                                               | Narrative                                                              |
| Audit Objectives (objectives)                      | No        | textarea   | standard template                                          | none                                                     | Yes (audit team)                                                               | Falls back to engagement objective if empty                            |
| Scope of Work (scope)                              | No        | textarea   | standard template                                          | none                                                     | Yes (audit team)                                                               | Falls back to engagement scope if empty                                |
| Exclusion from the Scope of Work (scopeExclusions) | No        | textarea   | The scope of work did not include:                         | none                                                     | Yes (audit team)                                                               | Narrative                                                              |
| Audit Methodology (methodology)                    | No        | textarea   | standard template                                          | none                                                     | Yes (audit team)                                                               | Narrative                                                              |
| Overall Audit Opinion (opinionRating)              | No        | select     | from generate dialog (default Satisfactory)                | one of Satisfactory / Needs Improvement / Unsatisfactory | Yes (audit team)                                                               | Drives the opinion badge color                                         |
| Opinion summary (opinionSummary)                   | No        | textarea   | standard template                                          | none                                                     | Yes (audit team)                                                               | Narrative                                                              |
| Recommendations                                    | No        | textarea   | standard template                                          | none                                                     | Yes (audit team)                                                               | Narrative                                                              |
| Top Messages for Senior Management (topMessages)   | No        | textarea   | standard template                                          | none                                                     | Yes (audit team)                                                               | Narrative                                                              |
| Key Risks (keyRisks)                               | No        | textarea   | Operational / Financial / Compliance / Reputation template | none                                                     | Yes (audit team)                                                               | Narrative                                                              |
| Summary of Key Audit Findings (summaryKeyFindings) | No        | textarea   | 1.\n2. template                                            | none                                                     | Yes (audit team)                                                               | Narrative                                                              |
| Immediate Action (mgmtAttentionImmediate)          | No        | textarea   | empty                                                      | none                                                     | Yes (audit team)                                                               | Management attention                                                   |
| Medium-Term Improvement (mgmtAttentionMediumTerm)  | No        | textarea   | empty                                                      | none                                                     | Yes (audit team)                                                               | Management attention                                                   |
| Follow up (followUp)                               | No        | textarea   | standard template                                          | none                                                     | Yes (audit team)                                                               | Narrative                                                              |
| Conclusion (conclusion)                            | No        | text       | standard template                                          | none                                                     | In edit form payload (not shown as its own visible section on the detail page) | Stored; used by generation only on this page                           |
| Auditor Comment (auditeeComment)                   | No        | textarea   | empty                                                      | none                                                     | Yes (Auditee only)                                                             | Comment by the responsible Auditor                                     |

The generate dialog has one field: **Overall Audit Opinion** ( `opinionRating` ), a select over Satisfactory / Needs Improvement / Unsatisfactory, defaulting to Satisfactory (report/page.tsx:70, 318-328).

## Tables

### List page — engagements list

- **Columns/content:** title; subtitle Department • Audit Type • Auditor name ; status pill (Pending / Draft / Final). It is a row-based list, not a column grid.
- **Sorting:** none in the UI. The API returns engagements ordered by `createdAt desc` (completed-engagements/route.ts:79).
- **Searching:** client-side over engagement title, department name, audit type, and assigned auditor name (report/page.tsx:142-147).
- **Filtering:** All / Draft / Final tabs (report/page.tsx:148-167).

- **Pagination:** client-side, 10 per page (report/page.tsx:65, 156-161).
- **Row actions:** click a row — if it has a report, opens the report detail; if it does not have a report and the user is not Auditee-only, opens the **Generate Audit Report** dialog (report/page.tsx:102-110). For Auditee-only users, no-report rows are disabled.
- **Bulk actions:** none.

**Detail page — reference and findings tables**

The detail page renders four tables (all read-only):

- **Priorities for the Implementation of Audit Recommendations** — static rows High / Medium / Low / Minor with descriptions (PRIORITY\_DEFINITIONS).
- **Definition of Finding Types** — static rows for the four finding types (FINDING\_TYPE\_DEFINITIONS).
- **Index of Audit Notes** — columns **Number**, **Summary of Findings**, **Priority** (one row per finding; empty → No observations recorded ).
- **Detailed Notes** — card per finding, not a grid.

No sorting/search/filter/pagination on detail-page tables.

---

**Buttons & Actions**

---

| Control                         | Permission (effective)                                            | Visible To                                                    | Action                                                         | API                                                 | Success Msg                        | Failure Msg                                                                                                                                                                                        | Audit Trail  |
|---------------------------------|-------------------------------------------------------------------|---------------------------------------------------------------|----------------------------------------------------------------|-----------------------------------------------------|------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------|
| Filter tabs (All/Draft/Final)   | <code>audit.fieldwork:view</code>                                 | All who can open the page                                     | Client-side filter                                             | —                                                   | —                                  | —                                                                                                                                                                                                  | No           |
| Search box                      | <code>view</code>                                                 | All                                                           | Client-side filter                                             | —                                                   | —                                  | —                                                                                                                                                                                                  | No           |
| Row click (has report)          | <code>view</code>                                                 | All (Auditee: only rows with a report)                        | Navigate to <code>/internal-audit/report/[engagementId]</code> | <code>GET .../report/[id]</code>                    | —                                  | —                                                                                                                                                                                                  | No           |
| Row click (no report)           | <code>audit.fieldwork:create</code> (for the subsequent generate) | Audit team (not Auditee-only)                                 | Open <b>Generate Audit Report</b> dialog                       | —                                                   | —                                  | —                                                                                                                                                                                                  | No           |
| Cancel (generate dialog)        | —                                                                 | Audit team                                                    | Close dialog                                                   | —                                                   | —                                  | —                                                                                                                                                                                                  | No           |
| <b>Generate Report</b> (dialog) | <code>audit.fieldwork:create</code>                               | Audit team                                                    | Create report, then open it                                    | <code>POST .../report/generate</code>               | Report generated successfully      | Failed to generate report or server error (e.g. Only completed engagements can have reports generated, Report already exists for this engagement, Engagement ID is required, Engagement not found) | Not verified |
| <b>Edit</b> (footer)            | <code>audit.fieldwork:edit</code>                                 | AuditHead or "Auditor" (Auditor key) per <code>canEdit</code> | Enter edit mode                                                | —                                                   | —                                  | —                                                                                                                                                                                                  | No           |
| <b>Cancel</b> (edit)            | —                                                                 | Audit team                                                    | Discard edits                                                  | —                                                   | —                                  | —                                                                                                                                                                                                  | No           |
| <b>Save</b> (edit)              | <code>audit.fieldwork:edit</code>                                 | Audit team                                                    | Save report fields + Auditor assignment                        | <code>PATCH .../report/[id]</code>                  | Report saved successfully          | Failed to save report                                                                                                                                                                              | Not verified |
| <b>Edit</b> (Auditor Comment)   | <code>audit.fieldwork:edit</code>                                 | Auditee only (not AuditHead/Auditor)                          | Enter comment edit mode                                        | —                                                   | —                                  | —                                                                                                                                                                                                  | No           |
| <b>Save</b> (Auditor Comment)   | <code>audit.fieldwork:edit</code>                                 | Auditee                                                       | Save <code>auditeeComment</code>                               | <code>PATCH .../report/[id]</code>                  | Auditor comment saved successfully | Failed to save auditor comment                                                                                                                                                                     | Not verified |
| <b>Finalize Report</b>          | AuditHead role (enforced server-side)                             | AuditHead, when status ≠ Final and not editing                | Set status to <code>Final</code>                               | <code>PATCH .../report/[id] {status:"Final"}</code> | Report finalized                   | Only an Audit Head can finalize or revert a report. / Failed to update report status                                                                                                               | Not verified |
| <b>Revert to Draft</b>          | AuditHead role                                                    | AuditHead, when status = Final                                | Set status to <code>Draft</code>                               | <code>PATCH .../report/[id] {status:"Draft"}</code> | Report reverted to draft           | Only an Audit Head can finalize or revert a report. / Failed to update report status                                                                                                               | Not verified |
| <b>Download Report</b>          | <code>audit.fieldwork:view</code>                                 | All who can open the report                                   | Download PDF                                                   | <code>GET .../report/[id]/download</code>           | (file download)                    | Failed to download report (client) /                                                                                                                                                               | Not verified |

| Control | Permission (effective) | Visible To | Action | API | Success Msg | Failure Msg                                                  | Audit Trail |
|---------|------------------------|------------|--------|-----|-------------|--------------------------------------------------------------|-------------|
|         |                        |            |        |     |             | server:<br>Unable to complete the request. Please try again. |             |

No "export" permission action exists. **Download Report** is a UI control backed by the `/download` PDF route, not a permission action.

## Step-by-Step Instructions

### A. Generate a new report (Audit Head / Audit Manager)

1. Open **Internal Audit > Report**.
2. (Optional) Use the **All / Draft / Final** tabs or the **Search engagements...** box to locate the engagement. Engagements with no report show a **Pending** pill.
3. Click the engagement row (Pending).
4. In the **Generate Audit Report** dialog, the description shows the engagement title. Choose the **Overall Audit Opinion** (Satisfactory / Needs Improvement / Unsatisfactory). Default is **Satisfactory**.
5. Click **Generate Report**. The button shows **Generating...** while in progress.
6. On success, a toast `Report generated successfully` appears, the list refreshes, and the report detail page opens automatically.

### B. Edit report sections (Audit Head / Audit Manager)

1. Open the engagement's report from the list.
2. Click **Edit** (footer). All narrative sections, the Overall Audit Opinion, and the Auditor dropdown become editable.
3. (Optional) Select the responsible **Auditor** from the dropdown (populated from your auditees).
4. Edit any sections.
5. Click **Save** (shows **Saving...**). Toast `Report saved successfully` confirms; the page exits edit mode and shows updated content. To abandon, click **Cancel**.

### C. Finalize / revert (Audit Head only)

1. Open a report whose status is **Draft**.
2. Click **Finalize Report** (green). Toast `Report finalized`; the status pill turns green (**Final**), and the PDF download no longer carries the DRAFT watermark.
3. To reopen for editing, click **Revert to Draft** on a Final report. Toast `Report reverted to draft`.

### D. Add an Auditor Comment (Auditor / Auditee)

1. Open the report from the list (only reports already generated are accessible).
2. In the **Auditor Comment** section, click **Edit**.
3. Type the comment in the textarea (placeholder `Enter your comment...`).
4. Click **Save** (shows **Saving...**). Toast `Auditor comment saved successfully`. **Cancel** discards.

### E. Download the report (any role with access)

1. Open the report.
2. Click **Download Report** (footer).
3. The browser downloads a PDF named `{reportCode}_{title-with-underscores}.pdf`. Draft reports include a diagonal **DRAFT** watermark; Final/Published reports do not.

## Workflow

Only two report statuses are reachable through the UI ( `Draft` and `Final` ).

| Current Status | User Action                                                                 | Validation                                                                                            | API                                                                      | DB Update                                                                                                                                                                                                          | Audit Trail  | Notification | Next Status  | Next User                                 |
|----------------|-----------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------|--------------|--------------|-------------------------------------------|
| (no report)    | Audit team selects a completed engagement and clicks <b>Generate Report</b> | Engagement must exist, status <code>Completed</code> , and have no existing report                    | POST<br><code>.../report/generate</code>                                 | Creates <code>AuditReport</code> with template sections, <code>status=Draft</code> , <code>draftGeneratedAt=now</code> , <code>opinionRating</code> from dialog, <code>overallResult</code> <code>Pass/Fail</code> | Not verified | None         | <b>Draft</b> | Audit team (refine sections)              |
| Draft          | Audit team edits sections and <b>Save</b>                                   | None (all fields optional)                                                                            | PATCH<br><code>.../report/[id]</code>                                    | Updates only supplied fields; sets <code>auditeeId</code> / <code>auditeeName</code> if Auditor selected                                                                                                           | Not verified | None         | Draft        | Audit Head (finalize) / Auditor (comment) |
| Draft          | Audit Head clicks <b>Finalize Report</b>                                    | Status must be <code>Draft</code> / <code>Final</code> ; caller must have <code>AuditHead</code> role | PATCH<br><code>.../report/[id]</code><br>{ <code>status:"Final"</code> } | <code>status=Final</code>                                                                                                                                                                                          | Not verified | None         | <b>Final</b> | —                                         |
| Final          | Audit Head clicks <b>Revert to Draft</b>                                    | Caller must have <code>AuditHead</code> role                                                          | PATCH<br><code>.../report/[id]</code><br>{ <code>status:"Draft"</code> } | <code>status=Draft</code>                                                                                                                                                                                          | Not verified | None         | <b>Draft</b> | Audit team                                |
| Draft or Final | Auditor (Auditee) edits <b>Auditor Comment</b> and <b>Save</b>              | None                                                                                                  | PATCH<br><code>.../report/[id]</code><br>{ <code>auditeeComment</code> } | Updates <code>auditeeComment</code>                                                                                                                                                                                | Not verified | None         | unchanged    | —                                         |

The legacy generate API also writes `overallResult` ( `Pass` when opinion is `Satisfactory`, otherwise `Fail` ) for back-compat (generate/route.ts:47). This is not shown on the page.

## Status Reference

The `status` column defaults to `Draft` and the schema comment lists `Draft`, `Review`, `Final`, `Published` (schema.prisma:3567). Only **Draft** and **Final** are reachable from this module; `Review` and `Published` are not produced by these pages or APIs.

| Status           | Meaning                                                                                                                                                                                                                                                    | How reached                                                                                   | Who can change it             | Next statuses |
|------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------|-------------------------------|---------------|
| <b>Draft</b>     | Working report; editable; PDF carries DRAFT watermark                                                                                                                                                                                                      | Set on generation ( <code>status: 'Draft'</code> ); or by Audit Head reverting a Final report | Audit Head (Finalize → Final) | Final         |
| <b>Final</b>     | Finalized report; no DRAFT watermark on PDF                                                                                                                                                                                                                | Audit Head clicks <b>Finalize Report</b>                                                      | Audit Head (Revert → Draft)   | Draft         |
| Review           | Not produced by this module                                                                                                                                                                                                                                | —                                                                                             | —                             | —             |
| <b>Published</b> | Not produced by this module's UI. Referenced only by the unused plural <code>reports</code> API and the Auditee read-gate there. The download route treats <code>Final</code> or <code>Published</code> as "final" (no watermark) (download/route.ts:334). | —                                                                                             | —                             | —             |

The list page treats any report whose status is not exactly `Final` as **Draft** for tab/pill purposes (report/page.tsx:149).

## Validation Rules

- **Generate — engagement ID required:** missing `engagementId` → 400 Engagement ID is required (generate/route.ts:36-41).
- **Generate — engagement must be completed:** `status ≠ Completed` → 400 Only completed engagements can have reports generated (generate/route.ts:81-86).
- **Generate — one report per engagement:** existing report → 400 Report already exists for this engagement (generate/route.ts:89-94).
- **Generate — engagement existence/tenant:** not found within tenant → 404 Engagement not found (generate/route.ts:74-79).
- **Opinion rating whitelist:** on generate, any value not in `Satisfactory` / `Needs Improvement` / `Unsatisfactory` falls back to `Satisfactory` (generate/route.ts:44-45). On PATCH, `opinionRating` is stored as supplied (no server whitelist), but the edit UI only offers the three valid values.
- **Status transition whitelist:** PATCH `status` must be `Draft` or `Final`, else 400 Invalid status. Must be `Draft` or `Final`. (report/[id]/route.ts:160-167).
- **Finalize/revert role check:** only `AuditHead` may change status, else 403 Only an Audit Head can finalize or revert a report. (report/[id]/route.ts:168-173).
- **Report sections:** no required-field validation — all narrative fields are optional and free text. PATCH updates only keys present in the body (report/[id]/route.ts:136-156).
- **Tenant + Audit Head isolation:** all report reads/updates are scoped by tenant filter and `auditHeadFilter`; reports are not shared between Audit Heads (report/[id]/route.ts:18-21; download/route.ts:30-31).

## Success Scenarios and Failure Scenarios



## Success

- **Report generated:** Report generated successfully ; the report opens in Draft.
- **Report saved:** Report saved successfully ; edit mode closes with updated content; field translations are triggered in the background.
- **Auditor comment saved:** Auditor comment saved successfully .
- **Finalized:** Report finalized ; pill turns green; subsequent PDFs drop the DRAFT watermark.
- **Reverted:** Report reverted to draft .
- **Downloaded:** the PDF downloads (filename {reportCode}\_{title}.pdf ).

## Failure

- **Engagement not completed / already has a report / missing ID:** the generate dialog stays open and the toast shows the server message (e.g. Only completed engagements can have reports generated ). *Resolve:* complete the engagement first, or open the existing report instead of regenerating.
- **Generate fails (other):** toast Failed to generate report . *Resolve:* retry; verify the engagement exists in your tenant.
- **Save fails:** toast Failed to save report . *Resolve:* retry; confirm you still have edit access and the report exists.
- **Finalize/revert by non-Audit-Head:** 403 Only an Audit Head can finalize or revert a report. shown as a toast. *Resolve:* an Audit Head must perform the action. (The Finalize/Revert buttons are only rendered for AuditHead, so this primarily guards direct API calls.)
- **Invalid status value (direct API):** Invalid status. Must be Draft or Final.
- **Download fails:** client toast Failed to download report ; the server returns Unable to complete the request. Please try again. *Resolve:* retry.
- **Report not found / no access:** the detail page renders **Report Not Found** with a link back to the report list (e.g., wrong engagement ID, or a report belonging to another Audit Head).

## System Behaviour

- **Auto record creation:** generating a report creates one `AuditReport` row pre-filled with the standard document-section templates (Executive Summary, Objectives, Scope, Scope Exclusions, Methodology, Opinion summary, Recommendations, Top Messages, Key Risks, Summary of Key Findings, Follow up, Conclusion), `status=Draft`, and `draftGeneratedAt` set to now (generate/route.ts:159-185).
- **Auto report code:** `reportCode` is a tenant-scoped serial `RPT-NNNN` derived from the highest existing trailing number +1 (generate/route.ts:7-24).
- **Auto-derived content from findings:** observation counts (Total/High/Medium/Low), the Summary-of-Findings bar chart, the Index of Audit Notes, and the Detailed Notes are all computed from the engagement's findings; severity is collapsed to High/Medium/Low via `riskLevelOf` (Critical/High→High, Medium→Medium, else→Low). No re-keying.
- **Fixed Distribution line:** the Distribution value is a hard-coded string `Audit Committee, CFO, Controller, IT Head` on both the page and the PDF (report/[id]/page.tsx:337; download/route.ts:220).
- **DRAFT watermark:** the PDF stamps a diagonal grey **DRAFT** watermark on every page unless the report status is `Final` or `Published` (download/route.ts:333-352).
- **Dynamic translation:** on generate, save, and comment-save, report fields are sent for background translation ( `translateRecord` server-side and `triggerTranslation` client-side); the page displays translated values via `useTranslatedRecord` / `useTranslatedData` when available.
- **Auditor name derivation:** when an Auditor is selected on save, `auditeeName` is computed from the selected user's first/last name and persisted alongside `auditeeId` (report/[id]/page.tsx:192-195).
- **Read-only behavior:** report sections are read-only outside edit mode and for Auditees (who may edit only the Auditor Comment). Finalize/Revert render only for Audit Head.
- **Audit-trail logging / notifications: Not verified** — no audit-trail write or notification dispatch was found in the report generate / update / download routes.

## Notes / Warnings / Tips

- The detail URL key is the **engagement ID**, not the report ID — links into reports use `/internal-audit/report/{engagementId}` .
- The dialog hint states: "You can refine the opinion and all report sections after generating." — generating early is safe; everything stays editable while Draft.
- An engagement can have only **one** report. To start over you would need to remove the existing report (no delete control exists on these pages).
- Auditors (Auditees) see only reports for their department and can edit only the **Auditor Comment**; they cannot generate reports or edit report sections.
- Effective access is governed by `audit.fieldwork` (not `audit.reports` ), because the functional list page calls the singular `/report/` endpoints.
- The schema's `Review` and `Published` statuses are not produced by this module; treat Draft and Final as the only operative statuses here.

# Follow-up

## Overview — Purpose, Business Objective

The **Follow-up** module is used to track the implementation of audit recommendations after an engagement's findings have been raised. For each audit engagement it provides a single **Follow-up Meeting Form for the Implementation of the Recommendations**, where the audit team records the follow-up meeting details, the meeting attendees, and a per-recommendation implementation-status grid (status, due date, percentage progress and notes).

The business objective is to give the Internal Audit team a structured, printable record that captures whether each recommendation arising from an engagement has been implemented, who is responsible, when it is due, and how far it has progressed — supporting closure of the audit cycle and management reporting.

The module is a standalone top-level menu item (a sibling of the "Internal Audit" menu), described in code as hosting "the Follow-up Meeting Form for tracking implementation of audit recommendations" ( `src/lib/navigation.ts:319-328` ).

## Access — Roles and Required Permissions

The module is governed by the `audit.capa` resource.

- **Navigation visibility** requires `audit.capa:view` ( `src/lib/navigation.ts:327` ).
- **List page** ( `/internal-audit/follow-up` ) and **detail page GET** require `audit.capa view` (API: `src/app/api/internal-audit/engagements/[id]/follow-up-meeting/route.ts:93` ).
- **Saving the form (PUT)** requires `audit.capa edit` ( `...follow-up-meeting/route.ts:164` ).
- **Export PDF / Print (download)** require `audit.capa view` ( `...follow-up-meeting/download/route.ts:231` ).

On the detail page the **Save** button and both **Add Row** buttons are only rendered when the client-side `canEdit` permission for `audit.capa` is true ( `src/app/(protected)/internal-audit/follow-up/[id]/page.tsx:102,254,328,392` ).

Permission matrix for the three documented roles (from `src/lib/permissions.ts` ):

| Role (display) | Internal key | audit.capa actions | Scope      | View | Create | Edit | Delete | Approve | Export                                      |
|----------------|--------------|--------------------|------------|------|--------|------|--------|---------|---------------------------------------------|
| Audit Head     | AuditHead    | * (all actions)    | all        | Yes  | Yes    | Yes  | Yes    | Yes     | — (no export action; see Buttons & Actions) |
| Audit Manager  | AuditManager | * (all actions)    | all        | Yes  | Yes    | Yes  | Yes    | Yes     | —                                           |
| Auditor        | Auditee      | view, edit         | department | Yes  | No     | Yes  | No     | No      | —                                           |

Notes:

- "Auditor" is the user-facing display name for the internal `Auditee` key via `ROLE_DISPLAY_OVERRIDES` ( `src/lib/permissions.ts:319-321` ).
- The Auditor (Auditee) role is **department-scoped** for `audit.capa` and has only `view` and `edit` ( `src/lib/permissions.ts:536` ). There is no `delete` or `create` action wired to any control on this page (the form is upserted via the same `edit`-gated PUT), so the `view / edit` pair is sufficient to use the entire page.
- There is **no dedicated permission action named** `export` anywhere in the matrix; the Export PDF and Print controls are gated only by `audit.capa:view` .

## Prerequisites

- The user must be signed in with a role that grants `audit.capa:view` (so the menu item appears and the pages load).
- At least one **Audit Engagement** must exist — the Follow-up list is a list of engagements fetched from `/api/internal-audit/engagements` ( `.../follow-up/page.tsx:75` ). Engagements with no findings still appear; the recommendation grid simply starts empty.
- To benefit from the **auto-prefilled recommendation grid**, the engagement should already have **Internal Audit Findings** that contain a non-empty `recommendation` value. When no form has been saved yet, the GET endpoint builds the recommendation rows from those findings ( `...follow-up-meeting/route.ts:62-87` ).
- To **save** edits, the user needs `audit.capa:edit` and must be associated with a customer account (the PUT returns "No customer account associated" if none) ( `...follow-up-meeting/route.ts:111-114` ).

**Screenshot:** *Insert screenshot here*

### Follow-up list page ( `/internal-audit/follow-up` )

Visible areas ( `src/app/(protected)/internal-audit/follow-up/page.tsx` ):

- **Breadcrumb** — "Internal Audit" (with a Home icon) > **Follow-up**.
- **Page header** — a `ListChecks` icon plus the title **Follow-up**.
- **Toolbar** above the table containing:
  - A **search box** with placeholder "Search engagements..." (filters by Audit ID or Engagement title).
  - A **Status** filter dropdown: "All Statuses", "Pending", "In Progress", "Completed".
  - A **Department** filter dropdown: "All Departments", followed by one item per department.
- **Engagements table** with columns: **Audit ID**, **Engagement**, **Department**, **Audit Manager**, **Status**, **Action**. Each row's Action column has an **Open** button linking to the detail page.
- Loading state shows a spinner; empty state shows "No engagements found."

Follow-up Meeting Form detail page ( /internal-audit/follow-up/[id] )

Visible areas ( src/app/(protected)/internal-audit/follow-up/[id]/page.tsx ):

- **Breadcrumb** — "Internal Audit" > **Follow-up** (link) > the engagement's Audit Task Number (or "Meeting Form" if blank).
- **Page header** — a back arrow (returns to the Follow-up list) and the title **Follow-up Meeting Form for the Implementation of the Recommendations**.
- **Header action buttons** — **Print**, **Export PDF**, and (only when `canEdit`) **Save**.
- **Meeting Details** card — six input fields: Audit Task Number, Assignment Title, Department, Management, Meeting Venue, History.
- **Attendees** card — an **Add Row** button (edit only) and a table (Name, Job Title, Management, Signature, plus a delete column).
- **Status of Implementation of Recommendations** card — summary chips (when at least one row exists), an **Add Row** button (edit only), and a recommendation grid (#, Recommendation, Official, Due Date, Implementation Status, Progress, Notes, plus a delete column).

Page Layout

List page

- **Header / breadcrumb:** as above.
- **Summary cards:** none on the list page.
- **Tabs:** none.
- **Search:** single text box, client-side filter on `auditId` and `engagementTitle`.
- **Filters:** Status (Pending / In Progress / Completed / All) and Department; both client-side.
- **Table:** see Tables section.
- **Row action:** **Open** button (outline) navigating to `/internal-audit/follow-up/{engagementId}`.
- **Footer / pagination:** none.

Detail page

- **Header / breadcrumb:** as above, plus back-arrow button.
- **Header buttons:** Print, Export PDF, Save (Save only when `canEdit`). All three are disabled while the page is loading or a save is in flight.
- **Cards (top to bottom):** Meeting Details, Attendees, Status of Implementation of Recommendations.
- **Summary chips** (inside the recommendations card, shown only when there is  $\geq 1$  recommendation): **Total**, **Implemented**, **Overdue**, **Avg. Progress** ( ... [id]/page.tsx:400-421 ).
- **Dialogs / side panels:** none. All editing is inline on the page.
- **Footer:** none.

Field Reference

Meeting Details (header fields)

| Field             | Required | Type       | Default                                                                                                | Validation | Editable                     | Description                                                                                           |
|-------------------|----------|------------|--------------------------------------------------------------------------------------------------------|------------|------------------------------|-------------------------------------------------------------------------------------------------------|
| Audit Task Number | No       | Text input | Prefilled from engagement <code>auditId</code> when no form saved ( <code>route.ts:82</code> )         | None       | Yes ( <code>canEdit</code> ) | Free-text reference for the audit task; also used in the breadcrumb.                                  |
| Assignment Title  | No       | Text input | Prefilled from engagement <code>engagementTitle</code> when no form saved ( <code>route.ts:81</code> ) | None       | Yes                          | Title of the audit assignment/engagement.                                                             |
| Department        | No       | Text input | Empty                                                                                                  | None       | Yes                          | Free-text department name (note: this is a plain text field, not the engagement's linked department). |
| Management        | No       | Text input | Empty                                                                                                  | None       | Yes                          | Management responsible.                                                                               |
| Meeting Venue     | No       | Text input | Empty                                                                                                  | None       | Yes                          | Where the follow-up meeting was held.                                                                 |
| History           | No       | Text input | Empty                                                                                                  | None       | Yes                          | Free-text history note.                                                                               |

Attendees row

| Field      | Required | Type       | Default | Validation | Editable | Description                 |
|------------|----------|------------|---------|------------|----------|-----------------------------|
| Name       | No       | Text input | Empty   | None       | Yes      | Attendee name.              |
| Job Title  | No       | Text input | Empty   | None       | Yes      | Attendee job title.         |
| Management | No       | Text input | Empty   | None       | Yes      | Attendee's management/area. |
| Signature  | No       | Text input | Empty   | None       | Yes      | Free-text signature field.  |

Recommendation row

| Field                 | Required | Type                          | Default                                                                            | Validation                                                              | Editable | Description                                            |
|-----------------------|----------|-------------------------------|------------------------------------------------------------------------------------|-------------------------------------------------------------------------|----------|--------------------------------------------------------|
| # (number)            | No       | Text input                    | Sequential index assigned on Add Row; prefilled 1..n from findings ( route.ts:22 ) | None                                                                    | Yes      | Row number/label.                                      |
| Recommendation        | No       | Textarea (2 rows)             | Empty; prefilled from finding recommendation                                       | None                                                                    | Yes      | The recommendation text.                               |
| Official              | No       | Text input                    | Empty; prefilled from finding responsiblePerson                                    | None                                                                    | Yes      | Official/person responsible for implementing.          |
| Due Date              | No       | Date picker                   | Empty; prefilled from finding targetDate ( route.ts:25 )                           | None (browser date control)                                             | Yes      | Implementation due date. Drives the Overdue indicator. |
| Implementation Status | No       | Select                        | "Open" on Add Row; mapped from finding status when prefilled ( route.ts:26-28 )    | One of: Open, In Progress, Implemented, Closed ( ... [id]/page.tsx:80 ) | Yes      | Tracks implementation state.                           |
| Progress              | No       | Number input (min 0, max 100) | "0" on Add Row; "100" if source finding status is "Closed" ( route.ts:29 )         | min 0 / max 100 attributes; not enforced server-side                    | Yes      | Percent complete; feeds the Avg. Progress chip.        |
| Notes                 | No       | Text input                    | Empty                                                                              | None                                                                    | Yes      | Free-text notes.                                       |

Note: no field on this page is marked required and there is **no Zod or server-side validation** on the form payload — the PUT handler accepts and stores whatever values are supplied ( route.ts:116-152 ).

## Tables

### Engagements table (list page)

- **Columns:** Audit ID, Engagement, Department, Audit Manager, Status, Action.
- **Audit Manager column** displays assignedAuditors joined by ", " (or "-") ( page.tsx:204-208 ).
- **Status column** renders a colored badge: Completed = green, In Progress = blue, Pending = yellow, anything else = grey ( page.tsx:40-51 ).
- **Searching:** client-side over Audit ID and Engagement title.
- **Filtering:** by Status and by Department (client-side).
- **Sorting:** none (rows render in the order returned by the API).
- **Pagination:** none.
- **Row actions:** Open only.
- **Bulk actions:** none.

### Attendees table (detail page)

- Inline-editable rows. Empty state: "No rows. Use Add Row." Each row has a trash (delete) icon button. No sorting/filtering/pagination.

### Recommendations table (detail page)

- Inline-editable rows. Columns: #, Recommendation, Official, Due Date, Implementation Status, Progress, Notes, delete.
- **Overdue rows** are highlighted with a red background and show a small "Overdue" label under the Due Date; the date input border turns red ( ... [id]/page.tsx:447,476-480 ).
- Empty state: "No rows. Use Add Row." No sorting/filtering/pagination.

## Buttons & Actions

| Control                    | Permission                                                                      | Visible To                         | Action                                                             | API                                                        | Success Msg                    | Failure Msg                             | Audit Trail                               | Notification |
|----------------------------|---------------------------------------------------------------------------------|------------------------------------|--------------------------------------------------------------------|------------------------------------------------------------|--------------------------------|-----------------------------------------|-------------------------------------------|--------------|
| Open (list row)            | audit.capa:view                                                                 | All roles with view                | Navigate to detail page                                            | none (client nav)                                          | —                              | —                                       | None                                      | None         |
| Save (detail header)       | audit.capa:edit (rendered only when canEdit )                                   | Audit Head, Audit Manager, Auditor | Upsert the form                                                    | PUT /api/internal-audit/engagements/{id}/follow-up-meeting | "Follow-up meeting form saved" | "Failed to save follow-up meeting form" | Not verified (no audit-log call in route) | None         |
| Print (detail header)      | audit.capa:view (save runs first, so effectively needs edit if changes pending) | All roles with view                | Save, then fetch PDF and open browser print dialog                 | PUT then GET .../follow-up-meeting/download                | (uses Save's toast)            | "Failed to print" / "Failed to save..." | Not verified                              | None         |
| Export PDF (detail header) | audit.capa:view (save runs first)                                               | All roles with view                | Save, then open PDF in a new tab                                   | PUT then GET .../follow-up-meeting/download                | (uses Save's toast)            | "Failed to save follow-up meeting form" | Not verified                              | None         |
| Add Row (Attendees)        | audit.capa:edit ( canEdit )                                                     | Audit Head, Audit Manager, Auditor | Append a blank attendee row (client only until Save)               | none until Save                                            | —                              | —                                       | None                                      | None         |
| Add Row (Recommendations)  | audit.capa:edit ( canEdit )                                                     | Audit Head, Audit Manager, Auditor | Append a recommendation row defaulting to status Open / progress 0 | none until Save                                            | —                              | —                                       | None                                      | None         |
| Trash icon (per row)       | edit                                                                            | rendered for all who can see rows  | Remove that row from the in-memory list (persists on next Save)    | none until Save                                            | —                              | —                                       | None                                      | None         |
| Back arrow (header)        | view                                                                            | All                                | Navigate to /internal-audit/follow-up                              | none                                                       | —                              | —                                       | None                                      | None         |

Important caveats:

- The **delete (trash) icon** in both tables is rendered unconditionally (it is not wrapped in `canEdit`), so a view-only context would still show it; however, removals only persist when the **Save** button is used, and Save requires `audit.capa:edit`.
- Print** and **Export PDF** both call `save()` first; if the user lacks `edit`, the PUT returns 403 and the action fails with "Failed to save follow-up meeting form" before the PDF is produced.

## Step-by-Step Instructions

### Open an engagement's follow-up form

1. Open **Follow-up** from the main menu.
2. (Optional) Type into **Search engagements...** to filter by Audit ID or Engagement title.
3. (Optional) Choose a **Status** and/or **Department** filter.
4. Locate the engagement row and click **Open**.

### Fill in the Meeting Details

1. On the detail page, in the **Meeting Details** card, edit any of: Audit Task Number, Assignment Title, Department, Management, Meeting Venue, History.
2. Click **Save**. A "Follow-up meeting form saved" confirmation appears.

### Record attendees

1. In the **Attendees** card, click **Add Row**.
2. Enter Name, Job Title, Management, Signature for each attendee (repeat Add Row as needed).
3. To remove an attendee, click the trash icon on that row.
4. Click **Save**.

### Track recommendation implementation

1. In the **Status of Implementation of Recommendations** card, review the rows that were pre-filled from the engagement's findings (if any), or click **Add Row** to add one.
2. For each row, set/adjust: # (number), Recommendation, Official, Due Date, Implementation Status (Open / In Progress / Implemented / Closed), Progress (0–100), Notes.
3. Watch the summary chips (Total, Implemented, Overdue, Avg. Progress) update as you edit.
4. Click **Save**.

## Export or print the form

1. Click **Export PDF** to save the current form (then open the generated PDF in a new tab), or **Print** to save and open the browser print dialog.
2. The downloaded file is named `Follow-up-Meeting-{auditId}.pdf` ( `download/route.ts:218` ).

## Workflow

This module does not implement an engagement-level multi-stage approval workflow; it is a single upsertable form per engagement. The only state transition is the per-recommendation **Implementation Status**.

| Current Status      | User Action                                                 | Validation                           | API                                    | DB Update                                                                            | Audit Trail                | Notification | Next Status                                             | Next User |
|---------------------|-------------------------------------------------------------|--------------------------------------|----------------------------------------|--------------------------------------------------------------------------------------|----------------------------|--------------|---------------------------------------------------------|-----------|
| (No form saved)     | Open detail page                                            | engagement must exist & be in tenant | GET <code>.../follow-up-meeting</code> | none (read)                                                                          | Not verified               | None         | Blank form prefilled from findings                      | same user |
| (Form / row exists) | Change a recommendation's Implementation Status, click Save | none (all fields optional)           | PUT <code>.../follow-up-meeting</code> | upsert <code>AuditFollowUpMeeting</code> ; <code>recommendations</code> JSON updated | Not verified (no log call) | None         | The chosen status (Open/In Progress/Implemented/Closed) | same user |

## Status Reference

### Recommendation Implementation Status (per row)

Defined as `IMPLEMENTATION_STATUSES = ["Open", "In Progress", "Implemented", "Closed"]` ( `...[id]/page.tsx:80` ).

| Status      | Meaning                                                                                                             | How reached                                                                                       | Who can change                            | Next statuses                    |
|-------------|---------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------|-------------------------------------------|----------------------------------|
| Open        | Recommendation not yet started (default for new rows; default mapping when a source finding status is unrecognized) | Default on Add Row; mapped from findings ( <code>route.ts:26-28</code> )                          | Audit Head, Audit Manager, Auditor (edit) | In Progress, Implemented, Closed |
| In Progress | Implementation under way                                                                                            | Selected in the Implementation Status dropdown                                                    | same                                      | Open, Implemented, Closed        |
| Implemented | Recommendation implemented (excluded from Overdue calculation)                                                      | Selected in dropdown                                                                              | same                                      | Open, In Progress, Closed        |
| Closed      | Recommendation closed (excluded from Overdue; counts as 100% progress when derived from a Closed finding)           | Selected in dropdown; mapped from a finding whose status is "Closed" ( <code>route.ts:29</code> ) | same                                      | Open, In Progress, Implemented   |

Derived (non-stored) state: **Overdue** — a row is treated as overdue when it has a Due Date in the past **and** its status is **not** Implemented or Closed ( `...[id]/page.tsx:84-96` ). Overdue is a computed display flag, not a stored status.

### Engagement Status (list page filter only)

The list-page Status filter offers **Pending, In Progress, Completed** (plus "All Statuses"); these are the engagement's own `status` values (rendered as colored badges) and are not set within the Follow-up module — they originate from the engagement record.

## Validation Rules

- **No required fields.** Every Meeting Details, Attendee and Recommendation field is optional. The form can be saved completely empty.
- **No Zod / server-side payload validation.** The PUT handler reads the fields directly and stores `attendees / recommendations` as JSON (or null when not arrays) ( `route.ts:116-152` ).
- **Progress input** carries `min={0} max={100}` HTML attributes only ( `...[id]/page.tsx:505-506` ); values outside that range are not rejected server-side.
- **Tenant / existence checks:** both GET and PUT first look up the engagement with the tenant filter and return **404 "Engagement not found"** if it is not in the caller's tenant ( `route.ts:47-49,107-109` ).
- **Customer account check:** PUT returns **400 "No customer account associated"** if the session has no customer account ( `route.ts:112-114` ).
- **Permission checks:** enforced by `withAuth` — `audit.capa:view` for GET/download, `audit.capa:edit` for PUT. There is no duplicate check (the record is keyed `@unique` on `engagementId`, so a second save upserts the existing form).

## Success Scenarios and Failure Scenarios

### Success

- **Form loads:** GET returns either the saved form or a blank shell pre-filled from findings; the page renders without error.
- **Save succeeds:** PUT upserts `AuditFollowUpMeeting`; toast **"Follow-up meeting form saved"** appears.
- **Export PDF / Print succeed:** the form is saved, then a PDF titled "Follow-up Meeting Form for the Implementation of the Recommendations" is generated containing Meeting Details, Attendees and the recommendation grid ( `download/route.ts:164-215` ).

### Failure

| Failure                        | Why                                                                                                                           | What the user sees                                                      | How to resolve                                                                               |
|--------------------------------|-------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------|----------------------------------------------------------------------------------------------|
| Load fails                     | GET returned non-OK (404 not found, 500, or network error)                                                                    | Toast "Failed to load follow-up meeting form"; form resets to empty     | Confirm the engagement exists and you have <code>audit.capa:view</code> ; retry              |
| Save fails                     | PUT non-OK — e.g. lacks <code>audit.capa:edit</code> (403), engagement not in tenant (404), no customer account (400), or 500 | Toast "Failed to save follow-up meeting form"                           | Ensure you have edit permission and a valid customer account; verify the engagement is yours |
| Print fails                    | The fetch of the download endpoint threw                                                                                      | Toast "Failed to print" (after Save's own toast)                        | Retry; check that the save succeeded first                                                   |
| Export PDF fails               | The pre-save (PUT) failed, so the PDF is never opened                                                                         | Toast "Failed to save follow-up meeting form"                           | Same as Save failure resolution                                                              |
| Engagements list fails to load | The engagements/departments fetch threw                                                                                       | Toast "Failed to load engagements"; table shows "No engagements found." | Retry; verify permissions/connectivity                                                       |

## System Behaviour

- **Auto-prefill from findings:** When no form exists yet, the GET endpoint builds the recommendation grid from the engagement's `InternalAuditFinding` rows that have a non-empty recommendation, mapping `recommendation` , `responsiblePerson` → Official, `targetDate` → Due Date, and `status` → Implementation Status (with Closed → 100% progress) ( `route.ts:10-32,62-87` ). The same fallback is applied in the PDF download when no recommendations are saved ( `download/route.ts:38-57` ).
- **Upsert behavior:** Saving creates the `AuditFollowUpMeeting` row on first save and updates it thereafter (one form per engagement, `engagementId @unique` ). `createdById` / `updatedById` are stamped from the session ( `route.ts:139-152` ; schema `prisma/schema.prisma:3739-3760` ).
- **JSON storage:** `attendees` and `recommendations` are serialized to JSON text columns on save and parsed back on read.
- **Computed metrics:** Total / Implemented / Overdue / Avg. Progress chips are computed client-side from the in-memory rows; they are not persisted.
- **Save-before-export:** Export PDF and Print both persist the current form before producing the PDF, so the exported document always reflects what is on screen.
- **No notifications:** Neither route sends any notification on save, export, or status change.
- **Audit trail:** No explicit audit-log write exists in either route handler — any audit logging performed centrally by the `withAuth` wrapper is **Not verified** here.
- **Read-only behavior:** When the user lacks `audit.capa:edit` , the Save and both Add Row buttons are hidden; inputs remain editable on screen but changes cannot be persisted (Save is unavailable and the PUT would be rejected).

## Notes / Warnings / Tips

- **Tip:** Add and complete the engagement's findings (with recommendations, responsible persons and target dates) before opening the Follow-up form so the recommendation grid is pre-populated automatically.
- **Warning:** Print and Export PDF **save the form first**. If you have unsaved edits you do not want to commit, do not use these buttons.
- **Note:** The **Department** and **Management** fields in Meeting Details are free-text and independent of the engagement's linked department — they are not validated against the organization's department list.
- **Note:** A row's **Overdue** highlight is purely derived from Due Date vs. today and the status; setting a row to **Implemented** or **Closed** clears the Overdue flag even if the due date has passed.
- **Tip:** Use the **Implementation Status** values consistently (Open → In Progress → Implemented/Closed) so the Implemented and Avg. Progress summary chips give a meaningful at-a-glance view.

# Feedback Survey

## Overview — Purpose, Business Objective

The **Feedback Survey** page captures structured stakeholder feedback on a completed (or in-progress) internal audit engagement. The page is titled **"Internal Audit Engagement Feedback Survey"** and carries the subtitle: *"Obtain feedback on the effectiveness, professionalism, and value of the engagement (QAIP)."* ( `feedback-survey/page.tsx:192-198` )

Its business objective is to support the **Quality Assurance and Improvement Program (QAIP)**: the audit function records how the auditee rated the engagement across six structured sections, an overall satisfaction score, and two open-ended comment fields ("what the team did well" and "improvements"). The completed survey can be exported as a print-friendly PDF for the engagement file.

One survey is stored per engagement. The data is persisted in the `AuditFeedbackSurvey` model, which has a `@unique` constraint on `engagementId` — meaning each engagement has at most one survey record ( `prisma/schema.prisma:3878-3894` ).

## Access — Roles and Required Permissions

The page and its APIs are gated entirely on the `audit.fieldwork` resource. There is no dedicated "feedback" or "survey" permission resource.

| Capability                                                              | Permission required                                                | Source                                                       |
|-------------------------------------------------------------------------|--------------------------------------------------------------------|--------------------------------------------------------------|
| See the nav item / open the page                                        | <code>audit.fieldwork:view</code>                                  | <code>navigation.ts:311</code>                               |
| Load a survey (GET)                                                     | <code>audit.fieldwork + action view</code>                         | <code>feedback-survey/route.ts:53</code>                     |
| Save a survey (PUT)                                                     | <code>audit.fieldwork + action edit</code>                         | <code>feedback-survey/route.ts:118</code>                    |
| Export PDF (GET download)                                               | <code>audit.fieldwork + action view</code>                         | <code>feedback-survey/download/route.ts:195</code>           |
| Edit controls visible (rating buttons, comments, Add Row, Delete, Save) | <code>client canEdit from usePermissions("audit.fieldwork")</code> | <code>feedback-survey/page.tsx:58, 206, 257, 286, 313</code> |

How the three documented roles map to this resource:

| Role (display) | Internal key              | <code>audit.fieldwork</code> actions / scope            | Effect on this page                                                                                        |
|----------------|---------------------------|---------------------------------------------------------|------------------------------------------------------------------------------------------------------------|
| Audit Head     | <code>AuditHead</code>    | * (all actions), scope <code>all</code>                 | Full view + edit + export across all engagements ( <code>permissions.ts:445</code> )                       |
| Audit Manager  | <code>AuditManager</code> | * (all actions), scope <code>all</code>                 | Full view + edit + export across all engagements ( <code>permissions.ts:471</code> )                       |
| Auditor        | <code>Auditee</code>      | <code>view, edit</code> , scope <code>department</code> | View + edit + export, limited to engagements in their department scope ( <code>permissions.ts:534</code> ) |

All three documented roles can therefore both fill in and export the survey. (The Auditor role's data visibility is department-scoped at the tenant-filter level; see System Behaviour.)

## Prerequisites

- At least one **Audit Engagement** must exist. The page loads engagements from `GET /api/internal-audit/engagements` ; if none are returned, the selector shows **"No engagements found"** ( `feedback-survey/page.tsx:69, 228-229` ).
- The user must hold `audit.fieldwork:view` to open the page and load a survey, and `audit.fieldwork:edit` to save changes.
- The user's session must be associated with a customer account; the PUT handler returns an error if no customer account is associated ( `feedback-survey/route.ts:71-74` ).
- No prior survey record is required — opening an engagement that has never been surveyed returns an empty shell that can be filled in from scratch ( `feedback-survey/route.ts:25-36` ).

**Screenshot:** *Insert screenshot here*

The page renders the following visible areas (top to bottom):

- Breadcrumb** — `Internal Audit > Feedback Survey` ( `page.tsx:178-185` ).
- Header** — a clipboard-check icon, the title **"Internal Audit Engagement Feedback Survey"**, and the QAIP subtitle. When an engagement is selected, an action group appears on the right with **Export PDF** and (for editors) **Save** buttons ( `page.tsx:188-218` ).
- Engagement selector card** — a white card labeled **"Audit Engagement"** containing a dropdown with placeholder **"Select an engagement"** ( `page.tsx:221-239` ).
- Empty state** — before an engagement is chosen, a dashed card reads **"Select an engagement to fill in the feedback survey."** ( `page.tsx:242-243` ).
- Loading state** — a spinner while a survey loads ( `page.tsx:246-247` ).
- Six section cards (A–F)** — each a table of questions with rating buttons, an **Add Row** button, and a **Comments** textarea ( `page.tsx:251-359` ).
- Overall Satisfaction card** — a 1–5 button group plus two open-text questions ( `page.tsx:362-415` ).

## Page Layout

- Breadcrumb:** `Internal Audit (Home icon) > Feedback Survey` .
- Header title:** "Internal Audit Engagement Feedback Survey" with subtitle about QAIP.
- Header action buttons** (only shown after an engagement is selected):
  - Export PDF** (outline, Download icon) — always shown when an engagement is selected; disabled while saving or loading.



- **Save** (Save icon; shows a spinning loader while saving) — shown only when `canEdit` is true; disabled while saving or loading.
- **Engagement selector:** label "Audit Engagement"; a `Select` dropdown. Each option is rendered as `{auditId} - {engagementTitle} | {auditId}` ( `page.tsx:233` ). Empty list shows "No engagements found".
- **Summary cards:** None. There are no summary/KPI cards on this page.
- **Tabs:** None.
- **Section cards (A–F):** Each card has:
  - A header bar showing the section label (e.g. **"SECTION A – ENGAGEMENT PLANNING"**) and, for editors, an **Add Row** button (Plus icon).
  - A table with a **Question** column followed by six rating columns: **5, 4, 3, 2, 1, N/A** (the value `NA` is displayed as "N/A") ( `feedback-survey.ts:15` , `page.tsx:54` , 269–273 ).
  - Each rating cell is a round button; the selected rating shows a check mark (✓) on a filled (primary) background ( `page.tsx:283–297` ).
  - Editor-added custom rows appear with an amber-tinted background, an editable text input (placeholder **"Enter question"**), and a Delete (trash) button ( `page.tsx:302–324` ).
  - A **Comments** label and a 2-row textarea per section ( `page.tsx:350–356` ).
- **Overall Satisfaction card** (header **"OVERALL SATISFACTION"**):
  - Label **"Overall satisfaction with the audit engagement"** with five buttons numbered **1–5** ( `page.tsx:368–390` ).
  - Label **"What did the audit team do particularly well?"** with a 3-row textarea ( `page.tsx:393–401` ).
  - Label **"What improvements would you recommend?"** with a 3-row textarea ( `page.tsx:404–412` ).
- **Filters / Search / Pagination / Footer / Side panels / Action menus:** None present.

## Field Reference

Survey content is keyed by question/section keys defined in `src/lib/internal-audit/feedback-survey.ts`. No field is marked "required" in code — every input is optional and persists whatever the user enters (or leaves blank).

| Field                                                                                  | Required           | Type                                                  | Default                       | Validation                                                                                                             | Editable                       | Description                                                                                                                     |
|----------------------------------------------------------------------------------------|--------------------|-------------------------------------------------------|-------------------------------|------------------------------------------------------------------------------------------------------------------------|--------------------------------|---------------------------------------------------------------------------------------------------------------------------------|
| Audit Engagement                                                                       | Yes (to load/save) | Single-select dropdown                                | none ("Select an engagement") | Must select an engagement before Save; otherwise toast "Select an engagement first." ( <code>page.tsx:146–149</code> ) | Yes                            | Chooses which engagement's survey to view/edit. Options come from <code>/api/internal-audit/engagements</code> .                |
| Question rating (each of the fixed questions a1–a5, b1–b4, c1–c3, d1–d3, e1–e3, f1–f3) | No                 | Single choice button: 5, 4, 3, 2, 1, NA (shown "N/A") | unselected                    | One value per question; selecting another replaces it                                                                  | Yes (if <code>canEdit</code> ) | Stored in <code>responses</code> JSON keyed by question key ( <code>page.tsx:115–116</code> ; <code>schema.prisma:3882</code> ) |
| Custom row text                                                                        | No                 | Text input                                            | empty                         | none enforced; blank text exports as " (untitled)" ( <code>download/route.ts:133</code> )                              | Yes (if <code>canEdit</code> ) | Editor-added question rows, stored in <code>customRows</code> JSON per section ( <code>schema.prisma:3884</code> )              |
| Custom row rating                                                                      | No                 | Single choice button (same options)                   | unselected                    | one value per row                                                                                                      | Yes (if <code>canEdit</code> ) | Stored in <code>responses</code> keyed by the custom row key ( <code>page.tsx:325–343</code> )                                  |
| Section Comments (per section A–F)                                                     | No                 | Multiline text (2 rows)                               | empty                         | none                                                                                                                   | Yes (if <code>canEdit</code> ) | Stored in <code>comments</code> JSON keyed by section key ( <code>page.tsx:117–118</code> ; <code>schema.prisma:3883</code> )   |
| Overall satisfaction                                                                   | No                 | Single choice button 1–5                              | null                          | Coerced to a number on save; non-finite values stored as <code>null</code> ( <code>route.ts:77–86</code> )             | Yes (if <code>canEdit</code> ) | Stored in <code>overallSatisfaction</code> <code>Int?</code> column                                                             |
| What did the audit team do particularly well?                                          | No                 | Multiline text (3 rows)                               | empty                         | none                                                                                                                   | Yes (if <code>canEdit</code> ) | Stored in <code>didWell</code> text column                                                                                      |
| What improvements would you recommend?                                                 | No                 | Multiline text (3 rows)                               | empty                         | none                                                                                                                   | Yes (if <code>canEdit</code> ) | Stored in <code>improvements</code> text column                                                                                 |

## Fixed survey questions (by section)

These are hard-coded in `feedback-survey.ts:18–76`:

- **SECTION A – ENGAGEMENT PLANNING**
  - a1: "The audit objectives and scope were clearly communicated."
  - a2: "The audit team adequately explained the audit approach and methodology."
  - a3: "Audit timelines and milestones were communicated in advance."
  - a4: "Information requests were reasonable and relevant to the audit scope."
  - a5: "The opening meeting effectively explained the audit process."
- **SECTION B – PROFESSIONALISM AND COMMUNICATION**
  - b1: "The audit team demonstrated professionalism throughout the engagement."
  - b2: "The audit team maintained independence and objectivity."
  - b3: "Communication with the audit team was timely and effective."
  - b4: "The audit team demonstrated appropriate technical competence."
- **SECTION C – AUDIT EXECUTION**
  - c1: "The audit was conducted efficiently."
  - c2: "Audit observations were discussed during the engagement."
  - c3: "Audit conclusions were supported by sufficient facts and evidence."

- **SECTION D – FINDINGS AND RECOMMENDATIONS**
  - d1: "Audit findings were clearly communicated."
  - d2: "Recommendations were practical and actionable."
  - d3: "The priority ratings assigned to findings were appropriate."
- **SECTION E – REPORTING**
  - e1: "The report was logically structured and professionally presented."
  - e2: "Management responses were fairly reflected."
  - e3: "The final report was issued within an acceptable timeframe."
- **SECTION F – VALUE PROVIDED**
  - f1: "The audit added value to the department."
  - f2: "The audit contributed to strengthening governance and internal controls."
  - f3: "Overall, the audit engagement met my expectations."

## Tables

Each section (A–F) renders an HTML table, not a sortable data grid.

- **Columns:** `Question` (left-aligned, min width ~260px) followed by six fixed rating columns headed **5 / 4 / 3 / 2 / 1 / N/A** ( `page.tsx:268-273` ).
- **Rows:** One row per fixed question, then any editor-added custom rows.
- **Row actions:**
  - Rating cells (round buttons) set the chosen rating; selecting a different one replaces the prior choice. Disabled when the user lacks edit permission.
  - Custom rows have an inline text input and a **Delete** (trash) button that removes the row and its stored rating ( `page.tsx:134-143`, `313-322` ).
- **Add Row** (per section, editors only) appends a new blank custom row ( `page.tsx:120-125`, `257-262` ).
- **Sorting:** None. **Searching:** None. **Filtering:** None. **Pagination:** None. **Bulk actions:** None.

## Buttons & Actions

| Control                                                 | Permission                                                                               | Visible To                                                                  | Action                                            | API                                                                                   | Success Msg                                                 | Failure Msg                                                                                                           | Audit Trail                          | Notification |
|---------------------------------------------------------|------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------|---------------------------------------------------|---------------------------------------------------------------------------------------|-------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------|--------------------------------------|--------------|
| Audit Engagement dropdown                               | <code>audit.fieldwork:view</code> (to load)                                              | All who can open page                                                       | Selects engagement and loads its survey           | <code>GET /api/internal-audit/engagements/{id}/feedback-survey</code>                 | none (silent load)                                          | toast "Failed to load feedback survey" ( <code>page.tsx:103</code> )                                                  | None (no audit-trail write in route) | None         |
| Rating button (5/4/3/2/1/N/A)                           | <code>audit.fieldwork:edit</code> (button disabled if no edit)                           | Editors                                                                     | Sets local rating for a question/row              | none until Save                                                                       | n/a                                                         | n/a                                                                                                                   | None                                 | None         |
| Add Row                                                 | <code>audit.fieldwork:edit</code>                                                        | Editors ( <code>canEdit</code> )                                            | Adds a blank custom question row to the section   | none until Save                                                                       | n/a                                                         | n/a                                                                                                                   | None                                 | None         |
| Delete (custom row trash)                               | <code>audit.fieldwork:edit</code>                                                        | Editors                                                                     | Removes the custom row and its rating locally     | none until Save                                                                       | n/a                                                         | n/a                                                                                                                   | None                                 | None         |
| Comments textarea / open-text fields / 1–5 satisfaction | <code>audit.fieldwork:edit</code>                                                        | Editors                                                                     | Edits local survey state                          | none until Save                                                                       | n/a                                                         | n/a                                                                                                                   | None                                 | None         |
| <b>Save</b>                                             | <code>audit.fieldwork:edit</code>                                                        | Editors ( <code>canEdit</code> ), shown only when an engagement is selected | Upserts the survey                                | <code>PUT /api/internal-audit/engagements/{id}/feedback-survey</code>                 | toast "Feedback survey saved" ( <code>page.tsx:158</code> ) | toast "Failed to save feedback survey" ( <code>page.tsx:161</code> ); or "Select an engagement first." if none chosen | None (no audit-trail write in route) | None         |
| <b>Export PDF</b>                                       | <code>audit.fieldwork:view</code> (download route); but it Saves first, which needs edit | All with engagement selected                                                | Saves the survey, then opens the PDF in a new tab | <code>PUT ../feedback-survey</code> then <code>GET ../feedback-survey/download</code> | (save toast as above)                                       | If save fails, export is aborted (no PDF) ( <code>page.tsx:168-171</code> )                                           | None                                 | None         |

Note on Export PDF: the handler calls `save()` first and only opens the download if the save succeeds ( `page.tsx:168-170` ). Because of this, a viewer who lacks `edit` would fail the save step and not receive a PDF, even though the download route itself only requires `view`. This save-then-download coupling is the actual implemented behavior.

## Step-by-Step Instructions

### Fill in and save a feedback survey

1. Open **Internal Audit > Feedback Survey** from the navigation.
2. In the **Audit Engagement** dropdown, select the engagement to survey. Existing survey data (if any) loads automatically.
3. For each question in sections A–F, click the rating button (**5, 4, 3, 2, 1**, or **N/A**) that reflects the response. A check mark (✓) appears on the chosen rating.
4. (Optional) Enter free text in each section's **Comments** box.
5. (Optional) Click **Add Row** in a section to add a custom question, type its text in the input, and select a rating for it.
6. In **Overall Satisfaction**, click a number **1–5** for overall satisfaction.
7. (Optional) Fill in **"What did the audit team do particularly well?"** and **"What improvements would you recommend?"**.
8. Click **Save**. On success a toast confirms **"Feedback survey saved"**.

### Remove a custom question row

1. Select the engagement.
2. In the relevant section, click the **trash** icon at the end of the custom row.
3. Click **Save** to persist the removal.

### Export the survey as PDF

1. Select the engagement.
2. Click **Export PDF**. The current survey is saved first, then the PDF opens in a new browser tab and downloads as `Feedback-Survey-{auditId}.pdf` (`download/route.ts:182`).

## Workflow

This page has **no multi-stage approval or status workflow**. The single operation is a save (upsert):

| Current state                 | User Action             | Validation                                                    | API                        | DB Update                                                                                                               | Audit Trail | Notification | Next state     | Next User  |
|-------------------------------|-------------------------|---------------------------------------------------------------|----------------------------|-------------------------------------------------------------------------------------------------------------------------|-------------|--------------|----------------|------------|
| No survey saved (empty shell) | Fill fields, click Save | Engagement must be selected; engagement must exist for tenant | PUT<br>.../feedback-survey | auditFeedbackSurvey.upsert → <b>create</b> with <code>createdById</code> / <code>updatedById</code> set to current user | None        | None         | Survey saved   | Any editor |
| Survey already saved          | Edit fields, click Save | Same                                                          | PUT<br>.../feedback-survey | auditFeedbackSurvey.upsert → <b>update</b> ( <code>updatedById</code> set; <code>createdById</code> unchanged)          | None        | None         | Survey updated | Any editor |

No status field exists on `AuditFeedbackSurvey`.

## Status Reference

**Not applicable.** The `AuditFeedbackSurvey` model has no status column and the page implements no statuses or state transitions ( `schema.prisma:3878-3894` ). The only persisted "state" indicators are the timestamps `createdAt` / `updatedAt` and the `createdById` / `updatedById` audit columns, which are not surfaced as user-facing statuses.

## Validation Rules

- **Engagement must be selected before Save.** If `selectedId` is empty, Save shows toast **"Select an engagement first."** and aborts ( `page.tsx:146-149` ).
- **Engagement must exist within the tenant.** Both GET and PUT look up the engagement with the tenant filter; if not found they return HTTP 404 "Engagement not found" ( `route.ts:20-22, 67-69` ).
- **Customer account required (PUT).** If the session has no customer account, PUT returns HTTP 400 "No customer account associated" ( `route.ts:71-74` ).
- **Overall satisfaction coercion.** On save, `overallSatisfaction` is converted with `Number(...)`; if the result is not finite it is stored as `null` ( `route.ts:77-86` ). The UI only offers integers 1–5.
- **JSON-shape guards.** On PUT, `responses`, `comments`, and `customRows` are stored only if they are objects; otherwise an empty `{}` is stored ( `route.ts:83-85` ).
- **No required-field enforcement.** Ratings, comments, and open-text are all optional; an entirely blank survey can be saved.
- **Permission checks.** GET requires `audit.fieldwork:view`; PUT and the page's edit controls require `audit.fieldwork:edit`. Edit controls are disabled in the UI when `canEdit` is false ( `page.tsx:286, 308, 354, 378, 399, 410` ).
- **No duplicate check needed.** The `@unique` constraint on `engagementId` plus the upsert means there is always exactly one survey per engagement; re-saving updates the existing record rather than creating a duplicate.

## Success Scenarios and Failure Scenarios

### Success scenarios:

- *Save a new survey:* upsert creates the record, response returns the saved data, toast **"Feedback survey saved"**.
- *Update an existing survey:* upsert updates the record (sets `updatedById`), same success toast.
- *Export PDF:* after a successful save, the PDF opens in a new tab and downloads as `Feedback-Survey-{auditId}.pdf`.
- *Load an engagement with no survey:* GET returns an empty shell ( `responses {}`, `comments {}`, `customRows {}`, `overallSatisfaction null`, blank text), and the page renders a blank, fillable form.

#### Failure scenarios:

| Scenario                         | Why it happens                                                                                     | What the user sees                                                         | How to resolve                                                                                     |
|----------------------------------|----------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------|
| Save with no engagement selected | <code>selectedId</code> is empty                                                                   | Toast "Select an engagement first."                                        | Choose an engagement in the dropdown first                                                         |
| Load fails                       | GET returns non-OK (e.g. 404 engagement not found, 500, or network error)                          | Toast "Failed to load feedback survey"; form resets to the empty shell     | Confirm the engagement exists and you have access; retry                                           |
| Save fails                       | PUT returns non-OK (e.g. 400 no customer account, 404 engagement not found, 500, or network error) | Toast "Failed to save feedback survey"                                     | Ensure your account is linked to a customer and you have <code>audit.fieldwork:edit</code> ; retry |
| Export aborted                   | The pre-export save failed                                                                         | No PDF opens (the function returns early); the save failure toast is shown | Fix the save error, then retry Export PDF                                                          |
| No engagements available         | <code>/api/internal-audit/engagements</code> returns none                                          | Dropdown shows "No engagements found"                                      | Create an audit engagement first                                                                   |

## System Behaviour

- **Single record per engagement.** Saving performs an upsert keyed on `engagementId` ( `route.ts:91-101` ); there is never more than one survey per engagement.
- **Author tracking.** On create, both `createdById` and `updatedById` are set to the current user; on update, only `updatedById` is set ( `route.ts:96-100` ). `createdAt` / `updatedAt` are maintained automatically by Prisma.
- **Tenant isolation.** All reads/writes apply `getTenantFilter(session)` against the engagement and store `customerAccountId` on create ( `route.ts:14, 61, 94` ). For the Auditor ( `Auditee` ) role, `audit.fieldwork` is scoped to `department`, constraining which engagements are accessible.
- **Empty shell on first view.** If no survey exists yet, GET returns a fully empty structure rather than 404, so the form is immediately editable ( `route.ts:25-36` ).
- **PDF generation.** The download route builds a print-friendly A4 PDF server-side with `pdf-lib`, numbering questions per section, rendering each rating as `[ value ]` (blank shown as `—`, `NA` shown as `N/A`), including section comments, the 1–5 overall satisfaction line, and the two open-text answers ( `download/route.ts:84-179` ). The file is returned as an attachment named `Feedback-Survey-{auditId}.pdf`.
- **No audit-trail logging.** Neither the save route nor the download route calls `recordAuditTrail`; saving or exporting a feedback survey is **not** recorded in the Audit Trail. (Verified by absence in `route.ts` and `download/route.ts`.)
- **No notifications.** No email or in-app notification is sent on save or export.
- **Read-only behavior.** When the user lacks `audit.fieldwork:edit`, the Save button and Add Row buttons are hidden, and all rating buttons, inputs, and textareas are disabled, while Export PDF remains visible (though its save step would fail for non-editors).
- **No background processing.** All actions are synchronous request/response.

## Notes / Warnings / Tips

- **Export PDF saves first.** Clicking **Export PDF** silently saves the current form before producing the PDF. If you do not want to persist your current edits, do not click Export PDF.
- **Ratings are exclusive per question.** Selecting a new rating replaces the previous one for that question or custom row; there is no way to clear a rating back to "unselected" once set (only by reloading without saving).
- **Custom rows need text.** A custom row left blank still saves, but appears as "(untitled)" in the exported PDF ( `download/route.ts:133` ).
- **One survey per engagement.** Re-opening and saving overwrites the existing survey for that engagement; there is no version history beyond the single `updatedAt` timestamp.
- **N/A vs blank.** In the PDF, an unanswered question shows `—`, while an explicit "N/A" choice shows `N/A` — these are distinct ( `download/route.ts:84` ).

# Document Library

## Overview — Purpose, Business Objective

The **Document Library** is the central repository within the Internal Audit module for storing, retrieving and querying reference documents that support audit work. It serves three business objectives:

1. **Document storage** — upload and keep three categories of supporting material: the company's policies and procedures, standard regulations, and previous audit reports.
2. **AI-powered knowledge retrieval ("Smart Search")** — ask natural-language questions against the uploaded corpus and receive an AI-generated answer drawn from the ingested document content.
3. **AI ingestion** — uploaded files are sent to an external AI backend (RunPod) and indexed ("ingested") so their content becomes searchable through Smart Search.

The page is the surface for uploading documents, monitoring ingestion status, downloading or deleting documents, running smart searches, and reviewing recent search history.

## Access — Roles and Required Permissions

All actions on this page are gated by the single permission resource `audit.documents` (the page route is mapped to this resource at `src/lib/permissions.ts:120`). Navigation visibility requires `audit.documents:view` (`src/lib/navigation.ts:312`).

Of the three documented roles:

| Role (internal key)                         | Displayed As  | <code>audit.documents</code> Permission                                              | Effect                                                                   |
|---------------------------------------------|---------------|--------------------------------------------------------------------------------------|--------------------------------------------------------------------------|
| Audit Head ( <code>AuditHead</code> )       | Audit Head    | <code>['*']</code> , scope <code>all</code> ( <code>permissions.ts:448</code> )      | Full access — view, create (upload), edit, delete, approve               |
| Audit Manager ( <code>AuditManager</code> ) | Audit Manager | <code>['*']</code> , scope <code>all</code> ( <code>permissions.ts:474</code> )      | Full access — view, create (upload), edit, delete, approve               |
| Auditor ( <code>Auditee</code> )            | Auditor       | <b>No <code>audit.documents</code> entry</b> ( <code>permissions.ts:526-529</code> ) | <b>No access</b> — Document Library is explicitly excluded for this role |

**Important:** The Auditor role (internal key `Auditee`, displayed as "Auditor" via `ROLE_DISPLAY_OVERRIDES` in `permissions.ts:319-321`) does **not** have Document Library access. The Auditee permission block ( `permissions.ts:526-529` ) explicitly lists "Document Library" among the modules it has NO access to. The Document Library nav item will not appear for this role, and the API routes will reject its requests.

Note: The legacy internal `Auditor` role key ( `permissions.ts:503` ) does carry `audit.documents: ['*']`, but that key is retired/hidden and is not assignable to users; the assignable "Auditor" is the `Auditee` key, which has no access.

Per-action permission mapping on the API routes:

| Action                        | Resource:Action                         | Source                                                    |
|-------------------------------|-----------------------------------------|-----------------------------------------------------------|
| List documents (GET)          | <code>audit.documents:view</code>       | <code>documents/route.ts:106</code>                       |
| Upload document (POST)        | <code>audit.documents:create</code>     | <code>documents/route.ts:245</code>                       |
| Get single document (GET)     | <code>audit.documents:view</code>       | <code>documents/[id]/route.ts:37</code>                   |
| Delete document (DELETE)      | <code>audit.documents:delete</code>     | <code>documents/[id]/route.ts:80</code>                   |
| Smart Search (POST)           | <code>audit.documents:view</code>       | <code>documents/search/route.ts:201</code>                |
| Recent searches (GET)         | <code>audit.documents:view</code>       | <code>documents/recent-searches/route.ts:30</code>        |
| Clear search history (DELETE) | <code>audit.documents:delete</code>     | <code>documents/recent-searches/route.ts:52</code>        |
| Trigger ingest (POST)         | <code>audit.documents:create</code>     | <code>documents/ingest/route.ts:288</code>                |
| Ingest status (GET)           | <code>audit.documents:view</code>       | <code>documents/ingest-status/[jobId]/route.ts:138</code> |
| Ingest result (GET)           | <code>audit.documents:view</code>       | <code>documents/ingest-result/[jobId]/route.ts:135</code> |
| Download (GET)                | None (no <code>withAuth</code> wrapper) | <code>documents/[id]/download/route.ts:14</code>          |

**Note:** The download endpoint ( `/api/internal-audit/documents/[id]/download` ) is a plain `GET` handler with **no** `withAuth` permission wrapper ( `documents/[id]/download/route.ts:14` ). It is not gated by the `audit.documents` permission. (Verified in code.)

The "approve" action exists in the permission matrix for completeness, but there is **no approval workflow or approve button on this page** — documents are uploaded and ingested, not approved.

## Prerequisites

Before this module is useful:

- The signed-in user must hold a role with `audit.documents` access (Audit Head or Audit Manager).
- For multi-tenant isolation, documents are scoped to the user's customer account and Audit Head ( `customerAccountId` / `auditHeadId` , set on upload at `documents/route.ts:194-195` ; list query filters on these at `documents/route.ts:21` ).
- For **Smart Search** and **Ingestion** to function, the external AI backend (RunPod / `PYTHON_BACKEND` ) must be reachable and the server-side `PYTHON_API_SECRET` environment variable must be configured. If the secret is missing, search and ingest endpoints return `Server misconfiguration: missing API secret` (search: `search/route.ts:67-71` ; ingest: `ingest/route.ts:92-97` ).
- For Smart Search to return relevant answers, documents should already have been uploaded and successfully ingested (status "completed").

**Screenshot:** *Insert screenshot here*

The page contains the following visible areas:

- **Breadcrumb** at the top: `Internal Audit` (Home icon) > `Dashboard` (link, shown only if the user can view the audit dashboard) > **Document Library** (current page).
- **Page header:** an `<h1>` title reading **Document Library**.
- A **tab bar** with four tabs: **Smart Search**, **Company's Policies and Procedures**, **Standard Regulations**, **Previous Audit Reports**. The default active tab is **Smart Search**.
- **Smart Search tab** shows two cards:
  - **Smart Document Query** card — a multi-line text area with placeholder *Enter your question here* and a circular send button (paper-plane / Send icon) in the corner.
  - **Recent Searches** card — header with a count badge (e.g. *N result(s)*) and a list of the current user's past searches; empty state shows *No Recent Searches / Your search history will appear here*.
- **Each of the three category tabs** (Policies, Regulations, Audit Reports) shows:
  - A card header with the category title and a count badge (number of documents in that category).
  - A **drag-and-drop upload area** with text *Drag and drop files here, or click to upload* and a hint *PDF, DOC, DOCX, XLS, XLSX, CSV, TXT*.
  - A **document list** below the upload area, with per-row file icon, file name, ingest-status indicator, and three icon action buttons (Ingest, Delete, Download). Empty state shows *No Documents / Upload your first document to get started*.
  - **Pagination** controls at the bottom of the list (10 items per page).

## Page Layout

### Breadcrumb

`Internal Audit` (Home icon, static) > `Dashboard` (link to `/internal-audit/dashboard` , conditionally rendered when `audit.dashboard:view` is granted) > **Document Library** (highlighted current page). Source: `page.tsx:611-627` .

### Header

A single `<h1>` reading **Document Library** ( `page.tsx:631` ). There are no summary cards on this page.

### Tabs

Four tabs ( `page.tsx:636-641` ):

| Tab Label (UI string)             | Internal value            | Content                                                              |
|-----------------------------------|---------------------------|----------------------------------------------------------------------|
| Smart Search                      | <code>smart-search</code> | Smart Document Query + Recent Searches                               |
| Company's Policies and Procedures | <code>policies</code>     | Upload area + document list for category <code>Policy</code>         |
| Standard Regulations              | <code>regulations</code>  | Upload area + document list for category <code>Regulation</code>     |
| Previous Audit Reports            | <code>reports</code>      | Upload area + document list for category <code>PreviousReport</code> |

### Smart Search tab — Smart Document Query card

- Card header: **Smart Document Query** ( `page.tsx:649-651` ).
- A **Textarea** (4 rows, min-height 120px) with placeholder **Enter your question here** ( `page.tsx:656` ).
- A send **Button** anchored in the corner of the textarea; shows a spinner while searching, otherwise a Send (paper-plane) icon. Disabled while searching or when the query is empty ( `page.tsx:664-674` ).
- Pressing **Enter** (without Shift) submits the search; Shift+Enter inserts a newline ( `page.tsx:279-284` ).

### Smart Search tab — Recent Searches card

- Card header: **Recent Searches**, with a right-side count badge **{N} result(s)** when there is at least one search ( `page.tsx:682-687` ).
- Empty state: icon plus **No Recent Searches** and **Your search history will appear here.** ( `page.tsx:691-697` ).
- Each entry shows a clock icon, the **query** text (bold, truncated), the formatted **createdAt** date/time, and — if present — the **result** text. When the search `status` is **Unsatisfactory**, the result text is rendered in amber; otherwise slate/gray ( `page.tsx:700-732` ).

### Category tabs — card structure

Each category tab ( `page.tsx:740-801` ) renders:

- Card header with the category title and a count badge ( `documents.<category>Count` ) shown only when the count is greater than zero.
- The **upload area** ( `renderUploadArea` , `page.tsx:423-471` ).
- The **document list** ( `renderDocumentList` , `page.tsx:533-607` ).

### Upload area (per category)

- A dashed drop zone; clicking it opens the hidden file input ( `multiple` enabled). Drag-over highlights the zone ( `page.tsx:433-454` ).
- While uploading: spinner + **Uploading...** ( `page.tsx:455-459` ).
- Idle: file icon, **Drag and drop files here, or click to upload**, and hint **PDF, DOC, DOCX, XLS, XLSX, CSV, TXT** ( `page.tsx:460-468` ).

### Document list rows

Each row ( `page.tsx:561-602` ) shows:

- A **file-type icon** (image / spreadsheet / document / generic, chosen by extension — `getFileIcon` , `page.tsx:374-386` ).
- The **file name** ( `doc.fileName` , truncated).
- An **ingest-status indicator** (see Status Reference).
- Row action buttons (right side): **Ingest** (RefreshCw icon, hidden while that document is actively ingesting), **Delete** (Trash icon), **Download** (Download icon).

### Pagination

Per-tab pagination ( `renderPagination` , `page.tsx:473-531` ): a range label **{start} to {end} of {total}** plus four navigation buttons — first page, previous, next, last. Page size is fixed at **10** items ( `page.tsx:104` ). Each tab maintains its own page state.

### Footer / Dialogs

- No page footer.
- One confirmation **dialog** is used on delete: title **Delete Document?**, body **This action cannot be undone.** ( `page.tsx:328` ).

## Field Reference

### Smart Search input

| Field | Required | Type                       | Default | Validation                                                                                                                                                              | Editable | Description                                             |
|-------|----------|----------------------------|---------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------|---------------------------------------------------------|
| Query | Yes      | Multi-line text (Textarea) | empty   | Must be non-empty / non-whitespace; client blocks empty ( <code>page.tsx:252-255</code> ) and server requires a non-empty string ( <code>search/route.ts:59-64</code> ) | Yes      | The natural-language question submitted to Smart Search |

### Document upload (multipart form fields sent by the page)

The page sends `file` , `category` , and `name` on upload ( `page.tsx:294-297` ). The server also accepts an optional `description` ( `documents/route.ts:155` ), though the page does not send one.

| Field       | Required     | Type          | Default                                                                  | Validation                                                                                                                      | Editable                               | Description                                           |
|-------------|--------------|---------------|--------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------|----------------------------------------|-------------------------------------------------------|
| file        | Yes          | File (binary) | —                                                                        | Server returns 400 <i>No file provided</i> if absent ( <code>documents/route.ts:161-166</code> )                                | n/a                                    | The uploaded file                                     |
| category    | Sent by page | String        | "Policy" if omitted server-side ( <code>documents/route.ts:153</code> )  | Not enumerated/validated server-side; page sends <code>Policy</code> , <code>Regulation</code> , or <code>PreviousReport</code> | n/a                                    | Determines which tab the document appears under       |
| name        | Sent by page | String        | falls back to original file name ( <code>documents/route.ts:188</code> ) | None                                                                                                                            | n/a                                    | Document display name; page sets it to the file name  |
| description | Optional     | String        | null                                                                     | None                                                                                                                            | Not verified (no edit UI on this page) | Optional description; not collected by this page's UI |

### InternalAuditDocument fields (system-generated; not user-entered on this page)

Source: `prisma/schema.prisma:3922-3945` and `documents/route.ts` .

| Field                           | Type            | Default                                                                                                                 | Description                     |
|---------------------------------|-----------------|-------------------------------------------------------------------------------------------------------------------------|---------------------------------|
| documentCode                    | String (unique) | Auto DOC-0001 ... sequential, globally unique; race fallback uses a timestamp-based code ( documents/route.ts:111-145 ) | Generated document code         |
| fileType                        | String          | derived from file extension, lowercased ( documents/route.ts:190 )                                                      | File type                       |
| fileSize                        | Int             | byte length of upload ( documents/route.ts:191 )                                                                        | File size in bytes              |
| filePath                        | String          | path returned by saveUploadedFile ( documents/route.ts:169,192 )                                                        | Stored file path                |
| fileData                        | Bytes           | encrypted binary written via raw SQL ( documents/route.ts:223-224 )                                                     | File binary (encrypted at rest) |
| uploadedAt                      | DateTime        | now ( documents/route.ts:193 )                                                                                          | Upload timestamp                |
| customerAccountId / auditHeadId | String?         | from session if present                                                                                                 | Tenant / Audit Head isolation   |

## Tables

The category tabs use a **list (not a sortable column table)**, so there are no column headers.

- **Columns / per-row data:** file-type icon, file name ( doc.fileName ), ingest-status indicator, and the three row action buttons.
- **Sorting:** Not user-configurable. Documents are returned ordered by uploadedAt descending (newest first) from the API ( documents/route.ts:65,70,75 ). There is no UI sort control.
- **Searching/filtering within the list:** None on the category lists. (Smart Search is a separate AI query, not a list filter.) Documents are server-side filtered by category into the three tabs ( documents/route.ts:63-77 ).
- **Pagination:** Client-side, 10 items per page, independent page state per tab, with first/prev/next/last controls ( page.tsx:473-531 ).
- **Row actions:** Ingest, Delete, Download (see Buttons & Actions).
- **Bulk actions:** None exposed in the UI. (The ingest API accepts an array of document IDs, but the page only triggers ingest one document at a time from the list, or for the batch just uploaded.)

The **Recent Searches** list is likewise a non-sortable list: each entry shows query, timestamp, and result text. No pagination control is rendered on it; it shows up to the API limit (default 10, recent-searches/route.ts:10 ).

## Buttons & Actions



| Control                           | Permission                          | Visible To                                          | Action                                                                                 | API                                                                                                                     | Success Msg                                                                                                                                                                                          | Failure Msg                                                                                                                                                             | Audit T                                                |
|-----------------------------------|-------------------------------------|-----------------------------------------------------|----------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------|
| Send (Smart Document Query)       | <code>audit.documents:view</code>   | Audit Head, Audit Manager                           | Submit the question to Smart Search; refresh Recent Searches; clear the input          | POST <code>/api/internal-audit/documents/search</code>                                                                  | Toast <b>Search completed</b> ( <code>page.tsx:267</code> )                                                                                                                                          | Toast <b>Please enter a query</b> (empty input, <code>page.tsx:253</code> ); Toast <b>Search failed</b> (non-OK or error, <code>page.tsx:270,273</code> )               | A Docu created ( <code>search</code> 176 ); n entry ve |
| Upload area (click / drag-drop)   | <code>audit.documents:create</code> | Audit Head, Audit Manager                           | Upload one or more files in the tab's category; then auto-trigger ingestion            | POST <code>/api/internal-audit/documents</code> (per file), then POST <code>/api/internal-audit/documents/ingest</code> | Toast <b>File uploaded successfully</b> (single) / <b>Files uploaded successfully</b> (multiple) ( <code>page.tsx:313</code> ); then <b>Document ingestion started</b> ( <code>page.tsx:238</code> ) | Toast <b>Failed to upload file</b> ( <code>page.tsx:321</code> ); ingest start failure: error message or <b>Failed to start ingestion</b> ( <code>page.tsx:247</code> ) | Docum no dedi verified                                 |
| Ingest (RefreshCw, per row)       | <code>audit.documents:create</code> | Audit Head, Audit Manager                           | (Re-)trigger AI ingestion for that single document; hidden while that doc is ingesting | POST <code>/api/internal-audit/documents/ingest</code>                                                                  | Toast <b>Document ingestion started</b> ( <code>page.tsx:238</code> ); on poll completion <b>Document ingested successfully</b> ( <code>page.tsx:173</code> )                                        | Toast with error or <b>Failed to start ingestion</b> ( <code>page.tsx:247</code> ); on poll: error or <b>Document ingestion failed</b> ( <code>page.tsx:190</code> )    | Docum records ( <code>inges</code> 266 )               |
| Delete (Trash, per row)           | <code>audit.documents:delete</code> | Audit Head, Audit Manager                           | Delete the document after confirmation                                                 | DELETE <code>/api/internal-audit/documents/{id}</code>                                                                  | Toast <b>Document deleted successfully</b> ( <code>page.tsx:335</code> )                                                                                                                             | Toast <b>Failed to delete document</b> ( <code>page.tsx:338,341</code> )                                                                                                | No ded verified ( <code>[id]/</code>                   |
| Download (Download, per row)      | None on endpoint (see note)         | Audit Head, Audit Manager (button rendered on page) | Open the file via the download endpoint in a new tab                                   | GET <code>/api/internal-audit/documents/{id}/download</code>                                                            | File download (no toast)                                                                                                                                                                             | Server returns 404 <i>File not found on server</i> if no binary/disk file ( <code>[id]/download/route.ts:65-70</code> )                                                 | Not ver                                                |
| Pagination (first/prev/next/last) | n/a (client-side)                   | Audit Head, Audit Manager                           | Change the visible page of the document list                                           | None (client slice)                                                                                                     | n/a                                                                                                                                                                                                  | n/a                                                                                                                                                                     | n/a                                                    |

The delete confirmation dialog (**Delete Document?** / **This action cannot be undone.**) must be confirmed before the DELETE call is made ( `page.tsx:328` ).

There is **no "Clear search history" button on this page** even though the API supports DELETE on `recent-searches` — that control is not rendered in the component (verified: no DELETE call to `recent-searches` in `page.tsx` ).

## Step-by-Step Instructions

### Run a Smart Search

1. Open **Internal Audit > Document Library**. The **Smart Search** tab is active by default.
2. In the **Smart Document Query** box, type your question.
3. Press **Enter** (or click the **Send** button). Shift+Enter adds a new line instead of submitting.
4. While the search runs, the Send button shows a spinner and is disabled.
5. On success, a **Search completed** toast appears, the input clears, and the result is added to **Recent Searches**.
6. Review the answer under **Recent Searches**. If the answer begins with "Unsatisfactory...", the result is shown in amber, indicating no relevant content was found.

### Upload document(s)

1. Open the relevant category tab: **Company's Policies and Procedures**, **Standard Regulations**, or **Previous Audit Reports**.
2. Either drag files onto the dashed upload area, or click it to open the file picker (multiple files allowed).
3. Wait for the **Uploading...** indicator to finish.
4. A success toast appears (**File uploaded successfully** or **Files uploaded successfully**).

5. The list refreshes and ingestion starts automatically — a **Document ingestion started** toast appears and the affected rows show an **Ingesting** indicator with a spinner.
6. When ingestion finishes, a **Document ingested successfully** toast appears and the row shows a green **Ingested** indicator. If it fails, a red **Failed** indicator and a failure toast appear.

### Re-ingest a single document

1. In a category tab, locate the document row.
2. Click the **Ingest** (circular arrows) button on that row. (The button is hidden while that document is already ingesting.)
3. Watch the row's status indicator change from **Ingesting** to **Ingested** or **Failed**.

### Download a document

1. In a category tab, locate the document row.
2. Click the **Download** (download arrow) button. The file opens/downloads in a new browser tab.

### Delete a document

1. In a category tab, locate the document row.
2. Click the **Delete** (trash) button.
3. In the **Delete Document?** dialog, confirm (body warns **This action cannot be undone.**).
4. On success a **Document deleted successfully** toast appears and the list refreshes.

## Workflow

The only multi-stage process on this page is **document ingestion** (asynchronous, polled).

| Current Status      | User Action                    | Validation                                                                                                      | API                                                      | DB Update                                                                                   | Audit Trail           | Notification                                              | Next Status                     | Next Actor         |
|---------------------|--------------------------------|-----------------------------------------------------------------------------------------------------------------|----------------------------------------------------------|---------------------------------------------------------------------------------------------|-----------------------|-----------------------------------------------------------|---------------------------------|--------------------|
| (no job)            | Upload file(s) or click Ingest | documentIds non-empty ( ingest/route.ts:80-85 ); file must be readable from DB/disk ( ingest/route.ts:173-178 ) | POST /ingest → external RunPod simple_ingest             | DocumentLibraryIngestJob rows created with status <b>queued</b> ( ingest/route.ts:255-266 ) | Job records created   | Toast <b>Document ingestion started</b>                   | <b>queued</b>                   | System (polling)   |
| queued / processing | (automatic polling every 3s)   | —                                                                                                               | GET /ingest-status/{jobId} → RunPod simple_ingest_status | updateMany sets status to RunPod's value ( ingest-status/route.ts:107-115 )                 | Status updated        | none (intermediate)                                       | <b>processing</b> then terminal | System             |
| processing          | (automatic polling)            | —                                                                                                               | GET /ingest-status/{jobId}                               | status → <b>completed</b> , sets completedAt ( ingest-status/route.ts:104-115 )             | Status updated        | Toast <b>Document ingested successfully</b>               | <b>completed</b>                | —                  |
| processing          | (automatic polling)            | —                                                                                                               | GET /ingest-status/{jobId}                               | status → <b>failed</b> , stores error , sets completedAt                                    | Status + error stored | Toast (RunPod error or <b>Document ingestion failed</b> ) | <b>failed</b>                   | User may re-ingest |

Polling interval is **3000 ms** ( page.tsx:76 ). Polling continues until a terminal status (completed/failed) is returned; once terminal, the status endpoint returns the cached status without re-polling RunPod ( ingest-status/route.ts:52-66 ).

The **Smart Search** flow is single-step: query → POST /search (calls RunPod simple\_query ) → result classified **Satisfactory** or **Unsatisfactory** and saved as a DocumentSearch row ( search/route.ts:145-176 ).

## Status Reference

### Ingestion job status ( DocumentLibraryIngestJob.status , schema default **queued** )

| Status     | Meaning                                              | How reached                                                                                                                  | Who can change   | Next statuses                   |
|------------|------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------|------------------|---------------------------------|
| queued     | Job created and submitted to RunPod, not yet started | On ingest trigger ( ingest/route.ts:262 )                                                                                    | System (polling) | processing, completed, failed   |
| processing | RunPod is processing the document                    | Status poll returns processing ( ingest-status/route.ts:103 )                                                                | System           | completed, failed               |
| completed  | Document successfully ingested/indexed               | Status poll returns completed ( ingest-status/route.ts:104 ); also set when result is fetched ( ingest-result/route.ts:108 ) | System           | (terminal)                      |
| failed     | Ingestion failed; error stored                       | Status poll returns failed ( ingest-status/route.ts:104 )                                                                    | System           | re-ingestable by user (new job) |

**UI status indicators** on each document row ( `page.tsx:388-421` ), based on the latest ingest job:

- **Ingesting** — blue spinner, shown while the document is in the active client-side ingesting set.
- **Ingested** — green check, shown when the latest job status is `completed`.
- **Failed** — red alert icon (tooltip shows the error), shown when the latest job status is `failed`.
- No indicator — no ingest jobs / status not terminal and not actively polling.

**Search result status** ( `DocumentSearch.status` , **schema default** `Satisfactory` )

| Status         | Meaning                                                             | How reached                                                                                                                            |
|----------------|---------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------|
| Satisfactory   | The AI returned a usable answer                                     | Extracted answer text present ( <code>search/route.ts:146-148</code> )                                                                 |
| Unsatisfactory | No relevant content found; result text begins "Unsatisfactory: ..." | No extractable answer ( <code>search/route.ts:149-153</code> ); rendered in amber in Recent Searches ( <code>page.tsx:721-724</code> ) |

## Validation Rules

- **Smart Search query** must be non-empty: client shows **Please enter a query** for blank input ( `page.tsx:252-255` ); server returns 400 **Query is required** if missing or non-string ( `search/route.ts:59-64` ).
- **Upload** requires a file: server returns 400 **No file provided** when no `file` is present ( `documents/route.ts:161-166` ). The client silently no-ops if no files are selected ( `page.tsx:287` ).
- **Document code uniqueness:** `documentCode` is globally unique; the server generates a sequential `DOC-NNNN` and retries up to 3 times on a P2002 unique-constraint collision, falling back to a timestamp-based code ( `documents/route.ts:111-145` , `179-215` ).
- **Ingest** requires a non-empty `documentIds` array (400 **documentIds (array) is required**, `ingest/route.ts:80-85` ) and at least one readable file (400 **No document files could be read from disk.**, `ingest/route.ts:173-178` ); if no documents match the tenant filter, 404 **No valid documents found** ( `ingest/route.ts:108-113` ).
- **Permission checks:** every API route except download is wrapped in `withAuth` with the `audit.documents` resource; unauthorized roles are rejected by the wrapper.
- **Tenant isolation:** list, ingest, and upload scope by `customerAccountId` / `auditHeadId` ( `documents/route.ts:19-23` , `ingest/route.ts:88-106` ).
- There is **no approval check** and **no duplicate-name check** on this page.

## Success Scenarios and Failure Scenarios

### Success

- **Search completed** — RunPod returned an answer (or an "Unsatisfactory" message); result saved and shown in Recent Searches.
- **File uploaded successfully / Files uploaded successfully** — file(s) stored; ingestion auto-started.
- **Document ingestion started** — ingest job(s) created on RunPod.
- **Document ingested successfully** — ingestion reached `completed`; row shows green **Ingested**.
- **Document deleted successfully** — document row and (if present) disk file removed.

### Failure

| Scenario                      | Why                                                                    | What the user sees                                                                                           | Resolution                                                                                       |
|-------------------------------|------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------|
| Empty query                   | Query blank/whitespace                                                 | Toast <b>Please enter a query</b>                                                                            | Enter text and retry                                                                             |
| Search non-OK / network error | RunPod error, missing API secret, or fetch failure                     | Toast <b>Search failed</b>                                                                                   | Verify AI backend is up / secret configured; retry                                               |
| Upload fails                  | Any non-OK response from upload API                                    | Toast <b>Failed to upload file</b>                                                                           | Check file/server; retry                                                                         |
| Ingest start fails            | RunPod unreachable, missing secret, no readable file, or no valid docs | Toast with server error or <b>Failed to start ingestion</b> ; the document is removed from the ingesting set | Verify backend reachable (503 <b>AI service is unreachable...</b> ), retry via the Ingest button |
| Ingestion fails (async)       | RunPod returns <code>failed</code>                                     | Toast (RunPod error or <b>Document ingestion failed</b> ); row shows red <b>Failed</b>                       | Click the Ingest button to retry                                                                 |
| Delete fails                  | Non-OK delete response                                                 | Toast <b>Failed to delete document</b>                                                                       | Retry; check document still exists                                                               |
| Download — file missing       | No <code>fileData</code> in DB and no file on disk                     | Browser shows 404 <b>File not found on server</b>                                                            | Re-upload the document                                                                           |

## System Behaviour

- **Automatic record creation:** Uploading a file creates an `InternalAuditDocument` row (with auto `documentCode` ) and writes the encrypted file binary to `fileData` via raw SQL ( `documents/route.ts:183-224` ). Each ingest run creates one `DocumentLibraryIngestJob` per document ( `ingest/route.ts:255-266` ). Each Smart Search creates a `DocumentSearch` row ( `search/route.ts:169-176` ).
- **Automatic ingestion on upload:** After a successful upload batch, the page automatically triggers ingestion for the newly uploaded document IDs ( `page.tsx:316-319` ).
- **Automatic status updates / background polling:** The client polls `/ingest-status/{jobId}` every 3 seconds until the job reaches a terminal status; the status endpoint updates the local job records with RunPod's reported status ( `page.tsx:147-203` , `ingest-status/route.ts:107-115` ). Polling timers are cleared

on unmount ( page.tsx:139-143 ).

- **Encryption at rest:** `fileData` is encrypted before storage and decrypted on download/ingest read using `maybeEncryptBytes` / `maybeDecryptBytes` over raw SQL ( `documents/route.ts:223` , `[id]/download/route.ts:38` , `ingest/route.ts:144` ).
- **File retrieval fallback:** Download and ingest first read the binary from `fileData` (DB); if absent, they fall back to reading from disk ( `[id]/download/route.ts:31-63` , `ingest/route.ts:137-162` ).
- **Dynamic translation:** On upload, the client calls `triggerTranslation('InternalAuditDocument', ...)` ( `page.tsx:310` ) and the server calls `translateRecord` when translation is configured ( `documents/route.ts:229-234` ); list views display translated name/fileName via `useTranslatedData` ( `page.tsx:107-109` ).
- **Recent Searches are per-user:** the recent-searches endpoint filters by `session.id` ( `recent-searches/route.ts:13-19` ); a user only sees their own search history.
- **Read-only / no-access behavior:** Roles without `audit.documents` (e.g. the Auditor/ Auditee role) do not see the nav item and are rejected by the API wrappers.
- **Audit-trail logging:** No dedicated audit-trail ( `audit.audit-trail` ) write was found in these routes for upload/delete/ingest/search. (Not verified that any audit-trail entry is created.)
- **In-app notifications:** No notification dispatch was found in these routes; user feedback is via toast messages only. (Not verified that any notification is sent.)

---

## Notes / Warnings / Tips

- **Warning — deletion is permanent.** The delete dialog states **This action cannot be undone**. Deleting a document also removes its ingested content's source; the document will no longer appear in the list (its ingest jobs cascade-delete per `schema.prisma:3961` ).
  - **Tip — ingest before searching.** Smart Search answers come from documents that have been ingested. If a search returns "Unsatisfactory", confirm the relevant documents show the green **Ingested** status.
  - **Tip — re-ingest failures.** If a row shows a red **Failed** status, hover for the error tooltip and click the **Ingest** button to retry.
  - **Note — accepted file hint.** The upload area advertises **PDF, DOC, DOCX, XLS, XLSX, CSV, TXT**, but the server does not enforce a file-type allowlist on upload (no extension validation found in `documents/route.ts` ). Treat the hint as guidance, not a hard restriction. (Verified: no server-side type check.)
  - **Note — Smart Search and ingestion depend on the external AI backend.** If the AI backend is down or unconfigured, search and ingestion will fail with the messages listed above; document upload, listing, download, and delete still work.
  - **Note — no "Clear history" control.** Although the API supports clearing search history, no button for it is rendered on this page.
-

# Audit Trail

## Overview — Purpose, Business Objective

The **Audit Trail** page provides a **read-only** log of user activity recorded by the system. It exists so the organization can review *who did what, in which module, and when* — supporting accountability, internal control, and forensic review.

The page header states its purpose explicitly, with text that changes by scope ( `src/app/(protected)/internal-audit/audit-trail/page.tsx:237-240` ):

- Organization-wide viewers (scope `all`): "Read-only log of all user activity across your organization."
- Own-activity viewers (scope `own`): "Read-only log of your activity across the platform."

Records are written automatically by the platform (see **System Behaviour**); there is no manual data entry on this page. The trail captures successful mutations across modules plus authentication events (Login / Logout).

## Access — Which of the three roles can use it + the exact permission(s) required

The page and its API are gated by the permission `audit.audit-trail / action view` (page resource declared at `src/app/api/internal-audit/audit-trail/route.ts:113`; navigation entry `audit.audit-trail:view` at `src/lib/navigation.ts:313`).

Two distinct **scopes** govern what each viewer sees, derived via `getPermissionScope(...)` ( `route.ts:18` ):

- **scope `all`** — sees every user's activity within the organization (tenant).
- **scope `own`** — sees only their own activity ( `route.ts:52`, where `userId = session.id` ).

Scope assignment for the three documented Internal Audit roles ( `src/lib/permissions.ts` ):

| Role (display) | Internal key              | <code>audit.audit-trail</code> | Scope      | Citation                        |
|----------------|---------------------------|--------------------------------|------------|---------------------------------|
| Audit Head     | <code>AuditHead</code>    | <code>view</code>              | <b>own</b> | <code>permissions.ts:452</code> |
| Audit Manager  | <code>AuditManager</code> | <code>view</code>              | <b>own</b> | <code>permissions.ts:478</code> |
| Auditor        | <code>Auditee</code>      | <code>view</code>              | <b>own</b> | <code>permissions.ts:538</code> |

For completeness, **Customer Administrator** is the role granted organization-wide visibility (scope **all**) — `audit.audit-trail`, `view`, scope `all` ( `permissions.ts:411` ). The code comment at `permissions.ts:410` states: "Audit Trail — CustomerAdmin sees ALL users' activity in the org (scope all)." None of the three Internal Audit roles (Audit Head, Audit Manager, Auditor) has the `all` scope; each sees only its own activity.

Note: The only RBAC action used here is **view**. There is no create, edit, delete, approve, or export action wired to this resource.

## Prerequisites — what must already exist before using this module

- The user must be authenticated and hold the `audit.audit-trail:view` permission (otherwise the nav item is hidden and the API returns a permission error via `withAuth`).
- Audit-trail entries are generated by user activity elsewhere in the platform. A brand-new account with no recorded activity (within the viewer's scope) will see the empty-state message "No audit records found." ( `page.tsx:352` ).
- For organization-wide viewers, the admin filter dropdowns are populated from existing records (facets); with no data the dropdowns contain only the "All ..." options.

**Screenshot:** *Insert screenshot here*

The page renders the following visible areas (top to bottom):

1. **Breadcrumb** — `Internal Audit > Audit Trail` ( `page.tsx:220-227` ).
2. **Page header** — an Activity icon, the title **Audit Trail**, and a one-line description that varies by scope ( `page.tsx:230-242` ).
3. **Filter panel** — a white card containing the Search box, admin-only User Name and User Role dropdowns, Action Type and Module Name dropdowns, From Date / To Date pickers, and a conditional **Clear** button ( `page.tsx:245-326` ).
4. **Results grid** — a 6-column table with sortable headers, a loading spinner row, an empty-state row, and data rows ( `page.tsx:329-375` ).
5. **Pagination bar** — record count summary, page-size selector, and Previous / Next controls with a "Page X of Y" indicator ( `page.tsx:377-425` ).

There are no summary cards, tabs, side panels, dialogs, or footer on this page.

## Page Layout

| Area                | Present? | Details                                                                                                              |
|---------------------|----------|----------------------------------------------------------------------------------------------------------------------|
| Breadcrumb          | Yes      | Internal Audit > Audit Trail (page.tsx:220-227)                                                                      |
| Header              | Yes      | Activity icon + title <b>Audit Trail</b> + scope-dependent description (page.tsx:230-242)                            |
| Summary cards       | No       | None present                                                                                                         |
| Tabs                | No       | None present                                                                                                         |
| Filter panel        | Yes      | Search, (admin) User Name, (admin) User Role, Action Type, Module Name, From Date, To Date, Clear (page.tsx:245-326) |
| Search box          | Yes      | Free-text, debounced 350 ms (page.tsx:108-114, 247-256)                                                              |
| Table               | Yes      | 6 columns, 3 sortable header groups (page.tsx:331-375)                                                               |
| Row actions         | No       | Rows are not clickable; no per-row menu                                                                              |
| Bulk actions        | No       | No selection checkboxes                                                                                              |
| Pagination          | Yes      | Count, page-size select, Previous / Next (page.tsx:377-425)                                                          |
| Side panel / drawer | No       | None                                                                                                                 |
| Dialogs / modals    | No       | None                                                                                                                 |
| Footer              | No       | None                                                                                                                 |

## Field Reference

This page has **no data-entry form** — all controls are read/filter controls. The table below documents the **filter and control inputs**.

| Field            | Required | Type        | Default                        | Validation                                                                     | Editable | Description                                                                                                                                                                                                      |
|------------------|----------|-------------|--------------------------------|--------------------------------------------------------------------------------|----------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Search           | No       | Text input  | empty                          | None; debounced 350 ms into query ( page.tsx:108-114 )                         | Yes      | Free-text search across user, module, action, record. Placeholder: "Search by user, module, action, record..." ( page.tsx:253 ). Server searches userName, module, action, recordId, userRole ( route.ts:81-87 ) |
| User Name        | No       | Select      | <b>All Users</b> ( __all__ )   | Options from facets ( route.ts:33 )                                            | Yes      | <b>Admin scope only</b> ( page.tsx:258 ). Filters by user name (server contains , case-insensitive — route.ts:58 )                                                                                               |
| User Role        | No       | Select      | <b>All Roles</b> ( __all__ )   | Options from facets ( route.ts:31 )                                            | Yes      | <b>Admin scope only</b> . Filters by role (server contains , case-insensitive — route.ts:59 )                                                                                                                    |
| Action Type      | No       | Select      | <b>All Actions</b> ( __all__ ) | Options from facets ( route.ts:32 )                                            | Yes      | Filters by exact action value ( route.ts:63 )                                                                                                                                                                    |
| Module Name      | No       | Select      | <b>All Modules</b> ( __all__ ) | Options from facets ( route.ts:30 )                                            | Yes      | Filters by exact module value ( route.ts:64 )                                                                                                                                                                    |
| From Date        | No       | Date picker | empty                          | Server applies >= start of day ( route.ts:70 )                                 | Yes      | Lower bound on Date & Time                                                                                                                                                                                       |
| To Date          | No       | Date picker | empty                          | Server applies <= 23:59:59.999 of that day ( route.ts:71-74 )                  | Yes      | Upper bound on Date & Time                                                                                                                                                                                       |
| Records per page | No       | Select      | <b>25</b>                      | Choices: 10, 25, 50, 100 ( page.tsx:396 ); server clamps 5–100 ( route.ts:44 ) | Yes      | Page size for the grid                                                                                                                                                                                           |

## Tables

The single results grid ( page.tsx:331-375 ) has these columns:

| # | Column header | Sortable      | Source field | Notes                                                      |
|---|---------------|---------------|--------------|------------------------------------------------------------|
| 1 | #             | No            | computed     | Row index = (page-1)*pageSize + idx + 1 (page.tsx:358-359) |
| 2 | User Name     | Yes           | userName     | Bold; snapshot of actor name at action time                |
| 3 | User Role     | Yes           | userRole     | Role snapshot; shows — when null (page.tsx:362)            |
| 4 | Action        | Yes           | action       | Rendered as a colored badge (page.tsx:363-367)             |
| 5 | Module/Entity | Yes           | module       | Module/entity name                                         |
| 6 | Date & Time   | Yes (default) | createdAt    | Localized date-time (page.tsx:194-204)                     |

**Sorting.** Clicking a sortable header toggles direction; an up/down arrow shows the active sort ( page.tsx:164-172 , 207-215 ). Default sort is **Date & Time descending** ( page.tsx:96-97 ). Server whitelists sortable columns to createdAt, userName, userRole, action, module ( route.ts:9 ); any other value falls back to createdAt ( route.ts:46 ). The # column is not sortable.

**Searching.** The Search box is debounced 350 ms then applied as query q, resetting to page 1 ( page.tsx:108-114 ). Server-side it matches (case-insensitive contains ) against userName, module, action, recordId, and userRole ( route.ts:79-88 ).

**Filtering.** All filters are applied server-side and combined (AND) into the where clause; the date range uses gte/lte ( route.ts:49-88 ). Changing any filter resets to page 1 ( page.tsx:176 ). A **Clear** button appears only when at least one filter is active and resets all filters and search ( page.tsx:179-192 , 319-324 ).

**Pagination.** Server-driven. The bar shows either "No records" or a range like 1–25 of N ( `page.tsx:381-384` ), a page-size selector (10/25/50/100), Previous and Next buttons (disabled at bounds or while loading), and "Page X of Y" ( `page.tsx:402-424` ).

**Row actions / bulk actions.** None. Rows are display-only; there are no checkboxes, row menus, or bulk operations.

Buttons & Actions

| Control                                                                               | Permission                                                    | Visible To                        | Action                                                      | API                                                 | Success Msg           | Failure Msg                                             | Audit Trail                                                                   | Notification |
|---------------------------------------------------------------------------------------|---------------------------------------------------------------|-----------------------------------|-------------------------------------------------------------|-----------------------------------------------------|-----------------------|---------------------------------------------------------|-------------------------------------------------------------------------------|--------------|
| Sortable column header (User Name / User Role / Action / Module/Entity / Date & Time) | <code>audit.audit-trail:view</code>                           | All viewers                       | Toggles sort column/direction, refetches (page.tsx:164-172) | <code>GET /api/internal-audit/audit-trail</code>    | None (silent refresh) | On fetch error, grid clears to empty (page.tsx:139-142) | No (reads are not logged; resource is skipped — <code>api-auth.ts:70</code> ) | None         |
| Search box                                                                            | <code>audit.audit-trail:view</code>                           | All viewers                       | Debounced query, page→1 (page.tsx:108-114)                  | <code>GET /api/internal-audit/audit-trail?q=</code> | None                  | Empty grid on error                                     | No                                                                            | None         |
| User Name / User Role filters                                                         | <code>audit.audit-trail:view</code> (scope <code>all</code> ) | Admin scope only                  | Filter by user/role (page.tsx:258-285)                      | <code>GET ...?userName=&amp;userRole=</code>        | None                  | Empty grid on error                                     | No                                                                            | None         |
| Action Type / Module Name filters                                                     | <code>audit.audit-trail:view</code>                           | All viewers                       | Filter by action/module (page.tsx:287-310)                  | <code>GET ...?action=&amp;module=</code>            | None                  | Empty grid on error                                     | No                                                                            | None         |
| From Date / To Date                                                                   | <code>audit.audit-trail:view</code>                           | All viewers                       | Set date range, page→1 (page.tsx:311-318)                   | <code>GET ...?from=&amp;to=</code>                  | None                  | Empty grid on error                                     | No                                                                            | None         |
| Clear                                                                                 | <code>audit.audit-trail:view</code>                           | All viewers (when filters active) | Reset all filters + search (page.tsx:319-324)               | <code>GET ...</code> (refetch)                      | None                  | —                                                       | No                                                                            | None         |
| Records-per-page select                                                               | <code>audit.audit-trail:view</code>                           | All viewers                       | Change page size, page→1 (page.tsx:385-400)                 | <code>GET ...?pageSize=</code>                      | None                  | Empty grid on error                                     | No                                                                            | None         |
| Previous                                                                              | <code>audit.audit-trail:view</code>                           | All viewers                       | Go to previous page (page.tsx:403-411)                      | <code>GET ...?page=</code>                          | None                  | —                                                       | No                                                                            | None         |
| Next                                                                                  | <code>audit.audit-trail:view</code>                           | All viewers                       | Go to next page (page.tsx:415-423)                          | <code>GET ...?page=</code>                          | None                  | —                                                       | No                                                                            | None         |

There is **no Export button** on this page. The platform's audit-action vocabulary includes an `Export` label ( `src/lib/audit-trail.ts:13` ) used by other modules, but the Audit Trail page itself offers no export control.

Step-by-Step Instructions

Open the Audit Trail

- 1. From the left navigation, expand **Internal Audit**.
- 2. Click **Audit Trail**.
- 3. The page loads with the most recent activity first (Date & Time, descending). The header text indicates whether you are viewing all-organization activity or only your own.

Search for activity

- 1. Type into the **Search** box at the top of the filter panel (e.g. a user name, module, action, or record identifier).
- 2. Wait briefly — after ~0.35 s the grid refreshes to matching rows and resets to page 1.

Filter by user or role (organization-wide viewers only)

- 1. Open the **User Name** dropdown and select a user, or leave **All Users**.
- 2. Open the **User Role** dropdown and select a role, or leave **All Roles**. The grid refreshes for each selection. (These two dropdowns are not shown to own-scope viewers.)

Filter by action and module

- 1. Open **Action Type** and pick an action (e.g. Create), or leave **All Actions**.
- 2. Open **Module Name** and pick a module, or leave **All Modules**.

Filter by date range

- 1. Set **From Date** and/or **To Date**.

2. The grid refreshes; the range is inclusive of the whole To-Date day.

### Sort the results

1. Click any sortable column header (User Name, User Role, Action, Module/Entity, or Date & Time).
2. Click the same header again to reverse direction (an arrow indicates the active sort).

### Page through results

1. Use the **Records per page** selector (10/25/50/100) to change page size.
2. Use **Previous** and **Next** to move between pages; the indicator shows "Page X of Y".

### Clear filters

1. When any filter is active, a **Clear** button appears in the filter panel.
2. Click **Clear** to reset all filters and the search box.

## Workflow

This page is **read-only**; it has no record-progression workflow of its own. Instead, it is the *display endpoint* for entries created automatically by other parts of the system. The relevant flow is the **logging** flow that produces the rows shown here:

| Stage        | Detail                                                                                                                                         |
|--------------|------------------------------------------------------------------------------------------------------------------------------------------------|
| User Action  | A user performs a successful mutation in another module (Create/Update/Delete/Approve), or signs in / signs out                                |
| Validation   | The originating route's <code>withAuth</code> permission and handler validation must pass; the response must be HTTP 2xx (api-auth.ts:195-199) |
| API          | Any <code>withAuth</code> -wrapped route with a non- <code>view</code> action; plus NextAuth <code>signIn</code> / <code>signOut</code> events |
| DB Update    | A row is inserted into <code>AuditTrail</code> via <code>recordAuditTrail(...)</code> (audit-trail.ts:57-75)                                   |
| Audit Trail  | The new row becomes visible on this page within the viewer's scope                                                                             |
| Notification | None — logging is fire-and-forget and silent (audit-trail.ts:54-55)                                                                            |
| Next Status  | Not applicable (entries are immutable; no status field)                                                                                        |
| Next User    | Not applicable                                                                                                                                 |

There is no submit/approve/reject lifecycle on this page itself.

## Status Reference

The `AuditTrail` model has **no status field** ( `prisma/schema.prisma:3899-3917` ). What is captured per row is an **action**, not a status. The canonical action labels defined for the trail are ( `src/lib/audit-trail.ts:4-15` ):

| Action label | Meaning              | How reached                                                                                                                 |
|--------------|----------------------|-----------------------------------------------------------------------------------------------------------------------------|
| Create       | A record was created | POST mutation succeeds (api-auth.ts:106)                                                                                    |
| Update       | A record was edited  | PUT / PATCH mutation succeeds (api-auth.ts:107)                                                                             |
| Delete       | A record was deleted | DELETE mutation succeeds (api-auth.ts:104)                                                                                  |
| Submit       | A submit action      | From originating module logic (label in vocabulary; not auto-derived by api-auth)                                           |
| Approve      | An approval          | Route action <code>approve</code> succeeds (api-auth.ts:105)                                                                |
| Reject       | A rejection          | From originating module logic (in vocabulary)                                                                               |
| Login        | User signed in       | NextAuth <code>signIn</code> event, module "Authentication" (auth.ts:537-538)                                               |
| Logout       | User signed out      | NextAuth <code>signOut</code> event, module "Authentication" (auth.ts:565-566)                                              |
| Export       | An export occurred   | From originating module logic (in vocabulary)                                                                               |
| View         | A view action        | Mapped from <code>view</code> (audit-trail.ts:24); note auto-capture skips <code>view</code> , so api-auth does not emit it |

Action badges are color-coded in the grid ( `page.tsx:54-76` ): create=green, update=blue, delete/reject=red, approve=emerald, submit=amber, login/logout=slate, export=purple, others=gray. (Badge matching is case-insensitive.)

Audit-trail entries are **immutable** — there is no edit or delete control and no status transition. They cannot be changed by any role from this page.

## Validation Rules

This page submits no data, so there are no form validation rules. The applicable rules are the server-side guards on the read API ( `route.ts` ):

- **Permission check.** Access requires `audit.audit-trail:view`; the `withAuth` wrapper rejects unauthorized requests ( `route.ts:113` ).
- **Tenant isolation.** Results are restricted to the caller's `customerAccountId` when present ( `route.ts:50` ).
- **Scope enforcement.** Own-scope viewers are forced to `userId = session.id` ( `route.ts:52` ); they cannot widen scope via query parameters. The admin `userName` / `userRole` filters are honored only when scope is `all` ( `route.ts:55-60` ).
- **Facets gating.** Requesting `?facets=1` returns empty arrays for own-scope viewers ( `route.ts:25-27` ).
- **Sort whitelist.** `sortBy` must be one of the allowed columns or it falls back to `createdAt` ( `route.ts:9, 46` ).



- **Page bounds.** `page`  $\geq 1$ ; `pageSize` clamped to 5–100 ( `route.ts:43-44` ).
- **Date handling.** `to` is extended to end-of-day so the range is inclusive ( `route.ts:71-74` ).

There are no duplicate checks or approval checks (no records are created here).

## Success Scenarios and Failure Scenarios

### Success

- Page loads and displays activity rows for the viewer's scope, newest first.
- Applying a filter, search, sort, or page change refreshes the grid to the matching subset.
- When no records match (or none exist in scope), the grid shows *"No audit records found."* ( `page.tsx:352` ) — this is a normal empty state, not an error.
- Pagination summary and Previous/Next behave per the current result set.

### Failure

- **Fetch failure / API error.** If the `GET` request fails or returns a non-OK status, the client catches it and resets the grid to empty (rows = [], total = 0, totalPages = 1) ( `page.tsx:139-142` ). The user simply sees no rows; no toast or error banner is shown. *Resolution:* retry by reloading the page or re-applying a filter; if it persists, the server logs *"Error reading audit trail"* and returns HTTP 500 ( `route.ts:108-110` ).
- **No permission.** A user without `audit.audit-trail:view` will not see the nav item, and the API rejects the request via `withAuth` .
- **Facet load failure (admin).** If the facets request fails, the dropdowns stay empty (only the "All ..." options); this is handled non-fatally and does not block the grid ( `page.tsx:158-160` ).

## System Behaviour

- **Automatic record creation.** Audit-trail rows are created automatically — never manually on this page. Two sources:
  1. **API mutations.** Every `withAuth` -wrapped route auto-logs a successful mutation: the action is non- `view` and the response status is 2xx ( `api-auth.ts:194-200` ). The action label is derived primarily from the HTTP method — DELETE→Delete, approve action→Approve, POST→Create, PUT/PATCH→Update ( `api-auth.ts:104-108` ). The module name is humanized from the resource id (e.g. `audit.operational-plan` → "Operational Plan", `audit-trail.ts:32-39` ), and a best-effort `recordId` is pulled from the route's `id` (or any `*Id`) param ( `api-auth.ts:84-90` ). The client IP is captured from `x-forwarded-for` / `x-real-ip` ( `api-auth.ts:95-98` ).
  2. **Authentication events.** NextAuth `signIn` and `signOut` events log **Login** and **Logout** under module **Authentication** ( `auth.ts:532-539`, `560-567` ).
- **What is NOT logged.** Read/ `view` actions are not auto-logged ( `api-auth.ts:196` ), and the `audit.audit-trail` resource itself is explicitly skipped to avoid recursion ( `api-auth.ts:70` ). Failed mutations (non-2xx) are not logged.
- **Snapshot fields.** `userName` and `userRole` are stored as snapshots at action time, so the trail remains accurate even if the user's name/role later changes or the user is deleted ( `schema.prisma:3903-3904`, comments).
- **Fire-and-forget / non-blocking.** Logging never throws into the originating request; failures are caught and only console-logged ( `audit-trail.ts:54-75`, `api-auth.ts:120-122` ). A logging failure will not break the user's underlying action.
- **Read-only display.** This page only reads ( `GET` ). There is no auto status update, no background processing, and no notification triggered by viewing, filtering, or sorting the trail.
- **Facets.** For organization-wide viewers, the filter dropdown values (modules, roles, actions, users) are loaded once from distinct values in the trail ( `route.ts:24-40`; `page.tsx:153-162` ).

## Notes / Warnings / Tips

- **Read-only by design.** No role — including Audit Head, Audit Manager, or Auditor — can create, edit, or delete audit-trail entries from this page; entries are immutable.
- **Scope awareness.** Audit Head, Audit Manager, and Auditor see **only their own** activity. Organization-wide visibility (and the User Name / User Role filters) is granted to Customer Administrator (scope `all` ), not to the three audit roles.
- **The To Date is inclusive of the entire day** — selecting the same From and To date returns that full day's records ( `route.ts:71-74` ).
- **Search is debounced** ~0.35 s; results refresh shortly after you stop typing.
- **On a fetch error the grid simply empties** with no error toast — if you unexpectedly see no rows, reload the page or clear filters and retry.
- **The View and Submit / Reject / Export labels** exist in the action vocabulary for use by other modules; the automatic API capture itself emits only Create / Update / Delete / Approve, and authentication emits Login / Logout.

# Audit Settings

## Overview — Purpose, Business Objective

The **Settings** area of Internal Audit is the master-data control panel for the module. It lets an administrator define the reusable reference data that every other Internal Audit screen draws on — audit categories and sub-categories, audit types, control natures, audit periodicities, escalation timelines, and the full risk-assessment configuration (factors, probability and impact scales, scoring calculation methods, and risk-score ranges).

The business objective is to keep classification, scoring, and escalation rules consistent across all audits in the organization. Instead of typing free text on every risk or finding, users pick from these centrally maintained lists, and the risk engine uses the configured calculation types and scoring ranges to compute inherent scores and risk ratings.

The landing page is a card grid ( `settings/page.tsx` ). Each card links to one sub-page:

| Card label (source string)    | Description (source string)                      | Destination                                              |
|-------------------------------|--------------------------------------------------|----------------------------------------------------------|
| Audit Category                | Manage audit categories and classifications      | <code>/internal-audit/settings/categories</code>         |
| Nature of Controls            | Define control types and characteristics         | <code>/internal-audit/settings/nature-of-controls</code> |
| Risk Assessment Configuration | Configure risk assessment parameters             | <code>/internal-audit/settings/risk-assessment</code>    |
| Periodicity                   | Set audit frequency and intervals                | <code>/internal-audit/settings/periodicity</code>        |
| Escalation Configuration      | Configure escalation timelines                   | <code>/internal-audit/settings/escalation</code>         |
| Audit Type                    | Define types of audits                           | <code>/internal-audit/settings/audit-types</code>        |
| Sub-Category                  | Manage sub-categories linked to audit categories | <code>/internal-audit/settings/sub-categories</code>     |

( `settings/page.tsx:24-73` .)

**Note.** A `Department` sub-page ( `settings/departments/page.tsx` ) and a `User Management` sub-page ( `settings/user-management/page.tsx` ) exist in the codebase, but they are intentionally **not** linked from the Settings card grid. Per the comment at `settings/page.tsx:67-73` , audit user creation is now done exclusively by the Customer Administrator via *Organization > Users*, and Departments duplicate *Organization > Profile > Departments*. This chapter documents only the seven cards listed above. The Departments sub-page is described briefly under *System Behaviour* for completeness.

## Access — Roles and Required Permissions

Every Settings page and its APIs are guarded by the resource `audit.settings` . The role grants are defined in `src/lib/permissions.ts` :

| Role (internal key)                                          | <code>audit.settings</code> actions                                         | Effect on Settings                    |
|--------------------------------------------------------------|-----------------------------------------------------------------------------|---------------------------------------|
| CustomerAdministrator                                        | <code>view, create, edit, delete</code> ( <code>permissions.ts:409</code> ) | Full CRUD on all master data          |
| Audit Head ( <code>AuditHead</code> )                        | <code>view only</code> ( <code>permissions.ts:450</code> )                  | Read-only; no New/Edit/Delete buttons |
| Audit Manager ( <code>AuditManager</code> )                  | <code>view only</code> ( <code>permissions.ts:476</code> )                  | Read-only; no New/Edit/Delete buttons |
| Auditor (displayed name; internal key <code>Auditee</code> ) | <code>view only</code> ( <code>permissions.ts:520</code> )                  | Read-only; no New/Edit/Delete buttons |

API action mapping (identical pattern across all settings routes, e.g. `audit-types/route.ts:36,92` and `audit-types/[id]/route.ts:44,107,155` ):

- `GET` → { resource: "audit.settings", action: "view" }
- `POST` → { resource: "audit.settings", action: "create" }
- `PUT` → { resource: "audit.settings", action: "edit" }
- `DELETE` → { resource: "audit.settings", action: "delete" }

There is **no** `export action` for `audit.settings` , and no export button appears on any Settings page.

Client-side, each page reads `usePermissions('audit.settings')` and conditionally renders the New / Edit / Delete controls on `canCreate` / `canEdit` / `canDelete` (e.g. `audit-types/page.tsx:53,270,315,326` ). Because Audit Head, Audit Manager, and Auditor have view-only, they see the lists and search but no action buttons.

**Note on practical access.** Although Audit Head / Audit Manager / Auditor hold `audit.settings:view` , the Internal Audit navigation entry that exposes the Settings landing page is permission-filtered in `src/lib/navigation.ts` . Where a role does not see the Settings menu link, it would reach these pages only by direct URL. The view permission above governs what the pages render once opened. *Menu visibility per role is documented in the Navigation chapter — not re-verified here.*

## Prerequisites

- The user must be authenticated and hold at least `audit.settings:view` .
- To create, edit, or delete master data, the user must be a **CustomerAdministrator** (the only role with create/edit/delete on `audit.settings` ).

- For the **Sub-Category** page, at least one **Audit Category** must already exist, because every sub-category must be linked to a category ( `sub-categories/page.tsx:149-154,445-447` ).
- For the **Risk Assessment** scoring ranges, the **Risk Rating Calculation** type drives which ranges are shown and what `calculationType` is stamped on new ranges ( `risk-assessment/page.tsx:298,734-735` ). Setting the calculation type first is recommended before adding ranges.

### Audit Type ( `settings/audit-types` )

**Screenshot:** *Insert screenshot here*

Visible areas: a breadcrumb ( `Internal Audit > Dashboard > Settings > Audit Type` , Dashboard shown only if the user can view it — `audit-types/page.tsx:246-265` ); a page header `Audit Type` with a `New Audit Type` button on the right (visible only when `canCreate` ); a white card containing a search box ( `Search audit types...` ), a two-column table ( `Type Name` , `Action` ), and pagination.

#### Page Layout

- Header:** `Audit Type` + primary button `New Audit Type` ( + icon).
- Search bar:** single text input, placeholder `Search audit types...`
- Table:** columns `Type Name` and `Action` . Empty state text `No audit types found` .
- Row actions:** Edit (pencil) and Delete (trash) icon buttons, each shown per permission.
- Add/Edit dialog:** title `Add Audit Type` or `Edit Audit Type` ; one field `Type Name *` ; buttons `Cancel` and `Save` ( `Saving...` while in flight).
- Delete dialog:** title `Confirm Delete` , message `Are you sure you want to delete "<name>"? This action cannot be undone.` , buttons `Cancel` / `Delete` .

#### Field Reference

| Field     | Required | Type | Default | Validation                                                                                                            | Editable | Description         |
|-----------|----------|------|---------|-----------------------------------------------------------------------------------------------------------------------|----------|---------------------|
| Type Name | Yes      | Text | empty   | Non-empty; <code>isValidName</code> — only letters, spaces, and hyphens ( <code>audit-types/page.tsx:106-113</code> ) | Yes      | The audit type name |

#### Buttons & Actions

| Control        | Permission | Visible To    | Action           | API                                                      | Success Msg                                  | Failure Msg                              | Audit Trail                        | Notification |
|----------------|------------|---------------|------------------|----------------------------------------------------------|----------------------------------------------|------------------------------------------|------------------------------------|--------------|
| New Audit Type | create     | CustomerAdmin | Opens Add dialog | —                                                        | —                                            | —                                        | Not verified (no logging in route) | None         |
| Save (create)  | create     | CustomerAdmin | Creates type     | <code>POST /api/internal-audit/audit-types</code>        | <code>Audit type created successfully</code> | <code>Failed to save audit type</code>   | Not verified                       | None         |
| Save (edit)    | edit       | CustomerAdmin | Updates type     | <code>PUT /api/internal-audit/audit-types/{id}</code>    | <code>Audit type updated successfully</code> | <code>Failed to save audit type</code>   | Not verified                       | None         |
| Delete         | delete     | CustomerAdmin | Deletes type     | <code>DELETE /api/internal-audit/audit-types/{id}</code> | <code>Audit type deleted successfully</code> | <code>Failed to delete audit type</code> | Not verified                       | None         |

API-level validation: server requires `name` ( `400 Audit type name is required` ), rejects duplicate names within the same tenant/audit head ( `400 Audit type with this name already exists` ), and blocks deletion when the type is linked to risks ( `400 Cannot delete audit type with associated risks` ) — `audit-types/route.ts:47-71` , `audit-types/[id]/route.ts:74-89,135-140` .

### Audit Category ( `settings/categories` )

**Screenshot:** *Insert screenshot here*

Same layout pattern as Audit Type. Breadcrumb ends in `Audit Category` ; header button `New Category` ; search `Search categories...` ; table columns `Category Name` and `Action` ; empty state `No categories found` . Add/Edit dialog title `Add Audit Category` / `Edit Audit Category` with one field `Category Name *` ( `categories/page.tsx:284-396` ).

#### Field Reference

| Field         | Required | Type | Default | Validation                                                                                                                  | Editable | Description             |
|---------------|----------|------|---------|-----------------------------------------------------------------------------------------------------------------------------|----------|-------------------------|
| Category Name | Yes      | Text | empty   | Non-empty ( <code>Category name is required</code> ); <code>isValidName</code> ( <code>categories/page.tsx:106-113</code> ) | Yes      | The audit category name |

#### Buttons & Actions

| Control       | Permission | Action           | API                                        | Success Msg                   | Failure Msg                               |
|---------------|------------|------------------|--------------------------------------------|-------------------------------|-------------------------------------------|
| Save (create) | create     | Creates category | POST /api/internal-audit/categories        | Category created successfully | server error or Failed to save category   |
| Save (edit)   | edit       | Updates category | PUT /api/internal-audit/categories/{id}    | Category updated successfully | server error or Failed to save category   |
| Delete        | delete     | Deletes category | DELETE /api/internal-audit/categories/{id} | Category deleted successfully | server error or Failed to delete category |

Server blocks deletion when the category has associated risks (400 Cannot delete category with associated risks ) — categories/[id]/route.ts:135-140 . The client surfaces the server's data.error in the toast ( categories/page.tsx:182-187 ). Audit trail / notifications: none in the route — Not verified.

## Sub-Category ( settings/sub-categories )

**Screenshot:** *Insert screenshot here*

Breadcrumb ends in Sub-Categories ; header button New Sub-Category ; search Search sub-categories... . Table has **three** columns: Sub-Category Name , Category , Action ( sub-categories/page.tsx:359-361 ); empty state No sub-categories found . The Add/Edit dialog ( Add Sub-Category / Edit Sub-Category ) has a Category \* dropdown (placeholder Select category , populated from existing categories) and a Sub-Category Name \* text field ( sub-categories/page.tsx:432-464 ).

### Field Reference

| Field             | Required | Type   | Default | Validation                                                                | Editable | Description           |
|-------------------|----------|--------|---------|---------------------------------------------------------------------------|----------|-----------------------|
| Category          | Yes      | Select | empty   | Must be chosen — Category is required ( sub-categories/page.tsx:149-154 ) | Yes      | Parent audit category |
| Sub-Category Name | Yes      | Text   | empty   | Non-empty ( Sub-category name is required ); isValidName                  | Yes      | Sub-category name     |

### Buttons & Actions

| Control       | Action               | API                                            | Success Msg                       | Failure Msg                                   |
|---------------|----------------------|------------------------------------------------|-----------------------------------|-----------------------------------------------|
| Save (create) | Creates sub-category | POST /api/internal-audit/sub-categories        | Sub-category created successfully | server error or Failed to save sub-category   |
| Save (edit)   | Updates sub-category | PUT /api/internal-audit/sub-categories/{id}    | Sub-category updated successfully | server error or Failed to save sub-category   |
| Delete        | Deletes sub-category | DELETE /api/internal-audit/sub-categories/{id} | Sub-category deleted successfully | server error or Failed to delete sub-category |

The Category column displays the linked category name resolved client-side; if unresolved it shows - ( sub-categories/page.tsx:261-263,375 ).

## Nature of Controls ( settings/nature-of-controls )

**Screenshot:** *Insert screenshot here*

Breadcrumb ends in Nature of Controls ; header button New Nature of Control ; search Search nature of controls... ; table columns Label , Action ; empty state No nature of controls found . Dialog title Add Nature of Control / Edit Nature of Control with one field Label \* ( nature-of-controls/page.tsx:282-397 ).

### Field Reference

| Field | Required | Type | Default | Validation                                                                           | Editable | Description          |
|-------|----------|------|---------|--------------------------------------------------------------------------------------|----------|----------------------|
| Label | Yes      | Text | empty   | Non-empty ( Label is required ); isValidName ( nature-of-controls/page.tsx:106-113 ) | Yes      | Control nature label |

### Buttons & Actions

| Control       | Action         | API                                                | Success Msg                            | Failure Msg                                        |
|---------------|----------------|----------------------------------------------------|----------------------------------------|----------------------------------------------------|
| Save (create) | Creates record | POST /api/internal-audit/nature-of-controls        | Nature of control created successfully | server error or Failed to save nature of control   |
| Save (edit)   | Updates record | PUT /api/internal-audit/nature-of-controls/{id}    | Nature of control updated successfully | server error or Failed to save nature of control   |
| Delete        | Deletes record | DELETE /api/internal-audit/nature-of-controls/{id} | Nature of control deleted successfully | server error or Failed to delete nature of control |

## Periodicity ( settings/periodicity )

**Screenshot:** *Insert screenshot here*

Breadcrumb ends in `Periodicity`; header button `New Periodicity`; search `Search periodicity...`. Table has **three** columns: `Interval`, `Months`, `Action` (`periodicity/page.tsx:330-332`); empty state `No periodicity found`. The Add/Edit dialog (`Add Periodicity` / `Edit Periodicity`) shows two fields side by side: `Interval *` (placeholder `Enter interval (e.g., Monthly, Quarterly)`) and `Months *` (numeric, `min=1`) — `periodicity/page.tsx:404-435`.

Field Reference

| Field    | Required | Type   | Default | Validation                                                                                                                  | Editable | Description                                  |
|----------|----------|--------|---------|-----------------------------------------------------------------------------------------------------------------------------|----------|----------------------------------------------|
| Interval | Yes      | Text   | empty   | Non-empty (Interval is required); isValidName ( <code>periodicity/page.tsx:114-120</code> )                                 | Yes      | Frequency label e.g. Monthly, Quarterly      |
| Months   | Yes      | Number | 1       | >= 1 (Months must be at least 1); isValidNumber (Please enter a valid number) ( <code>periodicity/page.tsx:121-127</code> ) | Yes      | Number of months represented by the interval |

Buttons & Actions

| Control       | Action              | API                                                      | Success Msg                      | Failure Msg                  |
|---------------|---------------------|----------------------------------------------------------|----------------------------------|------------------------------|
| Save (create) | Creates periodicity | POST <code>/api/internal-audit/periodicity</code>        | Periodicity created successfully | Failed to save periodicity   |
| Save (edit)   | Updates periodicity | PUT <code>/api/internal-audit/periodicity/{id}</code>    | Periodicity updated successfully | Failed to save periodicity   |
| Delete        | Deletes periodicity | DELETE <code>/api/internal-audit/periodicity/{id}</code> | Periodicity deleted successfully | Failed to delete periodicity |

Escalation Configuration ( `settings/escalation` )

This page is a **single-form configuration**, not a CRUD list. There is one escalation-config record; the page edits its four numeric day-thresholds.

**Screenshot:** *Insert screenshot here*

Visible areas (`escalation/page.tsx:179-306`): breadcrumb ending in `Escalation`; page header `Escalation Configuration`; a content card titled `Escalation Timeline Settings` with subtext `Configure the number of days before escalation for each activity type`; a two-column grid of four numeric inputs (each with a trailing `days` label); and a card footer with `Cancel` and `Save Changes`.

Field Reference

| Field               | Required | Type          | Default | Validation                                                                                   | Editable | Description                                          |
|---------------------|----------|---------------|---------|----------------------------------------------------------------------------------------------|----------|------------------------------------------------------|
| Response Submission | Yes      | Number (days) | 5       | >= 1 — Response Submission must be at least 1 day ( <code>escalation/page.tsx:86-89</code> ) | Yes      | Days before escalating a pending response submission |
| Acknowledgement     | Yes      | Number (days) | 1       | >= 1 — Acknowledgement must be at least 1 day                                                | Yes      | Days before escalating a missing acknowledgement     |
| Clarification       | Yes      | Number (days) | 2       | >= 1 — Clarification must be at least 1 day                                                  | Yes      | Days before escalating a clarification               |
| Issue Resolution    | Yes      | Number (days) | 3       | >= 1 — Issue Resolution must be at least 1 day                                               | Yes      | Days before escalating an unresolved issue           |

Buttons & Actions

| Control      | Permission      | Action                             | API                                                    | Success Msg                                  | Failure Msg                              | Notes                                                                                |
|--------------|-----------------|------------------------------------|--------------------------------------------------------|----------------------------------------------|------------------------------------------|--------------------------------------------------------------------------------------|
| Cancel       | (any with view) | Returns to Settings                | —                                                      | —                                            | —                                        | <code>router.push('/internal-audit/settings')</code>                                 |
| Save Changes | edit            | Saves config + returns to Settings | PUT <code>/api/internal-audit/escalation-config</code> | Escalation configuration saved successfully. | Failed to save escalation configuration. | Button shown only when <code>canEdit</code> ( <code>escalation/page.tsx:298</code> ) |

**System behaviour:** On `GET`, if no config row exists the API creates a default one (`responseSubmission 5, acknowledgement 1, clarification 2, issueResolution 3`) — `escalation-config/route.ts:13-22`. This config record has **no** `customerAccountId` / `auditHeadId`; tenant filtering is disabled, so it is a single global record (route comment at `escalation-config/route.ts:6,37`). After a successful save the user is redirected back to the Settings landing page (`escalation/page.tsx:126`). No audit-trail logging or notifications in the route — Not verified / none.

Risk Assessment Configuration ( `settings/risk-assessment` )

This is the most complex Settings page: a single screen managing four related master-data lists plus two calculation-type selectors. It is **not** paginated.

**Screenshot:** *Insert screenshot here*

Visible areas (`risk-assessment/page.tsx:438-774`): breadcrumb ending in `Risk Assessment`; header `Risk Assessment Configuration`; then a responsive grid of four cards:

- 1. **Factors** — header with `New Factor` button; table columns `Label`, `Action`; empty state `No factors found`.
- 2. **Probability** — header with `New Probability` button; table columns `Label`, `Value`, `Action`; empty state `No probabilities found`.

3. **Impact** — header with `New Impact` button; table columns `Label`, `Value`, `Action`; empty state `No impacts found`.
4. **Scoring Configuration** — contains:
  - `Probability-Impact Calculation` dropdown + a blue **Calculation Formula** preview box.
  - `Risk Rating Calculation` dropdown + a green **Calculation Formula** preview box.
  - `Scoring Range` sub-section with a `New Range` button and a table.

A shared Add/Edit dialog and a shared `Confirm Delete` dialog serve all four lists.

## Calculation type options

The two dropdowns share these options ( `risk-assessment/page.tsx:79-83` ): `High of all`, `Addition of all`, `Product of all`.

Formula previews shown for **Probability-Impact Calculation** ( `risk-assessment/page.tsx:651-668` ):

- `Product of all`: `Inherent Score = <factors joined by x> × Probability × Impact`
- `Addition of all`: `Inherent Score = <factors joined by +> + Probability + Impact`
- `High of all`: `Inherent Score = MAX(<factors>, Probability, Impact)`

Formula previews shown for **Risk Rating Calculation** ( `risk-assessment/page.tsx:690-707` ):

- `Product of all`: `Risk Rating = Inherent Score × Control Effectiveness Factor`
- `Addition of all`: `Risk Rating = Inherent Score + Control Effectiveness Factor`
- `High of all`: `Risk Rating = Inherent Score (based on highest value)`

## Field Reference (shared dialog, per list type)

| Field         | Applies to          | Required | Type   | Validation                                                                                                                                                                   | Description              |
|---------------|---------------------|----------|--------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------|
| Label         | All four lists      | Yes      | Text   | Non-empty ( <code>Label</code> is required ); <code>isValidName</code> ( <code>risk-assessment/page.tsx:231-237</code> )                                                     | The display label        |
| Value         | Probability, Impact | Yes      | Number | Required ( <code>Value</code> is required ); <code>isValidNumber</code> ( <code>Please enter a valid number</code> ) ( <code>risk-assessment/page.tsx:240-248</code> )       | Numeric weight           |
| Lowest Value  | Scoring Range       | Yes      | Number | <code>isValidNumber</code> ( <code>risk-assessment/page.tsx:254-256</code> )                                                                                                 | Lower bound of the range |
| Highest Value | Scoring Range       | Yes      | Number | <code>isValidNumber</code> ; <b>must be greater than Lowest Value</b> else Highest value must be greater than lowest value ( <code>risk-assessment/page.tsx:262-265</code> ) | Upper bound of the range |

Dialog titles by type ( `risk-assessment/page.tsx:389-397` ): `Add Factor / Edit Factor`, `Add Probability / Edit Probability`, `Add Impact / Edit Impact`, `Add Scoring Range (create) / Edit Risk Score Range (edit)`.

## Scoring Range table specifics

- Columns: `Label`, `Low`, `High`, `Action`. The `High` column is **hidden** when the current `Risk Rating Calculation` is `High of all` ( `risk-assessment/page.tsx:727-729,740-742` ).
- Only ranges whose `calculationType` equals the current `riskRatingCalcType` are listed ( `risk-assessment/page.tsx:734-735` ). New ranges are stamped with the current `riskRatingCalcType` as their `calculationType` ( `risk-assessment/page.tsx:298` ).
- Empty state: `No scoring ranges found`.

## Buttons & Actions

| Control                                   | Permission    | Action                      | API                                                                                            | Notes                                                                                                                 |
|-------------------------------------------|---------------|-----------------------------|------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------|
| New Factor / Save                         | create / edit | Create/update factor        | POST / PUT <code>/api/internal-audit/risk-factors[/{id}]</code>                                | No toast on success/failure (silent refetch) — see below                                                              |
| New Probability / Save                    | create / edit | Create/update probability   | POST / PUT <code>/api/internal-audit/probability[/{id}]</code>                                 | Sends <code>{label, value}</code>                                                                                     |
| New Impact / Save                         | create / edit | Create/update impact        | POST / PUT <code>/api/internal-audit/impact[/{id}]</code>                                      | Sends <code>{label, value}</code>                                                                                     |
| New Range / Save                          | create / edit | Create/update scoring range | POST / PUT <code>/api/internal-audit/scoring-ranges[/{id}]</code>                              | Sends <code>{label, lowValue, highValue, calculationType}</code>                                                      |
| Delete (any list)                         | delete        | Delete the item             | DELETE to the matching endpoint                                                                | Confirm dialog text is generic: <code>Are you sure you want to delete this item?</code> This action cannot be undone. |
| Probability-Impact Calculation (dropdown) | edit          | Saves immediately on change | PUT <code>/api/internal-audit/scoring-config</code> ( <code>probabilityImpactCalcType</code> ) | No toast                                                                                                              |
| Risk Rating Calculation (dropdown)        | edit          | Saves immediately on change | PUT <code>/api/internal-audit/scoring-config</code> ( <code>riskRatingCalcType</code> )        | No toast; changes which scoring ranges are shown                                                                      |

**Behaviour note.** Unlike the other settings pages, the Risk Assessment page's `handleSave`, `handleDelete`, and `handleConfigChange` do **not** raise success or error toasts; on success they silently re-fetch the data ( `risk-assessment/page.tsx:309-332,339-370,372-387` ). Validation errors are shown inline in the dialog.

**Scoring config system behaviour:** On `GET`, if no scoring-config row exists for the tenant/audit head, the API creates a default with `probabilityImpactCalcType = "Product of all"` and `riskRatingCalcType = "High of all"` (`scoring-config/route.ts:21-30`). The dropdowns fall back to these defaults in the UI when no value is present (`risk-assessment/page.tsx:636,675`).

## Tables (all CRUD list pages)

- **Sorting:** The list pages (Audit Type, Category, Sub-Category, Nature of Controls, Periodicity) have no clickable column-sort controls. The Risk Assessment page defines sort handlers in code ( `handleSortFactors` , etc., `risk-assessment/page.tsx:155-189` ) but **no sort buttons are wired into the rendered table headers**, so sorting is not user-accessible there.
- **Searching:** Audit Type, Category, Sub-Category, Nature of Controls, and Periodicity each have a single client-side search box that filters by the main label/name field, case-insensitive, and resets to page 1 on change. Risk Assessment and Escalation have no search.
- **Filtering:** No status/category filter dropdowns on the list pages. The Risk Assessment scoring-range table filters implicitly by the selected Risk Rating Calculation type.
- **Pagination:** Audit Type, Category, Sub-Category, Nature of Controls, and Periodicity use a fixed page size of **10** with the shared `Pagination` component. Risk Assessment and Escalation are not paginated.
- **Row actions:** Edit (pencil) and Delete (trash) icon buttons, each gated by `canEdit` / `canDelete` .
- **Bulk actions:** None on any page.

## Step-by-Step Instructions

### Create a master-data record (Audit Type / Category / Nature of Control / Periodicity)

1. Open *Internal Audit* > *Settings* and click the relevant card.
2. Click the `New ...` button (top right). (*Only visible to CustomerAdministrator.*)
3. In the dialog, fill the required field(s) — the label, and for Periodicity also `Months` .
4. Click `Save` . The button shows `Saving...` while the request is in flight.
5. On success a green toast appears (e.g. `... created successfully` ) and the table refreshes.

### Create a Sub-Category

1. Ensure at least one Audit Category exists.
2. Open the Sub-Category card and click `New Sub-Category` .
3. Choose a `Category` from the dropdown.
4. Enter the `Sub-Category Name` .
5. Click `Save` .

### Edit a record

1. Click the pencil icon on the row.
2. Change the field(s) in the dialog.
3. Click `Save` .

### Delete a record

1. Click the trash icon on the row.
2. In `Confirm Delete` , review the name, then click `Delete` (or `Cancel` ) .
3. On success a toast confirms deletion and the row disappears.

### Configure escalation timelines

1. Open the Escalation Configuration card.
2. Adjust each day value ( `Response Submission` , `Acknowledgement` , `Clarification` , `Issue Resolution` ); each must be at least 1.
3. Click `Save Changes` . You are returned to the Settings landing page and a success toast appears.

### Configure risk assessment

1. Open the Risk Assessment Configuration card.
2. To add a factor / probability / impact, click the matching `New ...` button, fill the dialog, click `Save` .
3. Set the `Probability-Impact Calculation` and `Risk Rating Calculation` dropdowns; each saves immediately and updates the formula preview.
4. To add a scoring range, click `New Range` , enter `Label` , `Lowest Value` , and `Highest Value` (highest must exceed lowest), then `Save` . The range is associated with the currently selected Risk Rating Calculation type.

## Workflow

These pages manage configuration master data, not a multi-stage approval workflow. A create/edit cycle is:

User Action (Save in dialog) → Client validation (required + `isValidName/isValidNumber`) → API call (POST/PUT) → Server validation (required name; duplicate-name check on named entities) → DB row created/updated (+ dynamic translation queued via `translateRecord`) → Audit Trail: not implemented in these routes → Notification: none → UI: toast + table refresh .

A delete cycle is: User Action (Delete in Confirm dialog) → API DELETE → Server dependency check (Audit Type / Category block when linked to risks) → DB row deleted (+ translations removed) → UI: toast + refresh .



There are no status transitions and no "Next User" hand-off in this module.

## Status Reference

Not applicable. None of the Settings master-data entities has a status field or lifecycle state. (No status values are defined or rendered on these pages.)

## Validation Rules

- **Required fields** are enforced client-side before the API call:
  - Type Name / Category Name / Sub-Category Name / Label / Interval — non-empty.
  - Sub-Category — `Category` must be selected.
  - Periodicity — `Months`  $\geq 1$ .
  - Probability/Impact — `Value` required.
  - Scoring Range — `Lowest Value` and `Highest Value` numeric; `Highest`  $>$  `Lowest`.
- **Character validation:** Name/label/interval fields use `isValidName` — only letters, spaces, and hyphens are allowed; otherwise `Only letters, spaces, and hyphens are allowed`.
- **Numeric validation:** `isValidNumber` is used for Months, Probability/Impact Value, and Scoring Range bounds.
- **Duplicate check (server):** Audit Type rejects duplicate names per tenant (400). (*Category and the other named lists' duplicate behavior is not verified here beyond the Audit Type route, which is the confirmed example.*)
- **Dependency check (server):** Audit Type and Audit Category cannot be deleted while linked to risks (400 `Cannot delete ... with associated risks`).
- **Permission check (server):** Every route is wrapped with `withAuth` requiring the matching `audit.settings` action; non-CustomerAdmin roles cannot create/edit/delete.

## Success Scenarios and Failure Scenarios

### Success

- Create/edit/delete succeeds → green toast (e.g. `Audit type created successfully`, `Category deleted successfully`); list refreshes.
- Escalation save succeeds → `Escalation configuration saved successfully`. and redirect to Settings.
- Risk Assessment create/edit/delete succeeds → silent refresh (no toast).

### Failures

- *Empty / invalid label* → inline red error under the field; request not sent. Resolve by entering a valid value.
- *Highest  $\leq$  Lowest in a scoring range* → inline error `Highest value must be greater than lowest value`; resolve by raising the highest value.
- *Missing category on a sub-category* → inline `Category is required`.
- *Duplicate audit-type name* → server returns 400; client shows `Failed to save audit type` (the audit-type page uses a generic message, not the server text).
- *Deleting an in-use Audit Type / Category* → server 400; the Category page shows the server error `Cannot delete category with associated risks` (it surfaces `data.error`); the Audit Type page shows the generic `Failed to delete audit type`. Resolve by removing the dependent risks first.
- *Server/network error* → destructive toast ( `Failed to save ... / Failed to delete ...` ) or a logged console error on pages without a toast.

## System Behaviour

- **Auto-creation of singleton configs:** The escalation-config and scoring-config GET endpoints create a default record on first read if none exists ( `escalation-config/route.ts:13-22`, `scoring-config/route.ts:21-30` ).
- **Multi-tenant scoping:** Audit Type, Category, Sub-Category, Nature of Controls, Periodicity, scoring-config, and the risk-assessment lists are scoped by `customerAccountId` and `auditHeadId` ( `audit-types/route.ts:14-25`, `scoring-config/route.ts:13-18` ). The escalation-config record is **global** (no tenant fields) — `escalation-config/route.ts:6`.
- **Dynamic translation:** On create/edit, each page calls `triggerTranslation` (client) and the routes call `translateRecord` (server) so labels are translated into the other supported languages; deletes call `deleteRecordTranslations` (e.g. `audit-types/route.ts:81`, `audit-types/[id]/route.ts:96,144` ). Displayed list data is passed through `useTranslatedData`.
- **Read-only enforcement:** Roles without create/edit/delete (Audit Head, Audit Manager, Auditor) see lists and search but no New/Edit/Delete controls, because those buttons are gated on `canCreate` / `canEdit` / `canDelete`.
- **Audit Trail logging:** No explicit audit-trail write was found in these settings routes (no `auditTrail` / `createAuditLog` calls). Marked **Not verified** in the action tables above.
- **Notifications:** None are triggered by Settings changes.
- **Departments sub-page (unlinked):** `settings/departments/page.tsx` is a CRUD page for departments with fields `name`, `description`, and a `headId` (head user) dropdown, also gated by `audit.settings`. It is not reachable from the Settings card grid and is considered superseded by *Organization > Profile > Departments* ( `settings/page.tsx:67-71` ). Not documented in detail here.

## Notes / Warnings / Tips

- **Tip.** Set the `Risk Rating Calculation` type before adding scoring ranges: ranges are tagged with the active calculation type and only ranges matching the current type are listed.
- **Warning.** Changing `Risk Rating Calculation` will hide scoring ranges created under a different calculation type (they are filtered out, not deleted).
- **Warning.** You cannot delete an Audit Type or Audit Category that is linked to existing risks; remove the dependent records first.
- **Note.** The Risk Assessment page gives no success/error toast — rely on the table refreshing (or the inline dialog error) to confirm the result.
- **Note.** Escalation Configuration is a single global record; editing it affects the whole installation, not a single tenant.



# User Management

## Overview — Purpose, Business Objective

The **User Management** chapter covers how Internal Audit user accounts are created, edited, viewed, deactivated/blocked, deleted, password-reset, and bulk-imported/exported. It is reached from the Internal Audit sidebar under **Organization → Users** ( `/internal-audit/organization/users` ) and from **Internal Audit Settings → User Management** ( `/internal-audit/settings/user-management` ).

Both URLs are thin re-exports of one shared, module-aware page component ( `src/app/(protected)/organization/users/page.tsx` ):

- `src/app/(protected)/internal-audit/organization/users/page.tsx:8` — `export { default } from "@app/(protected)/organization/users/page";`
- `src/app/(protected)/internal-audit/settings/user-management/page.tsx:15` — same re-export.

Because the page detects the `/internal-audit/` URL prefix, in this scope it **locks the Function field to "Audit"** and offers only Internal Audit roles ( `page.tsx:215, :225-227, :328-334` ). The business objective is to let an administrator provision the people who will participate in audits and assign them an audit role (Audit Head, Audit Manager, or Auditor).

**Important note on APIs.** Although the assignment references `api/internal-audit/users/**`, the live page does **not** call those endpoints. All CRUD on this page goes through the shared `/api/users` family ( `page.tsx:351,366,476,508,604,665,706,724` ). The `/api/internal-audit/users/**` routes exist in the codebase but are not wired to this page; this chapter documents the endpoints the page actually invokes, and notes the IA-prefixed routes separately where relevant.

## Access — Which of the three roles can use it + exact permission(s) required

The sidebar entry is gated by the permission `organization.users:view` ( `src/lib/navigation.ts:173` ). All actions on the page (create/edit/delete/ change-password) ultimately run through the shared `/api/users` endpoints, whose write operation `/api/users/[id]/change-password` requires `organization.users:edit` ( `src/app/api/users/[id]/change-password/route.ts:65` ).

Of the three documented Internal Audit roles, **none** holds `organization.users`:

| Role (internal key)                         | Displayed as  | Has <code>organization.users</code> ?                                    | Can use this page?   |
|---------------------------------------------|---------------|--------------------------------------------------------------------------|----------------------|
| Audit Head ( <code>AuditHead</code> )       | Audit Head    | No (permissions.ts:433-454 has no <code>organization.users</code> entry) | No — nav item hidden |
| Audit Manager ( <code>AuditManager</code> ) | Audit Manager | No (permissions.ts:458-480 has no <code>organization.users</code> entry) | No — nav item hidden |
| Auditor ( <code>Auditee</code> )            | Auditor       | No (permissions.ts:532-539 has no <code>organization.users</code> entry) | No — nav item hidden |

The roles that **do** hold `organization.users` and therefore see and operate this page are:

- **CustomerAdministrator** — `organization.*` with all actions, scope `all` ( `src/lib/permissions.ts:385` ). This is the role that creates Internal Audit users in this scope.
- **GRCAdministrator** — `system/super-admin` (sees all functions; `page.tsx:138-144` ).

**Warning.** The three audit roles (Audit Head, Audit Manager, Auditor) cannot reach this page in the Internal Audit workspace, because the navigation link is filtered out for them. User provisioning for Internal Audit is performed by the Customer Administrator. (The page also has a special read-only department view for `DepartmentReviewer / DepartmentContributor`, `page.tsx:201-205,1072-1108`, but those are not Internal Audit roles.)

## Prerequisites

Before creating a user on this page:

- At least one **Department** must exist — Department is a required field ( `page.tsx:447` ) and the dialog's Department dropdown is populated from `/api/departments` ( `page.tsx:350` ).
- An **active subscription** with available account capacity. On clicking **New User**, the page calls `/api/subscription-status`; creation is blocked if the plan is expired, absent, or the max-accounts limit is reached ( `page.tsx:393-417` ).
- **Designations** (optional) are loaded from `/api/organization-settings/designation` ( `page.tsx:352` ); the Designation field is optional.
- Reporting Managers (optional) are fetched per Function from `/api/users/reporting-managers?function=Audit` ( `page.tsx:381-390` ).

## Page Layout

**Screenshot:** *Insert screenshot here*

Visible areas of the page (non-department roles):

- **Breadcrumb** ( `page.tsx:1113-1124` ): Home icon → "Organization" → "Dashboard" (link) → **"Users"** (current).
- **Page header** ( `page.tsx:1128` ): h1 reading **"Users"**.
- **Tabs** ( `page.tsx:1131-1139` ):
  - **Account Overview** (default active tab).

- **User Management.**
- **All Users** — only rendered when the customer subscribes to more than one platform ( `showAllUsersTab` , `page.tsx:234-238,1136` ); for an Internal-Audit-only customer this tab is hidden.

- **Action buttons** (top-right of both the Account Overview and User Management tabs, `page.tsx:1146-1160,1300-1314` ): **Export, Import, New User.**
- **Account Overview tab** ( `page.tsx:1143-1294` ): a search box ("Search by Department Name") and a set of **department accordions**; each accordion shows the department name, a user-count badge, and an expandable table of that department's users with columns Full Name, Designation, Reporting Manager, Email, Last Login, Actions (View / Edit / Delete icon buttons) plus a (disabled) pagination row.
- **User Management tab** ( `page.tsx:1297-1363` ): a search box ("Search user..."), a **Role** filter dropdown, a **Department** filter dropdown, and a `DataGrid` table of users.
- **All Users tab** ( `page.tsx:1370-1374` ): renders the shared `AllUsersTab` component (cross-module assign-role view) — only when shown.
- **Dialogs:** New User ( `page.tsx:1411-1833` ), Edit Account ( `page.tsx:1836-2169` ), Import Users ( `page.tsx:2171-2242` ), User Details view ( `page.tsx:2244-2377` ), Change Password ( `page.tsx:2380-2452` ), Delete confirmation ( `page.tsx:2455-2475` ), and a Subscription Error dialog ( `page.tsx:2478-2499` ).

**Department-scoped roles** ( `DepartmentReviewer` / `DepartmentContributor` ) get a simplified read-only screen instead: breadcrumb, header **"Account Overview"**, a `<Department> - <n> users` line, and a read-only `DataGrid` with columns Full Name, Designation Name, Reporting Manager, Email ID, Last Login ( `page.tsx:1072-1108` ). These are not Internal Audit roles.

## Field Reference

New User dialog ( `page.tsx:1411-1833` ). Title: **"New User"**. Sections: Account Credentials, Personal Information, Organization & Role, Preferences, Account Status.

| Field             | Required | Type             | Default                                                   | Validation                                                                                                                                                    | Editable                                               | Description                                                                                                                                                                                                                      |
|-------------------|----------|------------------|-----------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| User ID           | n/a      | Text (read-only) | Auto-generated value from <code>/api/users/next-id</code> | None (disabled)                                                                                                                                               | No                                                     | Labelled "User ID (Auto-generated)" ( <code>page.tsx:1452</code> ). Server generates BAxxxx (see Next-ID).                                                                                                                       |
| Username          | Yes      | Text             | empty                                                     | Required ("Please Enter the UserName"); alphanumeric/underscore only ("Only letters, numbers, and underscores are allowed") ( <code>page.tsx:438-442</code> ) | Yes                                                    | Login username.                                                                                                                                                                                                                  |
| Email             | Yes      | Email            | empty                                                     | Required + format-validated via <code>validateEmail</code> ( <code>page.tsx:443-444</code> )                                                                  | Yes                                                    | Email address; must be unique within the customer.                                                                                                                                                                               |
| Password          | Yes      | Password         | empty                                                     | Required ("Password can not be empty") ( <code>page.tsx:448</code> )                                                                                          | Yes                                                    | Initial password.                                                                                                                                                                                                                |
| Confirm Password  | Yes      | Password         | empty                                                     | Required; must equal Password ("Passwords do not match") ( <code>page.tsx:449-452</code> )                                                                    | Yes                                                    | Confirmation.                                                                                                                                                                                                                    |
| First Name        | Yes      | Text             | empty                                                     | Required ("Please Enter the First Name"); letters/spaces only ( <code>page.tsx:423-427</code> )                                                               | Yes                                                    | Auto-builds Full Name.                                                                                                                                                                                                           |
| Last Name         | Yes      | Text             | empty                                                     | Required ("Please Enter the Last Name"); letters/spaces only ( <code>page.tsx:428-432</code> )                                                                | Yes                                                    | Auto-builds Full Name.                                                                                                                                                                                                           |
| Full Name         | Yes      | Text             | auto First Last                                           | Required ("Please Enter the Name"); letters/spaces only ( <code>page.tsx:433-437</code> )                                                                     | Yes                                                    | Editable after auto-fill.                                                                                                                                                                                                        |
| Function          | Yes      | Dropdown         | "Audit" (locked in IA scope)                              | Required ("Please Select the Function") ( <code>page.tsx:445</code> )                                                                                         | No (disabled in IA scope, <code>page.tsx:1580</code> ) | Locked to <b>Audit</b> under <code>/internal-audit/</code> ( <code>page.tsx:225-227,328-334</code> ).                                                                                                                            |
| Role              | Yes      | Dropdown         | empty                                                     | Required ("Please Select the Role") ( <code>page.tsx:446</code> )                                                                                             | Yes (enabled once Function set)                        | Audit options: <b>Audit Head, Audit Manager, Auditor</b> (internal keys <code>AuditHead</code> , <code>AuditManager</code> , <code>Auditee</code> ; <code>page.tsx:112</code> , displayed via <code>getRoleDisplayName</code> ). |
| Department        | Yes      | Dropdown         | empty                                                     | Required ("Please Select the Department") ( <code>page.tsx:447</code> )                                                                                       | Yes                                                    | From <code>/api/departments</code> .                                                                                                                                                                                             |
| Designation       | No       | Dropdown         | empty                                                     | None                                                                                                                                                          | Yes                                                    | From designation settings ( <code>page.tsx:1649-1666</code> ).                                                                                                                                                                   |
| Reporting Manager | No       | Dropdown         | empty                                                     | None; disabled until Function set                                                                                                                             | Yes                                                    | From <code>/api/users/reporting-managers?function=Audit</code> ( <code>page.tsx:1668-1699</code> ).                                                                                                                              |
| Language          | No       | Dropdown         | "English"                                                 | None                                                                                                                                                          | Yes                                                    | Options: English, Arabic, Hindi ( <code>page.tsx:1717-1719</code> ).                                                                                                                                                             |
| Time Zone         | No       | Dropdown         | "UTC"                                                     | None                                                                                                                                                          | Yes                                                    | UTC plus GMT offsets ( <code>page.tsx:1733-1766</code> ).                                                                                                                                                                        |
| Active            | No       | Checkbox         | checked (true)                                            | None                                                                                                                                                          | Yes                                                    | Account active flag ( <code>page.tsx:1778-1788</code> ).                                                                                                                                                                         |
| Blocked           | No       | Checkbox         | unchecked (false)                                         | None                                                                                                                                                          | Yes                                                    | Account blocked flag ( <code>page.tsx:1790-1800</code> ).                                                                                                                                                                        |

Edit Account dialog ( `page.tsx:1836-2169` ). Title: **"Edit Account"**. Differences from New User: User ID is shown read-only ( `page.tsx:1850-1851` ); the username field is labelled **"Name"** ( `page.tsx:1929` ); there is no password field (a **Change Password** button opens a separate dialog, `page.tsx:2151-2157` ); Blocked and Active are

radio buttons (Yes/No) rather than checkboxes ( `page.tsx:2091-2146` ). Edit validates First/Last/Full name, Name (username), and Email ( `page.tsx:572-595` ) — it does **not** re-validate Function/Role/Department as required.

Change Password dialog ( `page.tsx:2380-2452` ). Fields: **New Password** and **Confirm Password**; both required, must match ( `page.tsx:651-656` ).

## Tables

**User Management tab grid** ( `page.tsx:910-1008,1356-1361` ), columns in order:

| Column header | Source                                                                           |
|---------------|----------------------------------------------------------------------------------|
| User Name     | <code>userName</code>                                                            |
| Full Name     | <code>fullName</code>                                                            |
| Department    | translated department name / <code>department.name</code>                        |
| Designation   | <code>designation</code>                                                         |
| User Role     | <code>getRoleDisplayName(role)</code> (e.g. "Auditor" for <code>Auditee</code> ) |
| Status        | Badge "Active" / "Inactive" from <code>isActive</code>                           |
| Last Login    | <code>lastLogin</code> (locale date) or "-"                                      |
| Actions       | View (eye), Edit (pencil), Delete (trash) icon buttons                           |

- **Search:** free-text box matching `fullName` or `userName` , case-insensitive ( `page.tsx:1014-1015` ). The grid's own search is hidden ( `hideSearch={true}` , `page.tsx:1359` ).
- **Filters:** **Role** dropdown ("All Roles" + each assignable role) and **Department** dropdown ("All Departments" + each department) ( `page.tsx:1331-1352` , filtering at `page.tsx:1012-1013` ).
- **Row actions:** View (opens User Details), Edit (opens Edit Account), Delete (opens delete confirmation) — `page.tsx:966-1006` .
- **Bulk actions:** None per-row. Page-level bulk operations are **Export** (CSV download) and **Import** (CSV upload) — see Buttons & Actions.
- **Sorting/Pagination:** provided by the shared `DataGrid` component; specific behavior is — Not verified here (component-level).

**Account Overview accordion tables** ( `page.tsx:1196-1287` ): per-department, columns Full Name, Designation, Reporting Manager, Email, Last Login (shown as "-"), Actions (View/Edit/Delete). The pagination controls shown ( `page.tsx:1262-1275` ) are **disabled** (static "1 to N of N").

## Buttons & Actions

| Control                                  | Permission                                                     | Visible To                               | Action                                                                 | API                                                | Success Msg                                                     | Failure Msg                                                                                                           | Audit Trail  |
|------------------------------------------|----------------------------------------------------------------|------------------------------------------|------------------------------------------------------------------------|----------------------------------------------------|-----------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------|--------------|
| <b>New User</b>                          | organization.users:view to see; create runs through /api/users | CustomerAdministrator, GRCAAdministrator | Checks subscription, then opens New User dialog                        | /api/subscription-status (GET); /api/users (POST)  | "User created successfully" ( page.tsx:537 )                    | "Failed to create user"; field-specific email/username errors; subscription error dialog ( page.tsx:400-409,548-557 ) | Not verified |
| <b>Save</b> (New User)                   | as above                                                       | same                                     | Validates then creates user (after a cross-module existing-user check) | /api/users/check-existing (GET), /api/users (POST) | "User created successfully"                                     | "Failed to create user", duplicate username/email, role-assignment-blocked ( page.tsx:541-543 )                       | Not verified |
| <b>Edit</b> (row / view dialog)          | organization.users:view                                        | same                                     | Opens Edit Account dialog, pre-loads reporting managers                | /api/users/reporting-managers (GET)                | —                                                               | —                                                                                                                     | Not verified |
| <b>Save</b> (Edit Account)               | edit                                                           | same                                     | Validates and updates user                                             | /api/users/{id} (PUT)                              | "User updated successfully" ( page.tsx:616 )                    | "Failed to update user", email/username errors, role-assignment-blocked ( page.tsx:620-637 )                          | Not verified |
| <b>Change Password</b> (in Edit)         | edit                                                           | same                                     | Opens Change Password dialog                                           | —                                                  | —                                                               | —                                                                                                                     | —            |
| <b>Change Password</b> (submit)          | organization.users:edit                                        | same                                     | Validates match, updates password (bcrypt-hashed)                      | /api/users/{id}/change-password (POST)             | "Password changed successfully" ( page.tsx:673 )                | "Failed to change password" ( page.tsx:682 )                                                                          | Not verified |
| <b>View</b> (eye)                        | view                                                           | same                                     | Opens read-only User Details dialog                                    | —                                                  | —                                                               | —                                                                                                                     | —            |
| <b>Delete</b> (trash)                    | delete via /api/users/{id}                                     | same                                     | Opens delete confirmation, then deletes                                | /api/users/{id} (DELETE)                           | "User deleted successfully" ( page.tsx:709 )                    | "Failed to delete user" ( page.tsx:714,718 )                                                                          | Not verified |
| <b>Export</b>                            | view                                                           | same                                     | Downloads users_export_<date>.csv of current (translated) user list    | client-side only ( page.tsx:762-792 )              | Browser download                                                | —                                                                                                                     | Not verified |
| <b>Import</b>                            | create (per-row)                                               | same                                     | Opens Import Users dialog                                              | /api/users (POST per CSV row)                      | "Import completed: N users imported, M errors" ( page.tsx:879 ) | "Failed to import users. Please check the file format." ( page.tsx:888 )                                              | Not verified |
| <b>Download Template</b> (Import dialog) | —                                                              | same                                     | Downloads users_template.csv                                           | client-side only ( page.tsx:795-810 )              | Browser download                                                | —                                                                                                                     | Not verified |

Notes:

- The **Audit Trail** column is marked **Not verified** for write actions because the page code itself does not call an audit-logging API; whether the underlying /api/users handlers log is not confirmed in the files reviewed.
- Export** is a UI-only CSV control implemented client-side; there is no export permission action in the permission matrix.

## Step-by-Step Instructions

### Create a new audit user

- Open **Internal Audit** → **Organization** → **Users** (or **IA Settings** → **User Management**).
- Click **New User**. (If the subscription is expired/absent or at the account limit, an Error dialog appears with an **OK** button and creation is blocked.)
- In **Account Credentials**, note the auto-generated **User ID**; enter **Username**, **Email**, **Password**, and **Confirm Password**.
- In **Personal Information**, enter **First Name** and **Last Name** (**Full Name** auto-fills; edit if needed).
- In **Organization & Role: Function** is locked to **Audit**. Select a **Role** (Audit Head, Audit Manager, or Auditor), a **Department**, and optionally a **Designation** and **Reporting Manager**.
- In **Preferences**, optionally set **Language** and **Time Zone**.
- In **Account Status**, set **Active / Blocked** as needed.
- Click **Save**. The button shows "Saving..." while submitting. On success a "User created successfully" toast appears and the dialog closes.
  - If the username/email already exists for the same customer in another module, a confirm dialog (UserExistsConfirmDialog) appears offering to attach the new role to that existing user via the Assign Role dialog ( page.tsx:1378-1409 ).

### Edit a user

1. On the **User Management** tab (or an Account Overview department table), click the **Edit** (pencil) icon, or open **View** then click **Edit**.
2. Update fields. (Username field is labelled **Name** here.)
3. Optionally toggle **Blocked / Active** (Yes/No radios).
4. Click **Save** → "User updated successfully".

### Change a user's password

1. Open the user's **Edit Account** dialog.
2. Click **Change Password**.
3. Enter **New Password** and **Confirm Password** (must match).
4. Click **Change Password** (shows "Changing..." → "Password changed successfully").

### View a user

1. Click the **View** (eye) icon. The read-only **User Details** dialog opens.
2. Click **Close**, or click **Edit** to switch to the Edit Account dialog.

### Delete a user

1. Click the **Delete** (trash) icon.
2. In the **Delete User** confirmation ("Are you sure you want to delete ? This action cannot be undone."), click **Delete**.

### Export users

1. Click **Export** to download `users_export_<date>.csv`.

### Import users

1. Click **Import** to open the **Import Users** dialog.
2. (Optional) Click **Download Template** to get `users_template.csv`.
3. Click **Choose File** and select a `.csv` file.
4. Click **Import** (shows "Importing..."). A toast reports the imported/errors counts.

## Workflow

This module is account administration, not a multi-stage approval workflow. The only state-changing flows are:

- **Create:** New User → client validation → `/api/users/check-existing` → `/api/users` POST → user row + role created in DB → `triggerTranslation` → list refreshed + next User ID refreshed. Next state: user appears in list as **Active** (default). Next user: the created user can log in.
- **Edit:** Edit Account → client validation → `/api/users/{id}` PUT → DB update
  - `triggerTranslation` → list updated.
- **Change Password:** Change Password dialog → `/api/users/{id}/change-password` POST → password (bcrypt-hashed) updated in DB.
- **Delete:** Delete confirmation → `/api/users/{id}` DELETE → row removed from list.

Audit Trail and Notification stages are not implemented in the page code (no notification call is made on these actions in `page.tsx`).

## Status Reference

The user record exposes two boolean states surfaced as UI status:

| Status             | Field                          | Meaning                                                                                                                        | How reached                                         | Who can change                                   | Next states |
|--------------------|--------------------------------|--------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------|--------------------------------------------------|-------------|
| <b>Active</b>      | <code>isActive = true</code>   | Account enabled; shown as green "Active" badge ( <code>page.tsx:949</code> ). Default on create ( <code>page.tsx:318</code> ). | Default on create; or set via Active checkbox/radio | CustomerAdministrator / GRCAAdministrator (edit) | Inactive    |
| <b>Inactive</b>    | <code>isActive = false</code>  | Account disabled; shown as grey "Inactive" badge.                                                                              | Uncheck Active (New User) or set Active = No (Edit) | same                                             | Active      |
| <b>Blocked</b>     | <code>isBlocked = true</code>  | Account blocked. Shown in View ("Blocked: Yes/No") and set via checkbox/radio.                                                 | Set Blocked checkbox/radio                          | same                                             | Unblocked   |
| <b>Not blocked</b> | <code>isBlocked = false</code> | Default.                                                                                                                       | Default on create                                   | same                                             | Blocked     |

There is a `handleDeactivateUser` helper that PUTs `isActive: false` ( `page.tsx:722-737` ), but no button in the reviewed layout invokes it; deactivation is performed through the Edit dialog's Active radio.

## Validation Rules

Client-side, on **Create** ( `handleAddUser`, `page.tsx:421-457` ):

- First Name, Last Name, Full Name: required and letters/spaces only.
- Username: required and alphanumeric/underscore only.
- Email: required and format-valid.
- Function, Role, Department: required.

- Password and Confirm Password: required and must match. On validation failure the dialog scrolls to top and shows inline field errors; no API call is made.

Cross-module duplicate check ( `page.tsx:462-505` ): before POST, the page calls `/api/users/check-existing`. If the same customer already has the user **in this module**, it blocks with "This user already exists and is assigned in this module." If the collision is **cross-customer**, it blocks with "This username or email is already in use. Please choose a different one." If the same customer has the user in a **different module**, it opens the confirm/assign-role flow instead of creating a duplicate.

Client-side, on **Edit** ( `handleEditUser`, `page.tsx:569-595` ): First/Last/Full name, Name (username), and Email are validated; Function/Role/Department are not re-checked.

Change Password ( `page.tsx:651-656` ): New Password and Confirm Password required and must match.

Server-side (shared `/api/users/[id]` ): email uniqueness within the customer and email format are enforced; the typed `RoleAssignmentError` codes ( `MODULE_NOT_SUBSCRIBED`, `DUPLICATE_ROLE_IN_MODULE`, `ROLE_MODULE_MISMATCH`, `ROLE_NOT_IN_MAP` ) are surfaced as friendly toasts when the server returns 403 with a code ( `page.tsx:156-170,541-547` ).

## Success Scenarios and Failure Scenarios

### Success:

- Create: valid form → "User created successfully"; user added to list; next User ID refreshed.
- Edit: valid form → "User updated successfully".
- Change password: matching passwords → "Password changed successfully".
- Delete: confirm → "User deleted successfully".
- Import: CSV processed → "Import completed: N users imported, M errors".

### Failure:

- *Subscription blocked* — Why: expired/absent plan or account limit reached. User sees the Error dialog with the relevant message (e.g. "Subscription plan has expired, kindly contact VeriAI support") and an **OK** button; New User dialog does not open. Resolve: contact VeriAI support / upgrade plan.
- *Duplicate username/email (same module)* — Why: user already assigned in this module. User sees inline error "This user already exists and is assigned in this module." Resolve: use a different username/email or edit the existing user.
- *Duplicate (cross-customer)* — User sees "This username or email is already in use. Please choose a different one." Resolve: choose different values.
- *Role assignment blocked* — Why: server returned a `RoleAssignmentError` code. User sees a destructive toast "Role assignment blocked" with a friendly reason and an inline error on the Role field. Resolve: pick an eligible role / ensure the module is subscribed.
- *Validation errors* — required/format failures show inline; the dialog scrolls to the top.
- *Generic create/update/delete/password failure* — server error → toast/inline "Failed to ...". Resolve: retry; check connectivity.

## System Behaviour

- **Auto-generated User ID**: On dialog open and after each create, the page fetches `/api/users/next-id`, which returns the next `BAxxxx` ID ( `BA` + zero-padded 4-digit sequence, e.g. `BA0001` ) computed as the max existing `BA####` for the customer plus one ( `src/app/api/internal-audit/users/next-id/route.ts:12-23` mirrors this scheme). The field is read-only; the server generates the final ID server-side.
- **Auto Full Name**: editing First or Last Name auto-fills Full Name ( `page.tsx:1526-1527,1542-1543` ).
- **Function locked in IA scope**: under `/internal-audit/`, Function is forced to "Audit" and the dropdown disabled; the Role dropdown then offers only audit roles ( `page.tsx:225-227,328-334,1580` ).
- **Module-scoped user list**: the list is fetched as `/api/users?moduleCode=INTERNAL_AUDIT`, so only users holding an Internal Audit role appear; `CustomerAdministrator` rows are filtered out of the list ( `page.tsx:351,361` ).
- **Dynamic translation**: on create/edit, `triggerTranslation('User', ...)` runs client-side ( `page.tsx:533,613` ); the shared API may also call `translateRecord` server-side.
- **Password hashing**: the shared change-password endpoint `bcrypt`-hashes the new password before saving ( `src/app/api/users/[id]/change-password/route.ts:48` ).
- **Read-only department view**: `DepartmentReviewer` / `DepartmentContributor` see a simplified, action-free list scoped to their own department ( `page.tsx:1072-1108` ).

## Notes / Warnings / Tips

- **Tip**. Use the **Download Template** button in the Import dialog to get the exact expected CSV column order (Username, Email, Password, First Name, Last Name, Full Name, Designation, Function, Role, Department, Language, Timezone).
- **Warning**. Deletion is permanent — the confirmation states "This action cannot be undone."
- **Note**. The "All Users" tab only appears for customers subscribed to more than one platform; an Internal-Audit-only customer will not see it.
- **Note (for documentation accuracy)**. The `/api/internal-audit/users/[id]/change-password` endpoint reads a `password` body field, whereas this page's Change Password flow posts `{ newPassword, confirmPassword }` to the shared `/api/users/[id]/change-password` endpoint — confirming the page uses the shared route, not the IA-prefixed one.

# Organization (Internal Audit)

## Overview — Purpose, Business Objective

The **Organization** area inside the Internal Audit workspace lets customers who subscribe to the Internal Audit module manage their company-level setup — company profile, departments, users, processes, reports, and settings — without needing the full GRC suite. It is a trimmed parallel of the GRC Organization area.

Most of these pages are **re-exports of the existing GRC Organization pages** with Internal-Audit-scoped filtering applied by URL detection. The navigation file documents this design explicitly ( `src/lib/navigation.ts:155-179` ):

- No **Dashboard** (the GRC dashboard charts are GRC-specific) — the landing route redirects to **Profile** ( `src/app/(protected)/internal-audit/organization/page.tsx:8-10` ).
- Profile** shows only **Company Info** and **Departments** (GRC-only tabs such as Services, Regulations, Organization Chart are hidden by the shared component) — comment at `src/app/(protected)/internal-audit/organization/profile/page.tsx:3-8` .
- Process** is an Internal-Audit-specific page (NOT a GRC re-export) backed by the `InternalAuditProcess` model.
- Users** re-exports the GRC users page; its Function dropdown auto-filters to "Audit" for IA-only customers ( `.../users/page.tsx:3-8` ).
- Reports** hides the GRC Management Report and process-by-\* reports ( `.../reports/page.tsx:3-10` ).
- Organization Settings** hides GRC-only settings (BIA, Nature of Implementation, Process Frequency, Translations) ( `.../settings/page.tsx:3-9` ).
- Subscription & Billing** redirects to `/settings/subscription` ( `.../subscription/page.tsx:9-11` ).
- A **Context** route also exists and re-exports the GRC Context page unchanged ( `.../context/page.tsx:1-6` ), although it is **not listed** in the Internal Audit > Organization navigation section.

**Scope of this chapter.** The pages that re-export GRC components (Profile, Users, Reports, Settings, Context, Subscription) are documented in their own GRC chapters; only the IA-specific filtering described above is summarized here. The **Process** page is unique to the Internal Audit module and is documented in full below.

## Access — Roles and Required Permissions

The navigation entries under **Internal Audit > Organization** and their gating permissions ( `src/lib/navigation.ts:166-177` ):

| Nav item               | Route                                              | Permission required                            |
|------------------------|----------------------------------------------------|------------------------------------------------|
| Profile                | <code>/internal-audit/organization/profile</code>  | <code>organization.profile:view</code>         |
| Process                | <code>/internal-audit/organization/process</code>  | <code>audit.process:view</code>                |
| Users                  | <code>/internal-audit/organization/users</code>    | <code>organization.users:view</code>           |
| Reports                | <code>/internal-audit/organization/reports</code>  | <code>organization.dashboard:view</code>       |
| Organization Settings  | <code>/internal-audit/organization/settings</code> | <code>organization.settings:view</code>        |
| Subscription & Billing | <code>/settings/subscription</code>                | <code>subscription.customer-portal:view</code> |

Of the three documented Internal Audit roles, access to the **Process** page ( `audit.process` ) is:

| Role (display) | Internal key              | audit.process actions                             | Source                              |
|----------------|---------------------------|---------------------------------------------------|-------------------------------------|
| Audit Head     | <code>AuditHead</code>    | * (view, create, edit, delete, approve)           | <code>permissions.ts:439</code>     |
| Audit Manager  | <code>AuditManager</code> | * (view, create, edit, delete, approve)           | <code>permissions.ts:464</code>     |
| Auditor        | <code>Auditee</code>      | <b>none</b> — no <code>audit.process</code> grant | <code>permissions.ts:532-539</code> |

`CustomerAdministrator` also has `audit.process` actions `view, create, edit, delete` (`permissions.ts:407`).

**Important — the Auditor (Auditee) role cannot access the Internal Audit Organization area at all.** The Auditee permission block (`permissions.ts:532-539`) grants only `organization.department:view`, `audit.fieldwork`, `audit.reports`, `audit.capa`, and `audit.audit-trail`. It has none of `audit.process`, `organization.profile`, `organization.users`, `organization.settings`, or `organization.dashboard`, so none of the Organization nav items are visible to that role.

**Note:** The displayed role "Auditor" maps to the internal key `Auditee` via `ROLE_DISPLAY_OVERRIDES` (`permissions.ts:319-321`). The legacy internal `Auditor` key is retired/hidden and is not assignable.

## Prerequisites

Before using the IA Organization area (in particular the Process page):

- The customer account must be subscribed to the **Internal Audit** module (the navigation section is gated `module: "INTERNAL_AUDIT"`, `navigation.ts:168`).
- The signed-in user must hold a role that grants the relevant permission (see Access above).
- For the **Process** page specifically, the following lookups should already exist to make the form fully usable (all optional except Audit Category):
  - Audit Categories** — required to save a process; loaded from `/api/internal-audit/categories` (`process/page.tsx:165`).
  - Departments** — loaded from `/api/departments` (`process/page.tsx:164`); needed to filter, and to enable the Process Owner dropdown.

- **Audit Head users** — loaded from `/api/internal-audit/users?role=AuditHead` (process/page.tsx:167); used as the Process Owner options, scoped to the selected department.
  - **IA risks** — loaded from `/api/internal-audit/risks` (process/page.tsx:166); used in the "Link Risk" multi-select.
-



# Process (Internal Audit)

This is the only IA-specific page in the Organization area; the rest are GRC re-exports. The remaining sections document the Process page.

## Page Layout

**Screenshot:** *Insert screenshot here*

Visible areas of the Process page ( `src/app/(protected)/internal-audit/organization/process/page.tsx` ):

- **Breadcrumb** (lines 401-414): `Home` (links to `/internal-audit/dashboard`) > `Organization` > `Process`.
- **Header** (lines 416-434):
  - Title `Process`.
  - Subtitle: *"Manage internal audit processes and link them to risks from the audit risk register."*
  - `Add Process` button (top-right), shown only when the user has create permission ( `canCreate` ).
- **Filters row** (lines 436-460):
  - A search input with placeholder `Search processes...`.
  - A department filter dropdown defaulting to `All Departments`, listing each department.
- **Table** (lines 462-573) — a single white card containing the process list (columns detailed under Tables below).
- **Add / Edit dialog** (lines 576-880) — modal with title `Add Process` or `Edit Process` and description *"Capture a process owned by the internal audit team and link it to risks from the IA risk register."* Fields detailed under Field Reference; includes a drag-and-drop **Document** upload card.
- **Delete confirmation dialog** (lines 883-903) — title `Delete Process`.

There are no summary cards, tabs, side panels, footer, sorting controls, bulk actions, or pagination on this page.

## Field Reference (Add / Edit Process dialog)

| Field                  | Required | Type               | Default          | Validation                                                                                                                        | Editable | Description                                                                                                                                  |
|------------------------|----------|--------------------|------------------|-----------------------------------------------------------------------------------------------------------------------------------|----------|----------------------------------------------------------------------------------------------------------------------------------------------|
| Process Name           | Yes      | Text input         | empty            | Non-empty after trim; must pass <code>isValidName</code> ; must be unique per tenant/audit-head                                   | Yes      | Name of the process. Placeholder: "e.g. Quarterly Revenue Reconciliation" (page lines 591-608; 263-276)                                      |
| Department             | No       | Select             | empty ("Select") | —                                                                                                                                 | Yes      | Department the process belongs to. Choosing a department resets Process Owner if the current owner is not in that department (lines 610-638) |
| Audit Category         | Yes      | Select             | empty            | Must be selected (lines 271-273, 641-670)                                                                                         | Yes      | Audit category for the process. Placeholder: "Select audit category"                                                                         |
| Process Owner          | No       | Select             | empty            | Disabled until a Department is chosen; options limited to Audit Head users in the selected department (lines 672-725)             | Yes      | Process owner. Placeholder "Select a department first" when no department chosen                                                             |
| Description            | No       | Textarea           | empty            | — (trimmed; stored as null if blank)                                                                                              | Yes      | Free-text description. Placeholder: "Briefly describe this process" (lines 727-738)                                                          |
| Link Risk              | No       | Multi-select       | empty list       | —                                                                                                                                 | Yes      | Links risks from the IA risk register; options labelled <code>{riskId}</code> — <code>{riskName}</code> (lines 740-756)                      |
| Document (file upload) | No       | File drop / browse | empty            | Accept list: <code>.pdf, .docx, .doc, .xlsx, .xls, .csv, .png, .jpg, .jpeg, .ppt, .pptx</code> ; multiple allowed (lines 758-801) | Yes      | Supporting documents. Helper text: "Supported formats: PDF, DOCX, XLSX, CSV, PNG, JPG, PPT"                                                  |

Field labels use `t("...")`; English source strings are shown above.

## Tables

The process list table (page lines 462-573):

| Column header  | Source value                                                                             |
|----------------|------------------------------------------------------------------------------------------|
| Reference ID   | <code>processCode</code> (e.g. IAP001), or <code>-</code> if empty                       |
| Process Name   | <code>name</code>                                                                        |
| Description    | <code>description</code> (truncated), or <code>-</code>                                  |
| Audit Category | linked <code>category.name</code> , or <code>-</code>                                    |
| Process Owner  | full name of the Audit Head user matching <code>processOwner</code> , or <code>-</code>  |
| Department     | linked <code>department.name</code> , or <code>-</code>                                  |
| Actions        | Edit / Delete icon buttons — column shown only if the user has edit or delete permission |

Behavior:

- **Searching** — the search box filters client-side across Process Name, Description, Reference ID, and Department name (lines 214-228).
- **Filtering** — the department dropdown filters rows by `departmentId`; the default `All Departments` shows everything (lines 217-219).
- **Sorting** — no column sorting in the UI. The list arrives sorted by `createdAt` descending from the API (route.ts:43).
- **Pagination** — none; all matching rows render.
- **Row actions** — per-row **Edit** (pencil) and **Delete** (trash) icon buttons, each gated by `canEdit` / `canDelete` (lines 536-566).
- **Bulk actions** — none.
- **Empty / loading states** — shows a spinner with `Loading...` while loading, and `No processes found` when there are no matching rows (lines 494-509).

## Buttons & Actions

| Control                       | Permission                                            | Visible To                                | Action                                              | API                                                                                                                     | Success Msg                        | Failure Msg                                                                                                                                       | Audit Trail                     | Notification |
|-------------------------------|-------------------------------------------------------|-------------------------------------------|-----------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------|------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------|--------------|
| Add Process                   | <code>audit.process:create</code>                     | Audit Head, Audit Manager, Customer Admin | Opens empty Add dialog                              | —                                                                                                                       | —                                  | —                                                                                                                                                 | None (no audit-log call in API) | None         |
| Create Process (dialog)       | <code>audit.process:create</code>                     | Same as above                             | Creates process; uploads pending files              | <code>POST /api/internal-audit/processes</code> , then <code>POST /api/internal-audit/processes/{id}/attachments</code> | Toast title <b>Process created</b> | Toast <b>Error</b> with server message (e.g. "A process with this name already exists", "Process name is required", "Audit category is required") | None                            | None         |
| Edit (row icon)               | <code>audit.process:edit</code>                       | Audit Head, Audit Manager, Customer Admin | Opens Edit dialog pre-filled                        | —                                                                                                                       | —                                  | —                                                                                                                                                 | None                            | None         |
| Save Changes (dialog)         | <code>audit.process:edit</code>                       | Same as above                             | Updates process; uploads any new files              | <code>PATCH /api/internal-audit/processes/{id}</code> , then <code>attachments POST</code>                              | Toast title <b>Process updated</b> | Toast <b>Error</b> with server message                                                                                                            | None                            | None         |
| Delete (row icon)             | <code>audit.process:delete</code>                     | Audit Head, Audit Manager, Customer Admin | Opens Delete confirmation                           | —                                                                                                                       | —                                  | —                                                                                                                                                 | —                               | —            |
| Delete (confirm)              | <code>audit.process:delete</code>                     | Same as above                             | Deletes process + cascades attachments & risk links | <code>DELETE /api/internal-audit/processes/{id}</code>                                                                  | Toast title <b>Process deleted</b> | Toast <b>Error</b> with server message (e.g. "Failed to delete")                                                                                  | None                            | None         |
| Cancel (dialog)               | —                                                     | Anyone with dialog open                   | Closes dialog without saving                        | —                                                                                                                       | —                                  | —                                                                                                                                                 | —                               | —            |
| browse / drag-drop (Document) | <code>audit.process:edit</code> / <code>create</code> | Same as create/edit                       | Queues files for upload on save                     | (upload on save)                                                                                                        | —                                  | Toast <b>File upload failed</b> with description "Process saved without attachment" if upload fails after save                                    | None                            | None         |
| Remove (pending file)         | —                                                     | Dialog user                               | Removes a queued file before save                   | —                                                                                                                       | —                                  | —                                                                                                                                                 | —                               | —            |

Notes on failure messaging:

- File-upload failure does **not** roll back the saved process; the process is kept and the user sees the `File upload failed` toast (page lines 316-323).
- No notification, email, or audit-trail entry is produced by any of these actions — none of the process API routes call an audit-log helper (verified: no `auditLog` / `createAuditLog` / `logActivity` references under `src/app/api/internal-audit/processes`).

## Step-by-Step Instructions

Create a process

- 1. Navigate to **Internal Audit > Organization > Process**.
- 2. Click **Add Process** (top-right). The Add Process dialog opens.
- 3. Enter a **Process Name** (required).
- 4. Optionally choose a **Department**.
- 5. Select an **Audit Category** (required).
- 6. Optionally select a **Process Owner** (the dropdown is enabled only after a department is chosen, and lists Audit Head users in that department).
- 7. Optionally enter a **Description**.
- 8. Optionally add risks under **Link Risk**.
- 9. Optionally attach documents — drag files onto the upload area or click **browse**. Queued files appear under "Files to Upload"; click the X to remove one.
- 10. Click **Create Process**. On success a **Process created** toast appears, the dialog closes, and the list refreshes.

Edit a process

- 1. On the Process list, click the **Edit** (pencil) icon on the target row.
- 2. The Edit Process dialog opens pre-filled. Existing attachments are listed under "Existing Documents".
- 3. Change fields as needed; add new files if required.
- 4. Click **Save Changes**. On success a **Process updated** toast appears.

Delete a process

- 1. On the Process list, click the **Delete** (trash) icon on the target row.
- 2. In the **Delete Process** confirmation, read the warning ("This will also remove all linked risks and uploaded documents. This action cannot be undone.").
- 3. Click **Delete**. On success a **Process deleted** toast appears and the list refreshes.

Search / filter

- 1. Type into **Search processes...** to filter by name, description, reference ID, or department.
- 2. Use the **All Departments** dropdown to narrow by department.

Workflow

The Process record has **no status field and no approval/multi-stage workflow**. The lifecycle is a simple create / edit / delete CRUD:

| User action      | Validation                                        | API                                | DB update                                                                                                                     | Audit Trail | Notification |
|------------------|---------------------------------------------------|------------------------------------|-------------------------------------------------------------------------------------------------------------------------------|-------------|--------------|
| Create Process   | Name required + valid + unique; category required | POST /api/internal-audit/processes | Inserts InternalAuditProcess (auto processCode IAP001...), creates InternalAuditProcessRisk links; queues dynamic translation | None        | None         |
| Upload documents | File present                                      | POST .../{id}/attachments          | Inserts InternalAuditProcessAttachment rows; stores encrypted fileData                                                        | None        | None         |
| Edit Process     | Name (if sent) non-empty + unique                 | PATCH .../{id}                     | Updates fields; replaces risk links; queues translation                                                                       | None        | None         |
| Delete Process   | Record must exist in tenant/audit-head scope      | DELETE .../{id}                    | Deletes process; cascades attachments & risk links; deletes translations                                                      | None        | None         |

Status Reference

Not applicable — the InternalAuditProcess model ( prisma/schema.prisma:3050-3077 ) has no status column, and the Process page defines no status values. Omitted because no statuses exist.

Validation Rules

- **Process Name** — required; trimmed value must be non-empty (client message "Process name is required"; server returns "Process name is required" with HTTP 400). Must pass isValidName (client message "Please enter a valid name") (page lines 263-276, route.ts:79-84).
- **Audit Category** — required (client message "Audit category is required"; server returns "Audit category is required", HTTP 400) (page lines 271-273, route.ts:86-91).
- **Duplicate name** — a process name must be unique within the same tenant / audit-head scope. On create or rename, a duplicate returns "A process with this name already exists" (HTTP 400) (route.ts:96-109; [id]/route.ts:105-120 ). Enforced at DB level by @@unique([customerAccountId, auditHeadId, name]) (schema.prisma:3072).
- **Edit empty name** — sending an empty name on PATCH returns "Process name cannot be empty" (HTTP 400) ( [id]/route.ts:98-103 ).
- **Process Owner dependency** — the Process Owner select is disabled until a Department is chosen; options are limited to Audit Head users assigned to the selected department. If none exist, the dialog shows "No audit heads are assigned to the selected department." (page lines 672-725).
- **Permission checks** — each API route is wrapped with withAuth against audit.process for view/create/edit/delete (route.ts:55,171; [id]/route.ts:58,183,219; attachments/route.ts:44,115 ).
- **Tenant / audit-head scoping** — all reads and mutations are filtered by customerAccountId and auditHeadId derived from the session; records outside scope return "Process not found" (HTTP 404).

Success Scenarios and Failure Scenarios

Success

- Create succeeds → HTTP 201, **Process created** toast, dialog closes, list refreshes, `processCode` auto-assigned (IAP001, IAP002, ...).
- Edit succeeds → **Process updated** toast, list refreshes.
- Delete succeeds → **Process deleted** toast, list refreshes.

#### Failure

- **Missing name / category** → 400; user sees inline field error in the dialog and/or an **Error** toast with the server message. Resolution: fill the required field.
- **Duplicate name** → 400 "A process with this name already exists" shown in an **Error** toast. Resolution: use a different name.
- **Invalid name** → inline "Please enter a valid name". Resolution: correct the name to pass validation.
- **Save server error** → **Error** toast with "Failed to save process" (or the returned message). Resolution: retry / contact admin.
- **Attachment upload fails after save** → process is saved; **File upload failed** toast with "Process saved without attachment". Resolution: edit the process and re-add the file.
- **Load failure** → **Error** toast "Failed to load processes" (page lines 204-208). Resolution: refresh.
- **Out-of-scope or missing record on edit/delete** → 404 "Process not found".

## System Behaviour

- **Auto reference ID** — on create, the API generates `processCode` in the format `IAP###` by incrementing the highest existing code for the tenant (route.ts:111-125).
- **Cascade delete** — deleting a process removes its attachments and risk links via Prisma cascade relations (schema.prisma:3083, 3101-3103); the confirmation dialog warns of this.
- **Dynamic translation** — on create and edit, the server queues a translation job for the process `name` and `description` via `translateRecord` (route.ts:155-160; `[id]/route.ts:170-175`); on delete, translations are removed via `deleteRecordTranslations` (`[id]/route.ts:209-211`). The client also calls `triggerTranslation` after save (page lines 326-329). The list is displayed through `useTranslatedData` for the `InternalAuditProcess` model (page lines 151-153).
- **Attachment storage / encryption** — uploaded files are saved and the binary is stored in the DB column `fileData` encrypted at rest via `maybeEncryptBytes` (attachments/route.ts:96-98; schema.prisma:3088).
- **Audit-trail logging** — none; the process API routes do not write audit-log entries.
- **Notifications** — none are emitted for any process action.

## Notes / Warnings / Tips

- **Auditors (Auditee role) cannot see or use this area** — they lack `audit.process` and all `organization.*` view permissions, so the entire Internal Audit > Organization section is hidden for them.
- **Deleting a process is irreversible** and also removes all linked risks and uploaded documents (dialog warning, page lines 887-890).
- **Process Owner options depend on Department** — if the owner dropdown is empty, ensure an Audit Head user is assigned to the chosen department.
- The **Context** route exists under IA Organization but is not surfaced in the navigation; it re-exports the GRC Context page unchanged.
- **Subscription & Billing** intentionally keeps the legacy URL `/settings/subscription` (per the BA spec) even though it appears under the Organization group.

# Customer Accounts (Account Overview)

## Overview — Purpose, Business Objective

The **Customer Accounts** page is the superadmin (GRCAAdministrator) tenant overview for the Internal Audit module. It lists every customer account that has the Internal Audit module enabled ( `isInternalAuditEnabled = true` ), together with that account's primary Customer Administrator user, its active/inactive flag, and counts of audit engagements and findings recorded under each tenant.

This is **not** a customer-side audit workflow page. It does not let you run audits, create plans, or manage findings. Its sole purpose is to give the platform superadmin a single, read-only roster of which customers are subscribed to Internal Audit and a quick at-a-glance view of their audit activity volume. The only editing entry point provided is a link out to the canonical superadmin customer-accounts page, where module toggles and admin details are actually managed ( `src/app/(protected)/internal-audit/account-overview/page.tsx:10-13` ).

The page header subtitle states the business intent directly: "Customers with an active Internal Audit subscription." ( `page.tsx:118-120` ).

## Access — Roles and Required Permission

This page is protected by the resource `audit.account-overview` with action `view` on both the page (client-side `usePermissions("audit.account-overview")` , `page.tsx:46` ) and the API route ( `{ resource: "audit.account-overview", action: "view" }` , `route.ts:109` ).

In the permission matrix, `audit.account-overview` is granted only to **GRCAAdministrator** — `{ resource: 'audit.account-overview', actions: ['*'], scope: 'all' }` ( `src/lib/permissions.ts:377` ). The accompanying comment confirms the intent: "Internal Audit module - GRCAAdministrator only sees the customer overview ... They do NOT see the customer-side audit workflow pages" ( `permissions.ts:374-376` ).

| Role                           | Internal key                   | Has <code>audit.account-overview:view</code> ? |
|--------------------------------|--------------------------------|------------------------------------------------|
| Audit Head                     | <code>AuditHead</code>         | No                                             |
| Audit Manager                  | <code>AuditManager</code>      | No                                             |
| Auditor                        | <code>Auditee</code>           | No                                             |
| (Superadmin) GRC Administrator | <code>GRCAAdministrator</code> | Yes ( <code>permissions.ts:377</code> )        |

None of the three documented Internal Audit roles (Audit Head, Audit Manager, Auditor) can access this page. A user without the permission is shown the **Unauthorized** screen with the message: "You don't have permission to view Internal Audit customer accounts." ( `page.tsx:91-93` ).

## Prerequisites

- Before any rows appear on this page:
- The signed-in user must hold the **GRCAAdministrator** role (the only role granted `audit.account-overview:view` ).
  - At least one customer account must have **Internal Audit enabled** ( `isInternalAuditEnabled = true` ); the API filters to these accounts only ( `route.ts:28-30` ). If no account has it enabled, the API returns an empty list ( `route.ts:36-41` ).
  - The qualifying customer account must also have at least one user assigned the **CustomerAdministrator** role; the query requires `users.some.userRoles.some.role.name = "CustomerAdministrator"` ( `route.ts:45-51, 71` ). Accounts with IA enabled but no Customer Administrator user are excluded from the list.

## Page Layout

**Screenshot:** *Insert screenshot here*

The page renders the following visible areas (all from `page.tsx:95-194` ):

- Breadcrumb** ( `page.tsx:97-105` ): a Home icon and "Internal Audit", a chevron separator, then the current page label "Customer Accounts" in highlighted text.
- Header row** ( `page.tsx:107-121` ):
  - A ClipboardCheck icon and the page title **Customer Accounts**.
  - A count **Badge** to the right of the title showing the number of rows, e.g. "3 customers" (or "1 customer" when there is exactly one) — singular/plural handled in code ( `page.tsx:114-116` ).
  - A right-aligned subtitle paragraph: "Customers with an active Internal Audit subscription." ( `page.tsx:118-120` ).
- Search bar** ( `page.tsx:123-134` ): a search input with a magnifier icon and placeholder "Search by company or code". There are no other filters.
- Data table** ( `page.tsx:136-193` ) inside a white rounded card. Columns and states described below.
- There is **no** "Add", "Create", "Export", or bulk-action control on this page, and **no** tabs, side panels, or footer.

While permissions are still loading, the page shows a centered spinner instead of any content ( `page.tsx:83-89` ).

## Field Reference

This page has no data-entry form. The only interactive input field is the search box.

| Field                     | Required | Type       | Default | Validation       | Editable | Description                                                                                                                               |
|---------------------------|----------|------------|---------|------------------|----------|-------------------------------------------------------------------------------------------------------------------------------------------|
| Search by company or code | No       | Text input | empty   | None (free text) | Yes      | Filters the list by company name or customer code; debounced 300 ms before triggering a refetch ( <code>page.tsx:52-56, 127-132</code> ). |

All other values shown on the page (Customer Code, Company Name, Admin User, Email, Active, Engagements, Findings) are **read-only display data** returned by the API and are not editable here.

Tables

The single table lists qualifying customer accounts ( `page.tsx:138-192` ).

**Columns** ( `page.tsx:139-150` ):

| Column        | Source field                                           | Notes                                                                                                                                                                                              |
|---------------|--------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Customer Code | <code>customerCode</code> (= account code )            | Rendered in bold ( <code>page.tsx:169</code> )                                                                                                                                                     |
| Company Name  | <code>companyName</code> (= account name )             |                                                                                                                                                                                                    |
| Admin User    | <code>fullName</code> of primary CustomerAdministrator | Falls back to "-" if none ( <code>route.ts:93</code> )                                                                                                                                             |
| Email         | <code>email</code> of primary CustomerAdministrator    | Muted text; falls back to "-" ( <code>route.ts:94</code> )                                                                                                                                         |
| Active        | <code>active</code> ("Yes" / "No")                     | Center-aligned, shown as a Badge — "default" variant when "Yes", "secondary" when "No" ( <code>page.tsx:173-177</code> ). Derived from account <code>isActive</code> ( <code>route.ts:95</code> ). |
| Engagements   | <code>engagementCount</code>                           | Center-aligned; count of <code>auditEngagements</code> for the account ( <code>route.ts:78, 96</code> )                                                                                            |
| Findings      | <code>findingCount</code>                              | Center-aligned; count of <code>internalAuditFindings</code> for the account ( <code>route.ts:78, 97</code> )                                                                                       |
| Action        | —                                                      | End-aligned; contains the <b>Edit</b> button (see Buttons & Actions)                                                                                                                               |

- **Sorting:** No interactive column sorting. The API returns rows sorted by company name ascending ( `orderBy: { name: "asc" }` , `route.ts:81` ).
- **Searching:** Via the search box only; matches account `name` or `code` , case-insensitive ( `route.ts:53-62` ).
- **Filtering:** No additional filters beyond search; the underlying dataset is always filtered to IA-enabled accounts that have a Customer Administrator.
- **Pagination:** The API supports `limit` (default 50) and `offset` (default 0) parameters and returns pagination metadata ( `route.ts:20-21, 38-39, 82-83, 102` ), but the page does **not** send these parameters or render any pagination controls — it requests only `search` ( `page.tsx:61-63` ). In practice up to 50 rows are shown.
- **Row actions:** A single **Edit** action per row (see below).
- **Bulk actions:** None.

**Table states:**

- **Loading:** a centered spinner spans all 8 columns ( `page.tsx:152-157` ).
- **Empty (with search):** "No customers match your search." ( `page.tsx:161-162` ).
- **Empty (no search):** "No customers have an active Internal Audit subscription yet." ( `page.tsx:163` ).

Buttons & Actions

| Control               | Permission                                                        | Visible To       | Action                                                                               | API                                                                                                                  | Success Msg                   | Failure Msg                                                               | Audit Trail | Notification |
|-----------------------|-------------------------------------------------------------------|------------------|--------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------|-------------------------------|---------------------------------------------------------------------------|-------------|--------------|
| Search input (typing) | <code>audit.account-overview:view</code>                          | GRCAdministrator | Debounces 300 ms then refetches the list filtered by company/code                    | <code>GET /api/internal-audit/account-overview?search=&lt;term&gt;</code> ( <code>page.tsx:58-75</code> )            | None (table updates in place) | On error, table clears to empty; no toast ( <code>page.tsx:67-72</code> ) | None        | None         |
| Edit (per row)        | <code>audit.account-overview:view</code> (only gate on this page) | GRCAdministrator | Navigates to the canonical superadmin customer-accounts page focused on that account | None (client-side Link to <code>/grc/customer-accounts?focus=&lt;account id&gt;</code> , <code>page.tsx:181</code> ) | N/A (page navigation)         | N/A                                                                       | None        | None         |

There are no toast messages defined anywhere on this page — list-load failures silently render an empty table ( `page.tsx:67-72` ). No Create, Delete, or Approve actions exist on this page.

Step-by-Step Instructions

Task 1 — View the Internal Audit customer roster

1. Sign in as a GRCAdministrator.
2. Open the **Internal Audit** section in the sidebar and click **Customer Accounts** ( `src/lib/navigation.ts:300` ).
3. The page loads and the table displays all customers with an active Internal Audit subscription, sorted by company name.
4. Read the badge next to the title for the total customer count.

Task 2 — Search for a specific customer

1. On the Customer Accounts page, click the **Search by company or code** box.
2. Type part of the company name or the customer code.
3. Wait briefly (about 300 ms) — the table refreshes automatically with matching rows. No button press is required.

4. To clear the search, delete the text; the full list returns.

### Task 3 — Edit a customer's Internal Audit subscription / admin details

1. Locate the customer's row in the table.
2. In the **Action** column, click **Edit**.
3. You are taken to the canonical superadmin customer-accounts page ( `/grc/customer-accounts` ) with that account in focus, where module toggles and admin details are managed ( `page.tsx:181` ; `page.tsx:10-13` ). Editing itself happens on that page, not here.

## Workflow

This page is a **read-only roster with a navigation-out link**; it does not advance any audit record through a status lifecycle. There is no create/edit/approve workflow on this page, so a status-transition table does not apply. The only sequence is:

| Current Status   | User Action       | Validation | API                                                   | DB Update        | Audit Trail | Notification | Next Status                                     | Next User        |
|------------------|-------------------|------------|-------------------------------------------------------|------------------|-------------|--------------|-------------------------------------------------|------------------|
| (Viewing roster) | Type in search    | None       | GET <code>/api/internal-audit/account-overview</code> | None (read-only) | None        | None         | (Viewing roster)                                | —                |
| (Viewing roster) | Click <b>Edit</b> | None       | None                                                  | None             | None        | None         | Hand-off to <code>/grc/customer-accounts</code> | GRCAdministrator |

## Status Reference

This page implements no record-status lifecycle of its own. The only status-like value displayed is the **Active** flag:

| Value | Meaning                                                        | How reached                        | Who can change it                                                 | Next values |
|-------|----------------------------------------------------------------|------------------------------------|-------------------------------------------------------------------|-------------|
| Yes   | Customer account is active ( <code>isActive = true</code> )    | Set on the customer account record | Not changed here — managed on <code>/grc/customer-accounts</code> | No          |
| No    | Customer account is inactive ( <code>isActive = false</code> ) | Set on the customer account record | Not changed here — managed on <code>/grc/customer-accounts</code> | Yes         |

(Value source: `route.ts:95` ; rendered `page.tsx:173-177` .)

## Validation Rules

- **Search input:** free text, no format or length validation; an empty search returns the full IA-enabled list ( `page.tsx:61-62` , `route.ts:19` , `53` ).
- **Server-side dataset filters** (not user-facing validation, but they govern what appears):
  - Account must have `isInternalAuditEnabled = true` ( `route.ts:28-30` ).
  - Account must have a user with role `CustomerAdministrator` ( `route.ts:45-51` , `71` ).
  - Search matches account `name` or `code` , case-insensitive ( `route.ts:53-62` ).
- **Permission check:** Both client and server enforce `audit.account-overview:view` ; failing it yields the Unauthorized screen (client) or a blocked API request (server via `withAuth` ).
- No duplicate checks, approval checks, or input-format validation exist on this page (there is no data entry).

## Success Scenarios and Failure Scenarios

### Success scenarios (producible by the code):

- Authorized GRCAdministrator loads the page and one or more IA-enabled customers with a Customer Administrator exist → table lists them, count badge shows the total ( `page.tsx:166-190` ).
- Search term matches → table narrows to matching rows.
- Search term matches nothing → "No customers match your search." ( `page.tsx:161-162` ).
- No qualifying customers exist at all → "No customers have an active Internal Audit subscription yet." ( `page.tsx:163` ).

### Failure scenarios:

- **Insufficient permission.** *Why:* user lacks `audit.account-overview:view` . *What the user sees:* the Unauthorized screen, "You don't have permission to view Internal Audit customer accounts." ( `page.tsx:91-93` ). *Resolution:* an account with the GRCAdministrator role is required.
- **API request fails (non-OK response or network error).** *Why:* server error (the route returns HTTP 500 "Failed to load account overview" on an exception, `route.ts:104-107` ), or a fetch exception. *What the user sees:* the table simply renders empty (no toast or error banner is shown) because the page sets accounts to an empty array on any non-OK or thrown error ( `page.tsx:67-72` ). With no active search, this looks identical to the "no subscriptions yet" empty state. *Resolution:* retry by reloading the page; if it persists, check server logs (the API logs "[`/api/internal-audit/account-overview`] failed:" at `route.ts:105` ).
- **IA-enabled column missing in DB (extremely unlikely).** *Why:* `isInternalAuditEnabled` column not present. *What happens:* the raw query is caught and `iaAccountIds` stays empty, so the API returns an empty list ( `route.ts:32-34` , `36-41` ) — the page shows the "no subscriptions yet" empty state.

## System Behaviour

- **Read-only page.** No records are created, updated, or deleted from this page. The Edit action only navigates away.
- **Automatic refetch on search.** Typing in the search box debounces 300 ms, then refetches; each settled search value triggers exactly one request ( `page.tsx:52-56` , `77-79` ).
- **Initial load gating.** The list is fetched only after the permission check confirms `canView` ( `page.tsx:77-79` ).

- **Derived counts.** Engagement and finding counts are computed server-side via Prisma `_count` over `auditEngagements` and `internalAuditFindings` relations ( `route.ts:77-78` ), so they reflect live data each time the list loads.
- **Audit-trail logging:** None on this page — there are no write operations to log.
- **Notifications:** None are sent or received on this page.
- **Background processing:** None.

## Notes / Warnings / Tips

---

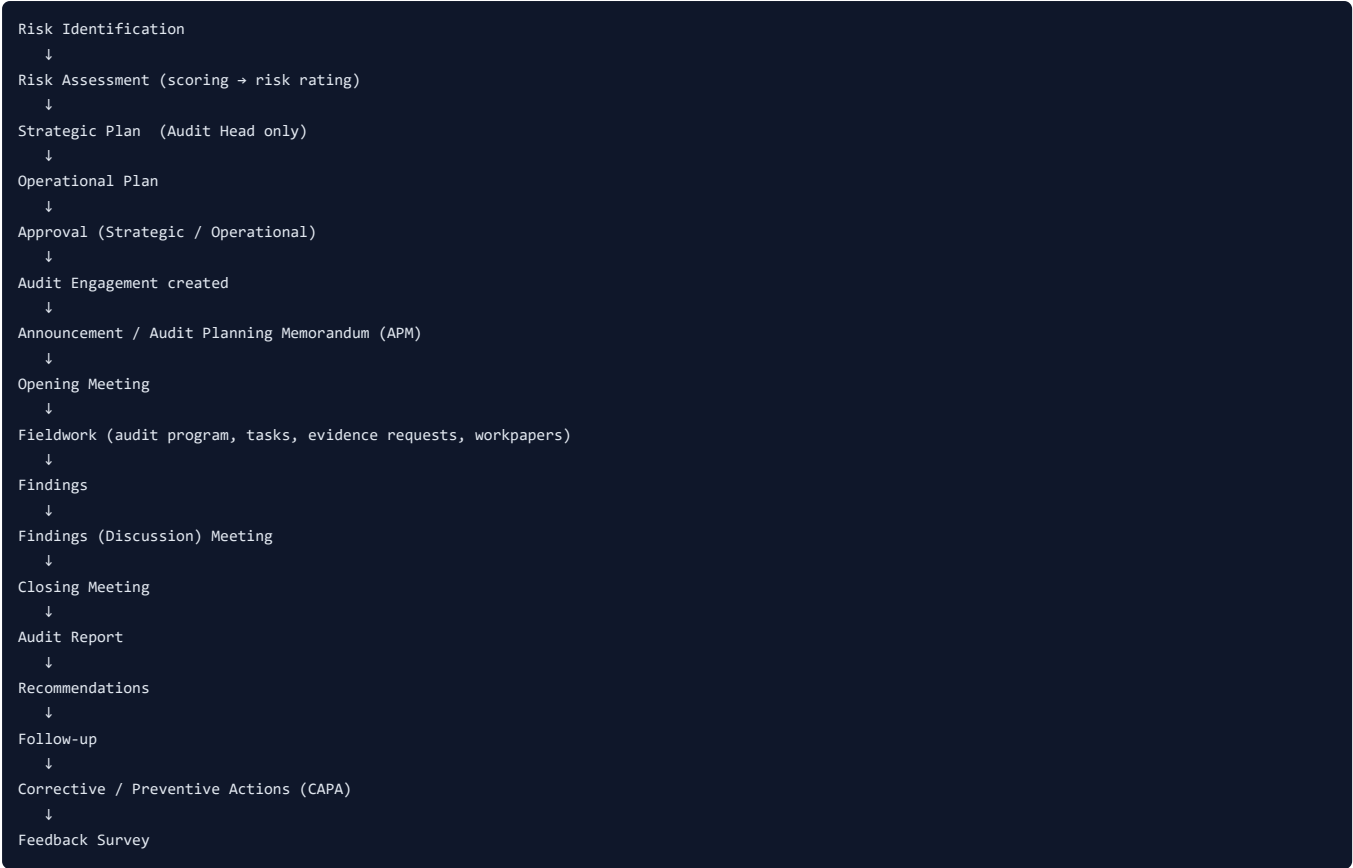
- This page is the GRCAAdministrator's view only. The three Internal Audit roles (Audit Head, Audit Manager, Auditor) will not see "Customer Accounts" under Internal Audit and cannot open this page.
  - A customer that has Internal Audit enabled but no Customer Administrator user will **not** appear in the list, because the query requires a CustomerAdministrator-role user ( `route.ts:45-51` ). Assign a Customer Administrator to make the account visible here.
  - If the list looks empty unexpectedly, it can mean either there are genuinely no IA subscriptions or the API call failed — the page renders both the same way (empty table). Reload the page to retry, and check that you have the GRCAAdministrator role.
  - All edits to a customer's module toggles and admin details are made on `/grc/customer-accounts` (reached via **Edit**), keeping a single source of truth for customer changes ( `page.tsx:10-13` ).
  - Although the API accepts `limit / offset` pagination parameters, the page does not paginate; up to 50 customers are shown (the default limit). This is sufficient for typical tenant counts but worth noting if a deployment exceeds 50 IA-enabled customers.
-



# Complete Audit Lifecycle

This chapter ties the individual modules together into the end-to-end audit lifecycle as it is implemented in the application. Each step lists the responsible role, the action performed, the system response, the resulting status change, and the next responsible role. Detailed mechanics for each step are in that module's own chapter. Where a specific automation (notification or audit-trail entry) could not be confirmed from the code, it is marked **Not verified**.

## Lifecycle at a glance



## Step-by-step

| #  | Step                                        | Responsible Role                                         | Action                                                                                    | System Response & Status                                                                                      | Next Role               |
|----|---------------------------------------------|----------------------------------------------------------|-------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------|-------------------------|
| 1  | <b>Risk Identification</b>                  | Audit Head / Audit Manager                               | Record auditable risks and risk factors.                                                  | Risk created in the Internal Audit Risk Register.                                                             | Audit Head / Manager    |
| 2  | <b>Risk Assessment</b>                      | Audit Head / Audit Manager                               | Score probability × impact using the scoring configuration.                               | Risk receives a <b>risk rating</b> (Extreme/High/Medium/Low).                                                 | Audit Head              |
| 3  | <b>Strategic Plan</b>                       | <b>Audit Head only</b>                                   | Build the multi-year strategic audit plan from rated risks.                               | Strategic Plan created (Draft).                                                                               | Audit Head              |
| 4  | <b>Operational Plan</b>                     | Audit Head / Audit Manager                               | Derive the annual operational plan from the strategic plan.                               | Operational Plan created (Draft).                                                                             | Audit Head              |
| 5  | <b>Approval</b>                             | Audit Head (Strategic); Audit Head/Manager (Operational) | Approve the plan; a signed/approval document is produced.                                 | Plan status → <b>Approved</b> (signed copy / approval doc generated).                                         | Audit Head / Manager    |
| 6  | <b>Audit Engagement created</b>             | Audit Head / Audit Manager                               | Create an engagement from the approved plan (auditId, title, department, auditor, dates). | Engagement created with status <b>Planned</b> .                                                               | Audit Head / Manager    |
| 7  | <b>Announcement / APM</b>                   | Audit Head / Audit Manager                               | Prepare and print the Audit Planning Memorandum; announce the audit.                      | APM document available (print/preview).                                                                       | Assigned Auditor        |
| 8  | <b>Opening Meeting</b>                      | Auditor / Audit Manager                                  | Record the opening meeting (attendees, minutes/MoM).                                      | Meeting saved against the engagement.                                                                         | Auditor                 |
| 9  | <b>Fieldwork</b>                            | Auditor (dept scope)                                     | Execute the audit program: tasks, evidence requests, workpapers.                          | Engagement status → <b>In Progress</b> ; evidence requests move Pending → In Progress → Submitted → Reviewed. | Auditor / Auditee       |
| 10 | <b>Findings</b>                             | Auditor                                                  | Raise findings with severity, condition, criteria, cause, effect.                         | Finding created with status <b>Open</b> .                                                                     | Auditor / Audit Manager |
| 11 | <b>Findings (Discussion) Meeting</b>        | Auditor / Auditee                                        | Discuss findings with the auditee; capture responses.                                     | Meeting saved; finding responses recorded.                                                                    | Audit Manager           |
| 12 | <b>Closing Meeting</b>                      | Audit Manager / Audit Head                               | Record the closing meeting and agreed actions.                                            | Meeting saved against the engagement.                                                                         | Audit Head              |
| 13 | <b>Audit Report</b>                         | Audit Manager / Audit Head                               | Generate the audit report from the engagement and findings.                               | Report created; can be previewed/printed.                                                                     | Audit Head              |
| 14 | <b>Recommendations</b>                      | Audit Manager / Audit Head                               | Record recommendations against findings/report.                                           | Recommendations stored with the finding/report.                                                               | Auditee                 |
| 15 | <b>Follow-up</b>                            | Auditor (dept scope)                                     | Track implementation of recommendations via the Follow-up form.                           | Follow-up records progress against each recommendation.                                                       | Auditee / Auditor       |
| 16 | <b>CAPA (Corrective/Preventive Actions)</b> | Auditee (dept scope)                                     | Record and progress corrective actions for each finding.                                  | CAPA moves Open → In Progress → <b>Closed</b> .                                                               | Auditor / Audit Head    |
| 17 | <b>Feedback Survey</b>                      | Auditee / Auditor                                        | Complete the post-audit feedback survey.                                                  | Survey responses stored against the engagement.                                                               | Audit Head              |

**Note on automation.** Status buckets above reflect the values the application recognises (engagement: Planned / In Progress / Completed; finding & CAPA: Open / In Progress / Closed; evidence request: Pending / In Progress / Submitted / Reviewed). The exact notification e-mails and audit-trail rows generated at each transition are documented per-module; system-wide due-date reminders are sent by the daily reminders job (see the Appendix → Notification Reference). Any transition not explicitly emitting a notification is **Not verified** as automated and should be treated as a manual hand-off.

**Tip.** The lifecycle is gated by role: planning (steps 3–7, 12–14) is owned by the Audit Head / Audit Manager, while execution within a department (steps 9–11, 15–17) is where the **Auditor** role operates. See the Role × Module Access Matrix for exact per-step access.

# Role × Module Access Matrix

This matrix is derived strictly from `src/lib/permissions.ts` ( `ROLE_PERMISSIONS` ) for the three documented roles: **Audit Head** ( `AuditHead` ), **Audit Manager** ( `AuditManager` ), and **Auditor** (internal key `Auditee`, displayed as "Auditor").

## Legend

- **Full Access** — view, create, edit, delete (and approve where defined).
- **Read Only** — view only.
- **Limited Access** — partial actions and/or restricted (department/own) scope.
- **Hidden** — no permission; the module does not appear in the sidebar.

| Module                               | Audit Head                     | Audit Manager                  | Auditor                            |
|--------------------------------------|--------------------------------|--------------------------------|------------------------------------|
| Dashboard                            | Full Access                    | Full Access <sup>1</sup>       | Hidden                             |
| Audit Charter                        | Full Access                    | Full Access                    | Hidden                             |
| Independence & Objectivity           | Full Access                    | Full Access                    | Hidden                             |
| Audit Universe                       | Full Access                    | Full Access                    | Hidden                             |
| Risk Identification                  | Full Access                    | Full Access                    | Hidden                             |
| Risk Register                        | Full Access                    | Full Access                    | Hidden                             |
| Risk Universe                        | Full Access                    | Full Access                    | Hidden                             |
| Risk Assessment                      | Full Access                    | Full Access                    | Hidden <sup>2</sup>                |
| Strategic Plan                       | Full Access                    | <b>Read Only</b> <sup>3</sup>  | Hidden                             |
| Operational Plan                     | Full Access                    | Full Access                    | Hidden                             |
| Audit Engagement                     | Full Access                    | Full Access                    | Hidden                             |
| Engagement Meetings                  | Full Access                    | Full Access                    | Hidden <sup>4</sup>                |
| Fieldwork                            | Full Access                    | Full Access                    | <b>Limited Access</b> <sup>5</sup> |
| Findings                             | Full Access                    | Full Access                    | <b>Limited Access</b> <sup>5</sup> |
| Recommendations                      | Full Access                    | Full Access                    | Limited Access <sup>5</sup>        |
| Audit Report                         | Full Access                    | Full Access                    | <b>Read Only</b> <sup>6</sup>      |
| Follow-up                            | Full Access                    | Full Access                    | <b>Limited Access</b> <sup>7</sup> |
| Feedback Survey                      | Full Access                    | Full Access                    | Limited Access <sup>8</sup>        |
| Document Library                     | Full Access                    | Full Access                    | Hidden                             |
| Audit Trail                          | Read Only <sup>9</sup>         | Read Only <sup>9</sup>         | Read Only <sup>9</sup>             |
| Audit Settings                       | <b>Read Only</b> <sup>10</sup> | <b>Read Only</b> <sup>10</sup> | Hidden                             |
| User Management                      | Hidden <sup>11</sup>           | Hidden <sup>11</sup>           | Hidden <sup>11</sup>               |
| Organization (Internal Audit)        | Limited Access <sup>12</sup>   | Limited Access <sup>12</sup>   | Hidden                             |
| Customer Accounts (Account Overview) | Hidden <sup>13</sup>           | Hidden <sup>13</sup>           | Hidden <sup>13</sup>               |

## Footnotes

1. **Dashboard – Audit Manager:** has the `audit.dashboard` permission (Full), but the click-through **drill-down dialogs are disabled** in the UI for this role — only Audit Head can drill down ( `dashboard/page.tsx:216-218` ).
2. **Risk Assessment:** reached from within the risk workflow rather than a dedicated sidebar link; it is governed by the audit risk permissions, so it follows the same access as Risk Identification / Risk Register. The Auditor role has none of these permissions.
3. **Strategic Plan – Audit Manager:** `audit.strategic-plan` is granted as **view only** ( `permissions.ts:466` ). Only **Audit Head** can create a Strategic Plan ( `permissions.ts:441` ).
4. **Engagement Meetings – Auditor:** meetings are part of the Audit Engagement ( `audit.planning` ) workflow, which the Auditor role does not have, so the meeting screens are not accessible to them.
5. **Fieldwork / Findings / Recommendations – Auditor:** `audit.fieldwork` is granted **view + edit, department scope** ( `permissions.ts:534` ). The Auditor can work within fieldwork for their own department but cannot create/delete engagement-level structures.
6. **Audit Report – Auditor:** `audit.reports` is **view only, department scope** ( `permissions.ts:535` ).
7. **Follow-up – Auditor:** `audit.capa` is **view + edit, department scope** ( `permissions.ts:536` ).
8. **Feedback Survey – Auditor:** the Feedback Survey sidebar item is gated by `audit.fieldwork:view` ( `navigation.ts:311` ), which the Auditor role holds, so the survey is visible to them.
9. **Audit Trail:** all three roles have `audit.audit-trail` as **view, own scope** ( `permissions.ts:452, 478, 538` ) — each user sees only their own activity. (Only the Customer Administrator sees all users' activity.)
10. **Audit Settings:** `audit.settings` is **view only** for both Audit Head and Audit Manager ( `permissions.ts:450, 476` ). Full create/edit/delete of audit master data belongs to the **Customer Administrator** ( `permissions.ts:409` ).
11. **User Management:** the Internal Audit user-management screens are gated by `organization.users`, which none of the three audit roles hold; this is a **Customer Administrator** function.

12. **Organization (Internal Audit) – Audit Head / Manager:** within this area only **Process** ( `audit.process` ) is fully available to the audit roles; Profile, Users, and Organization Settings are gated by `organization.*` permissions held by the Customer Administrator. Hence "Limited Access."
  13. **Customer Accounts (Account Overview):** gated by `audit.account-overview` , which is held only by the **GRC Administrator** (super-admin tenant overview)  
— not by any customer-side audit role.
-

# Appendix

## A. Glossary

| Term                    | Meaning                                                                                                                         |
|-------------------------|---------------------------------------------------------------------------------------------------------------------------------|
| <b>APM</b>              | Audit Planning Memorandum — the planning document produced for an audit engagement (print/preview available on the engagement). |
| <b>CAPA</b>             | Corrective and Preventive Action — actions raised against an audit finding and tracked to closure.                              |
| <b>MoM</b>              | Minutes of Meeting — the record captured for opening, discussion, and closing meetings.                                         |
| <b>Auditable</b>        | An entity in the Audit Universe that can be selected for audit.                                                                 |
| <b>Risk Rating</b>      | The Extreme / High / Medium / Low classification produced by Risk Assessment scoring.                                           |
| <b>Engagement</b>       | A single audit instance (auditId, title, department, assigned auditor, dates, status).                                          |
| <b>Evidence Request</b> | A request to an auditee to supply supporting evidence during fieldwork.                                                         |
| <b>Workpaper</b>        | A fieldwork document evidencing the audit testing performed.                                                                    |
| <b>Finding</b>          | An issue identified during fieldwork, with severity and supporting detail.                                                      |
| <b>Follow-up</b>        | Tracking of whether agreed recommendations/actions have been implemented.                                                       |

## B. Role Definitions

Descriptions are taken verbatim from `ROLES` in `src/lib/permissions.ts`.

| Role (internal key)       | UI Display     | Description                                                                                                                               |
|---------------------------|----------------|-------------------------------------------------------------------------------------------------------------------------------------------|
| <code>AuditHead</code>    | AuditHead      | "Full access to Internal Audit module, all audit data." Only role that can create Strategic Plans.                                        |
| <code>AuditManager</code> | AuditManager   | "Full Internal Audit access except creating Strategic Plans (view-only); can edit Operational Plans."                                     |
| <code>Auditee</code>      | <b>Auditor</b> | "Limited access to Fieldwork, CAPA Tracking, and Reports only." Displayed to users as "Auditor" via <code>ROLE_DISPLAY_OVERRIDES</code> . |

**Note.** The legacy internal `Auditor` key is retired and hidden from assignment; the role users assign as "Auditor" is internally `Auditee`.

## C. Permission Matrix (audit.\* resources)

Derived from `ROLE_PERMISSIONS`. ✓ = action granted. Scope shown where it is not "all".

| Resource                               | Module                      | Audit Head     | Audit Manager  | Auditor           |
|----------------------------------------|-----------------------------|----------------|----------------|-------------------|
| <code>audit.dashboard</code>           | Dashboard                   | V C E D A      | V C E D A      | —                 |
| <code>audit.auditables</code>          | Audit Universe              | V C E D A      | V C E D A      | —                 |
| <code>audit.charter</code>             | Audit Charter               | V C E D A      | V C E D A      | —                 |
| <code>audit.risk-identification</code> | Risk Identification         | V C E D A      | V C E D A      | —                 |
| <code>audit.risk-register</code>       | Risk Register               | V C E D A      | V C E D A      | —                 |
| <code>audit.risk-universe</code>       | Risk Universe               | V C E D A      | V C E D A      | —                 |
| <code>audit.strategic-plan</code>      | Strategic Plan              | V C E D A      | <b>V</b>       | —                 |
| <code>audit.operational-plan</code>    | Operational Plan            | V C E D A      | V C E D A      | —                 |
| <code>audit.planning</code>            | Audit Engagement / Meetings | V C E D A      | V C E D A      | —                 |
| <code>audit.independence</code>        | Independence & Objectivity  | V C E D A      | V C E D A      | —                 |
| <code>audit.fieldwork</code>           | Fieldwork / Findings        | V C E D A      | V C E D A      | <b>V E</b> (dept) |
| <code>audit.reports</code>             | Audit Report                | V C E D A      | V C E D A      | <b>V</b> (dept)   |
| <code>audit.capa</code>                | Follow-up                   | V C E D A      | V C E D A      | <b>V E</b> (dept) |
| <code>audit.documents</code>           | Document Library            | V C E D A      | V C E D A      | —                 |
| <code>audit.settings</code>            | Audit Settings              | <b>V</b>       | <b>V</b>       | —                 |
| <code>audit.audit-trail</code>         | Audit Trail                 | <b>V</b> (own) | <b>V</b> (own) | <b>V</b> (own)    |
| <code>audit.process</code>             | Organization › Process      | V C E D A      | V C E D A      | —                 |
| <code>organization.department</code>   | (dropdowns)                 | V              | V              | V (dept)          |

Key: V = view, C = create, E = edit, D = delete, A = approve.

## D. Status Reference

Statuses recognised across the Internal Audit module (see each module chapter for transitions):

| Domain                       | Statuses                                                                                                                  |
|------------------------------|---------------------------------------------------------------------------------------------------------------------------|
| Audit Engagement             | Planned / Planning / Draft / Pending · In Progress / InProgress / Ongoing / Active · Completed / Complete / Done / Closed |
| Finding                      | Open · (In Progress) · Closed / Completed                                                                                 |
| CAPA                         | Open · In Progress · Closed                                                                                               |
| Evidence Request             | Pending · In Progress · Submitted · Reviewed (overdue when due date passed and still Pending/In Progress)                 |
| Strategic / Operational Plan | Draft · Approved (signed copy / approval document generated on approval)                                                  |
| Risk (rating)                | Extreme / Critical · High · Medium / Moderate · Low                                                                       |

## E. Notification Reference

| Notification       | Trigger                                                    | Recipients                                                                                                            |
|--------------------|------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------|
| Due-date reminders | Daily scheduled job ( /api/cron/due-reminders , 08:00 UTC) | Assignees / responsible persons of items due within 24 hours, including CAPA/Findings due soon and evidence due soon. |

Other per-action notifications, where present, are documented in the relevant module chapter. Any transition not listed there is **Not verified** as generating a notification.

## F. Audit Trail Events

The Audit Trail captures activity automatically. The events recorded are:

- **Create, Update, Delete, Approve** (data changes)
- **Login, Logout** (authentication)

Scope: the Customer Administrator sees all users' activity; Audit Head, Audit Manager, and Auditor each see **only their own** activity. (See the Audit Trail chapter.)

## G. Navigation Reference

The exact Internal Audit sidebar tree, with each item's required permission (from `src/lib/navigation.ts` ). Visibility per role is filtered by these permissions.

### Internal Audit

| Item                       | Route                               | Permission                     |
|----------------------------|-------------------------------------|--------------------------------|
| Customer Accounts          | /internal-audit/account-overview    | audit.account-overview:view    |
| Dashboard                  | /internal-audit/dashboard           | audit.dashboard:view           |
| Independence & Objectivity | /internal-audit/independence        | audit.independence:view        |
| Audit Charter              | /internal-audit/audit-charter       | audit.charter:view             |
| Audit Universe             | /internal-audit/audit-universe      | audit.auditables:view          |
| Risk Identification        | /internal-audit/risk-identification | audit.risk-identification:view |
| RiskRegister               | /internal-audit/risk-register       | audit.risk-register:view       |
| Strategic Plan             | /internal-audit/strategic-plan      | audit.strategic-plan:view      |
| Operational Plan           | /internal-audit/operational-plan    | audit.operational-plan:view    |
| Audit Engagement           | /internal-audit/audit-engagement    | audit.planning:view            |
| Report                     | /internal-audit/report              | audit.reports:view             |
| Feedback Survey            | /internal-audit/feedback-survey     | audit.fieldwork:view           |
| Document Library           | /internal-audit/document-library    | audit.documents:view           |
| Audit Trail                | /internal-audit/audit-trail         | audit.audit-trail:view         |
| Audit Settings             | /internal-audit/settings            | audit.settings:view            |

### Follow-up (separate top-level menu)

| Item      | Route                     | Permission      |
|-----------|---------------------------|-----------------|
| Follow-up | /internal-audit/follow-up | audit.capa:view |

### Organization (Internal Audit workspace)

| Item                   | Route                                 | Permission                        |
|------------------------|---------------------------------------|-----------------------------------|
| Profile                | /internal-audit/organization/profile  | organization.profile:view         |
| Process                | /internal-audit/organization/process  | audit.process:view                |
| Users                  | /internal-audit/organization/users    | organization.users:view           |
| Reports                | /internal-audit/organization/reports  | organization.dashboard:view       |
| Organization Settings  | /internal-audit/organization/settings | organization.settings:view        |
| Subscription & Billing | /settings/subscription                | subscription.customer-portal:view |

**Note.** Fieldwork, Findings, Engagement Meetings, Risk Universe, Risk Assessment, and CAPA do not have their own top-level sidebar entries — they are reached from within the engagement / fieldwork / risk workflows, as described in their chapters.